Master's degree thesis

LOG953 Sustainable Energy Logistics

Verifiable Crypto-Erasure for Cross-Border Health Data Audit Trails under the European Health Data Space

A Design Science Study of the Tri-Lateral Retention Feasibility Problem in the Norwegian Implementation Context

Arshad Akhtar Abbasia

Supervisor: Prof. João Ferreira

Molde, November 2026

Molde University College
Specialized University in Logistics

Abstract

The European Health Data Space Regulation (EU) 2025/327 subjects cross-border health data audit records to three retention requirements at once: audit-retention floors (one year for Secure Processing Environment access logs under Article 73(1)(e) and, for MyHealth@EU audit repositories, a period the eHDSI specifications leave to national law: six years in the Norwegian pilot, ten in the secondary literature), the right to erasure under Article 17 GDPR, and the six-month deletion ceiling of Article 68(12). No instrument reconciles them, and the implementing acts that must specify Secure Processing Environment requirements are not due until 26 March 2027.

The thesis develops the Tri-Lateral Retention Feasibility (TRF) Model, a constraint-satisfaction formulation in which the semantics of audit verifiability is an explicit parameter. Under plaintext-verifiability semantics the constraints are infeasible whenever an erasure or deletion deadline falls inside a retention window (Proposition 1). Under accountability-preserving semantics they are jointly satisfiable for every arrival pattern of erasure requests and permit expiries and for every retention floor (Proposition 2). Two further results locate the conflict: a ceiling collides with a floor only if it is no longer than the floor, and the event the ceiling is anchored to decides whether the collision is visible in the text or only in each record's history (Proposition 3); moving a record out of the regulated environment satisfies the ceiling but not the right to erasure (Proposition 4). The witnessing mechanism, Crypto-Erasure by Invalidation, deletes each record's payload with its per-record key and, for Secure Processing Environment logs at the deletion ceiling, removes the record's link to the patient, while retaining the accessor's identity, event metadata, a hiding commitment and a logged invalidation entry in a tamper-evident log.

Both results are checked in a Python sandbox over two hundred generated records; replacing their payloads with Synthea-generated FHIR R4 resources changes no figure. The counts depend on the generator parameters and are not estimates of real frequency; the sandbox validates the artefact's implementation of the model and is not independent evidence for the propositions. The collision that needs no erasure request arises only on a contestable broad reading of Article 68(12), and only for log entries that are themselves electronic health data, as entries kept at patient-record granularity are.

The contribution is bounded: no novel cryptographic primitive or formal method, informal proofs, simulated key destruction, and two principal interpretive steps and four subsidiary premises without regulatory authority. The formal results are deliberately elementary: Proposition 1, that some departure from plaintext verifiability is unavoidable, carries the formal argument, while Proposition 2 verifies that a principled departure suffices. The weight lies in the legal necessity analysis and the mechanism design, not in the proofs. The thesis offers four contributions: a formal model of the

conflict, feasibility results with an executable witness, a mechanism specification with its residue analysed, and an integration analysis against Norwegian infrastructure.

Keywords: European Health Data Space; GDPR Article 17; cryptographic erasure; audit trail; data retention; design science research; Secure Processing Environment; MyHealth@EU; information logistics; Norway

Artefact: `https://github.com/Astheno-sphere/TRF-thesis`, branch `joao-base`, code in `demo_app/` (archived release 1.3.0: `https://doi.org/10.5281/zenodo.23989242`; all versions: `https://doi.org/10.5281/zenodo.23819274`). Demonstration: `https://trfhimolde.streamlit.app/`

Sammendrag

Forordning (EU) 2025/327 om det europeiske helsedataområdet (EHDS) underlegger revisjonsspor for grensekryssende helsedata tre lagringskrav samtidig: minstekrav til lagring av revisjonslogger (ett år for tilgangslogger i sikre analyserom etter artikkel 73(1)(e) og, for MyHealth@EU, en periode som eHDSI-spesifikasjonene overlater til nasjonal lovgivning: seks år i den norske utprøvingen, ti år i sekundærlitteraturen), retten til sletting etter GDPR artikkel 17, og en sletteplikt på seks måneder etter artikkel 68(12). Ingen rettsakt forener disse, og gjennomføringsrettsaktene som skal fastsette kravene til sikre analyserom skal ikke foreligge før 26. mars 2027.

Oppgaven utvikler Tri-Lateral Retention Feasibility (TRF)-modellen, en betingelsesbasert formulering der semantikken for revisjonsverifiserbarhet er en eksplisitt parameter. Under semantikk der en post er verifiserbar bare så lenge innholdet er lesbart i klartekst, er kravene uforenlige så snart en slettefrist eller en sletteplikt faller innenfor lagringsperioden (proposisjon 1). Under semantikk som bevarer etterrettelighet, kan kravene tilfredsstilles samtidig for alle tidspunkter for slettebegjæringer og utløp av tillatelser og for alle lagringsminimum (proposisjon 2). To resultater til avgrenser konflikten: en øvre grense kolliderer med et lagringsminimum bare når den ikke er lengre enn minimumet, og hendelsen grensen regnes fra avgjør om kollisjonen kan ses i teksten eller bare i den enkelte postens historikk (proposisjon 3); å flytte en post ut av det regulerte miljøet oppfyller sletteplikten, men ikke retten til sletting (proposisjon 4). Mekanismen som viser dette, Crypto-Erasure by Invalidation, ødelegger nøkkelen til innholdet i hver enkelt post og fjerner, for tilgangslogger i sikre analyserom når sletteplikten inntreffer, postens kobling til pasienten, samtidig som identiteten til den som ga seg tilgang, hendelsesmetadata, en skjulende forpliktelse (commitment) og en logget ugyldiggjøringspost beholdes i en logg der endringer kan avsløres.

Begge resultatene kontrolleres i en Python-sandkasse med to hundre genererte poster; å erstatte innholdet deres med syntetiske FHIR R4-data generert med Synthea endrer ingen tall. Antallene avhenger av parameterne i generatoren og er ikke anslag over reell hyppighet; sandkassen kontrollerer at artefakten implementerer modellen riktig og er ikke uavhengig belegg for proposisjonene. Kollisjonen som ikke krever noen slettebegjæring, oppstår bare under en omstridt, vid lesing av artikkel 68(12), og bare for loggposter som selv er elektroniske helsedata, slik poster som føres på nivå med den enkelte pasientjournal, er.

Bidraget er avgrenset: ingen nye kryptografiske primitiver eller formelle metoder, uformelle bevis, simulert nøkkelødeleggelse og to sentrale tolkningssteg og fire underordnede premisser uten støtte i rettskilder. De formelle resultatene er bevisst elementære: vekten ligger i den rettslige nødvendighetsanalysen og i utformingen av mekanismen, ikke i bevisene. Oppgaven gir fire bidrag: en formell modell av konflikten, gjennomførbarhetsresultater med et kjørbart vitnebyrd, en spesi-

fikasjon av mekanismen med analyse av det som blir igjen, og en analyse av hvordan mekanismen kan integreres i norsk infrastruktur.

Nøkkelord: europeisk helsedataområde; GDPR artikkel 17; kryptografisk sletting; revisjonsspor; lagringstid; design science-forskning; sikkert analyserom; MyHealth@EU; informasjonslogistikk; Norge

Contents

Abstract . . . . . **i**

Sammendrag . . . . . **iii**

Statement of Contribution . . . . . **ix**

Declaration of Originality . . . . . **xi**

Nomenclature and Abbreviations . . . . . **xii**

Chapter 1. Introduction **1**

1.1 Background and Context 1

1.2 Problem Statement 3

1.3 Research Objectives and Questions 4

1.4 Significance and Relevance 7

1.5 Scope and Out-of-Scope 8

1.6 Methodological Approach 9

1.7 Thesis Structure 10

Chapter 2. Literature Review and Theoretical Foundation **11**

2.1 Review Protocol 11

2.2 The Cross-Border Health Data Exchange Landscape 14

2.3 The Audit-Retention versus Right-to-Erasure Tension 16

2.4 Cryptographic Approaches to Audit Compliance 20

2.5 Formal Approaches to Regulatory-Compliance Verification 25

2.6 Norwegian Secondary-Use Infrastructure 27

2.7 Information Logistics Framing 29

2.8 Comparative Analysis 31

2.9 Identified Research Gaps 33

2.10 Conceptual Positioning of the Thesis 35

Chapter 3. Methodology and Research Design **36**

3.1 Research Paradigm 36

3.2 The Design Science Cycle Adopted 37

3.3 The Specification-and-Demonstration Variant, Extended with Formal Modelling 37

3.4 Formal-Modelling Methodology 39

3.5 Synthetic Data 40

3.6 Sandbox Implementation Approach 41

3.7 Validity, Reliability, and Limitations 43

3.8 Evaluation Design for the Next Cycle 45

3.9 Ethical Considerations 45

Chapter 4. The Tri-Lateral Retention Feasibility Model and the Crypto-Erasure by Invalidation Mechanism 47
4.1 Purpose and Structure of the Chapter 47
4.2 What Must Be Retained: The Necessity Analysis 48
4.3 The Model: Objects and Notation 50
4.4 The Three Constraints 53
4.5 Two Semantics of Verifiability 54
4.6 Propositions 1 and 3: Infeasibility, and Where the Ceiling Is Anchored 56
4.7 Proposition 2: Feasibility under Accountability-Preserving Verifiability 59
4.8 The Mechanism: Crypto-Erasure by Invalidation 62
4.9 Residue Analysis 67
4.10 Rival Designs and Proposition 4 69
4.11 Integration with the Norwegian Infrastructure 72
4.12 Summary 76

Chapter 5. Demonstration 78
5.1 Purpose and Claim 78
5.2 Implementation 78
5.3 Results under Semantics I 82
5.4 Corollary 1.2: Infeasibility Without an Erasure Request 83
5.5 Independent Cross-Check 84
5.6 Witness at the Extended Response Period 86
5.7 Results under Semantics II 86
5.8 What the Demonstration Establishes, and What It Does Not 88

Chapter 6. Discussion 90
6.1 What the Thesis Establishes 90
6.2 The Authority Problem 91
6.3 Key Destruction and the Limits of Assurance 93
6.4 The Cost Objection 94
6.5 Scalability 95
6.6 Evaluation Design and the Role of Stakeholder Assessment 95
6.7 Synthetic Data and the Limits of the Demonstration 96
6.8 Implications for Practice and Policy 97
6.9 Theoretical Implications 98
6.10 Where the Ceiling Is Anchored: a Cross-Sector Test 99
6.11 Summary 100

Chapter 7. Conclusion 102
7.1 The Problem and the Answer 102
7.2 Contributions 103
7.3 What the Thesis Does Not Establish 105
7.4 The Two Principal Open Questions of Authority 105

7.5 Future Work . . . 106
7.6 Closing . . . 107

References . . . 108

Appendix A. Code Artefacts and Reproduction Record . . . 115
A.1 Availability . . . 115
A.2 Contents . . . 117
A.3 Environment and generation provenance . . . 118
A.4 Software environment . . . 119
A.5 Exact commands . . . 119
A.6 What the code does . . . 120
A.7 Data provenance . . . 122
A.8 Integrity record . . . 122
A.9 Known limitations of the artefact . . . 123
A.10 Source listing: `trf_checker.py` . . . 124
A.11 Source listing: `synthea_layer.py` . . . 134
A.12 Source listing: `norwegian_layer.py` . . . 137
A.13 Source listing: `cross_sector_check.py` . . . 139
A.14 The demonstration viewer: `app.py` and `ui.py` . . . 141
A.15 Source listing: `crypto_envelope.py` . . . 141
A.16 Console output of the reported run . . . 144
A.17 Console output of the payload-provenance comparison, full cohort . . . 145
A.18 Console output of the erasure-response-period witness . . . 146
A.19 Console output of the Norwegian context module . . . 147
A.20 Console output of the cross-sector instance . . . 148
A.21 Console output of the payload-provenance comparison, committed subset . . . 149
A.22 Console output of the envelope-encryption module . . . 149
A.23 Source listing: `z3_check.py` . . . 150
A.24 Console output of the bounded SMT check . . . 153

Appendix B. Search Query Log . . . 154
Round 1: 25 May 2026 (landscape, infrastructure, regulatory baseline) . . . 154
Round 2: 29 May 2026 (verification and correction round) . . . 155
Round 3: 15 September 2026 (resumption; novelty and currency) . . . 155
Round 4: 16 September 2026 (adversarial novelty, prior art, currency) . . . 156
Round 5: 28 September 2026 (locator verification and source-standing audit) *[R]* . . . 156
Note on coverage . . . 158
Prospective Boolean protocol for replication . . . 159

Appendix C. Expert Evaluation Instrument . . . 160
C.1 Purpose and status . . . 160
C.2 Panel composition . . . 161
C.3 Session structure . . . 162
C.4 Demonstration script . . . 162

C.5 Semi-structured interview guide . . . 163
C.6 Closed-response questionnaire . . . 164
C.7 Analysis . . . 166
C.8 Data protection, if executed . . . 167

Appendix D. Correspondence with Public Authorities . . . 168
D.1 Helsedirektoratet, on the retention of the cross-border audit trail . . . 168
D.2 Datatilsynet, on the GDPR-side questions . . . 169

List of Figures

Figure 1.1. The two audit logs this thesis concerns and where the mechanism attaches . . 5

Figure 4.1. Crypto-Erasure by Invalidation at the audit boundary . . . 63

Figure 5.1. The artefact's modules and data path . . . 80
Figure 5.2. Record 100, month by month . . . 84

List of Tables

Table 2.1. Comparative Analysis of Cryptographic Compliance Approaches to Health Data Audit . . . 31

Table 4.1. Requirements traced to the mechanism . . . 73

Table 5.1. The artefact as published . . . 79
Table 5.2. Generation parameters (complete) . . . 81
Table 5.3. Violations under Semantics I (seed 20260915, n = 200) . . . 82
Table 5.4. Exhaustive search over α assignments (horizon = 14 months) . . . 85
Table 5.5. Results at $\delta = 1$ and $\delta = 3$ (seed 20260915, n = 200) . . . 86
Table 5.6. Results under Semantics II (same 200 records, same seed) . . . 86
Table 5.7. Constructed against Synthea-generated payloads (same seed, same timings) . . 89

Table B.1. Prospective Boolean search strings . . . 159

Statement of Contribution

This thesis makes four contributions, each stated at the level it can be defended. They are contributions of framing and feasibility, not of cryptographic invention: the apparent conflict is dissolved by making precise what a verifiable retained record must be, and not, on the necessity analysis of Chapter 4, Section 4.2, by weakening any of the three obligations.

1. A formal model of the tri-lateral retention conflict. The TRF Model expresses audit-retention floors, the erasure right, and the deletion ceiling as constraints over a single binary variable per record, with verifiability semantics as an explicit parameter. The method of formalising legal compliance as satisfiability is established in the literature and is not claimed here; its application to a retention system combining floors, a right, and a ceiling, and the isolation of verifiability as the parameter determining feasibility, are new to the reviewed literature.

2. Feasibility results with an executable witness. Proposition 1 establishes infeasibility under the semantics of an audit log that keeps its payload readable. Proposition 2 establishes satisfiability under an alternative and exhibits the trajectory achieving it. Both are proved informally and checked executably, with a separately written exhaustive cross-check and a bounded SMT check of Propositions 1–3. Proposition 3 states the exact condition under which a ceiling collides with a floor and shows that the ceiling's anchor decides whether the collision can be read from the text; Proposition 4 shows why relocating a record, the rival that removes it from the environment, does not dissolve the conflict. Proposition 1 is offered as a negative result in its own right: wherever an erasure or deletion deadline falls inside a retention window, it marks as unworkable any design that keeps the payload readable for the length of the floor.

3. A mechanism specification with its residue analysed against the applicable legal threshold. Crypto-Erasure by Invalidation is specified in implementable detail, with each record's metadata partitioned into the accessor's fields, which accountability requires and the mechanism retains, and the link to the patient, which it keeps on the cross-border path where the person's access-information right needs it and removes from Secure Processing Environment logs at the ceiling, and with entries committed to a tamper-evident log whose inclusion proofs the demonstration checks. Its surviving residue is characterised as pseudonymised rather than anonymous, by the Norwegian standard and by the European Data Protection Board's Guidelines 02/2025, under which encrypted data remain personal data after key deletion makes them unintelligible.

4. An integration analysis against verified Norwegian infrastructure. The mechanism is placed at the audit-repository step of the MyHealth@EU flow and the access-logging boundary of a Secure Processing Environment, and adds no requirement of a new kind to the Norwegian criteria put to

public hearing in 2025 and their 2024 draft: key custody falls under their mandatory information-security management system, and the log under their requirement of tamper-proof access logs.

What is not claimed. No novel cryptographic primitive or construction. No novel formal method. No first-ever framework for anything. No deployed system, no performance result, no connection to any National Contact Point. No proof that key destruction occurred, as distinct from an attestation that it did. No authority that key destruction discharges the erasure obligation for copies that cannot be deleted at once. No empirical estimate of how often the conflict arises in practice. No regulatory authority for either of the two principal interpretive steps the argument depends upon, both of which are identified in Chapter 6 and proposed for resolution in Chapter 7, or for the four subsidiary premises listed in Chapter 3, Section 3.7.

A note on the project name. This work has been presented in preliminary form under the name VERA-SNARK, which originates in an earlier design iteration that envisaged zero-knowledge succinct arguments as the enforcement machinery. The design-science process showed that the audit-trail retention problem requires no such machinery, and the mechanism specified here contains none. The name is retained for continuity with that earlier presentation, and the evolution is discussed in Chapter 1, Section 1.6. Chapter 7, Section 7.5 identifies the distinct problem for which zero-knowledge arguments do become necessary.

Declaration of Originality

This thesis is my own work. Where the work of others is used, it is cited. Where an argument originates in the supervisory relationship or in feedback on drafts, that is noted in the text.

Two declarations are made explicitly.

Ethics. This research involved no human participants, no interviews, no surveys, no observation of persons, and no personal data of any kind, apart from correspondence with public authorities, whose officials are named in their official capacity. All data used are synthetic, generated by Synthea, and describe no real individual. No approval from the Norwegian Agency for Shared Services in Education and Research (Sikt), from any regional research-ethics committee, or from any institutional review board was required for this work, and none was sought or obtained.

Sources. Every factual claim in this thesis is traceable to a source retrievable at the time of writing, with two stated exceptions: the SPUHiN hearing version, whose public page has since been withdrawn, and correspondence with Helsedirektoratet, reproduced in Appendix D. Where verification of a source remains incomplete, the text says so. An earlier draft of this project, discarded in May 2026, contained citations to works that do not exist and a statement of ethics approval that was never obtained; every citation in the present work has been checked against a primary or retrievable source.

Use of AI assistance. Anthropic's Claude was used throughout this project as a research and drafting assistant: for literature search and source verification, for critique of the author's arguments, for drafting and redrafting prose to the author's direction, and for writing the Python code in Appendix A; Archify was used to generate the thesis's diagrams and figures, and Parallel AI was used as an additional research and source-retrieval assistant. All design decisions, the model's formulation, the interpretive legal arguments, and the acceptance or rejection of every suggestion are the author's own, and the author is answerable for the whole. This declaration is made in the form the institution's guidance requires and should be read alongside it.

Nomenclature and Abbreviations

Model notation

Symbol	Meaning
a	An audit record
$m(a)$	Event metadata: actor, contact point, patient pseudonym, document category, legal basis, outcome
$p(a)$	Personal-data payload of the record
$c(a)$	Hiding commitment to the payload, $c = \mathrm{Commit}(p, r)$
$r(a)$	Per-record commitment salt
$k(a)$	Payload key
$\iota(a)$	Invalidation entry: month, legal ground, authorising actor
$t(a)$	Month in which the access event occurred
$F(a)$	Retention floor, in months (72 in the Norwegian cross-border pilot, 120 illustrative in Chapter 5, 36 under Article 9(2); 12 for SPE access logs)
$\sigma(a)$	Pathway: primary or secondary
$t_r(a)$	Month an erasure request arrives (∞ if none)
$t_\pi(a)$	Month a data permit expires (∞ if not applicable)
$P(a)$	Payload retention period set by the controller (∞ if none; Section 4.8)
$t^I(a)$	Invalidation month, $\min(t_r + \delta,\ t_\pi + 6,\ t + P)$
δ	Erasure response period, in months (GDPR Art. 12(3))
$\alpha(a, t)$	Payload accessibility at month t: 1 if recoverable, 0 otherwise
$V(a, t)$	Whether the record counts as verifiable at month t
V^{I}, V^{II}	Verifiability under Semantics I (plaintext) and Semantics II (accountability-preserving)
$m_{\mathrm{acc}}(a)$, $m_{\mathrm{subj}}(a)$	Accessor fields and subject fields of the event metadata (Section 4.3)
$\beta(a, t)$	Subject-link variable at month t: 1 if the subject fields are readable, 0 otherwise
$p_{\mathrm{n}}(a)$, $p_{\mathrm{r}}(a)$	Part of the payload that auditing needs, and the remainder (Corollary 2.3)
$e(a)$, L	Month of the event a ceiling is anchored to, and the ceiling length in months (Proposition 3)
C1, C2, C3	Retention floor, erasure right, and deletion ceiling constraints

Abbreviations

Term	Expansion
ATNA	Audit Trail and Node Authentication (IHE integration profile)

Term	Expansion
CEF	Coordinated Enforcement Framework (EDPB)
DSR	Design Science Research
EDPB	European Data Protection Board
EEA	European Economic Area
EEHRxF	European Electronic Health Record Exchange Format
eHDSI	eHealth Digital Service Infrastructure
eHMSEG	eHealth Member States Expert Group
eHOMB	eHealth Operational Management Board
EHDS	European Health Data Space
FHIR	Fast Healthcare Interoperability Resources (HL7)
GDPR	General Data Protection Regulation (EU) 2016/679
HDAB	Health Data Access Body
HSM	Hardware Security Module
IHE	Integrating the Healthcare Enterprise
NCPeH	National Contact Point for eHealth
NHN	Norsk Helsenett SF
NIST	National Institute of Standards and Technology (US)
NORTRE	Norwegian Trusted Research Environments
OpenNCP	Open National Contact Point software stack
PoSE	Proof of Secure Erasure
SoK	Systematization of Knowledge
SPE	Secure Processing Environment
SPUHiN	Secure Provision and Use of Health Data in Norway (project)
TEHDAS2	Towards European Health Data Space, Joint Action 2
TRF	Tri-Lateral Retention Feasibility (Model)
zk-SNARK	Zero-Knowledge Succinct Non-Interactive Argument of Knowledge

Chapter 1. Introduction

1.1 Background and Context

Regulation (EU) 2025/327 on the European Health Data Space was adopted on 11 February 2025, published in the Official Journal on 5 March 2025, and entered into force on 26 March 2025. It establishes the first Union-wide legal framework for the primary and secondary use of electronic health data across all Member States and European Economic Area countries (European Parliament and Council of the European Union, 2025). The regulation creates a binding architecture for cross-border exchange of patient summaries, electronic prescriptions, laboratory results, medical imaging, and hospital discharge reports, with primary-use exchange of patient summaries and ePrescriptions becoming mandatory across the EU by March 2029, and in Norway and the other EEA states from the dates fixed on incorporation into the EEA Agreement, and the remaining priority categories by March 2031 (European Commission, 2025b).

The technical infrastructure underpinning this regulatory shift is MyHealth@EU, the federated pull-based system that allows a clinician in one Member State to retrieve a patient summary or dispense an ePrescription issued in another Member State. Each participating country operates a single National Contact Point for eHealth (NCPeH), and all cross-border exchanges flow through a six-step gateway protocol implemented in the Open National Contact Point (OpenNCP) software stack. These six steps cover service discovery, patient discovery, document retrieval, pivot translation between national clinical document formats and a common European format, security and consent validation, and audit logging (Simjanoska Misheva et al., 2025).

Norway's integration with MyHealth@EU is operational but deliberately narrow: a pilot run by the Norwegian Directorate of Health and the Norwegian Health Network receives patient summaries at two emergency clinics, and no relevant patients had yet presented when the Directorate last reported (Helsedirektoratet, 2026; Chapter 2, Section 2.2 gives the details). As Norway is an EEA member rather than a Member State, EHDS implementation runs through the EEA Joint Committee, and Helsedirektoratet delivered its formal EHDS gap analysis on 11 April 2025 (Helsedirektoratet, n.d.). The infrastructure that will generate the cross-border audit records with which this thesis is concerned is therefore live in Norwegian production.

EHDS also establishes a new layer of patient rights. Citizens gain the right to access and download their electronic health data, to view logs of who has accessed it, to set granular restrictions on cross-border sharing, and to opt out of secondary use (European Parliament and Council of the European Union, 2025). These rights interact directly with two long-standing instruments. The first is the IHE Audit Trail and Node Authentication (ATNA) integration profile, which defines the

technical structure through which access events are logged in cross-border exchanges. ATNA itself prescribes no retention period. The retention obligation arises from the deployment binding: under the eHDSI security framework adopted for MyHealth@EU operations, ATNA-compliant audit repositories are reported to retain their logs for a minimum of ten years (IHE International, 2023; Simjanoska Misheva et al., 2025). The Norwegian operator reports that no eHDSI specification fixes a period, which is left to national law, and that its pilot uses six years; I therefore treat the floor as a parameter and ten years as an illustrative long value (Chapter 2, Section 2.3). The second is the General Data Protection Regulation (EU) 2016/679, whose Article 17 establishes the data subject's right to obtain erasure of personal data without undue delay under specified conditions (European Parliament and Council of the European Union, 2016).

A third constraint arises from the implementing infrastructure for EHDS secondary use. The TEHDAS2 Joint Action's guideline for Health Data Access Bodies specifies that the electronic health data in a Secure Processing Environment must be deleted within six months of the expiry of the data permit, operationalising Article 68(12) of the EHDS Regulation (TEHDAS2, 2026a, Section 7.2).

The same regulation imposes a retention obligation on the same environment. Article 73(1)(e) EHDS requires of every Secure Processing Environment "the keeping of identifiable logs of access to and activities in the secure processing environment for the period necessary to verify and audit all processing operations in that environment; logs of access shall be kept for at least one year" (European Parliament and Council of the European Union, 2025). Article 68(12) provides that "the electronic health data within the secure processing environment shall be deleted within six months of the expiry of the data permit". Where an environment logs access at patient-record granularity, an entry linking a patient's record to an access is itself electronic health data within the environment. On the broad reading set out in Chapter 4, Section 4.6, the Regulation then requires of a single environment that such data be deleted within six months of permit expiry and that identifiable logs be kept for at least twelve months. That reading is contestable, and I state its grounds rather than assuming it; under the narrower alternative, or where logs are kept at dataset granularity, the conflict in the secondary-use pathway arises through Article 17 erasure requests instead, as it does in the cross-border pathway, and the thesis's results are unaffected.

Cross-border health data exchange therefore operates under three kinds of retention regime that do not yet have a documented technical reconciliation. The first is audit-retention floors, instantiated as the long floor of cross-border audit repositories, which national law sets, and the one-year floor imposed on Secure Processing Environment access logs by Article 73(1)(e) EHDS. The second is an erasure obligation for personal data, exercisable at any time by the data subject. The third is a six-month deletion ceiling for processed data in Secure Processing Environments. This thesis is positioned within that unresolved tension.

1.2 Problem Statement

The European Health Data Space establishes legal rights and operational obligations, but it does not prescribe how the three retention regimes described above are to be reconciled in technical practice. The result is a structural conflict embedded in the cross-border audit trail.

When a Norwegian patient is treated in another Member State, the access event is logged in the local NCPeH's ATNA-compliant audit repository, retained for the period national law and the operator set (six years in the Norwegian pilot, Section 1.1), and accessible to the patient through the home country's audit-log interface (Simjanoska Misheva et al., 2025). If, during that window, the patient exercises the right to erasure under GDPR Article 17, the institution faces a choice between three positions, each of which violates one of the other regimes. Deleting the audit record honours Article 17 but destroys the integrity of the audit chain that the eHDSI framework, eIDAS-based access traceability, and EHDS patient rights all depend upon. Retaining the audit record in full preserves the chain but fails the erasure obligation. Pseudonymising the record creates ambiguity about whether the pseudonymisation is reversible, which under GDPR Recital 26 may not satisfy true anonymisation.

An apparent resolution must be confronted at the outset. Article 17(3)(b) GDPR exempts erasure to the extent that processing is necessary for compliance with a legal obligation to which the controller is subject. It could therefore be argued that the audit-retention obligation simply disapplies Article 17 for audit records, and that no conflict exists. I take the position, defended in Sections 2.3 and 4.2, that the conflict survives the exemption in a precise form. The exemption extends only as far as retention is *necessary* for the legal obligation, and the data-minimisation principle of Article 5(1)(c) GDPR requires that no more personal data be retained than the obligation demands. Retaining the full plaintext payload of an audit record for the length of the floor exceeds what accountability requires, since the accountability function of the record can be preserved without continued access to that payload; for Secure Processing Environment logs I argue this for the part of the payload auditing does not need (Chapter 4, Corollary 2.3). Moreover, the six-month deletion ceiling under Article 68(12) EHDS admits no equivalent exemption. What may lawfully be retained is therefore the accountability skeleton of the record rather than its full personal-data content: and specifying, formalising, and demonstrating exactly that residue is the work of this thesis.

The same conflict arises in the secondary-use pathway through erasure requests, and, as a conditional extension, it arises there even without them: on the broad reading of Article 68(12), for logs kept at patient-record granularity (Chapter 4, Section 4.6). Consider a researcher who receives a data permit from the national health data access body, Helsedataservice (Folkehelseinstituttet, 2024), and processes the data within a Norwegian Secure Processing Environment such as those operated by the Trusted Research Environments collaboration NORTRE (Norwegian Trusted Research Environments, n.d.). On the broad reading the environment must therefore be emptied of electronic health data six months after permit expiry, under Article 68(12) as operationalised by TEHDAS2, while continuing to hold, for at least a further six months, identifiable records of who accessed what within it, exactly as Section 1.1 sets out; no provision resolves the two. Article 73(5) requires the Commission to lay down, by means of implementing acts and by 26 March 2027, the technical,

organisational, information-security, confidentiality, data-protection and interoperability requirements for Secure Processing Environments. The secondary-use provisions themselves, Articles 68 and 73 among them, become applicable on 26 March 2029. The collision is therefore not yet operative, and the window in which its resolution could be specified rather than improvised closes with those implementing acts.

Figure 1.1 places both audit logs in the infrastructure, with the point at which the mechanism of Chapter 4 attaches to each.

These conflicts are not theoretical, and the Norwegian policy process has moved while leaving them unresolved. The SPUHiN project, jointly led by Helsedirektoratet and the Norwegian Institute of Public Health, acknowledged in its November 2024 draft recommendations that Norway lacks a formal regulatory definition of a Secure Processing Environment (SPUHiN, 2024). Following a public hearing between July and October 2025, the Directorate states that the criteria are included in deliverable D5.2, with separate compliance checklists for SPE providers and SPE user organisations, positioned as a national reference basis pending the EU implementing act (SPUHiN, 2025). The version I inspected, the one put to hearing, contains governance and functional requirements but no mechanism reconciling the retention and erasure regimes. The absence is observed in that version and has not been checked against the deliverable as submitted.

A small but rapidly growing body of cryptographic research has begun to address adjacent problems. Albalwy (2026) demonstrates zero-knowledge policy enforcement for cross-institutional health data sharing within a single jurisdiction. Natsiavas et al. (2021) document KONFIDO, the most direct architectural ancestor for cross-border health data security, which combined trusted execution environments, homomorphic encryption, and blockchain-based auditing on the OpenNCP gateway. Bai et al. (2022) describe Health-zkIDM, a Hyperledger Fabric-based decentralised identity system for healthcare. None of these works addresses the audit-retention versus erasure tension at the cross-border audit layer, and none provides a formal account of the conditions under which the three regimes can be jointly satisfied.

The problem this thesis addresses is therefore twofold: the absence of a formal characterisation of the tri-lateral retention conflict in cross-border health data audit trails under EHDS, and the consequent absence of a technically specified, regulation-aligned mechanism for resolving it in a manner compatible with the operational reality of Norwegian implementation.

1.3 Research Objectives and Questions

The objective of this thesis is to formally characterise, and then resolve by design, the conflict between the three retention regimes identified in Section 1.2.

The analytical core of the thesis is the Tri-Lateral Retention Feasibility Model (TRF Model), a constraint-satisfaction formulation developed in Chapter 4 within the established tradition of formal legal-compliance verification (Feng et al., 2023). It decomposes each cross-border audit record into event metadata (the accessor's fields and the link to the patient) and a payload bound by a cryptographic commitment, and expresses the three regimes as constraints over discretised time.

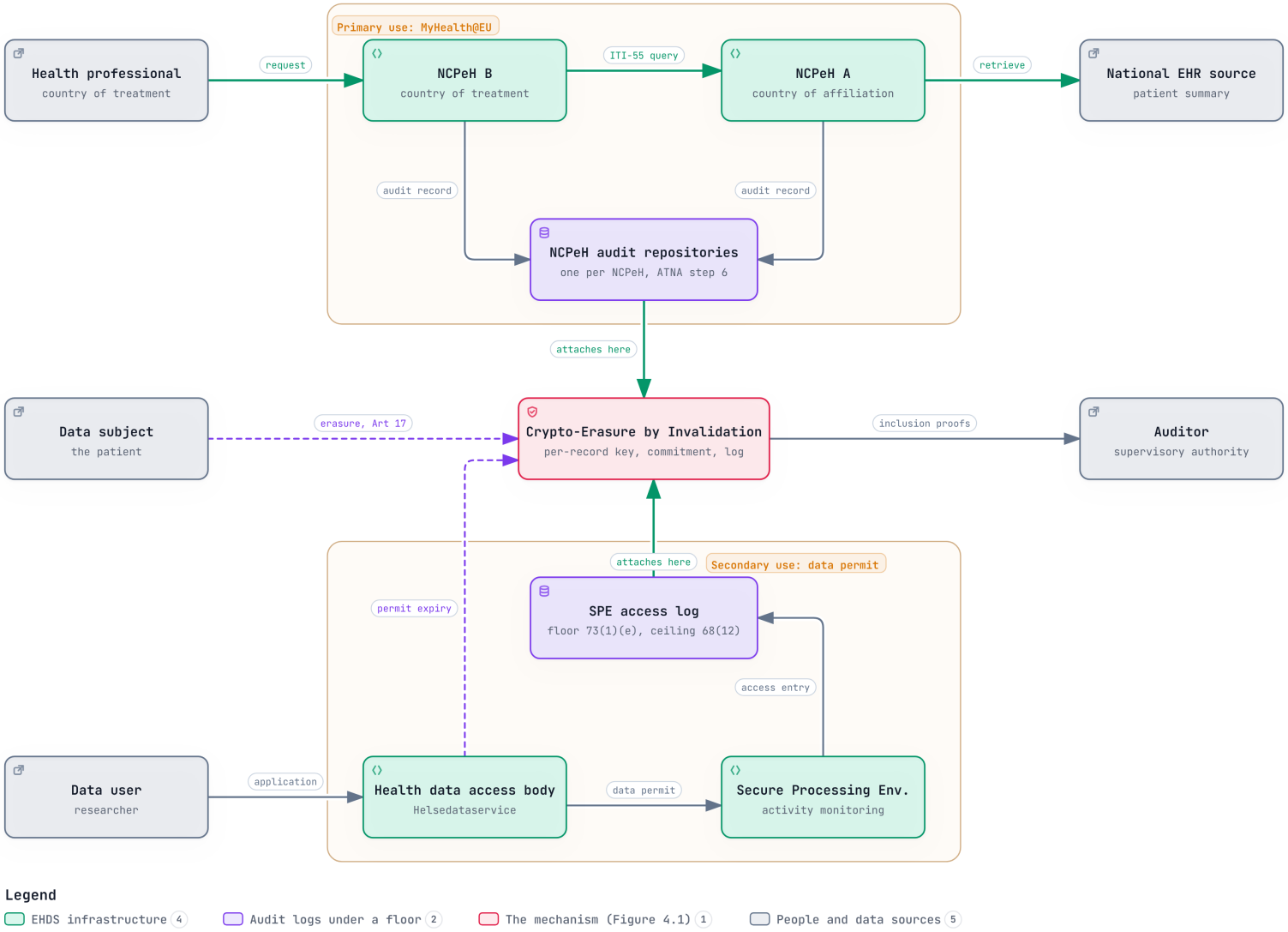


Figure 1.1. The two audit logs this thesis concerns and where the mechanism attaches. In primary use, each National Contact Point writes an audit record of the cross-border exchange to its own audit repository. In secondary use, a Secure Processing Environment operating under a data permit writes an access log, bound by the one-year floor of Article 73(1)(e) and, on the broad reading, the ceiling of Article 68(12). Crypto-Erasure by Invalidation (Figure 4.1) attaches at both logs, takes erasure requests from the data subject and each permit's expiry from the health data access body, and gives auditors inclusion proofs. Placement as specified in Chapter 4, Section 4.11.

The model is tri-lateral in structure, being floor, right, and ceiling, rather than in the number of instruments it accommodates, with the retention floor parameterised so that a long cross-border audit floor and the one-year Secure Processing Environment log floor are two instances of one constraint. Examining satisfiability under two competing semantics of verifiability, Chapter 4 proves the system infeasible under plaintext verifiability whenever a deadline falls inside a retention window and jointly satisfiable, for every arrival pattern of erasure requests and permit expiries, under an accountability-preserving semantics (intact metadata, a surviving commitment, and a logged, witnessed invalidation event); the constructive witness of that result is the mechanism Crypto-Erasure by Invalidation, which applies the cryptographic-erasure technique recognised in NIST Special Publication 800-88 Revision 2 at the audit-trail boundary. Two further results locate the conflict: a deletion ceiling can collide with a retention floor only if it is no longer than the floor, and its anchor decides whether the collision is visible in the text (Proposition 3), and relocating a record meets the ceiling but not the right to erasure (Proposition 4).

The thesis is guided by one primary research question.

Primary research question. How can a verifiable crypto-erasure mechanism be designed to reconcile the conflicting data-retention requirements of cross-border health data exchange under the European Health Data Space, while preserving audit integrity in a Norwegian implementation context?

The conflicting requirements are three: the audit-retention floors applying to the exchange (the one-year minimum imposed on Secure Processing Environment access logs by Article 73(1)(e) EHDS, and, for IHE ATNA audit repositories, a longer period the specifications leave to national law, reported as ten years in the literature and decided at six for the Norwegian pilot by Helsedirektoratet as controller); GDPR Article 17's right to erasure; and the six-month deletion ceiling of Article 68(12) EHDS, as operationalised by TEHDAS2.

The primary question is decomposed into three sub-questions.

SQ1. What are the precise points of conflict between the audit-retention floors, GDPR Article 17, and the Article 68(12) deletion ceiling in the cross-border EHDS workflow, and under what formal conditions are the three regimes jointly satisfiable?

SQ2. Can a cryptographic invalidation mechanism, in which the references binding audit records to personal data are mathematically invalidated rather than the records being deleted, satisfy all three constraints simultaneously, across floors of differing duration?

SQ3. How would such a mechanism integrate with Norway's current cross-border infrastructure, specifically the NCPeH operated by Helsedirektoratet and Norsk Helsenett, the Health Data Access Body Helsedataservice, and the Secure Processing Environments operated under NORTRE?

SQ1 is addressed through Chapter 2's literature analysis and the formal characterisation in Chapter 4. SQ2 is addressed through the TRF Model's feasibility propositions, the mechanism specification in Chapter 4, and the executable demonstration in Chapter 5. SQ3 is addressed through Chapter 4's integration analysis and Chapter 6's discussion of implications for Norwegian implementing actors.

1.4 Significance and Relevance

A note on the title first. "Verifiable" qualifies the invalidation record, which an auditor can check for attribution and for inclusion in a tamper-evident log, not the erasure itself, which no auditor can verify (Chapter 4, Section 4.9).

The significance of this thesis rests on four convergent factors.

First, the timing is concrete rather than abstract. The Group One priority categories of EHDS become mandatory across the EU in March 2029 (in Norway, subject to incorporation into the EEA Agreement), with Group Two following in March 2031, and the implementing acts specifying technical detail are due by March 2027 (European Commission, 2025b). Norway's NCPeH is in live pilot operation, with its outbound capability under construction during 2026 (Helsedirektoratet, 2026), as Section 1.1 describes. Decisions about how cross-border audit trails will handle conflicting retention obligations will be made within the current implementation window. The regulatory background to those decisions is one the European Data Protection Board's February 2026 Coordinated Enforcement Framework report on Article 17, spanning thirty-two supervisory authorities and 764 controllers, explicitly identifies as unsettled, naming the definition and implementation of retention periods among the recurring difficulties (European Data Protection Board, 2026a). In parallel, the Board's Guidelines 02/2025 on blockchain technologies state, in paragraph 51, that once the decryption key is deleted the encrypted data will be unintelligible, at least until the algorithm is broken, while holding in the same paragraph that encrypted personal data is still personal data, and in paragraph 125 that an erasure request requires the data to be erased or rendered anonymous (European Data Protection Board, 2026b). The Guidelines thus recognise what key deletion achieves without treating it as erasure, and the mechanism proposed here is designed accordingly: it deletes the payload, and relies on key destruction only for copies that cannot be deleted at once (Chapter 4, Section 4.8). The further condition that the controller document its threat model derives from Aikebaier's (2026) interpretation rather than from the Guidelines themselves.

Second, the Norwegian implementation context provides a concrete, named substrate. It includes a presumptive Health Data Access Body in Helsedataservice (Folkehelseinstituttet, 2024), not yet formally designated under the Regulation, and a developed Trusted Research Environment collaboration in NORTRE (Norwegian Trusted Research Environments, n.d.). It also includes national SPE criteria from the SPUHiN process, whose checklists in the hearing version do not address the retention-erasure question (SPUHiN, 2025), and parallel legislative work on professional confidentiality and cross-organisational access (Stortinget, 2025).

Third, the contribution is positioned at a level the existing literature does not occupy. The general method of formalising legal compliance as a satisfiability problem is established (Feng et al., 2023), and the cryptographic-erasure technique is recognised in standards (Chandramouli & Hibbard, 2025) and critiqued in practice. But no published work found in this review formally models the specific tri-lateral conflict of the cross-border health audit trail, and no work derives a reconciling mechanism from such a model. This holds also for the conflict's conditional extension. The collision between the six-month deletion ceiling of Article 68(12) and the one-year log-retention floor of Article 73(1)(e) is stated within a single regulation, yet the review I conducted found no treat-

ment of it in the literature. The Joint Action's specification for these environments comes closest: it requires deletion at permit expiry "while ensuring compliance with applicable legal obligations and traceability or reproducibility requirements", and leaves the balance to each operator's policy (TEHDAS2, 2026b, Table 5.2, OPR-6, p. 43). Its expert commentary raises "open questions about how accountability and anonymisation obligations intersect" for a related record, the project logbooks researchers keep (TEHDAS2, 2026b, Annex 7, p. 96). It asks for the balance; it does not supply one. Part of the explanation is procedural: in the 2022 proposal these obligations sat in Articles 46 and 50 and were renumbered on adoption in 2025, so that much existing commentary discusses them under superseded numbering and in separate literatures. The gap is corroborated externally, though the corroborating source carries limited weight and I do not rest the claim on it alone. The most recent systematisation of the cryptographic-erasure literature, a single-author preprint that has not been peer-reviewed, closes by naming erasure under multi-regime retention conflict among five open problems for the field (Aikebaier, 2026). Albalwy (2026) occupies the cross-institutional space within a single jurisdiction; KONFIDO (Natsiavas et al., 2021) addressed cross-border security without resolving the retention-erasure tension and depended on trusted hardware. The thesis's novelty claim is therefore layered and bounded: the formal characterisation of an unformalised conflict, expressed through an information-logistics lens that is itself new to this problem, with the mechanism as the derived solution: an application of recognised primitives, not a claim of foundational cryptographic novelty.

Fourth, I frame the problem as one of information logistics, and the framing is where I come from: before this programme I worked for four years in cross-border procurement and logistics across the DACH region, India and the United Arab Emirates. Physical cross-border logistics meets a similar problem in customs, where documentation must be retained while the goods it describes may be ordered destroyed. This situates the contribution within the disciplinary identity of Sustainable Energy Logistics at HiMolde. The borrowing is specific rather than wholesale: customs law already keeps the record of goods after the goods themselves have been destroyed (Chapter 2, Section 2.7), and that separation of the record from the thing recorded is the move Chapter 4 makes for the audit trail.

1.5 Scope and Out-of-Scope

This thesis is bounded by a deliberate and explicit scope, set by what can be defended within the time and resources of an MSc thesis.

The thesis contributes a formal model, a design-science specification derived from it, and an executable demonstration. The TRF Model formalises the conflict, and the Crypto-Erasure by Invalidation mechanism is specified as the model's constructive feasibility witness. A Python-based sandbox using synthetic Synthea-generated FHIR data then demonstrates both the infeasibility result under plaintext semantics and the feasibility result under invalidation semantics. The model, the specification, and the demonstration together constitute the artefact.

The thesis explicitly does *not* include the following. First, it does not build a working zero-knowledge SNARK circuit; no component of the mechanism requires one, and the cryptographic machinery that an earlier design iteration envisaged is treated as future work, at the one point where it becomes necessary (Chapter 7, Section 7.5). Second, it does not deploy to a real National Contact Point for eHealth; integration with Norwegian NCPeH operations remains an architectural mapping rather than a runtime test. Third, it does not conduct human-subject interviews, and no qualitative empirical data are reported. Fourth, it does not measure hardware energy consumption, and no sustainability metrics are claimed beyond conceptual framing. I claim no energy saving for the mechanism; its place in a programme in Sustainable Energy Logistics is in the logistics of information rather than of energy: it treats a regulated cross-border record as a consignment whose custody, retention and destruction are governed by the regimes it crosses. Fifth, it does not use real patient data; all sandbox data are synthetic and contain no information about real individuals. Sixth, it does not implement healthcare-professional authentication or consent-propagation protocols beyond the invalidation mechanism itself. Seventh, it does not provide machine-checked formal proofs; the four propositions are proved informally at the level of rigour standard for design-science work, and their executable check in the sandbox is a demonstration, not a verification in the proof-assistant sense. Eighth, it does not prove destruction of cryptographic keys; the mechanism's guarantees are conditional on honest key destruction, a limitation examined in Chapter 6. Ninth, it does not model the national retention laws of receiving jurisdictions beyond the Union-level instruments; the time horizon of the model is parameterised so that jurisdiction-specific floors can be substituted. Tenth, it does not address non-EU and non-EEA jurisdictions.

Three components related to the broader research direction are outside the scope of this thesis: a zero-knowledge assertion circuit for healthcare-professional authorisation, a sustainability indicator for proof systems, and a cross-border consent-revocation propagation protocol. Results for them have not been produced and are not claimed.

1.6 Methodological Approach

I adopt Design Science Research, as established by Hevner et al. (2004) and elaborated by Peffers et al. (2007), in its specification-and-demonstration variant, extended with a formal-modelling step. The DSR cycle of problem identification, objectives, design and development, demonstration, evaluation, and communication is mapped onto the thesis chapters, with the design phase anchored in the TRF Model. The mechanism is developed as the constructive answer to a formally stated feasibility question, following the tradition of formal compliance verification exemplified by Feng et al. (2023). It employs lighter machinery, a feasibility formulation over one binary state variable per record, suited to defence at Master's level and to the logistics-modelling training of my programme.

The project name VERA-SNARK originates from an earlier design iteration, presented in preliminary form at the NORS 2025 conference, which envisaged zero-knowledge succinct arguments as the enforcement machinery. The design-science process (specifically, the formal analysis of what the three retention regimes actually require) showed that cryptographic commitments and a logged invalidation registry suffice for the audit-trail problem, and that no SNARK is required; an accumu-

lator layer is specified in Chapter 4 as optional and is not implemented. The project name is retained for continuity; the mechanism specified and demonstrated in this thesis contains no SNARK, and the evolution from the earlier architecture is itself an instance of the DSR cycle functioning as intended.

The demonstration is conducted in a controlled sandbox using synthetic data generated by Synthea, an open-source generator of synthetic patient records compliant with HL7 FHIR R4, the version reflected in the current Norwegian basisprofiler maintained by HL7 Norway (HL7 Norway, 2025). The sandbox has two layers: a feasibility checker that walks synthetic audit records through randomised arrivals of erasure requests and permit expiries, verifying that the constraint system fails under plaintext-verifiability semantics and holds under invalidation semantics; and a realism layer feeding Synthea-generated records into the checker. The evaluation strategy is analytical: internal validity through the logical consistency of the model and the coherence of mechanism and propositions; external validity through compatibility with verified existing infrastructure; reliability through deterministic execution with fixed random seeds. No empirical performance benchmarks are reported. The full methodological treatment is provided in Chapter 3.

1.7 Thesis Structure

The thesis is organised in seven chapters and appendices.

Chapter 1 introduces the regulatory background, the problem, the research objectives, the significance of the study, the scope and explicit out-of-scope boundaries, and the methodological approach.

Chapter 2 reviews the literature in six domains: the cross-border health data exchange landscape under EHDS; the audit-retention versus right-to-erasure tension, including the Article 17(3)(b) exemption argument; cryptographic approaches to audit compliance, including secure deletion and tamper-evident logging; formal approaches to regulatory-compliance verification; the Norwegian secondary-use infrastructure; and the information-logistics framing. It identifies the research gaps and positions the contribution.

Chapter 3 establishes the design science research paradigm, the specification-and-demonstration variant extended with formal modelling, the synthetic data methodology, the sandbox approach, and validity, reliability, and ethical considerations.

Chapter 4 develops the TRF Model, covering its sets, decomposition, constraints, the two verifiability semantics, the infeasibility and feasibility propositions, and the anchoring proposition. It then specifies the Crypto-Erasure by Invalidation mechanism derived from it, including the key hierarchy, the invalidation registry and the tamper-evident log, analyses its residue, compares it against six rival designs with the location proposition, and traces it requirement by requirement to the regulation, the Joint Action's specification for Secure Processing Environments, and the Norwegian NCPeH and NORTRE infrastructure (Table 4.1).

Chapter 5 presents the sandbox demonstration: the executable feasibility check, the separately written exhaustive cross-check, a bounded SMT check of Propositions 1–3, the audit-log integrity and tamper tests, and the optional run with real envelope encryption. *Chapter 6* discusses findings and their implications for practice, theory, and policy, engages the principal counter-positions, and tests the model on a statute outside health. *Chapter 7* concludes, summarises contributions, revisits limitations, and outlines future work.

Chapter 2. Literature Review and Theoretical Foundation

2.1 Review Protocol

2.1.1 Type of review and why it is named as such

This review is a structured narrative review conducted under a documented and dated protocol, not a systematic review. A systematic review executes a pre-registered strategy in a single sweep against a fixed set of indexed databases, with independent screening by more than one reviewer; this review proceeded iteratively across four dated search rounds and a fifth, verification-only round, used natural-language rather than Boolean queries, drew substantially on primary regulatory and government sources not indexed in bibliographic databases at all, and was screened by one reviewer. Calling it systematic would misdescribe it.

What the review can offer instead is replicability of a different and, for this subject, more appropriate kind. It provides a complete record of what was searched and when, the criteria applied, and the screening account. It also provides a prospective Boolean protocol that a researcher may execute against indexed databases, to test whether the conclusions survive a systematic sweep. Section 2.1.6 provides that protocol and states plainly that it was not the instrument used here.

2.1.2 What the review had to establish

The review is organised around the conceptual architecture of the thesis rather than around exhaustive coverage of a field. It had to establish four conditions on which the contribution depends. The first is that the cross-border landscape under the European Health Data Space is advanced enough, and Norwegian participation committed enough, for the contribution to be timely. The second is that the audit-retention versus erasure tension is real, named in primary sources, and unresolved. The third is that cryptographic and formal approaches have matured enough to make the proposed mechanism plausible while leaving the specific conflict unaddressed. The fourth is that the Norwegian secondary-use infrastructure provides a concrete substrate. A search strategy optimised for recall across a defined corpus would not have served these conditions, three of which turn on primary legal and governmental material.

2.1.3 Sources searched

Academic literature was searched through Google Scholar, arXiv, the Cryptology ePrint Archive, PubMed and PubMed Central, and publisher platforms including Springer, IEEE Xplore, MDPI, Sage, JMIR, and BMC. Primary regulatory material was retrieved directly from EUR-Lex, the European Commission's Directorate-General for Health and Food Safety, and the European Data Protection Board. Standards material was retrieved from IHE International, NIST, and HL7 and HL7 Norway. Norwegian governmental and institutional material was retrieved from helsedirektoratet.no, helsedata.no, datatilsynet.no, nortre.no, and stortinget.no. Joint Action material was retrieved from tehdas.eu. Patent literature was searched through public patent databases in the final round.

2.1.4 Search rounds

Round	Date	Purpose	Distinct queries
0	before 24 May 2026	Exploratory reading and drafting, documented at artifact level only	not recoverable
1	25 May 2026	Landscape, infrastructure, regulatory baseline	16
2	29 May 2026	Verification and correction of the initial draft's claims	10
3	15 September 2026	Resumption; novelty audit and currency check	7 (plus 3 retrievals of the author's own drafts)
4	16 September 2026	Adversarial novelty testing, prior art, final currency	23
5	28 September 2026	Locator verification and source-standing audit; no discovery queries	18 locator checks
		Total discovery and verification queries, rounds 1–4	**56**

Round 0 is the exploratory reading that preceded the documented rounds. Its queries were not recorded, and it contributes nothing to the absence claim of Section 2.9, which rests on the four documented search rounds.

Every query in rounds 1 to 4 is reproduced verbatim, by round, in Appendix B. A fifth round, on 28 September 2026, contained no discovery queries: it verified locators and source standing for entries already in the bibliography, and is described by target in Appendix B. The queries were natural-language rather than Boolean, which reflects both the mixed academic and governmental character of the corpus and the exploratory character of the early rounds.

Two features of the round structure bear on how the results should be read. Rounds 2 and 4 were adversarial in intent. Round 2 tested the claims carried forward from the exploratory phase. Round 4 sought work that would defeat the thesis's novelty claim rather than support it, which is how the closest prior art, a database retention-and-purging research programme and its associated patent, was located and disclosed.

2.1.5 Selection criteria and screening

Two criteria governed inclusion throughout. Every cited source must be retrievable through a public URL, a DOI, or a primary repository at the time of writing, so that any claim can be independently verified; the two exceptions, a withdrawn hearing document (SPUHiN, 2025) and official correspondence, are labelled where they are cited. And where secondary commentary conflicts with primary regulatory or standards text, the primary text prevails; secondary sources are cited for analysis or for evidence of practice, never for the factual content of an instrument.

Material was included in three categories: peer-reviewed work published between 2018 and 2026 bearing on cross-border health data exchange, cryptographic erasure, formal compliance verification, or the GDPR erasure right; primary regulatory, legislative, standards, or governmental material of any date; and practitioner and industry material, where the claim being supported is one about industry practice rather than about law.

Four kinds of material were excluded: work addressing data-protection regimes outside the European Union and European Economic Area without comparative bearing; opinion writing without an identifiable evidential basis; work not retrievable at the time of writing; and any source that could not be verified against a primary or publisher record.

Screening proceeded from query results through title and abstract assessment to full-text or full-document assessment, with sources entering the working bibliography only after the verification step. Because the review was iterative rather than a single sweep, a PRISMA flow diagram reporting identification, screening, eligibility, and inclusion counts cannot be reconstructed for rounds 1 and 2, whose intermediate counts were not retained. Reporting reconstructed counts would give the appearance of a systematic process that was not followed. What is retained and reported instead is the full query log, the working bibliography with its verification status per source, and the correction record.

2.1.6 Prospective Boolean protocol for replication

A prospective Boolean protocol, offered so that a researcher may test this review's conclusions against a systematic sweep of indexed databases, is set out in Appendix B (Table B.1). It was not the instrument used here, and is stated prospectively.

2.1.7 Limitations of the protocol

Five limitations follow from how the review was conducted.

The exploratory phase before round 1 is not claimed as evidence, because its queries were never recorded. Screening was performed by a single reviewer, so no inter-rater reliability can be reported. Intermediate screening counts for the first two rounds were not retained, so no PRISMA flow diagram is offered. The queries were natural-language, so recall cannot be characterised in the way a Boolean strategy over an indexed corpus permits. The absence of prior work on the central conflict, reported in Section 2.9, rests on four dated search rounds, two of them adversarial, together

with an independent corroborating statement in the cryptographic literature. But an absence established by searching remains weaker evidence than a positive finding. Section 2.9 therefore states the additional reasons the gap is likely genuine, rather than resting on the searches alone.

2.2 The Cross-Border Health Data Exchange Landscape

The European Union's cross-border health data infrastructure rests on a regulatory framework that has matured rapidly during the past three years, and on a technical platform that has been in operation, in voluntary form, for more than a decade. The two layers are now converging under the European Health Data Space Regulation, which establishes the legal architecture within which the existing technical platform must scale.

Regulation (EU) 2025/327 of 11 February 2025 establishing the European Health Data Space was published in the Official Journal on 5 March 2025 and entered into force on 26 March 2025. Its entry into force opened a multi-year transition during which Member States and European Economic Area countries must align their national infrastructures with binding Union-wide requirements (European Parliament and Council of the European Union, 2025). Entry into force and application must be distinguished, and the distinction bears directly on this thesis. Under Article 105 the Regulation applies generally from 26 March 2027, with staggered commencement thereafter. The secondary-use provisions of Chapter IV, which include both the Article 68(12) deletion ceiling and the Article 73(1)(e) log-retention floor, become applicable on 26 March 2029, and further milestones fall in March 2031 and March 2035. The regulation governs both primary use (the provision of healthcare to the data subject) and secondary use (research, innovation, policy-making, regulatory activities, and public health) (European Commission, 2025b). For primary use, the Article 105 calendar runs from the implementing acts due by 26 March 2027, through Group One categories (patient summaries, ePrescriptions) exchangeable by 26 March 2029 and Group Two categories (laboratory results, medical imaging, hospital discharge reports) by 26 March 2031 (European Commission, 2025b). Each Member State must designate one or more digital health authorities by 26 March 2027 (Article 19(1)), and the requirements on electronic health record systems follow the same schedule from 26 March 2029 (European Parliament and Council of the European Union, 2025).

The technical platform implementing cross-border primary use is MyHealth@EU, the operational successor to the eHealth Digital Service Infrastructure (eHDSI). MyHealth@EU connects national systems through National Contact Points for eHealth (NCPeH), each operated by the participating country's competent authority and funded historically through the Connecting Europe Facility Telecom Programme (2015–2020) and currently through the EU4Health Programme (2021–2027) (European Commission, 2025a). Governance is exercised by two coordinating bodies: the eHealth DSI EU countries Expert Group (eHMSEG), composed of managers responsible for NCPeH implementation in participating countries, and the eHealth Operational Management Board (eHOMB), composed of European Commission representatives and the eHMSEG Chairs (European Commission, 2025a).

The MyHealth@EU operational architecture follows a six-step transmission flow at the NCPeH gateway level, recently characterised in detail by Simjanoska Misheva et al. (2025): service and patient

discovery against the patient's home-country gateway; retrieval of the requested document, typically an International Patient Summary or an ePrescription; conversion through a pivot transformer to the common European Electronic Health Record Exchange Format; validation of the requesting clinician's eIDAS identity token and application of consent policies; and logging of the transaction in an IHE Audit Trail and Node Authentication compliant audit repository, whose retention period is left to national law (Section 2.3).

Norway's integration with MyHealth@EU began in January 2023 under the joint operational responsibility of Helsedirektoratet and Norsk Helsenett SF, the national operator of the closed Norwegian health network, with a planned duration of 41 months. The pilot is live and in production at the emergency clinics in Bodø and Stjørdal, receiving patient summaries for citizens of other participating states, with further clinics requesting the service for the next stage, and in 2026 the project began establishing NCP-A, the contact point through which Norwegian health data will be shared outward (Helsedirektoratet, 2026). The legal basis, privacy notices and data protection impact assessment were completed by 31 March 2025. The Directorate's portfolio reporting records that no relevant patients had yet presented for the solution to be used in practice, so the infrastructure is operational while the volume of records generated remains small; this thesis relies on the former and does not claim the latter. Infrastructure for receiving ePrescriptions has been planned and developed but is not yet in use (Helsedirektoratet, 2026). Because Norway is a member of the European Economic Area rather than of the European Union, the EHDS Regulation does not apply directly but is being processed for incorporation through the EEA Joint Committee; the Norwegian Directorate of Health delivered its formal EHDS impact and gap analysis on 11 April 2025 (Helsedirektoratet, n.d.).

Parallel to the primary-use track, the regulation establishes a secondary-use track through which national Health Data Access Bodies coordinate access to electronic health data for research, innovation, and policy purposes. The interconnecting infrastructure for secondary use is HealthData@EU, which complements MyHealth@EU and operates under different technical and governance arrangements. The technical, functional, and security specifications for the Secure Processing Environments through which secondary-use data must be processed have been developed under the TEHDAS2 Joint Action, a coordinated effort of twenty-nine countries running until December 2026 (Healthy Europe, 2026). TEHDAS2 published these specifications during 2026. They set out the minimum technical, functional, and security capabilities that Secure Processing Environments must offer, together with baseline interoperability requirements for federations of such environments, and position the document as input to standardisation work and to the European Commission's implementing acts (TEHDAS2, 2026b). The implementing acts themselves, which will lay down the binding technical, organisational, information-security, confidentiality, data-protection, and interoperability requirements for Secure Processing Environments under Article 73(5) EHDS, are due by 26 March 2027 and had not been adopted at the time of writing. The national body exercising access-decision authority, and the presumptive Health Data Access Body under this regime, is Helsedataservice, hosted at the Folkehelseinstituttet (Norwegian Institute of Public Health), which since 2023 has held the decision-making authority for eleven statutory national health registries (Folkehelseinstituttet, 2024).

The historical context of these institutional arrangements is important for the present thesis. The Norwegian central analytics platform Helseanalyseplattformen was paused in December 2021 following legal challenges related to the Schrems II judgment on transatlantic data transfers, and was formally discontinued (avviklet) by the Ministry of Health and Care Services in February 2023. The Direktoratet for e-helse, which had led much of the early national e-health standards work, was merged into Helsedirektoratet with effect from 1 January 2024 (Helsedirektoratet, 2024). The Norwegian secondary-use infrastructure that the EHDS will be implemented against is therefore not a centralised analytic platform. It is a distributed model resting on the three university-based trusted research environments, TSD at the University of Oslo, SAFE at the University of Bergen, and HUNT Cloud at NTNU, coordinated through the NORTRE collaboration (Norwegian Trusted Research Environments, n.d.).

The cross-border landscape is therefore mature in its regulatory architecture, advancing in its technical infrastructure, and concretely defined in its Norwegian implementation. It is against this landscape that the audit-retention and erasure tensions become not abstract but operationally consequential, as Section 2.3 will demonstrate.

2.3 The Audit-Retention versus Right-to-Erasure Tension

The thesis is built around a structural tension between three retention regimes that operate concurrently on the same cross-border health data event, each grounded in a primary source (a technical integration profile, a binding regulation, and an evolving Joint Action specification), none resolving the others. This section examines each in turn, then the resulting conflict, the principal legal objection to it, and the regulatory doctrine on what counts as erasure.

The first regime is technical. The IHE Audit Trail and Node Authentication (ATNA) profile, maintained in Volume 1 Chapter 9 of the IHE IT Infrastructure Technical Framework, specifies the foundational audit and security requirements for nodes participating in interoperable health information exchange (IHE International, 2023). ATNA establishes a Basic Secure Node that must authenticate other nodes, encrypt communications using TLS, log triggered events such as queries, views, additions, deletions, and changes within the security domain, and transmit those audit records to an Audit Record Repository. The IHE specification itself does not mandate a single global retention period, leaving that decision to the realm-specific or domain-specific deployment binding. The eHDSI security framework that operationalises ATNA within the MyHealth@EU infrastructure is reported to specify retention in concrete terms: Simjanoska Misheva et al. (2025) characterise a minimum of ten years for audit repositories as the binding deployment baseline for cross-border NCPeH operations. That tutorial article gives no source for the figure. The primary document this thesis could inspect, the agreement under which National Contact Points join the cross-border services, requires each party to ensure its contact point's compliance "with the requirements for logs, audit trails, non-repudiation" and states no period in its main text (eHealth Network, 2017, clause II.4.2); the annexes that would fix one were not available. Correspondence with Helsedirektoratet, the Norwegian NCPeH operator and controller, resolves the point directly: the directorate confirms that neither the requirements catalogue nor the associated Security Services, System Architecture, NCPeH Architec-

ture, and Audit Trail specifications fix a retention method or period, that the matter is left to national legislation, and that for the pilot it has decided on a six-year retention, with the production figure undecided and reserved to the directorate as data controller (H. L. Larsen, Helsedirektoratet, personal communication, 19 October 2026); the reply is reproduced, with permission, in Appendix D. The implementing regulation on MyHealth@EU adopted since, Commission Implementing Regulation (EU) 2026/2083, which applies from 26 March 2027, requires the national contact points, as joint controllers, to log exchanges of personal data systematically, recording the actors involved, the categories of data and the purposes (Article 15(1)(f)(ii)); it too sets no period for keeping those logs (European Commission, 2026). The reported ten-year figure is therefore not an established requirement but one reading of a parameter the primary source leaves unfixed; the thesis treats the floor as illustrative at any value, and Chapter 4, Corollary 2.2 shows that no result depends on it. This retention floor exists because cross-border audit records support not only patient-facing access logs but also accountability for the eIDAS-based authentication of the requesting clinician, the consent validation step, and the audit trail required under the European Health Data Space patient-rights provisions.

The second regime is legal. Article 17 of the General Data Protection Regulation (Regulation (EU) 2016/679) establishes the data subject's right to obtain from the controller the erasure of personal data concerning them without undue delay, where one of the conditions in Article 17(1) applies (European Parliament and Council of the European Union, 2016). These conditions include the cessation of the original purpose, the withdrawal of consent without an alternative legal basis, an objection under Article 21 with no overriding legitimate interest, and unlawful processing. The data controller bears an independent obligation to erase in these conditions, irrespective of whether the data subject has formally exercised the right (European Data Protection Board, 2026a). Article 17(3) provides limited exemptions, of which three are directly relevant to the cross-border audit context. Article 17(3)(b) permits the controller to refuse erasure where processing is necessary for compliance with a legal obligation imposed by Union or Member State law. Article 17(3)(c) permits refusal for reasons of public interest in the area of public health in accordance with points (h) and (i) of Article 9(2) and Article 9(3), a ground open to a health-sector controller for records of care given across a border. Article 17(3)(d) permits refusal where processing is necessary for scientific or historical research purposes or statistical purposes, in so far as erasure is likely to render impossible or seriously impair the achievement of those purposes. The European Data Protection Board's Coordinated Enforcement Framework report on Article 17 was published on 18 February 2026, following an investigation involving 32 supervisory authorities and 764 controllers. It identified the implementation of retention periods among the recurring issues, and recommended further practical guidance on how to define and implement retention periods consistent with national legal obligations (European Data Protection Board, 2026a; Matheson, 2026).

The third regime is operational and emerging. The TEHDAS2 Joint Action's guideline for Health Data Access Bodies on procedures and formats for data access carries the deletion deadline into its procedure: data are to be deleted from a Secure Processing Environment within six months of the expiry of the data permit, following Article 68(12) of the European Health Data Space Regulation

(European Parliament and Council of the European Union, 2025; TEHDAS2, 2026a, Section 7.2). This is a ceiling rather than a floor.

The regulation places a retention floor on that same environment. Article 73(1)(e) EHDS requires of Secure Processing Environments "the keeping of identifiable logs of access to and activities in the secure processing environment for the period necessary to verify and audit all processing operations in that environment; logs of access shall be kept for at least one year" (European Parliament and Council of the European Union, 2025). Article 68(12) requires that "the electronic health data within the secure processing environment shall be deleted within six months of the expiry of the data permit". On the broad reading it reaches access logs kept at patient-record granularity, whose entries are themselves data concerning health; on a narrower reading it reaches only the permitted dataset. Peer-reviewed commentary on the secondary-use framework likewise finds the Regulation's definition of "electronic health data" ambiguously drafted, warning that this may produce inconsistent data-management practices (Rak, 2024, p. 928); it does not address the access-log question itself. The reading is contestable, and Chapter 4, Section 4.6 sets out the grounds on both sides. On the broad reading, for logs kept at patient-record granularity, this is the audit-retention versus erasure tension in its purest form. It is not a conflict assembled across instruments of differing legal weight, but a floor and a ceiling stated in adjacent articles of the same chapter of the same regulation. The implementing acts that might reconcile them are not due from the Commission until 26 March 2027 under Article 73(5), two years before the provisions themselves become applicable on 26 March 2029.

The common practitioner heuristic for multi-framework environments, which is to apply the longest applicable retention period across all frameworks, cannot resolve this: it works when every obligation is a floor, and fails entirely when one obligation is a ceiling, since extending retention to satisfy the longer floor is precisely what the ceiling forbids. The absence of an applicable heuristic is one reason the conflict has remained open in practice as well as in the literature.

In the cross-border pathway the conflict takes the form Chapter 1, Section 1.2 describes: a granted erasure request leaves an audit record pointing at data that no longer exist, and a refused one must be justified as necessary for a specific legal obligation, as the European Data Protection Board recommended in February 2026 (Matheson, 2026). Practitioner and supervisory commentary reads the erasure obligation as extending to all storage locations of the personal data, backups and logs included (see, e.g., the Norwegian legal commentary summarised in Berngaard, 2024), which is why the audit trail cannot be carved out of the conflict.

The most direct legal objection to the existence of the conflict must be addressed before its technical treatment. Article 17(3)(b) GDPR provides that the right to erasure does not apply to the extent that processing is necessary for compliance with a legal obligation to which the controller is subject. On a broad reading, the audit-retention obligation of the cross-border audit repository would simply disapply Article 17 for audit records, and the three regimes would never collide. This thesis argues that the exemption narrows the conflict without dissolving it, for three reasons grounded in the primary instruments. First, the exemption is bounded by necessity: it excuses only the processing that the legal obligation actually requires, and the data-minimisation and storage-limitation principles of Article 5(1)(c) and 5(1)(e) GDPR continue to apply to whatever is retained. The accountability function of a cross-border audit record, namely who accessed what, when, from where, under which

legal basis, and with what outcome, does not require continued controller access to the full personal-data payload of the underlying exchange. Retention of the payload in accessible plaintext for the length of the floor therefore exceeds the necessity that Article 17(3)(b) protects. Second, the Norwegian Data Protection Authority's internal-control guidance places precisely this balancing on the controller. It requires organisations to determine lawful retention periods and deletion deadlines through an explicit weighing of purpose, business need, and both retention rights and retention duties imposed by other law (Datatilsynet, n.d.-a). That formulation presupposes, rather than dissolves, the coexistence of retention obligations and deletion obligations on the same records. Third, the six-month deletion ceiling of Article 68(12) EHDS, as operationalised in the TEHDAS2 guidance for Health Data Access Bodies, contains no exemption parallel to Article 17(3)(b); within the secondary-use pathway the ceiling binds regardless of how the erasure-versus-retention balance is struck for the audit floor. The conflict therefore survives the exemption in a precise, narrowed form: the contested object is not whether audit records may be retained, but how much of a record may remain accessible, for how long, and in what state: exactly the question the mechanism developed in Chapter 4 formalises.

A direct technical solution to this tension exists in the literature on cryptographic erasure, though its application to the cross-border health audit problem has not been systematically developed. The National Institute of Standards and Technology's Special Publication 800-88 Revision 2 recognises cryptographic erasure as a purge-grade sanitization technique, in which the encryption key used to protect the data is irreversibly destroyed while the encrypted data remain on the storage medium (Chandramouli & Hibbard, 2025). Practitioner implementation guidance asserts that cryptographic erasure is increasingly accepted as a means of satisfying Article 17 in distributed cloud environments, conditional on auditable key management and demonstrably irreversible key destruction (Dhandala, 2026). That assertion is reported here as evidence of industry practice rather than as a statement of regulatory position; the authoritative position on cryptographic unrecoverability is the European Data Protection Board's, set out later in this section. SecuPi (2025) criticises it as operationally costly in row-level encryption; Chapter 6, Section 6.4 engages that critique.

Regulatory doctrine on what counts as erasure has moved substantially during the review period, in a direction that bears directly on this thesis. The Norwegian Data Protection Authority's privacy-by-design guidance states that anonymisation is equated with deletion of personal data ("anonymisering likestilles med sletting av personopplysninger"), so that rendering data irreversibly non-identifiable discharges the deletion obligation (Datatilsynet, n.d.-b). The same authority's anonymisation guidance, however, sets a deliberately high threshold: encryption is characterised as a means of protecting data, not of rendering it unidentifiable, and data remain personal as long as the controller retains any key or linkage capable of re-identification (Datatilsynet, 2015). At Union level, the European Data Protection Board's Guidelines 02/2025 on the processing of personal data through blockchain technologies state, in paragraph 51, that upon deletion of the decryption key the encrypted data will be unintelligible, at least until the algorithm is broken, and in the same paragraph that encrypted personal data is still personal data (European Data Protection Board, 2026b). Technical impossibility cannot be invoked to justify non-compliance (paragraph 50), and an erasure request requires the data to be erased or rendered anonymous (paragraph 125). The

Guidelines therefore describe what key deletion achieves without classifying it as erasure, and they hold that hashed data may likewise remain personal data. The further condition that the controller document the threat model under which the data are considered unrecoverable is not the Board's formulation but Aikebaier's (2026) interpretation, and the two carry different authority. Read together, these positions define the legal corridor within which any cryptographic-erasure mechanism must operate: key destruction yields unintelligibility rather than erasure, so a mechanism relying on it must still delete what it can and state what remains; it is defensible at most where destruction is irreversible in the documented threat model; and any residue that survives, including hashes and commitments, must itself be assessed against the high anonymity threshold. Chapter 4 designs to this corridor explicitly, and Section 2.4 returns to the residue question.

What does not yet exist in the literature, and what this thesis addresses, is the specific design of a verifiable invalidation mechanism operating at the cross-border audit-trail boundary. That boundary is defined by ATNA, the cross-border retention floor, GDPR Article 17(3)(b), and the six-month rule of Article 68(12). The mechanism must be both technically demonstrable and compatible with the operational reality of Norwegian NCPeH and Helsedataservice. The next section reviews the cryptographic literature that informs the design of such a mechanism.

2.4 Cryptographic Approaches to Audit Compliance

A growing body of cryptographic and systems research has developed mechanisms that address parts of the audit-compliance problem in cross-border and multi-institutional health data settings. The four most relevant strands are trusted-execution-environment-based architectures applied to OpenNCP, blockchain-based audit logging adapted to healthcare, zero-knowledge proofs applied to electronic health records and decentralised identity, and the underlying cryptographic primitives of commitment schemes and accumulators that make revocation mathematically tractable. This section reviews each strand in turn, together with the secure-deletion foundation on which cryptographic erasure rests and the adjacent literatures from which the present problem must be distinguished.

The KONFIDO project, funded under the Horizon 2020 programme between 2016 and 2019, remains the most directly relevant architectural ancestor for the present work. It extended the OpenNCP cross-border health data exchange platform with a security toolkit whose pillars included a blockchain-based auditing component for cross-border traceability and liability support, alongside hardware-rooted identity, homomorphic encryption for computation on encrypted patient summaries, and distributed security monitoring (Diamantopoulos et al., 2019; Staffa et al., 2018). The lessons-learned synthesis of Natsiavas et al. (2021) documents two gaps directly relevant here. First, the architecture relied on Intel Software Guard Extensions trusted execution environments, a hardware dependency that complicates broad NCPeH deployment across heterogeneous Member State infrastructures. Second, its blockchain auditing component provided immutable traceability but did not engage the General Data Protection Regulation's right to erasure as a design constraint: the audit chain was valued for its immutability, with the conflict between immutability and erasure left unresolved.

The second strand, blockchain-anchored records adapted to healthcare, has a deployed precedent in the Norwegian clinical context: the NewbornTime project. Brunner et al. (2025) document the deployment of a Hyperledger-based digital consent platform at Stavanger University Hospital, used between November 2021 and June 2025 in the collection of 1,012 thermal videos of newborn resuscitation events. The platform stores consent status immutably on-chain while keeping personal data encrypted and off-chain, providing a protected API for authorised retrieval and a documented General Data Protection Regulation-compliant withdrawal mechanism. The clinical viability of blockchain-anchored consent infrastructure in a Norwegian regulated healthcare setting is therefore established, although the system addresses consent recording rather than the audit-trail erasure problem.

A third strand applies zero-knowledge proofs to electronic health record access control. The closest comparator is Albalwy (2026), whose ZK-EHR framework uses a Groth16 zk-SNARK circuit to let a patient, a doctor or a researcher prove that they hold policy-compliant credentials for cross-institutional sharing without revealing identity, role or affiliation, with encrypted records held off-chain and verification on-chain. It works within a single jurisdiction; the cross-border space addressed by MyHealth@EU, with its eIDAS-based authentication chains and audit repositories spanning several national legal regimes, is distinct.

Health-zkIDM (Bai et al., 2022) shows that decentralised identity management with zero-knowledge components runs at more than 400 transactions per second on Hyperledger Fabric; it targets identity verification rather than audit-trail erasure.

zkFL-Health (Sharma et al., 2025) combines federated learning, trusted execution and succinct proofs generated with Halo2 or Nova, so that an aggregator proves it used exactly the committed client updates, and records the commitments on-chain as what the authors call an "immutable audit trail". It illustrates the pattern on which the mechanism of this thesis also rests: commitments in the trail, data held elsewhere.

A fourth strand, less visible in the healthcare literature but foundational to any verifiable invalidation mechanism, is the cryptographic accumulator and commitment scheme literature. One-way accumulators compress a finite set into a single short value supporting membership testing (Benaloh & de Mare, 1994); dynamic accumulators add efficient revocation and the mathematical machinery for verifiable membership and non-membership proofs over sets that change over time (Camenisch & Lysyanskaya, 2002), surveyed across applications from anonymous credentials and certificate revocation to blockchain-based audit systems (Ren, 2022).

The integrity of the audit trail itself has an older literature. Tamper-evident logs chain each entry to its predecessor under evolving keys, so that entries written before an attacker compromises the logging machine can be neither read nor altered without detection (Schneier & Kelsey, 1999); replacing the chain with a Merkle tree (Merkle, 1988) lets both the presence of a single entry and the consistency of an earlier log version with a later one be checked with a proof logarithmic in the size of the log (Crosby & Wallach, 2009), a construction Certificate Transparency standardised for public append-only logs (Laurie et al., 2013) and has operated at the scale of the web's certificate infrastructure (Laurie, 2014). These designs make a log immutable in the sense accountability needs. None was designed for a log that must also lose content on request, and a log that records personal data in

its entries, as KONFIDO's blockchain component did, reproduces the immutability-against-erasure tension described above. Chapter 4, Section 4.8 keeps the construction and resolves the tension by deciding what an entry may contain.

A second line of work resolves the same tension the other way, by allowing content inside an integrity-protected structure to change: chameleon hashes, collision-resistant except for a trapdoor holder (Krawczyk & Rabin, 1998); sanitizable signatures, where a designated sanitizer replaces marked parts while the signature still verifies (Ateniese et al., 2005); redactable signatures, where parts are removed without any key (Johnson et al., 2002); and redactable blockchains, where a trapdoor holder rewrites a block and the chain still validates, with the right to be forgotten named as a use case (Ateniese et al., 2017), the rewrite power later spread across attribute-key holders (Derler et al., 2019) or a voting majority (Deuber et al., 2019) and surveyed with the GDPR as its main motivation (Politou et al., 2021). Each weakens the binding: integrity comes to mean consistent with what the authorised editor allows rather than unchanged since written, and whoever holds the editing power can rewrite history. The mechanism of this thesis takes the opposite route. Its log is never edited; erasable content is kept out of it, and destroyed by destroying keys. The trust that redaction places in an editor is placed instead in key destruction (Chapter 6, Section 6.3).

The technique this thesis applies sits within a mature secure-deletion literature whose central caution must be carried into the design. The canonical systematisation by Reardon et al. (2013) defines secure deletion as rendering data irrecoverable from a physical medium, organises approaches by their interface to that medium, and demonstrates that the further an approach operates from the medium, the harder it becomes to assert that destruction has actually occurred. Cryptographic erasure is the limiting case of this observation, and an old one: Boneh and Lipton (1996) proposed making files removable from backups by encrypting them and later forgetting the key. It operates entirely above the medium, reducing the deletion of arbitrarily large data to the deletion of a key, and thereby inheriting in concentrated form the problem that key destruction itself cannot be proven to an external party by inspection. This limitation is not fatal. NIST SP 800-88 Revision 2 recognises cryptographic erase as a purge-grade sanitization technique precisely because, within a documented key-management boundary, it offers high assurance. But it defines the boundary of any crypto-erasure guarantee: the mechanism's properties are conditional on honest and verifiable key-lifecycle management, a condition examined further in Chapter 6. Deadline- and policy-driven key destruction has its own lineage. The Ephemerizer destroys each key at its data's expiry, so that data which expired before a later compromise stay unrecoverable (Perlman, 2005); Vanish makes data self-destruct after a set time by holding shares of the key in a distributed hash table, where they expire (Geambasu et al., 2009); and policy-based secure deletion destroys key components so that every item matching a deletion policy becomes unreadable at once (Cachin et al., 2013). Each meets a deletion deadline by destroying keys. None treats a retention floor that must be honoured alongside the deadline, and none specifies what an auditor can still verify once the key is gone.

During the review-update period, the formal treatment of cryptographic erasure advanced significantly. Aikebaier's (2026) systematisation of cryptographic erasure on public ledgers organises the application-layer construction space along two axes, data locus and key custody, into a twelve-cell grid of canonical constructions from 2006 to 2026. It extends IND-CCA security with a key-lifecycle

adversary model parametrised by hardware-security-module side-channel leakage, coercion fraction over the custody committee, and algorithmic-break horizon. It then states a one-directional sufficiency theorem: the resulting Destruction-IND-CCA notion suffices for a semantic-security formalisation of the EDPB Guidelines 02/2025 criterion of rendering data unrecoverable. The work is a single-author preprint with industry affiliation and has not been peer-reviewed; it is treated here as a systematisation of the field rather than as settled result, and the thesis does not rest any legal conclusion on it.

Three features of that work matter for the positioning of this thesis. First, it proposes a formal treatment of the erasure side of the problem, the cryptographic conditions under which key destruction could count as erasure, on which this thesis can build rather than a gap it must fill. Second, the work confines itself to erasure under Article 17 and does not treat retention under sectoral law. Third, and most directly, among the five open problems it identifies for the field is *erasure under multi-regime retention conflict*: the problem this thesis addresses in one regulatory setting. The gap claimed in Section 2.9 is therefore not established solely by this author's failure to find prior work; it is named as open by the most recent systematisation of the relevant cryptographic literature.

Four adjacent bodies of work must finally be distinguished from the problem addressed here, three academic and one practitioner. The first is the extensive blockchain-and-GDPR literature. Finck's analyses for the European Parliament and in the data-protection literature established the canonical tension between ledger immutability and the right to erasure. They also produced two findings of continuing relevance: that the meaning of "erasure" and "anonymisation" under GDPR is itself legally uncertain, and that hashed or encrypted data likely remain personal data for GDPR purposes so long as re-identification is possible (Finck, 2018, 2019). A systematic review of 114 papers in this literature reports difficulties in exercising data-subject rights, the right to be forgotten foremost among them, as the first of three principal issue types arising from blockchain immutability (Belen-Saglam et al., 2023). That conflict is adjacent to, but distinct from, the one this thesis addresses: it arises from a technological property (immutability) chosen by the system designer, whereas the conflict here arises from regulatory instruments imposing simultaneous floors and ceilings on retention regardless of storage technology. The distinction matters for design: a blockchain-immutability conflict can be dissolved by choosing mutable storage, while the tri-lateral regulatory conflict cannot be dissolved by any storage choice at all. Finck's finding on hashes, however, applies with full force to this thesis's mechanism: a commitment that survives invalidation is a residue that must be assessed against the anonymity threshold, and Chapter 4 therefore specifies hiding (salted) commitments and treats the residue question as a first-class design constraint rather than a footnote.

A second is the closest prior art to the mechanism proposed in this thesis. A research programme at DePaul University has addressed the reconciliation of retention and purging obligations in relational database systems across a sequence of publications and a granted patent. Scope, Rasin, Lenard, Heart, and Wagner (2022) formalise data-policy compliance rules for retention and purging and implement automated enforcement in a relational database. Companion work extends the approach to database backups through cryptographic erasure (Scope, Rasin, Lenard, Wagner, & Heart, 2022). The approach is claimed in United States Patent 12,425,209 (Scope & Rasin, 2025), which specifies

shadow tables holding encrypted copies whose encryption keys are selected according to the purge date of the data they protect, with purging effected by destroying the corresponding key.

This is a substantial body of work and it converges independently on the same insight as the present thesis: that key-lifecycle control is the natural engineering response to conflicting retention obligations. Three differences bound the overlap, and the first is decisive.

The mechanism satisfies the retention obligation by keeping *recoverable* encrypted copies, the key still exists until the purge date arrives, in shadow tables and shadow backups. That is the correct design when both obligations are floors and the purge date is known in advance, because retention simply runs until the later date. It cannot work against a deletion ceiling. Keyed ciphertext remains personal data under the Norwegian threshold established in Section 2.3, since the controller retains the means of re-identification; holding recoverable copies to satisfy a retention floor is therefore precisely what Article 68(12) forbids of a Secure Processing Environment. The tri-lateral case inverts the design requirement rather than extending it.

Second, the work addresses per-value data within a database and its backups, not the audit trail of a cross-border exchange, and it supplies no verifiability semantics: nothing in the framework allows an external auditor to establish what was purged, when, or on what legal ground. Third, the erasure trigger in that work is a scheduled purge date fixed in advance, whereas the erasure right modelled here arrives at an arbitrary time chosen by the data subject, which is what makes the feasibility question non-trivial. The programme is prior art for the technique and for the retention–purge reconciliation problem in databases; it is not prior art for the tri-lateral conflict, for the audit-trail setting, or for the verifiability semantics.

A third concerns whether erasure can be proven at all. Proof-of-Secure-Erasure protocols seek evidence that a prover has erased its memory, and recent formal work relaxes the isolation assumptions those protocols traditionally require (Bursuc et al., 2024). In the quantum setting, encryption with certified deletion produces a deletion certificate, and its authors identify public verifiability, allowing parties other than the originator to verify such a certificate, as an open problem (Broadbent & Islam, 2020). This literature marks the outer boundary of the present thesis: the mechanism specified in Chapter 4 logs an *attested* invalidation, not a *proven* one, and the difference between those is the subject of an active research programme rather than something this thesis resolves.

The fourth, the practitioner body, is the rapidly consolidating industry pattern of crypto-shredding for reconciling erasure with record-keeping obligations, articulated most fully for the financial sector, where GDPR Article 17 collides with the five-to-seven-year retention obligations of MiFID II Article 16(7) and analogous instruments (VeritasChain, 2026). The pattern (encrypt per subject, destroy the key on request, retain the ciphertext and the structural record) is the same family of technique this thesis employs, and its cross-sector articulation confirms that the technique itself is established practice rather than a novel contribution. Three things distinguish the present work from this practitioner pattern. First, the financial formulation is bi-lateral (a retention floor against an erasure right); the EHDS setting adds a third, structurally different constraint, a deletion ceiling on Secure Processing Environments, producing a tri-lateral system whose joint satisfiability is not obvious and has not been analysed. Second, the practitioner pattern asserts reconciliation; it

does not provide a formal model within which reconciliation is derived, nor verifiability semantics, commitments and a tamper-evident log, by which an external auditor can check that invalidation occurred and what it invalidated. Third, no articulation of the pattern addresses the cross-border health audit trail, its standards stack, or a national implementation substrate. These three deltas (the formal tri-lateral model, the verifiability semantics, and the cross-border health instantiation) are where the contribution of this thesis lies, and Section 2.9 states them as gaps with this precision.

Three observations emerge from this survey. First, the technical components on which a verifiable cryptographic-erasure mechanism for cross-border health audit trails can draw all exist in mature form: per-record envelope encryption under a key hierarchy, hiding commitments, tamper-evident Merkle logs, cryptographic erase as recognised by NIST, and cryptographic accumulators with revocation semantics, together with options this mechanism does not use, namely trusted execution environments at the OpenNCP layer, zero-knowledge proof systems applied to healthcare, and blockchain-anchored consent and audit infrastructures, each reviewed above. Second, none of these works combines them to address the specific tension between long cross-border audit-retention floors, GDPR Article 17 erasure rights, and TEHDAS2 Secure Processing Environment deletion in the cross-border European context. Third, the Joint Action drafting the Secure Processing Environment specification asks operators to balance deletion against applicable legal obligations without saying how (TEHDAS2, 2026b, Table 5.2, OPR-6, p. 43), and its expert commentary, writing of the project logbooks researchers keep, notes open questions about how accountability and anonymisation obligations intersect (TEHDAS2, 2026b, Annex 7, p. 96). The contribution of this thesis is positioned at the first of these, the balance the specification asks for and does not define.

2.5 Formal Approaches to Regulatory-Compliance Verification

The thesis's analytical method belongs to a research tradition that treats legal compliance as a formal-verification problem, and reviewing it both anchors the method and bounds the novelty claim.

The most direct methodological ancestor is the work of Feng et al. (2023) on bounded satisfiability checking of legal properties expressed in Metric First-Order Temporal Logic. Their approach formalises obligations drawn from legal texts as temporal-logic properties, reduces satisfiability checking to Satisfiability Modulo Theories solving, and generates counterexamples that witness compliance violations, with case studies spanning regulated domains including healthcare. The significance for this thesis is double-edged. On one side, the general method (regulatory obligations as formal constraints, compliance as a satisfiability question, violations as derivable counterexamples) is established, and this thesis claims no novelty for it. On the other side, the method has not been applied to the specific tri-lateral conflict of the cross-border health audit trail. The instantiation developed in Chapter 4 also employs lighter machinery than the MFOTL-and-SMT apparatus: a feasibility formulation over discretised time with one binary accessibility variable per record, in the constraint-modelling style of the operations-research tradition. The choice of lighter machinery is methodological, not accidental. The tri-lateral conflict turns on a single semantic question, what "verifiable" means for an audit record. A formulation that isolates that question is more defensible, more communicable, and more faithful to the logistics-modelling identity of the thesis than a

fully general temporal-logic encoding. The closest work on the GDPR itself is Arfelt et al. (2019), who formalise the monitorable GDPR obligations in the same logic and check them against system logs with the MonPoly tool; their formula for Article 17(1) requires deletion within thirty days of a request. Like Feng et al., they check single obligations against what a system did. Neither asks whether a floor, a right and a ceiling can be met together, which is the question of this thesis.

A second relevant strand is the formal treatment of erasure obligations in adjacent technical settings. In machine learning, formal accounts of the right to erasure have produced the machine-unlearning literature (Bourtoule et al., 2021; Cao & Yang, 2015); these works formalise what it means to remove a data subject's influence from a trained model, a different erasure object from the audit record treated here, but methodologically kindred in deriving mechanisms from formally stated erasure requirements. In databases, Chakraborty et al. (2025) start from the observation that also motivates this thesis: data regulations such as the GDPR require erasure while leaving its definition open to interpretation. They give a formal definition under which any inference about deleted data, drawn through dependencies between records, stays bounded to what could have been inferred before the data were inserted, and they design mechanisms that enforce it at minimal cost. Their object differs from the one treated here, being erasure inside a single database whose records depend on one another rather than the joint satisfiability of conflicting retention regimes over a record's life. The move is nonetheless kindred, and it corroborates, from peer-reviewed work, that what counts as erasure is a design parameter to be fixed formally rather than a given. In cryptography, the 2026 systematisation of cryptographic erasure discussed in Section 2.4 provides a formal treatment of the erasure side of the present problem, including a security notion and a one-directional argument that this notion suffices for a semantic-security formalisation of the regulatory unrecoverability test, while explicitly excluding sectoral retention law from its scope.

A third strand applies optimisation and operations-research methods to regulatory compliance itself. Compliance-management systems for cross-border data transfer have been proposed as engineering artefacts (Zhuang et al., 2024). This strand demonstrates that compliance reconciliation is a recognised object for the modelling tradition in which the author is trained; it has not, however, been applied to the reconciliation of data-retention regimes.

The synthesis of this section is a precise statement of what is and is not available. Available: a general formal method for legal-compliance satisfiability (Feng et al., 2023); a proposed formal treatment of cryptographic erasure (Aikebaier, 2026) and the Board's account of what key deletion achieves (European Data Protection Board, 2026b); optimisation methods for regulatory compliance in physical supply chains. Three things are not available anywhere in the reviewed literature. The first is a formal feasibility analysis of the tri-lateral retention system, with floor, right, and ceiling operating concurrently on the same records, in any sector. The second is any formal treatment situated at the cross-border health audit boundary, and the third is any treatment in information-logistics terms. The Tri-Lateral Retention Feasibility Model of Chapter 4 is constructed to occupy exactly this space, borrowing its method from the first strand, its erasure semantics from the second, and its modelling style from the third.

2.6 Norwegian Secondary-Use Infrastructure

Norway's secondary-use infrastructure for health data is the substrate against which the European Health Data Space will be implemented at the national level. The infrastructure has three layers: a governance and access-decision layer through Helsedataservice, a data-custodian layer through the major registry holders, and an analytical-processing layer through a set of Secure Processing Environments coordinated through the NORTRE collaboration but extending, in operational practice, well beyond it. Each layer presents a distinct compliance surface, and each interacts directly with the audit-retention versus erasure tension developed in Section 2.3.

Helsedataservice is the national body through which access to health data for secondary use is decided. The Ministry of Health and Care Services has since designated Folkehelseinstituttet as Norway's national coordinating Health Data Access Body; how many access bodies Norway will have is not yet settled (Folkehelseinstituttet, 2026). Respondents to the 2025 national hearing on Secure Processing Environment criteria observed that Norway had not at that point appointed a coordinating Health Data Access Body of the kind Articles 55 to 59 EHDS require (Norsk forening for allmennmedisin, 2025). That is consistent with the secondary-use provisions of the Regulation not becoming applicable until 26 March 2029. It took on its current authority on 15 March 2023, when decision-making authority over data access from eleven central health registries was transferred to Helsedataservice under the statutory changes introduced through Prop. 63 L (Forskningsetikk, 2023; Helse- og omsorgsdepartementet, 2020). Helsedataservice is part of the Norwegian Institute of Public Health, to which it moved with the Directorate of e-health's health-data department on 1 January 2024. Applications are submitted through the helsedata.no portal; Helsedataservice decides access for the eleven registries within its authority and invoices case processing, while in some cases the registry owners decide and prepare the data themselves (Helsedataservice, n.d.-a, n.d.-b).

The Secure Processing Environment layer is where the operational reconciliation of EHDS Article 73 with Norwegian implementation must occur, and the national policy process has now completed its first full cycle there. The SPUHiN project's November 2024 draft recommendations documented the state of Norwegian SPE practice in a passage that remains the decisive empirical fact for mechanism design in this thesis. Based on applicants' own descriptions in permit applications to Helsedataservice during 2023, the drafting team observed that "it is however most common to use either an analysis infrastructure currently available from the universities… or some type of server, database, folder, area or zone most likely provided by the data controller's own IT provider. A few also refer to OneDrive, Office365, disconnected PC or a partner in another country" (SPUHiN, 2024, p. 4). The Norwegian SPE landscape is therefore not merely distributed across the three NORTRE university nodes but operationally fragmented, with substantial secondary-use processing occurring outside any trusted-research-environment substrate.

Following a public hearing conducted between July and October 2025, the criteria were, by the Directorate's account, included in SPUHiN deliverable D5.2, *Recommendations for minimum requirements for Secure Processing Environments in Norway*. The deliverable comprises separate compliance checklists for SPE providers and SPE user organisations, with each requirement graded as mandatory or recommended. It was developed in collaboration with researchers, data custodians, tech-

nology suppliers, and authorities, and is positioned as a national reference basis for actors preparing for the coming EHDS requirements pending the Union implementing act (Helsedirektoratet, 2025; SPUHiN, 2025). Inspection of the checklists in the hearing version shows their scope to be information-security management, identity assurance, and access governance, with identifiable access logs kept for at least one year (P13 and P24 in the 2024 draft; Chapter 4, Section 4.11). They grade an ISMS requirement as mandatory and ISO 27001 certification as recommended, require eID-based login with defined assurance levels, and set personnel-security controls. Several recommended requirements are explicitly anticipated to harden into expectations as EHDS is implemented (SPUHiN, 2025). What those criteria do not contain, at any grade, is a requirement or mechanism addressing the reconciliation of audit-retention obligations with erasure and deletion obligations on the records the SPE generates. The gap identified by this thesis therefore survives the hearing version, not only the 2024 draft: Norway now has national SPE criteria that govern how the environment is secured and who may enter it, while leaving unaddressed what happens when the retention regimes on its records collide.

The three primary NORTRE nodes (TSD at the University of Oslo (operational since 2012), SAFE at the University of Bergen (2015), and HUNT Cloud at NTNU (2013)) provide infrastructure meeting European trusted-research-environment standards and participate in the EOSC-ENTRUST federation blueprint (Norwegian Trusted Research Environments, n.d.). On the primary-use side, the national infrastructure has moved from preparation into operation during the review period: with the NCPeH pilot of Section 2.2 in production (Helsedirektoratet, 2026), the infrastructure that will generate the cross-border audit records this thesis concerns is live in Norway, though no relevant patient had yet presented when the Directorate last reported (Section 2.2).

The design consequence carried into Chapter 4 is unchanged and strengthened. A verifiable cryptographic-erasure mechanism that assumes a clean, homogeneous SPE substrate would fail against the documented fragmentation; a mechanism that assumes the substrate question will be settled by the national criteria would fail against their actual scope. The same holds at Union level. The Secure Processing Environment specification published by TEHDAS2 during 2026 as deliverable D7.4 defines the minimum capabilities such environments must offer and the interoperability baseline for federating them. The Joint Action's guidance on using data within such an environment treats deletion at permit closure as an operational service. Neither connects that deletion obligation to the one-year identifiable-log retention floor imposed on the same environment by Article 73(1)(e) (TEHDAS2, 2026a, 2026b). The body drafting the specifications for both provisions has not addressed their interaction. A mechanism designed at the audit-trail boundary (operating identically whether the processing occurred in TSD, on a controller's own server, or on a disconnected PC, and requiring of the substrate nothing that the national criteria do not already demand) fits the Norwegian context as it actually is.

2.7 Information Logistics Framing

The thesis frames the audit-retention versus erasure problem as one of information logistics, which places it within the discipline of Sustainable Energy Logistics at HiMolde and within a literature on cross-border data movement under regulatory constraint.

The framing rests on the discipline's own definitions, not on analogy alone. The Council of Supply Chain Management Professionals defines logistics management as the part of supply chain management that "plans, implements, and controls the efficient, effective forward and reverse flow and storage of goods, services and related information between the point of origin and the point of consumption" (Council of Supply Chain Management Professionals, n.d.). An audit record is related information in exactly this sense. The thesis concerns its storage and its planned exit: the reverse end of the flow, where a record is retained, reduced or disposed of.

Operations research supplies the closest formal relative. Perishable inventory theory studies stock that must be held to meet demand but expires after a fixed or random lifetime (Nahmias, 1982). A record under a retention floor and a deletion ceiling is perishable stock with two clocks. Proposition 3 (Chapter 4, Section 4.6) can be read in that idiom: when the expiry period is no longer than the holding period and its clock starts at a different event from the holding clock, whether an item can be held as long as it must depends on each item's history, not on the rule book.

The energy sector's own data infrastructure schedules retention in the same terms. Elhub, the Norwegian electricity data hub, keeps a customer's personal data for a further three years and 41 days after both the supply and the grid contract end, "for eventuell feilretting og mulighet for å korrigere økonomiske oppgjør" [for any correction of errors and to allow financial settlements to be corrected], and keeps metering values for ten years only where the customer asks (Elhub, 2026). That is a retention period per data category, anchored to an event: the form of the floor parameter in Chapter 4, Section 4.3, in a different sector. The extension the data subject controls has no counterpart in the model. The parallel is more than illustrative: an electricity data hub that must retain metering and settlement records for correction while honouring an erasure request faces the same floor-against-right structure the model formalises, so the floor-against-right part of the TRF Model applies there directly. Whether a ceiling collision also arises, whether some deletion duty no longer than a floor is anchored to a different event, is the test of Proposition 3, which this thesis has not run for the energy sector; it is the application in which this programme's logistics-of-information framing is most directly its own.

The International Chamber of Commerce (2025) policy brief on data flows in supply chains documents that cross-border data flows are functionally equivalent to material flows in their structural role within global supply chain operations. They enable real-time coordination, traceability, customs clearance, and the deployment of digital tools across jurisdictional boundaries. They are also subject to the same kind of fragmented regulatory landscape that has historically constrained physical cross-border logistics through divergent national rules. Restrictive and fragmented data policies act as non-tariff barriers in the same operational sense that documentation requirements, retention obligations, and audit rules act as non-tariff barriers in physical logistics.

A Norwegian patient summary moving from a Norwegian National Contact Point for eHealth to a Spanish point of care is a digital good crossing a jurisdictional boundary. It must satisfy the originating jurisdiction's audit and retention rules, the destination jurisdiction's clinical and consent rules, and any superordinate Union-level provisions. The audit log of the cross-border access event is the digital equivalent of the customs documentation that accompanies physical goods. The retention floor on that audit log is the digital equivalent of customs record-keeping. The Union Customs Code requires the person concerned to keep the documents and information on which a customs declaration rests "for at least three years", the period running from the end of the year in which the declaration is accepted or the procedure discharged, and extended while a correction, an appeal or court proceedings are pending (European Parliament and Council of the European Union, 2013, Article 51). The erasure obligation of Article 17 GDPR has its physical counterpart in destruction: customs authorities "may require goods which have been presented to customs to be destroyed" (Article 197). The two do not collide, because destruction reaches the goods and record-keeping reaches the documents, so the record of a destroyed consignment, including the fact of its destruction, is kept for the full period. That separation of the record from the thing recorded is what Semantics II does for the audit trail, where accountability attaches to the record of the access and of its payload's invalidation rather than to the payload's continued existence (Chapter 4, Section 4.5). Checked against the anchoring result of Chapter 6, Section 6.10, the customs case confirms it from the other side: the destruction power is anchored to an external event, a customs decision, and would cross the record-keeping floor if it reached the documents; it does not, because it is confined to the goods. The analogy also marks where it stops. In customs the floor and the destruction act on different objects by design, whereas in an audit trail the personal data and the record of their processing begin in the same record, and the mechanism has to separate them.

The analogy constrains one decision in the design. Customs record-keeping obligations are not uniform across jurisdictions: a consignment crossing several borders accumulates documentation duties of differing lengths, and the operational answer has never been to build a separate ledger per jurisdiction but to hold one chain-of-custody record whose retention parameter is set per consignment by whichever regime governs it. The same structure is what Chapter 4, Section 4.3 adopts when it makes the retention floor a parameter of the record rather than a constant of the model. That decision is what allows a long cross-border audit floor and the one-year Secure Processing Environment log floor to be instances of one constraint rather than two, and it is what allows a national floor to be substituted without reconstructing the model. It was taken because the logistics reading of the problem made a per-consignment parameter the obvious form, where a purely legal reading would more naturally have produced two separate obligations modelled separately.

A small but technically substantial literature has begun to address cross-border data flow compliance as a logistics and supply chain problem in its own right. Zhuang et al. (2024) propose a Compliance Management System for Cross-Border Data Transfer that integrates multiple legal frameworks into a unified real-time compliance engine, demonstrating that the operational complexity of cross-border data flow under fragmented regulatory regimes is sufficient to warrant a dedicated system-engineering response. The present thesis sits within this emerging literature, contributing a

specific mechanism for the audit-retention component of the broader cross-border health data flow problem.

2.8 Comparative Analysis

The position of the proposed contribution within the existing literature is summarised in Table 2.1, which compares this thesis against the most directly relevant comparator systems and analytical neighbours on six dimensions. These are the scope of cross-border versus cross-institutional operation, the dependency on hardware-rooted trust, and the engagement with the GDPR right to erasure as a design constraint. They also include the targeting of primary use versus secondary use under the European Health Data Space, the grounding in Norwegian operational context, and the presence of a formal model of the retention–erasure conflict.

Table 2.1. Comparative Analysis of Cryptographic Compliance Approaches to Health Data Audit

System	Cross-Border or Cross-Institutional	Hardware Dependency	Addresses GDPR Article 17 Erasure	Primary or Secondary Use	Norwegian Context	Formal Model of the Retention–Erasure Conflict
Peer-reviewed systems						
KONFIDO (Diamantopoulos et al., 2019; Natsiavas et al., 2021)	Cross-border (OpenNCP)	Yes: Intel SGX	No: treats immutability as feature	Primary use	EU pilot; not Norway-specific	No
ZK-EHR (Albalwy, 2026)	Cross-institutional	No: software only	Partial: revocation, not the retention conflict	Primary use (clinical)	None	No
Health-zkIDM (Bai et al., 2022)	Identity (institutional)	No	No	Primary use (identity)	None	No
NewbornTime (Brunner et al., 2025)	Single-institution (Stavanger)	No	Yes: consent withdrawal	Primary use (clinical research)	Yes: Norwegian deployment	No
National policy framework						
SPUHiN D5.2 criteria (SPUHiN, 2025)	National policy framework	n/a: specification	No: not addressed at any grade	Secondary use (SPE)	Yes: Norwegian policy, hearing version	No

System	Cross-Border or Cross-Institutional	Hardware Dependency	Addresses GDPR Article 17 Erasure	Primary or Secondary Use	Norwegian Context	Formal Model of the Retention–Erasure Conflict
Preprints and practitioner sources (not peer-reviewed; compared for position only)						
zkFL-Health (Sharma et al., 2025)	Cross-institutional federated	Yes: TEE aggregator	No	Secondary use (AI training)	None	No
Ledger crypto-erasure SoK (Aikebaier, 2026)	Storage-technology scope (public ledgers)	No	Yes: formalises erasure side only	n/a	None	Partial: formalises erasure, excludes retention law by stated scope
Practitioner crypto-shredding pattern (VeritasChain, 2026)	Sector pattern (finance)	No	Yes: asserted, bi-lateral	n/a	None	No: asserted reconciliation, no model, no verifiability semantics
This thesis (TRF Model + Crypto-Erasure by Invalidation)	**Cross-border**	**No mandatory hardware; HSM recommended for key custody**	**Yes: derived from the model, designed against the EDPB 02/2025 position on key deletion**	**Both, at the audit-trail boundary**	**Yes: designed against the documented Norwegian substrate**	**Yes: tri-lateral feasibility model with infeasibility and feasibility results**

The table makes the position of the contribution explicit against both its architectural and its analytical neighbours. Rows in the third band are not peer-reviewed; they are compared for the position they occupy, and no claim of the thesis rests on any of them alone. On the architectural axis, no comparator combines cross-border operation, software-only deployment, engagement with the erasure right, applicability across both use pathways, and Norwegian grounding. The review update added an analytical axis, on which the two nearest neighbours are clear. The first is the 2026 ledger-erasure systematisation, which gives a formal treatment of the erasure semantics this thesis consumes while excluding the retention conflict from its scope. The second is the practitioner crypto-shredding pattern, which asserts a bi-lateral reconciliation without a model, without verifiability semantics, and without the deletion-ceiling constraint that makes the EHDS setting tri-lateral. No entry in either axis contains a formal analysis of the joint satisfiability of a retention floor, an erasure right, and a deletion ceiling on the same records: the object the TRF Model supplies.

The thesis accordingly claims neither the cryptographic primitives, which are established (Section 2.4), nor the general formal method, which is established (Section 2.5), nor the reconciliation idea, which practitioner literature already asserts bi-laterally. It claims the formal tri-lateral characterisation, the verifiability semantics of invalidation, and the cross-border health instantiation on the Norwegian substrate: each verified above as unoccupied.

2.9 Identified Research Gaps

The literature reviewed in this chapter establishes four specific gaps that motivate the thesis contribution, stated with the boundaries the review imposes.

The first gap is formal-analytical, and it is the primary gap. No published work in any reviewed strand provides a formal model of the tri-lateral retention system, in which an audit-retention floor, a subject-triggered erasure right, and a fixed deletion ceiling operate concurrently on the same records. The strands reviewed are the cross-border health security literature, the cryptographic-erasure literature including its 2026 systematisation, the blockchain-and-GDPR literature, the formal legal-compliance-verification literature, and the practitioner compliance literature. The general method for such modelling exists (Feng et al., 2023), and the erasure side has a formal treatment in a preprint (Aikebaier, 2026). The bi-lateral floor-versus-right conflict has been named by regulators (European Data Protection Board, 2026a) and asserted resolved by practitioners (VeritasChain, 2026). But the tri-lateral system, whose deletion ceiling changes the structure of the feasibility question, has not been formally characterised anywhere.

The gap holds also for the conflict's conditional extension. The collision between the six-month deletion ceiling of Article 68(12) and the one-year identifiable-log retention floor of Article 73(1)(e) requires no synthesis across instruments of differing legal weight: on the broad reading, for logs kept at patient-record granularity, it is stated by one regulation, in adjacent articles of one chapter, about one environment. The review conducted for this thesis located no treatment of it in the academic literature or in the professional commentary on EHDS secondary use. The Joint Action drafting the specifications comes closest. Its specification requires deletion at permit expiry "while ensuring compliance with applicable legal obligations and traceability or reproducibility requirements where relevant" and leaves "the deletion and retention policy" to "balance these obligations" (TEHDAS2, 2026b, Table 5.2, OPR-6, p. 43). Its expert commentary raises a related question in a narrower setting, the project logbooks researchers keep: these raise "open questions about how accountability and anonymisation obligations intersect", and "further guidance will be needed on retention of project-level collaborative metadata" (Annex 7, p. 96). The body drafting the requirements asks for the balance without supplying it; no mechanism supplying it for access logs has been published. Two factors explain the omission without diminishing it. Procedurally, these obligations were renumbered from Articles 46 and 50 of the 2022 proposal on adoption in 2025, so that much existing commentary analyses them under superseded numbering in separate literatures. Substantively, the standard practitioner heuristic for conflicting retention obligations, apply the longest applicable period, is inapplicable where one of the obligations is a ceiling, leaving practitioners without a default to reach for and therefore without an occasion to articulate the conflict. Neither factor

makes the conflict any less binding on the environments that must satisfy both provisions from 26 March 2029, nor on the implementing acts that must specify how they are satisfied by 26 March 2027.

The gap does not rest on this author's search alone. Aikebaier's (2026) systematisation of the cryptographic-erasure literature closes by identifying five open problems for the field, of which the fifth is erasure under multi-regime retention conflict. The work is a single-author preprint with industry affiliation and no peer review, and carries correspondingly less weight. What it establishes is that an author surveying this literature in 2026 regarded the problem as open, which is corroborating rather than dispositive. The gap claim rests primarily on the four documented search rounds of Section 2.1.4 and on the absence of any treatment in the regulatory and Joint Action guidance reviewed in Sections 2.3 and 2.6; the preprint is consistent with that finding and does not carry it.

The second gap is application-specific. The cryptographic primitives required exist in mature form: cryptographic erasure as recognised in NIST Special Publication 800-88 Revision 2 and now treated formally for Article 17 purposes in a preprint, hiding commitments, and dynamic accumulators with efficient revocation (Camenisch & Lysyanskaya, 2002). None has been integrated into a mechanism designed for the cross-border European Health Data Space audit trail, spanning the primary-use NCPeH layer and the secondary-use Helsedataservice and SPE layer. Such a mechanism would need verifiability semantics that let an auditor confirm both that an event occurred and that its payload was lawfully invalidated, demonstrated against synthetic data in the FHIR version the Norwegian profiles constrain.

The third gap is contextual. The Norwegian SPE criteria in their hearing version (SPUHiN, 2025) govern environment security, identity, and access, and the documented operational reality beneath them remains fragmented to the level of consumer cloud services and disconnected personal computers (SPUHiN, 2024). A compliance mechanism for the retention conflict must therefore be substrate-independent, designed at the audit-trail boundary, and must demand of the processing environment nothing beyond what the national criteria already require: a design constraint no reviewed proposal satisfies.

The fourth gap is legal-technical and was surfaced by the review update. The regulatory corridor for cryptographic erasure has not been mapped onto the audit-trail setting. That corridor comprises the EDPB's recognition that key deletion makes encrypted data unintelligible while leaving them personal data, the Norwegian equation of anonymisation with deletion, and the simultaneously high Norwegian threshold under which surviving keys, hashes, or linkages keep data personal. In the audit-trail setting, the mechanism's surviving residue (metadata, commitments, invalidation entries) must itself be assessed against that threshold and its status stated. Treating this residue question as a first-class design constraint, rather than an afterthought, is a contribution requirement that the reviewed literature imposes on this thesis and that Chapter 4 meets: it finds the residue pseudonymised, not anonymous (Chapter 4, Section 4.9).

These four gaps converge on the research question stated in Chapter 1 and are addressed, respectively, by the formal model, the mechanism specification, the boundary-placement design decision,

and the residue analysis of Chapter 4, with the demonstration of Chapter 5 witnessing the first two executably.

2.10 Conceptual Positioning of the Thesis

The contribution of this thesis is positioned at the intersection of the four identified gaps, and its architecture follows from that positioning. The analytical artefact is the Tri-Lateral Retention Feasibility Model, a constraint formulation in the tradition of formal legal-compliance verification but in the modelling style of operations research, developed in full in Chapter 4 and previewed in Section 2.3. Two features of it matter for positioning here. It is tri-lateral in structure rather than in instrument count: the retention floor is parameterised, so that a long cross-border audit floor and the one-year Article 73(1)(e) Secure Processing Environment log floor are two instances of a single constraint, and jurisdiction-specific floors can be substituted without reconstruction. And its reconciling mechanism, Crypto-Erasure by Invalidation, operates within the regulatory corridor of Section 2.3 rather than asserting reconciliation as the practitioner crypto-shredding pattern does.

The thesis does not claim novelty for any cryptographic primitive, for the general method of formalising compliance as satisfiability, or for the idea that key destruction can reconcile erasure with retention, each of which the reviewed literature already contains. It claims that three things are together novel: the formal characterisation of the tri-lateral conflict, the expression of that conflict and its resolution in information-logistics terms, and the derivation and demonstration of the reconciling mechanism for the cross-border health audit trail on the documented Norwegian substrate. The comparative analysis of Section 2.8 supports that claim entry by entry. The remaining chapters elaborate this claim through the methodology of Chapter 3, the model and specification of Chapter 4, and the executable demonstration of Chapter 5. The counter-positions identified in this review are engaged substantively in Chapter 6: the unprovability of key destruction, the personal-data status of surviving residues, and the operational-complexity critique of crypto-shredding.

Chapter 3. Methodology and Research Design

3.1 Research Paradigm

This thesis adopts Design Science Research (DSR) as its governing paradigm. DSR is the appropriate choice where the research objective is not to describe or explain an existing phenomenon but to create and evaluate an artefact that addresses a defined problem in an information-systems context. Hevner et al. (2004) establish the canonical framing. Design science produces and applies artefacts, namely constructs, models, methods, and instantiations. Their utility is assessed against the problem environment from which the problem was drawn, and their rigour against the knowledge base from which the design draws. Peffers et al. (2007) operationalise this into a six-activity process model that supplies the procedural structure adopted here.

The problem addressed in this thesis satisfies the conditions under which DSR is the correct paradigm rather than a convenient label. The problem is real, arising from binding regulatory instruments operating concurrently on live cross-border infrastructure rather than from a theoretical puzzle. It is unsolved, in the precise sense established in Chapter 2: no reviewed work formally characterises the tri-lateral retention conflict or derives a mechanism from such a characterisation. It admits an artefact as its answer, since what is missing is a design: a way of organising audit records and their cryptographic bindings such that three concurrent obligations can be jointly satisfied. And its evaluation is tractable within the resources of a Master's thesis, because the artefact's central claim is a claim about logical consistency under stated constraints, which can be argued formally and checked executably, rather than a claim about performance in deployment, which could not.

Three alternative paradigms were considered and rejected. A qualitative interview study of Norwegian implementing actors would have produced descriptive knowledge but no mechanism, and required ethical clearance and participant access disproportionate to the contribution. A systematic literature review would have consolidated the state of knowledge, a function partly discharged in Chapter 2, but the gap is the absence of a design, not of a synthesis. A purely formal-methods study in the tradition of Feng et al. (2023) would have produced the model without the artefact, and required proof-assistant machinery and expertise outside this programme's scope. DSR, in the variant developed in Section 3.3, produces the model and the artefact together, the model supplying the rigour and the artefact the relevance.

3.2 The Design Science Cycle Adopted

The Peffers et al. (2007) six-activity model structures the thesis and maps onto its chapters as follows.

Activity 1: Problem identification and motivation. The tri-lateral retention conflict is identified from primary regulatory and technical sources and shown to be unresolved in both the literature and Norwegian national policy. Chapters 1 and 2.

Activity 2: Definition of objectives for a solution. The research question and three sub-questions state what a solution must achieve: joint satisfaction of the three regimes, preservation of audit accountability, verifiability by an external auditor, and compatibility with the Norwegian infrastructure as it actually operates. Chapter 1, Section 1.3.

Activity 3: Design and development. The Tri-Lateral Retention Feasibility (TRF) Model is constructed, the two competing semantics of audit verifiability are defined, the infeasibility and feasibility results are established, and the Crypto-Erasure by Invalidation mechanism is specified as the constructive witness of feasibility. Chapter 4.

Activity 4: Demonstration. The model and mechanism are instantiated in a software sandbox operating over synthetic patient records, which exhibits the infeasibility result under plaintext semantics and the feasibility result under invalidation semantics. Chapter 5.

Activity 5: Evaluation. The artefact is evaluated against the objectives of Activity 2 on three axes, internal consistency, external compatibility with verified infrastructure, and engagement with the principal counter-positions surfaced in Chapter 2. Chapters 5 and 6.

Activity 6: Communication. The thesis itself. Chapters 6 and 7.

Peffers et al. (2007) distinguish several entry points into this cycle. This thesis is a problem-centred initiation: the work began from an observed conflict between instruments, not from an available technology in search of application. The distinction matters for the integrity of the contribution, because it is the reason the mechanism is derived from the model rather than assumed in advance and justified afterwards. An earlier iteration of this project did proceed from technology to problem, envisaging zero-knowledge succinct arguments as the enforcement machinery before the requirements were formally stated; the analysis reported in Chapter 4 showed that machinery to be unnecessary for the audit-trail problem. That correction is itself an instance of the design cycle operating as intended.

3.3 The Specification-and-Demonstration Variant, Extended with Formal Modelling

DSR admits artefacts at several levels of abstraction. Hevner et al. (2004) distinguish constructs, models, methods, and instantiations; March and Smith's (1995) earlier typology, on which that classification draws, makes the same separation. This thesis produces an artefact at two of these levels: a *model* (the TRF Model, a formal representation of the problem domain and its constraints) and a

partial *instantiation* (the sandbox, which realises the model and its mechanism in executable form over synthetic data). It does not produce a deployed system, and it does not claim to.

The variant adopted is therefore specification-and-demonstration: the contribution is the specified artefact together with a demonstration that it behaves as specified, rather than a production implementation together with field evaluation. This variant is well-established in DSR practice for problems where deployment is infeasible within the research setting but where the design claim is nonetheless checkable.

The extension particular to this thesis is the insertion of a formal-modelling step between Activity 2 and Activity 3. Rather than proceeding directly from objectives to design, the thesis first formalises the problem as a constraint-satisfaction question and establishes what any solution must do in order to succeed. The mechanism is then derived as the constructive answer to that question. The methodological warrant for this step comes from the formal legal-compliance verification tradition reviewed in Chapter 2, Section 2.5, in which regulatory obligations are expressed as formal properties and compliance is decided as a satisfiability problem (Feng et al., 2023).

Three consequences follow from taking this step, and they shape the remainder of the methodology.

First, the infeasibility claim becomes falsifiable in a way that an asserted architecture is not, and the feasibility claim, being constructive, is verified rather than tested (Chapter 4, Section 4.7). If the constraint system is satisfiable under the proposed semantics, the mechanism follows; if it is not, the mechanism fails, and the failure is visible in the model rather than only in deployment.

Second, the evaluation criteria are fixed in advance by the model rather than chosen afterwards to suit the artefact. The mechanism succeeds exactly when it renders the three constraints jointly satisfiable while preserving the accountability content of the audit record; no other success criterion is admitted.

Third, the machinery must be proportionate. This thesis employs a lighter formalism than the Metric First-Order Temporal Logic and Satisfiability Modulo Theories apparatus of Feng et al. (2023): a feasibility formulation over discretised time with one binary accessibility variable per audit record, in the constraint-modelling style of operations research. The justification is threefold. The conflict turns on a single semantic question, what "verifiable" means for an audit record, and a formulation that isolates that question communicates it more clearly than a general temporal-logic encoding. The lighter formulation is defensible at Master's level by an author trained in logistics modelling rather than formal methods, which matters for the integrity of a thesis that must be owned and defended by its author. And the formulation is executable in ordinary Python, which makes the propositions checkable by a reader with no proof-assistant background. The cost of this choice is expressive power: the model cannot represent obligations whose structure exceeds the chosen formalism, a limitation recorded in Section 3.7 and revisited in Chapter 6.

3.4 Formal-Modelling Methodology

This section states how the TRF Model is constructed. The model itself, with its full notation, propositions, and proofs, is developed in Chapter 4; what follows is the method by which it is built and the standard to which it is held.

Step 1: Decomposition of the object. Each cross-border audit record is decomposed into components that the regulatory instruments treat differently. The event metadata comprises the accountability content: which actor accessed which category of record, at what time, from which national contact point, under which legal basis and consent policy, with what outcome. Within the metadata, the accessor's fields are separated from the link to the patient, because the two are reached by different obligations (Chapter 4, Section 4.3). The payload comprises what the record carries about what was accessed: the demographic query of a cross-border record, the logged activity of a Secure Processing Environment record (Chapter 4, Section 4.3). A cryptographic commitment binds the second to the first, so that the record can attest to what was accessed without retaining it in accessible form, and a key governs access to the payload. This decomposition is the modelling move on which everything else rests, and it is derived from the legal analysis of Chapter 2, Section 2.3 rather than assumed: it is the necessity boundary of Article 17(3)(b), read with the minimisation principle of Article 5(1)(c), that separates what must be retained from what may not be.

Step 2: Translation of each regime into a constraint. Each regime is expressed as a constraint over discretised monthly time on the state of a record. The retention floor requires that the record remain verifiable throughout its retention window. The Article 17 erasure right requires that, following a valid erasure request, the payload cease to be accessible within the response period. The Article 68(12) deletion ceiling requires that, following permit expiry, payload accessibility cease within six months for records arising in the secondary-use pathway. The model is tri-lateral in the number of constraint types, not in the number of legal instruments it accommodates. The floor is a single parameterised constraint with two instances in the present setting: a long minimum for cross-border audit repositories, which national law sets and the model illustrates at ten years (Chapter 4, Section 4.3), and the one-year minimum imposed on Secure Processing Environment access logs by Article 73(1)(e) EHDS. Because the horizon is parameterised rather than hard-coded, the second instance required no structural change to the model, and jurisdiction-specific floors can be substituted on the same basis. The translation is documented claim by claim against the primary instruments, so that a reader can check each constraint against its source.

Step 3: Definition of the competing semantics. The pivotal move is to make explicit an assumption that the instruments leave implicit. Under *plaintext-verifiability semantics*, a record satisfies the retention constraint only while its payload remains accessible in recoverable form. Under *accountability-preservation semantics*, a record satisfies the retention constraint while its metadata is intact, its commitment survives, and any invalidation event is itself recorded and witnessed. Both are candidate readings of what an audit repository is for; the thesis argues that the second is the reading the instruments actually require and the first is what an audit log that keeps its payload readable assumes.

Step 4: Establishing the two results. Proposition 1 states that under plaintext-verifiability semantics the constraint system is infeasible whenever an erasure deadline or a deletion-ceiling deadline falls within a record's retention window, which, over a multi-year window, covers a request arriving in almost any month; how often requests in fact arrive is not modelled (Section 3.7). The second floor instance makes the result sharper rather than weaker: where a one-year log-retention floor operates against a six-month deletion ceiling on the same environment, infeasibility under plaintext semantics arises from the two retention provisions alone, with no erasure request required to trigger it. Proposition 2 states that under accountability-preservation semantics the system is jointly satisfiable for every arrival pattern of erasure requests and permit expiries, and exhibits the mechanism that achieves this as the constructive witness. Two further results are obtained by the same method from the constraints rather than from the semantics: Proposition 3 states the exact condition under which a ceiling and a floor collide, and Proposition 4 states what relocating a record does to the ceiling and to the right. All four are argued informally at the level of rigour standard for design-science work rather than machine-checked; Section 3.7 records what that means for the strength of the claim.

Step 5: Executable checking. Because the formulation is light, both results can be checked by direct execution rather than only by argument. The checker described in Section 3.6 walks synthetic records through randomised arrivals of erasure requests and permit expiries and evaluates the constraints under each semantics in turn, producing violations under the first and none under the second. This does not constitute formal verification in the proof-assistant sense, and is not presented as such; it is a demonstration that the propositions hold on the instances examined, and its value is that it makes the argument inspectable by a reader who does not wish to take the proofs on trust.

3.5 Synthetic Data

The demonstration requires patient records with realistic structure. No real patient data are used at any point in this thesis, and none were requested or obtained.

Synthetic records are generated using Synthea, an open-source synthetic patient generator that simulates the lifetime medical histories of statistically realistic but entirely fictional individuals, producing records in standard health-data formats (Walonoski et al., 2018).[1] Synthea is appropriate here for three reasons. Its output conforms to HL7 FHIR, the interoperability standard underlying the European Electronic Health Record Exchange Format. Its generation is seeded, so that a given seed reproduces a given population exactly. And it is established in the health-informatics literature as a substitute for real data in system-development contexts, which means its use requires no novel methodological defence.

Three configuration decisions are fixed, and one limitation of the generator must be recorded alongside them. The output conforms to *FHIR R4*, not R5, because the Norwegian national profile set (basisprofiler) maintained by HL7 Norway constrains R4; matching the Norwegian profile version keeps the payloads in the form Norwegian systems constrain, without making the demonstration representative of Norwegian clinical practice (Appendix A, A.7). The population is approximately *one*

hundred synthetic patients, whose resources supply payload bytes; the two hundred audit records and their pseudonyms are generated independently (Chapter 5, Section 5.2). That size is large enough to exercise the audit-record lifecycle across varied clinical encounter patterns and small enough to remain inspectable by hand when a result needs to be traced to its cause. Because the thesis reports no statistical inference, no power calculation governs this choice. And *random seeds are fixed and reported*, population seed and clinician seed both set to 20260915, so that the entire demonstration is reproducible from the thesis text.

The limitation concerns profiles rather than versions. Synthea's default export conforms to the US Core implementation guide and draws its demographic, geographic, and care-pattern parameters from a United States population. The FHIR version therefore matches the version Norwegian basisprofiler constrain, but the profiles and the clinical content do not represent Norwegian practice, and this thesis makes no claim that they do. The consequence is bounded and is verified rather than assumed in Chapter 5, Section 5.8: because no constraint in the model reads the content of a payload, the demonstration's results are invariant to payload provenance, and Norwegian representativeness is required of the *infrastructure analysis* in Chapter 4 rather than of the generated records.

Synthea's fidelity has been independently validated, and the validation bounds what may be claimed for it. Chen et al. (2019) computed four clinical quality measures over a 1.2-million-patient Synthea cohort and compared them against publicly reported state and national rates. They found Synthea reliable in modelling demographics and the probability of services being offered, but limited in modelling heterogeneous health outcomes following intervention and in reproducing regional variation in care quality. These limitations do not, however, bear on the use made of Synthea in this thesis: the demonstration requires structurally valid FHIR resources to serve as payloads, not accurate post-intervention outcome distributions. Had this thesis made epidemiological or clinical-effectiveness claims, the validation findings would be disqualifying; because it makes claims only about the behaviour of audit records under constraint, they are not.

The records themselves are not the object of study. They are the realism layer: the demonstration's claims concern the behaviour of audit records and their cryptographic bindings under the three constraints, and the synthetic clinical data supply plausible content for the exchanges that generate those audit records. This distinction is important for interpreting the results reported in Chapter 5, and is restated there.

3.6 Sandbox Implementation Approach

The sandbox is implemented in Python and has two layers, separated so that the load-bearing claim rests on the smaller and more inspectable component, and one optional module that reports no thesis figure.

The *feasibility checker* is the primary layer and the executable witness of the propositions. It constructs audit records as the tuples defined in Chapter 4, Section 4.3, in two classes: cross-border audit records carrying the illustrative ten-year floor, and Secure Processing Environment access-log records carrying the one-year floor and the six-month ceiling. It then generates randomised arrivals

of erasure requests and permit expiries across a monthly time horizon, and evaluates the three constraints under each semantics in turn, reporting violations. The two classes differ only in their floor parameter and in whether the ceiling applies, which is what makes them instances of one model rather than two models. The checker is kept small enough to be read and checked in full; Table 5.1 gives its size. A reader who doubts Proposition 1 can find in its output the specific record, month, and constraint at which plaintext semantics fails; a reader who doubts Proposition 2 can confirm that no violation arises under invalidation semantics across the generated instances.

The *realism layer* wraps the checker so that its inputs derive from Synthea-generated FHIR bundles rather than from abstract record identifiers, computing commitments over the actual payloads and setting each record's document category from its bundle. It is smaller than the checker (Table 5.1) and is not load-bearing: if the wrapper were removed, the propositions and their executable check would stand unchanged. Its function is to demonstrate that the model's abstractions correspond to the structure of real health-data artefacts rather than only to a convenient idealisation, and to test, by execution rather than assertion, whether any reported result depends on payload provenance.

Both layers, together with a demonstration viewer that executes them unmodified, are published in a public repository listed in Appendix A, so that the sandbox described here can be inspected and run rather than only read about.

Cryptographic operations use standard library primitives: salted commitments constructed with a standard hash function, and simulated key destruction implemented as irreversible removal of key material from the sandbox's state. The commitments are hiding by construction when salts are drawn at random (the reported run derives salts from the record identifier for reproducibility; see Appendix A, A.6), which is a design requirement rather than an implementation detail, since Chapter 2 established that an unsalted hash of personal data may itself remain personal data. Every access event, invalidation and subject-link removal is appended to an append-only Merkle log, so that the verifiability condition can be checked as an inclusion proof that fails if an entry is altered. *No zero-knowledge proof system is implemented at any point*, and none is required. The mechanism's verifiability rests on commitments, on the recorded invalidation event and on the log, not on succinct arguments. The optional module repeats the record lifecycle with real AES-256-GCM envelope encryption, to show that unreadability follows from key destruction rather than being asserted.

The constraint system is cross-checked on small instances by a separately written exhaustive search over every assignment of the accessibility variable, as an independent confirmation that the hand-written checker implements the constraints as stated (Chapter 5, Section 5.5). A bounded SMT check with the Z3 solver poses each proposition as a request for a counterexample over every parameter combination within stated bounds (Chapter 5, Section 5.5). Both are robustness measures rather than components of the contribution.

What the sandbox does not do bounds what Chapter 5 may claim. It does not connect to any National Contact Point, real or test. It does not implement the OpenNCP transmission flow. It does not implement authentication or consent evaluation. It does not measure execution time, memory, throughput, or energy, and no such measurements are reported anywhere in this thesis.

3.7 Validity, Reliability, and Limitations

The evaluation strategy is analytical rather than empirical, and its criteria are stated here in advance of the results.

Internal validity concerns whether the artefact is internally coherent: whether the constraints faithfully represent the instruments they translate, whether the two semantics are stated precisely enough to be distinguished, whether the propositions follow from the definitions, and whether the mechanism specified in Chapter 4 is in fact the witness the feasibility result requires. This is assessed by argument and by the executable check of Section 3.6, and it is the axis on which the contribution principally stands or falls.

External validity concerns whether the artefact would fit the environment from which the problem was drawn. It is assessed by compatibility analysis against verified infrastructure: the audit-logging boundary of the MyHealth@EU transmission flow, the Norwegian NCPeH as it is now operating in live pilot, the Helsedataservice access pathway, the Norwegian Secure Processing Environment criteria in their hearing version, and the Secure Processing Environment specification published by TEHDAS2 during 2026 as deliverable D7.4. The last of these is a moving baseline: the binding requirements are to be laid down by Commission implementing acts due on 26 March 2027, after this thesis is submitted, so compatibility is assessed against the best-specified state of the infrastructure available at the time of writing rather than against its final form. The analysis is recorded requirement by requirement in Table 4.1, each row naming its source, what the mechanism does, and whether the artefact executes it or meets it by specification. Compatibility analysis is weaker evidence than deployment, and is not presented as equivalent to it.

Reliability is addressed through determinism. Fixed seeds, reported parameters, and a fully specified checker mean that another researcher can reproduce every reported result exactly. Because no timing or performance claims are made, no repeated-run averaging is required.

Eight limitations are recorded at the outset rather than deferred to the conclusion, because each bounds what the later chapters may assert. This section is the canonical statement of them; later chapters refer back to it rather than restating it, and where a chapter adds a limitation specific to its own material it says so.

The first is the *proof standard.* The propositions are argued informally and checked executably on generated instances; they are not machine-checked, and the executable check confirms the results on the instances examined rather than establishing them for all instances. The claim made in this thesis is correspondingly bounded.

The second is the *expressiveness of the formalism.* The deliberate lightness described in Section 3.3 means the model cannot represent obligations whose structure exceeds a monthly-discretised binary-accessibility formulation: conditional obligations with complex temporal nesting, for instance, or interactions with instruments not included in the three modelled.

The third is the *key-destruction assumption.* The mechanism's guarantees are conditional on honest and irreversible destruction of key material. As Chapter 2 established through the secure-deletion

literature, no approach operating above the storage medium can prove to an external observer that destruction occurred; the guarantee is conditional on a documented key-management boundary, which is the same condition the regulatory guidance on cryptographic unrecoverability imposes. This limitation is structural rather than incidental, and Chapter 6 engages the practitioner critique that builds on it.

The fourth is *scope*. The thesis models Union-level instruments and the Norwegian implementation; it does not model the national retention laws of other receiving jurisdictions, though the parameterisation of the retention horizon is designed to accommodate them. It addresses neither non-EEA jurisdictions nor the authentication and consent-propagation problems adjacent to the one examined.

The fifth is the *operational cost* of the mechanism. Per-record key granularity imposes a key-management burden that the thesis argues is bounded and auditable but does not quantify; Chapter 6, Section 6.4 engages the critique and Section 6.5 sets out how the components scale.

The sixth concerns *interpretive authority*. Two principal steps in the argument rest on reasoning rather than on any regulatory holding: that an invalidated record continues to satisfy a retention obligation (on which the request-driven case of Proposition 1 also rests, since it presupposes that the payload is not necessary for the floor's purpose), and that Article 68(12) reaches the access logs a Secure Processing Environment generates where they are kept at patient-record granularity. Chapter 6, Section 6.2 confronts both and Chapter 7, Section 7.4 proposes how they would be settled. Four subsidiary premises also rest on reasoning rather than authority, each bounding a specific result rather than the whole: that Article 9 EHDS binds the controller of the repository holding the patient link, and that Article 17(3)(b) covers that link beyond the three-year period of Article 9(2) (Chapter 4, Section 4.2); the legal premise of Proposition 4 (Section 4.10); and whether auditing after the deletion ceiling still needs the subject link (Chapter 7, Section 7.4).

The seventh and eighth are abstractions in the model itself, and they are stated because the model's simplicity is what makes it defensible and also what bounds it.

The seventh is that the model treats every erasure request as valid. Article 17 is qualified: a controller may lawfully refuse a request where one of the exemptions in Article 17(3) applies, and in the audit setting many requests will be refused on exactly the Article 17(3)(b) ground the thesis discusses. A refused request imposes no erasure deadline, so the model, which treats every arriving request as triggering constraint C2, overstates how often erasure-driven collisions occur. It does not overstate whether they occur: Proposition 1 requires only that some valid request fall inside a retention window, and Corollary 1.2 involves no erasure request at all. The abstraction therefore inflates the frequencies reported in Chapter 5 and leaves the propositions untouched, which is why no result in this thesis is stated as a frequency.

The eighth is that the model represents a record's payload as a single unit that is either readable or not. Real systems often erase at field level, redacting some elements of a record while retaining others, and a single binary accessibility variable cannot represent that. The simplification is conservative with respect to the propositions, since a mechanism that satisfies the constraints for a whole payload satisfies them for any subset of it, but it means the model says nothing about par-

tial erasure. Chapter 4, Corollary 2.3 extends the model with one variable per part of the payload for the one case where that matters, a payload part that auditing needs; a mechanism designed for field-level redaction in general would need that richer state space throughout.

3.8 Evaluation Design for the Next Cycle

The evaluation reported in this thesis is analytical, as Section 3.7 sets out. Design Science Research also admits expert assessment as an evaluation method, and a specification-and-demonstration study of this kind commonly designs the evaluation that a subsequent cycle executes (Hevner et al., 2004; Peffers et al., 2007). That design has been produced and is specified in full in Appendix C.

The instrument comprises an eight-person expert panel drawn from four perspectives, two participants each: data protection, health IT architecture, Secure Processing Environment operation, and information logistics. It pairs a semi-structured interview guide with a closed-response Likert questionnaire across four dimensions (perceived utility, regulatory alignment, operational viability, and audit integrity), and a thematic analysis plan routing findings into revisions of the trust model, the residue analysis, and the next design iteration. Appendix C specifies the session protocol, the questions and the items in full.

Two features of the design matter here. Interview question seven asks practitioners directly whether Article 68(12) reaches the access logs an environment generates (the interpretive question on which Corollary 1.2 depends, identified in Chapter 4, Section 4.6) because practitioner readings of that provision are evidence this author cannot generate analytically. And the questionnaire pairs an item on what the mechanism lets an auditor verify, that an invalidation was logged and is unaltered, with an item on whether that attestation suffices without proof that the key was destroyed.

The instrument has not been executed. Executing it would process personal data about identifiable professionals, requiring notification to Sikt and a lead time of four to six weeks. It would also require revision of the scope statement in Chapter 1, Section 1.5, of Section 3.9 below, and of the Declaration of Originality, each of which states that this research involves no human participants. Those statements are accurate for the thesis as submitted. Chapter 7, Section 7.5 carries execution of this instrument as the immediate next step in the research programme.

3.9 Ethical Considerations

The ethical profile of this thesis is unusually simple, and the simplicity is a consequence of deliberate design choices rather than an absence of reflection.

No personal data are processed at any stage, apart from correspondence with public authorities, whose officials are named in their official capacity. All records are synthetically generated and describe no real individual. No human participants are involved: no interviews, surveys, observations, or usability studies were conducted, and no data about identifiable persons were collected. Consequently no approval from the Norwegian Agency for Shared Services in Education and Research,

from a regional research-ethics committee, or from any institutional review board was required, and none is claimed.

The choice of synthetic data is itself ethically grounded rather than merely convenient, and the grounding rests on a Norwegian supervisory decision rather than on commentary. The relevant decision is that of 11 May 2021, in which the Norwegian Data Protection Authority imposed an administrative fine of NOK 1,250,000 on the Norwegian Confederation of Sports (Norges idrettsforbund). The authority held that the organisation had no lawful basis for testing a cloud migration using the personal data of 3.2 million individuals. It reasoned that processing must be necessary for its purpose, and that the purpose could not be pursued where it was achievable by less privacy-invasive means; it further found the scale of personal data used in testing to be unnecessary (Datatilsynet, 2021). The general position that testing should proceed on anonymised or, preferably, synthetic data, attributed to both the Norwegian authority and the European Data Protection Supervisor, is set out in the Norwegian professional literature summarising this line of practice (Deloitte Advokatfirma, 2020). A thesis that proposes a mechanism for protecting personal data in audit trails would sit poorly with itself if it used real patient data to demonstrate that mechanism. The methodological choice and the ethical position coincide.

Two further commitments govern the reporting of results. Every claim of fact is traceable to a source retrievable at the time of writing, with the two exceptions stated in the Declaration of Originality, and where verification remains incomplete the incompleteness is flagged rather than smoothed over. No quantitative result is reported that was not produced by the procedures described in this chapter, and no capability is claimed that was not built: the components excluded from scope in Chapter 1, Section 1.5 are described as future work and never as achievements.

[1] Synthea is documented in Walonoski et al. (2018), *Journal of the American Medical Informatics Association*, 25(3), 230–238, https://doi.org/10.1093/jamia/ocx079.

Chapter 4. The Tri-Lateral Retention Feasibility Model and the Crypto-Erasure by Invalidation Mechanism

Proposition statements and proofs in this chapter are the author's own. Regulatory claims are anchored to the primary instruments cited at each point.

4.1 Purpose and Structure of the Chapter

A patient asks for her data to be erased. The audit record of who looked at them must stay verifiable for years: six in the Norwegian cross-border pilot; one, in a research environment, where a third rule wants health data gone six months after the permit ends. Can an audit record obey all three? This chapter answers: not if verifiable means readable; yes if it means accountable. It gets there in three steps, and each step licenses the next.

First, it establishes what the law actually requires to be retained, as distinct from what an audit log may happen to retain. This is the necessity analysis begun in Chapter 2, Section 2.3, and it produces the decomposition on which the model rests.

Second, it constructs the Tri-Lateral Retention Feasibility (TRF) Model: the retention regimes as constraints over discretised time, with two candidate semantics for what it means for an audit record to be verifiable, and states and proves four results within it. Proposition 1 establishes that under plaintext-verifiability semantics the constraint system is infeasible. Proposition 2 establishes that under an alternative semantics it is jointly satisfiable, by a constructive proof that exhibits the mechanism achieving satisfaction. Proposition 3 states exactly when a deletion ceiling collides with a retention floor and what the ceiling's anchor decides, and Proposition 4 shows why moving a record out of the regulated environment, the most direct rival design, meets the ceiling but not the right to erasure.

Third, it specifies that mechanism, Crypto-Erasure by Invalidation, in enough detail to be implemented, analyses the residue it leaves behind against the legal threshold that residue must clear, compares it against rival designs, and maps it onto the Norwegian infrastructure verified in Chapter 2.

The order of exposition follows the order in which the thesis has developed the problem: the cross-border primary-use case is treated first throughout, with the Secure Processing Environment case following as the second and sharper instance.

A note on what the propositions are and are not. They are mathematical statements about a model, proved informally at the standard of rigour normal for design-science work, and checked executably in Chapter 5. They are not machine-checked, and they are not claims about the world independent of the model's fidelity. Their force depends entirely on whether the constraints faithfully translate the instruments, which is why Section 4.2 documents that translation claim by claim rather than asserting it.

4.2 What Must Be Retained: The Necessity Analysis

Everything in this chapter rests on one split: the part of an audit record the law needs kept, and the part it does not. The split is not a modelling convenience. It is derived from the legal position established in Chapter 2, Section 2.3, and everything downstream inherits it.

Article 17(3)(b) GDPR exempts from erasure processing that is necessary for compliance with a legal obligation. The audit-retention obligations are such obligations. But the exemption is bounded by necessity, and Article 5(1)(c) requires that personal data be adequate, relevant, and limited to what is necessary for the purposes of processing. The question is therefore not whether an audit record may be retained, but which parts of it necessity protects.

The purpose that the retention obligations serve is accountability: establishing, after the fact, that a particular access occurred, by whom, when, under what authority, and with what result. That purpose is served by the event metadata. It is not served by continued controller access to personal data the record carries beyond those attributes: the demographic content of the logged query, or, where a deployment keeps it, the content of the document that was exchanged. A supervisory authority investigating whether a Spanish clinician's access to a Norwegian patient summary in March 2027 was lawful needs to know that the access occurred, which clinician performed it, under which eIDAS assertion, against which consent policy, and whether it succeeded. It does not need the patient's name and birth date as typed into the query, still less the patient's medication list, to answer that question.

This yields the central claim of the necessity analysis: *the accountability function of a cross-border audit record is discharged by its metadata and by a binding commitment to its payload, and does not require the payload to remain accessible.* On this thesis's analysis, retention of accessible plaintext payload for the length of the floor therefore exceeds what Article 17(3)(b) protects, and Article 5(1)(c) requires that it not be retained where the purpose can be achieved without it: a reading argued here from the primary instruments, not one a supervisory authority has yet confirmed. It follows that the payload need not, and should not, wait for an erasure request: once the short-lived purpose it serves has lapsed (resolving a disputed patient match, for instance), the controller should invalidate it on its own initiative. Section 4.8 provides for this as a payload retention period, which enters the model as a third trigger of the same invalidation.

Per record class. The argument has to be made for each class separately, because the payload is defined by where it comes from (Section 4.3), not by whether it is needed. For a cross-border record it is specific: the accountability question is which clinician accessed which patient's record, under which assertion and with what outcome, and the accessor fields with the patient link answer it; the patient's name and birth date as typed into the query add nothing to that answer. Should a supervisory authority nonetheless hold part of the payload necessary for a particular accountability purpose, a possibility this thesis does not exclude, the conditional analysis of Corollary 2.3 applies to the cross-border record as it does to the Secure Processing Environment record, and the mechanism retains that part under the same necessity test. For a Secure Processing Environment record it is weaker. Article 73(1)(e) asks for logs sufficient "to verify and audit all processing operations in that environment", and an auditor checking that an extraction stayed within its permit may need to know what was run. The thesis therefore does not assume that the whole activity content is unnecessary there; Corollary 2.3 states what follows if part of it is needed.

The patient link. The link from an access event to the person whose data were accessed is not payload: it is the other half of the accountability question. The Regulation gives natural persons the right to obtain information on any access to their personal electronic health data through the health professional access service, including "information on the healthcare provider or other individuals who accessed the personal electronic health data", "the date and time of access" and "which personal electronic health data were accessed", available "for at least three years from each date of access to the data" (Article 9(1)–(2) EHDS). That information cannot be produced from a record that no longer says whose data were accessed. For the controller that must provide it, or supply the records it is produced from, retaining the link is therefore necessary for compliance with a legal obligation within the meaning of Article 17(3)(b). An erasure request then reaches the payload but not the link, at least for the period Article 9(2) fixes and once Article 9 applies. The argument has two limits. Article 9 is framed around the health professional access service, so whether it binds the controller of a foreign National Contact Point's audit repository, and covers every cross-border access event, depends on how the access is made and how the Member States assign the duty; where it does not, the patient-facing audit-log interface of MyHealth@EU (Chapter 1, Section 1.2) gives the link a purpose but not a legal obligation, and Article 17(3)(b) does not follow. And beyond the Article 9(2) period the link is kept for the rest of the floor on the strength of whatever national provision fixes the repository's retention, which this thesis has not identified (Section 4.3); for that stretch its retention after an erasure request is exactly as contestable as the floor itself. It is removed at the terminal transition (Section 4.8). In a Secure Processing Environment Article 9 does not apply. There the link is kept after an erasure request until the ceiling only if auditing "all processing operations" under Article 73(1)(e) needs it, which is the question Chapter 7, Section 7.4 leaves to the supervisory authority, and the ceiling may reach it in any case (Section 4.6).

Two sources support it and one limits it. The Norwegian Data Protection Authority's internal-control guidance places exactly this weighing on the controller, requiring determination of lawful retention periods and deletion deadlines through explicit balancing of purpose, business need, and both retention rights and retention duties (Datatilsynet, n.d.-a). The Authority's privacy-by-design guidance equates anonymisation with deletion (Datatilsynet, n.d.-b), which is what permits a trans-

formed record to satisfy an erasure obligation at all. The limit is that the same Authority sets a high threshold for when data cease to be personal: encryption protects data rather than rendering them unidentifiable, and data remain personal while any key or linkage capable of re-identification is retained (Datatilsynet, 2015). The residue left by the mechanism must therefore be analysed against that threshold rather than assumed to clear it, which is the work of Section 4.9.

The accessor's own rights. The accessor fields are themselves personal data of the health professional or researcher who acted, and those persons hold their own Article 17 right in respect of them. That right does not empty the audit log, for the same reason the payload analysis turns on necessity: retaining the accessor's identity, the time, the legal basis and the outcome is necessary for compliance with a legal obligation, Article 73(1)(e) for Secure Processing Environment logs and, for cross-border records, Article 9(2) EHDS and whatever national provision fixes the repository's retention, so Article 17(3)(b) GDPR exempts that retention for as long as such an obligation runs. A period an operator sets without a basis in Union or Member State law would not engage the exemption. The six-year period of the Norwegian pilot is such a decision, taken by Helsedirektoratet as controller (Appendix D); unless a national legal basis for it is identified it is a policy floor, so that before Article 9 applies on 26 March 2029, and beyond its 36 months after that, retaining the patient link against an erasure request has no secure Article 17(3)(b) basis. That is a finding for the controller rather than a limit on the model: by Corollary 2.2 a lower or absent floor removes collisions and creates none. What necessity does not protect is not kept: the accessor fields are destroyed at the terminal transition once the retention obligation lapses (Section 4.8).

Which controller bears the duty. The erasure duty falls on a definite controller, and the cross-border architecture names it. Commission Implementing Decision (EU) 2019/1765, which lays down the rules for the eHealth Digital Service Infrastructure and is incorporated into the EEA Agreement, makes the participating Member States, through their national authorities or designated bodies, the controllers of the personal data they process through the infrastructure, and requires them to allocate responsibilities between themselves; the Commission is a processor only and "shall not have access to patients' personal data" (European Commission, 2019, Article 7). The controller of a given National Contact Point's audit repository is therefore that point's own national authority, not the Commission, and it is that authority on which an Article 17 request lands and on which the Article 17(3)(b) necessity analysis of this section operates. For a Norwegian-held cross-border audit record that authority is the operator of the Norwegian NCPeH (Section 4.11).

4.3 The Model: Objects and Notation

The model is deliberately small: one record, one clock, and one main question asked every month. Can the payload still be read?

Let the time domain be discretised into months, indexed by $t \in \mathbb{N}$, with $t = 0$ the month in which the system begins operation. Monthly granularity is chosen because every obligation in the system is expressed in months or years, and because the shortest deadline in the system, the erasure response period, is one month.

Let A be the set of audit records. Each record $a \in A$ is generated by a single access event and is represented as a tuple

$$a = \big(m(a),\ p(a),\ c(a),\ k(a),\ t(a),\ F(a),\ \sigma(a) \big)$$

where:

- $m(a)$ is the *event metadata*: the actor identifier, the actor's national contact point, the patient pseudonym, the document category accessed, the legal basis and consent policy applied, the timestamp, and the outcome. Metadata contains no clinical content. It is partitioned as $m(a) = m_{\text{acc}}(a) \cup m_{\text{subj}}(a)$. The *accessor fields* $m_{\text{acc}}(a)$ record who acted, when, under which legal basis or permit, and with what outcome. The *subject fields* $m_{\text{subj}}(a)$ relate the event to a data subject: the patient pseudonym and any reference to that subject's records. The partition does work only in the Secure Processing Environment case (Section 4.6).
- $p(a)$ is the *payload*: the content the record carries about what was accessed, as distinct from who accessed it, when and under what authority. It is defined by its source, which depends on the record class; whether accountability needs it is argued per class in Section 4.2, and Corollary 2.3 states what follows if part of it is needed. For a cross-border record it is the identifying content of the logged query. The IHE Cross Gateway Patient Discovery transaction (ITI-55), by which one country's gateway locates a patient in another, requires the person's name and birth time unless an identifier is supplied, and requires both gateways to record the query segment, base64-encoded, in the audit message's ParticipantObjectQuery field (IHE International, 2024, Sections 3.55.4.1.2.1 and 3.55.5.1). The audit record therefore holds the patient's demographic query and not only a pseudonym. This is the transaction on which the patient-identification step of the MyHealth@EU flow rests (Chapter 2, Section 2.2); the eHDSI audit specification that profiles it was not available to this thesis, so the IHE requirement is taken as the baseline any profile starts from. For a Secure Processing Environment record it is the content of the logged activity, where the environment logs at that level: the text and parameters of the query or command run against the permitted dataset, and any output retained with the entry. The Joint Action's specification requires these logs to cover "access to electronic health data" and "data import, export, or release of outputs" and fixes no fields (TEHDAS2, 2026b, Table 5.4, OPR-17, p. 51); what an environment records under those headings beyond the accessor fields is $p(a)$, and whether auditing "all processing operations" needs part of it is the question Corollary 2.3 answers conditionally. The model does not require $p(a)$ to be a clinical document.
- $c(a)$ is a *commitment* to the payload, $c(a) = \text{Commit}(p(a), r(a))$, where $r(a)$ is a per-record random salt. The commitment scheme is required to be *hiding* (the commitment reveals nothing about the payload to an adversary without the salt) and *binding* (no second payload can be opened against the same commitment). The requirement that it be hiding rather than a bare hash is a consequence of Section 4.9 and is not optional.
- $k(a)$ is the *payload key*: the key material under which $p(a)$ is stored.
- $t(a)$ is the month in which the access event occurred.
- $F(a) \in \mathbb{N}$ is the *retention floor* applying to the record, expressed in months.

- $\sigma(a) \in \{\text{primary}, \text{secondary}\}$ is the *pathway* in which the record arose.

The floor is a parameter of the record rather than a constant of the model. The form is taken from chain-of-custody practice in physical cross-border logistics, where a consignment carries one custody record whose retention parameter is set by whichever jurisdiction's regime governs it, rather than a separate ledger per jurisdiction; Chapter 2, Section 2.7 sets out the correspondence. In the present setting it takes one value per record class, with the cross-border value a parameter:

- $F(a) = 120$ for cross-border audit records held in ATNA-compliant audit repositories, this being the ten-year figure reported in the secondary literature as the eHDSI deployment baseline for MyHealth@EU operations (Simjanoska Misheva et al., 2025). The value is illustrative: the primary agreement inspected requires audit trails without stating a period (eHealth Network, 2017, clause II.4.2), the Norwegian operator reports that the specifications leave the period to national law and that its pilot uses six years (Chapter 2, Section 2.3), and by Corollary 2.2 no result depends on it: the argument of Corollary 1.1 holds unchanged at $F = 72$ or $F = 36$. The IHE ATNA profile itself prescribes no retention period; the floor arises from the deployment binding, and the model is correct only if this distinction is preserved. A binding value is available from the Regulation itself once Article 9 applies: information on access to a person's data must remain available "for at least three years from each date of access" (Article 9(2) EHDS), which gives $F(a) = 36$ wherever the audit record is what that information is produced from (Section 4.2).
- $F(a) = 12$ for access logs of Secure Processing Environments, this being the one-year minimum imposed by Article 73(1)(e); activity logs are kept "for the period necessary to verify and audit", which the model takes as at least the same year of Regulation (EU) 2025/327 (European Parliament and Council of the European Union, 2025). The Joint Action's specification recommends five years (TEHDAS2, 2026b, Table 5.4, OPR-18, p. 51); by Proposition 3 a longer floor enlarges the set of records whose permit expiry falls inside it, and by Corollary 2.2 no result depends on the value.

Two event processes act on records. An *erasure request* arrives for record a at month $t_r(a)$ if the data subject exercises Article 17 in respect of the personal data underlying that record; if no request arrives, $t_r(a) = \infty$. A request concerns personal data already recorded, so $t_r(a) \geq t(a)$; the response period satisfies $\delta \geq 1$; and arithmetic is over $\mathbb{N} \cup \{\infty\}$ with $\infty + n = \infty$. A *permit expiry* occurs at month $t_\pi(a)$ for records with $\sigma(a) =$ secondary, being the month in which the data permit under which the processing occurred expires; for primary-pathway records $t_\pi(a) = \infty$.

Finally, let $\alpha(a, t) \in \{0, 1\}$ be the *payload-accessibility variable*: $\alpha(a, t) = 1$ if the controller can recover $p(a)$ in intelligible form at month t, and 0 otherwise. This single binary variable per record per month is the entire state space of the model, and its minimality is deliberate: the conflict turns on exactly one question, which is whether the payload is readable, and a formulation that admits no other state variable cannot obscure that question behind modelling detail. The cost of that minimality is that the model cannot represent field-level redaction, where some elements of a payload are erased and others retained; Chapter 3, Section 3.7 records this as a stated abstraction, and Corollary 2.3 relaxes it for one case.

The Secure Processing Environment case needs one further variable, and only on the reading of Article 68(12) that Section 4.6 identifies. Let $\beta(a,t) \in \{0,1\}$ be the *subject-link variable*: $\beta(a,t) = 1$ if the subject fields $m_{\text{subj}}(a)$ can be read in the environment at month t, and 0 otherwise. Where that reading does not apply, β is unconstrained and plays no part in any result.

Let $V(a,t) \in \{0,1\}$ denote whether record a *counts as verifiable* at month t. V is not defined yet; defining it is the subject of Section 4.5, and the two competing definitions are what the propositions distinguish.

4.4 The Three Constraints

Each regime now becomes a constraint on the trajectory of α and V: one floor that says how long a record must last, and two limits that say how soon its payload must go.

C1: Retention floor. For every record a and every month t with $t(a) \le t \le t(a) + F(a)$:

$$V(a,t) = 1 \qquad \forall\, t \in \big[\, t(a),\ t(a) + F(a) \,\big]$$

The record must count as verifiable throughout its retention window. The window is closed at both ends and so spans $F + 1$ monthly indices. This is deliberate: the obligations are minimums ("at least one year"), and a record written during month $t(a)$ completes F full months only during month $t(a) + F$, so requiring verifiability through that month is the conservative reading of "at least". A half-open window would shorten every obligation by up to a month. Source: an illustrative long value for $F = 120$ (Section 4.3); Article 73(1)(e) EHDS for $F = 12$.

C2: Erasure right. For every record a for which a valid erasure request arrives at $t_r(a) < \infty$, and for every month $t \ge t_r(a) + \delta$:

$$\alpha(a,t) = 0 \qquad \forall\, t \ge t_r(a) + \delta$$

The payload must cease to be accessible within the response period δ. Source: Article 17(1) GDPR, with δ determined by Article 12(3) GDPR, which requires the controller to act without undue delay and in any event within one month of receipt, extendable by two further months for complex or numerous requests provided the data subject is informed within the first month. The model takes $\delta = 1$ as the baseline and admits $\delta = 3$ as the extended case; results are stated for arbitrary finite δ and do not depend on which is chosen. Constraint C2 is triggered only by a *valid* request. The model does not represent the Article 17(3) exemptions under which a controller may lawfully refuse, and so treats every arriving request as valid; Chapter 3, Section 3.7 explains why this affects the frequencies reported in Chapter 5 but not the propositions. Article 17(3)(c), which disapplies the right where processing is necessary for reasons of public interest in the area of public health, narrows C2 further, in the same direction, in both pathways. In the secondary-use pathway two provisions narrow C2 further. Article 17(3)(d) GDPR disapplies the right where processing is necessary for "scientific or historical research purposes or statistical purposes in accordance with Article 89(1) in so far as the

right referred to in paragraph 1 is likely to render impossible or seriously impair the achievement of the objectives of that processing", and the Regulation gives natural persons instead a right to opt out of secondary use, which is reversible and does not reach processing under data permits issued before it was exercised (Article 71(1) and (3) EHDS). For the environment's own access logs, which serve Article 73(1)(e) rather than the research, the exemption that applies within the floor is Article 17(3)(b). The effect is that fewer SPE requests reach C2 than the model assumes, and a record that no request reaches faces only the floor and the ceiling, which is the case of Corollary 1.2.

C3: Deletion ceiling. Let $\rho(a) = 1$ where the ceiling reaches record a, that is, where its log entry is itself electronic health data within the environment, and $\rho(a) = 0$ otherwise. On the broad reading of Article 68(12) set out in Section 4.6, $\rho(a) = 1$ for entries kept at patient-record granularity, and for entries kept at dataset granularity only where the activity content they retain is itself data concerning health; on the narrow reading, $\rho(a) = 0$ for every access log. For every record a with $\sigma(a)$ = secondary and $\rho(a) = 1$, and every month $t \geq t_\pi(a) + 6$:

$$\alpha(a, t) = 0 \qquad \forall\, t \geq t_\pi(a) + 6$$

and, where the record's subject fields are electronic health data within the environment (Section 4.6),

$$\beta(a, t) = 0 \qquad \forall\, t \geq t_\pi(a) + 6$$

Electronic health data must not remain in the Secure Processing Environment more than six months after permit expiry. Source: Article 68(12) EHDS, which provides that "the electronic health data within the secure processing environment shall be deleted within six months of the expiry of the data permit" (European Parliament and Council of the European Union, 2025), as operationalised by TEHDAS2 (2026a, Section 7.2).

The structural asymmetry between C1 on one hand and C2–C3 on the other is the whole problem. C1 is a lower bound on the persistence of a property; C2 and C3 are upper bounds on the persistence of accessibility. Whether they conflict depends entirely on whether V is defined in terms of α, which is the question Section 4.5 makes explicit.

4.5 Two Semantics of Verifiability

Everything now turns on one undefined word: verifiable. Two definitions are available, and the propositions show that they lead to opposite answers.

Semantics I: plaintext verifiability. A record counts as verifiable exactly when its payload is accessible:

$$V^I(a, t) = \alpha(a, t)$$

This is the semantics of an audit log that keeps what was accessed readable for as long as it keeps the record. Under it, an audit record whose payload cannot be produced is treated as an incomplete or broken record, and audit integrity is understood as the continued producibility of what was accessed. The reference implementation of the cross-border gateway is built as such a log: whatever an audit message carries stays readable. In the 2017 OpenNCP source, the audit record repository stored every received audit message whole, in a database column for the message content. The patient identifier sat in a readable column, and a further column held the participant-object query. The repository refused to modify a stored message, and its audit code had no scheduled retention or purge logic, so how long the content stayed readable was left to the operator (OpenNCP Project, 2017). The schema deployed with OpenNCP 9.1.0 in 2026 keeps the same columns (Sundhedsdatastyrelsen, 2026); whether they are populated in a given deployment was not inspected. In the 2017 source the patient-discovery audit carried the patient identifier and the full SOAP security header of the request, which in the model are subject and accessor fields, though not the demographic query that ITI-55 asks gateways to record. "Verification" there meant that the sending gateway signed each audit message (enveloped XML signature); the repository stored the signature but did not check it, and kept no hash chain or other tamper evidence beyond its refusal to modify. How other deployments configure retention is not established here. No instrument states this semantics, and none states the alternative. Semantics I is therefore best read as the de facto semantics of deployed audit repositories, of which the OpenNCP reference implementation is one instance, rather than as a legal requirement; Proposition 1 shows why a repository built on it cannot meet the three regimes together, and so why such repositories must change.

Semantics II: accountability-preserving verifiability. A record counts as verifiable when its accountability content is intact and any loss of payload accessibility is itself accounted for:

$$V^{II}(a,t) = 1 \iff \text{(i)} \wedge \text{(ii)} \wedge \text{(iii)}$$

where, at month t: (i) $m_{\text{acc}}(a)$ is intact and unmodified, and so is $m_{\text{subj}}(a)$ unless its removal is recorded under (iii); (ii) $c(a)$ is present and binding; and (iii) if $\alpha(a,t') = 1$ for some $t' < t$ and $\alpha(a,t) = 0$, or likewise for β, then an invalidation entry $\iota(a)$ recording the transition, its month, its legal ground, and its authorising actor, is present in the audit trail and is itself covered by (i).

Under Semantics II an audit record that has lost its payload is not a broken record. It is a complete record of an access event *and* of the lawful invalidation of that event's payload. The audit trail grows rather than shrinks when erasure occurs.

Neither semantics is stipulated by the instruments. Sections 4.2 and 4.10 argue that Semantics II is the better reading of what the instruments require; the propositions below establish what follows from each.

4.6 Propositions 1 and 3: Infeasibility, and Where the Ceiling Is Anchored

Under Semantics I the conflict is not bad luck or rare timing. It is a contradiction, and it can be located to the month. Its request-driven case presupposes the conclusion of Section 4.2, that the payload is not necessary for the floor's purpose, so that Article 17(3)(b) does not exempt it and an erasure request reaches it. Were the payload necessary, the exemption would apply, C2 would not reach it, and only the ceiling case would remain.

> *Proposition 1.* Under Semantics I, the constraint system $\{C1, C2, C3\}$ is infeasible for any record a such that
>
> $$t_r(a) + \delta \le t(a) + F(a) \quad \text{or} \quad t_\pi(a) + 6 \le t(a) + F(a).$$
>
> The second disjunct is tested only for records the ceiling reaches, that is, with $\sigma(a)$ = secondary and $\rho(a) = 1$.

Proof. Take a record a satisfying the first disjunct, and let $t^* = t_r(a)+\delta$. By hypothesis $t^* \le t(a)+F(a)$, and since erasure requests arrive after the access that generates the record, $t^* \ge t(a)$. Hence t^* lies within the retention window, so C1 requires $V(a, t^*) = 1$. Under Semantics I, $V^I(a, t^*) = \alpha(a, t^*)$, so C1 requires $\alpha(a, t^*) = 1$. But C2 requires $\alpha(a, t) = 0$ for all $t \ge t_r(a)+\delta = t^*$, so C2 requires $\alpha(a, t^*) = 0$. The two requirements are contradictory, and no assignment of α satisfies both. The argument for the second disjunct is identical, with $t^* = t_\pi(a) + 6$ and C3 in place of C2, on the analogous assumption that $t_\pi(a) + 6 \ge t(a)$; should the ceiling deadline precede the record's creation, the contradiction arises at $t(a)$ itself, where C1 and C3 both bind. ∎

Remark (converse). If neither disjunct holds, the system is feasible under Semantics I: set $\alpha(a, t) = 1$ for every month of the retention window and $\alpha(a, t) = 0$ afterwards. C1 then holds, and C2 and C3, where they bind at all, bind only after the window has closed. Proposition 1 is therefore an exact characterisation of infeasibility under Semantics I, and it is this converse that the control case of Section 5.5 exercises.

Corollary 1.1 (cross-border case). For cross-border audit records, $F(a)$ is the period left to national law: 72 months in the Norwegian pilot, as set by Helsedirektoratet as controller, 120 as reported in the literature and used illustratively in Chapter 5. The system is infeasible for record a whenever an erasure request arrives at any month $t_r(a) \le t(a) + F(a) - \delta$: that is, at any point but the last δ months of the window, whatever its length, so, under the baseline response period, a request in any of the 72 months from $t(a)$ to $t(a) + 71$ collides with the pilot's six-year floor. The condition is therefore not one of unusual timing: it holds for a request arriving in any but the last month of the window. How often data subjects exercise Article 17 is an empirical question that the model does not answer (Chapter 3, Section 3.7).

Corollary 1.2 (Secure Processing Environment case). For Secure Processing Environment access logs, $F(a) = 12$ and $\sigma(a)$ = secondary. Suppose the permit expires at or before the sixth month of the record's retention window, so that $t_\pi(a) + 6 \le t(a) + 12$. Then C1 and C3 are contradictory at

$t^* = t_\pi(a)+6$ by the argument above, provided C3 reaches the record. *Where it does, no erasure request is required.* It does so when the log entry is itself electronic health data within the environment ($\rho(a) = 1$, Section 4.4), which, on the reading set out below, is the case for logs kept at patient-record granularity and, for logs kept at dataset granularity, only where the activity content they retain is itself data concerning health. The corollary also assumes that the activity content, and not only the subject fields, is data concerning health: were it not, Semantics I could keep the payload readable and delete only the subject fields, and the collision would not arise. For patient-level activity, which records and which variables a researcher touched, the premise holds; it is stated here as a premise, not derived. For such records the infeasibility follows from two provisions of a single regulation acting on a single environment. Article 73(1)(e) requires the identifiable log to remain verifiable for twelve months, and Article 68(12) requires the electronic health data within the environment to be deleted six months after permit expiry. Where the remaining permit duration at the time the log is written is six months or less, the two windows necessarily overlap. The model makes no claim about how often this occurs in practice; the collision's existence, not its frequency, is what Corollary 1.2 asserts.

Where it holds, Corollary 1.2 is a conditional extension of the problem statement; the request-driven conflict of Corollary 1.1 does not depend on it. It shows that the conflict does not depend on the exercise of a data-subject right, on the eHDSI deployment baseline, or on any synthesis across instruments of differing legal weight. It is internal to Regulation (EU) 2025/327.

The interpretive condition on which Corollary 1.2 depends. The corollary holds if, and only if, the deletion obligation of Article 68(12) reaches the identifiable access logs that Article 73(1)(e) requires to be kept. That condition is contestable and is stated as such.

Article 68(12) provides that "the electronic health data within the secure processing environment shall be deleted within six months of the expiry of the data permit". Its scope is set by location rather than by provenance: it does not say "the data made available under the data permit". Its object, however, is electronic health data, which Article 2(2)(a) and (c) define as "data concerning health and genetic data, processed in an electronic form", personal or non-personal. An access log is therefore not reached merely because it sits within the environment. An entry recording that an authorised researcher opened a dataset at a given time concerns the researcher, not anyone's health, and Article 73(1) ties the identifiability of logs to the persons who access: access is restricted to "authorised natural persons listed in the data permit" (point (a)), and the handling of data to "authorised identifiable individuals" (point (c)). The Joint Action's specification for these environments reads Article 73(1)(e) the same way: "All SPE logs MUST identify the actor" (TEHDAS2, 2026b, Table 5.1, EHDSR-7, p. 31). An entry kept at patient-record granularity is different. Recording that a named patient's record in a disease cohort was accessed reveals that the patient belongs to the cohort, which is data concerning health. Such entries are electronic health data within the environment, and on the broad reading, which takes the provision's scope from its location, Article 68(12) reaches them, and Corollary 1.2 follows for them.

The contextual case for the narrow reading is that the provision sits within the data-permit article, adjacent to provisions on permit duration, extension, and storage fees, and that the mischief it addresses is the indefinite retention of permitted datasets after the purpose that justified them has

lapsed. The rest of the paragraph supports this: it concerns the cost of storing the dataset, "a storage system with reduced capabilities", and "the formula for the creation of the requested dataset". On that reading the obligation attaches to the permit dataset, the access logs fall outside it, and no collision between Articles 68(12) and 73(1)(e) arises.

A third, harmonising reading is also available. On it, Article 68(12) reaches the logs but yields to the specific retention duty of Article 73(1)(e) as an exception mandated by law; the Joint Action's specification points this way when it requires termination procedures that allow "for exceptions mandated by applicable law" (TEHDAS2, 2026b, p. 39). On that reading Corollary 1.2's contradiction does not arise, because the ceiling yields to the floor for whatever the floor requires. The question then becomes what the floor requires. If it is plaintext verifiability, the subject's health data stay in the environment for the whole floor despite Article 68(12) and the minimisation principle; if it is accountability, only the accessor fields stay, and the subject fields and the payload still go at the ceiling, which is the partition Proposition 2 applies. The harmonising reading therefore removes the contradiction without removing the question, and moves it to the necessity analysis of Section 4.2, where this thesis places the weight.

This thesis states Corollary 1.2 conditionally, for logs kept at patient-record granularity on the broad reading, and gives the grounds for both readings rather than choosing one by assertion. What turns on the reading is the collision's sharpest form, not the thesis's results. Under the narrow reading, Corollary 1.2 lapses, and with it both the claim that infeasibility arises without any data-subject action and the distinctive case in which a single record is bound by all three regimes at once; the cross-border and Secure Processing Environment settings then each reduce to a retention floor against an erasure right, so that on the narrow reading what distinguishes the contribution from the bilateral crypto-shredding of existing practice is the verifiability semantics and the cross-border instantiation, not the co-location of three constraints on one record. Proposition 1 itself is untouched, because its first disjunct concerns erasure requests rather than permit expiry: identifiable access logs remain personal data whoever provided them, they remain within the scope of Article 17, and a request arriving inside the twelve-month floor collides with Article 73(1)(e) exactly as the cross-border case collides with the eHDSI floor. Corollary 1.1 is untouched entirely. Proposition 2, the mechanism, and the residue analysis are untouched, since they are indifferent to which instrument generates the deadline.

The narrow reading, or logs kept at dataset granularity, therefore cost the thesis its conditional extension (Corollary 1.2) and the single-record tri-lateral collision it carries, but none of Propositions 1 to 4, the mechanism, or the verifiability semantics on which the contribution principally rests. The broad reading, for logs kept at patient-record granularity, adds a collision that requires no data subject to act, and Proposition 2 resolves it without choosing between the readings, because the accessor fields that Article 73(1)(e) requires to be identifiable are not the subject fields that Article 68(12) may reach (Section 4.7). Chapter 6 treats the resolution of this interpretive question as a matter for supervisory authority rather than for this author, alongside the authority question concerning verifiability itself.

Where the ceiling is anchored. Corollary 1.2 and the cross-sector instance of Chapter 6, Section 6.10 are both cases of one condition, the structural content of the problem rather than a property of either instrument.

> *Proposition 3 (anchoring).* Let a record's floor of F months run from its creation month $t(a)$, and let a ceiling of L months run from an event at month $e(a) \geq t(a)$. Under Semantics I, the floor and the ceiling are jointly satisfiable for a if and only if $e(a) + L > t(a) + F$. Hence (i) if the ceiling is anchored to the same event as the floor, $e(a) = t(a)$, they are satisfiable for every record if and only if $L > F$, a condition decidable from the text alone; and (ii) if the ceiling is anchored to an external event, then whenever $L \leq F$ they fail for exactly those records with $e(a) - t(a) \leq F - L$, a set that the text does not reveal and each record's history determines.

Proof. C1 under Semantics I requires $\alpha(a, t) = 1$ for every month t up to $t(a) + F$; the ceiling requires $\alpha(a, t) = 0$ for every $t \geq e(a) + L$. Since $e(a) + L \geq t(a)$, some month of the window carries both demands if and only if $e(a) + L \leq t(a) + F$. Cases (i) and (ii) substitute $e(a) = t(a)$ and rearrange. ∎

The condition $e(a) + L > t(a) + F$ holds equally where the anchor event precedes creation, $e(a) < t(a)$; a ceiling already passed at creation then makes the record infeasible from $t(a)$. The hypothesis $e(a) \geq t(a)$ restricts the statement to the cases this thesis treats, and the bounded check of Chapter 5, Section 5.5 uses the same restriction.

The proposition corrects as well as formalises. A collision needs a ceiling no longer than the floor whichever way it is anchored; what the anchor decides is whether the collision can be seen. A provision that measured both limits from one event and set the ceiling inside the floor would contradict itself on its face. Section 17 of politiregisterloven, a floor of twelve months and a ceiling of thirty-six from the same log entry, does not (Chapter 6, Section 6.10). A ceiling measured from an external event can sit inside the floor with no visible contradiction, because whether the two clocks cross depends on when that event falls for each record. Article 68(12) is of the second kind: six months from permit expiry against twelve months from the log entry, with the collision arising for exactly the records whose permit expires within six months of the entry, which is the condition of Corollary 1.2. The diagnostic question for any candidate instance is therefore whether a ceiling no longer than the floor is anchored to an event other than the one the floor runs from.

4.7 Proposition 2: Feasibility under Accountability-Preserving Verifiability

Change what verifiable means and, in the model as formalised, the contradiction disappears for every record, every pattern of requests and every floor. The proof builds the trajectory that does it, and that trajectory is the mechanism.

> *Proposition 2.* Under Semantics II, the constraint system $\{C1, C2, C3\}$ is jointly satisfiable for every record $a \in A$, for every arrival pattern of erasure requests $\{t_r(a)\}$ and permit expiries $\{t_\pi(a)\}$, and for every floor parameter $F(a) \in \mathbb{N}$.

Proof (constructive). Define the following trajectory for an arbitrary record a. Let

$$t^I(a) = \min\big(\, t_r(a) + \delta,\;\; t_\pi(a) + 6,\;\; t(a) + P(a) \,\big)$$

be the *invalidation month*, where $P(a)$ is the payload retention period of Section 4.8 ($P(a) = \infty$ where none is set), with the convention that the minimum of infinite terms is ∞. Construct the trajectory:

1. For $t < t^I(a)$: set $\alpha(a,t) = 1$. Retain $m(a), c(a), k(a)$, and $p(a)$.
2. At $t = t^I(a)$, if finite: destroy $k(a)$ irreversibly; where the ground is Article 68(12) and C3 reaches the subject fields, remove $m_{\text{subj}}(a)$ as well and set $\beta(a,t) = 0$; append to the audit trail an invalidation entry $\iota(a)$ recording the month, the legal ground (Article 17(1), Article 68(12), or Article 5(1)(c) and (e) where the payload retention period fixed the month), what was removed, and the authorising actor; retain $m_{\text{acc}}(a)$ and $c(a)$ unchanged.
3. For $t > t^I(a)$: set $\alpha(a,t) = 0$, and $\beta(a,t) = 0$ where step 2 removed the subject fields. Retain $m_{\text{acc}}(a), c(a)$, and $\iota(a)$.
4. If C3 reaches the subject fields and $t^I(a) < t_\pi(a) + 6$, so that an erasure request or the payload retention period fixed the invalidation month, remove $m_{\text{subj}}(a)$ at $t_\pi(a) + 6$, set $\beta(a,t) = 0$ from that month, and append a second entry to $\iota(a)$ recording it.

Where $t^I(a) \le t(a)$, a record written at or after its own deadline, the payload is never held readable: set $\alpha(a,t) = 0$ from $t(a)$ and append $\iota(a)$ at $t(a)$. C1 still holds, because Semantics II does not read α.

It must be shown that this trajectory satisfies all three constraints.

C2 is satisfied. If $t_r(a) < \infty$ then $t^I(a) \le t_r(a) + \delta$ by construction, and by steps 2–3, $\alpha(a,t) = 0$ for all $t \ge t^I(a)$, hence for all $t \ge t_r(a) + \delta$. If $t_r(a) = \infty$, C2 is vacuous.

C3 is satisfied. If $\sigma(a)$ = secondary and $t_\pi(a) < \infty$ then $t^I(a) \le t_\pi(a) + 6$, and by the same steps $\alpha(a,t) = 0$ for all $t \ge t_\pi(a) + 6$, and $\beta(a,t) = 0$ from the same month wherever C3 reaches the subject fields. If $t^I(a)$ was set by an earlier erasure request, step 4 removes the subject fields at $t_\pi(a) + 6$. Otherwise C3 is vacuous.

C1 is satisfied. Let t be any month in the retention window, $t(a) \le t \le t(a) + F(a)$. Condition (i) holds because no step of the construction modifies or removes $m_{\text{acc}}(a)$, and the only removal of $m_{\text{subj}}(a)$ is recorded in $\iota(a)$. Condition (ii) holds because no step removes $c(a)$; the commitment is not derived from $k(a)$ and its persistence is unaffected by key destruction. For condition (iii): if $\alpha(a,t) = 1$ the condition is vacuous; if $\alpha(a,t) = 0$ then $t \ge t^I(a)$, and step 2 has placed $\iota(a)$ in the audit trail, where step 3 retains it, and $\iota(a)$ is covered by (i). Hence $V^{II}(a,t) = 1$ throughout the window. The terminal transition of Section 4.8 takes place after the window and is not part of this trajectory.

All three constraints are satisfied, for arbitrary arrival times and arbitrary $F(a)$. ∎

Corollary 2.1. The construction requires no coordination between the erasure process and the retention process, and no knowledge at the time a record is created of whether an erasure request will ever arrive. The invalidation month is determined entirely by events as they occur.

Corollary 2.2. Because $F(a)$ is arbitrary in the proof, the result holds simultaneously for an illustrative ten-year cross-border floor, the six-year floor of the Norwegian pilot and the one-year Secure

Processing Environment floor, and for any national floor substituted for either. The model is tri-lateral in constraint type and indifferent to the number of floor instances.

Corollary 2.3 (sensitivity to what auditing needs). Extend the model with one accessibility variable per part of the payload, which the single-variable model of Section 4.3 cannot express, and partition the payload as $p(a) = p_n(a) \cup p_r(a)$, where $p_n(a)$ is any part that auditing turns out to need, and retain $p_n(a)$ with the accessor fields. The trajectory of Proposition 2, with $p_r(a)$ in place of $p(a)$, satisfies C1 and C2, and it satisfies C3 unless $p_n(a)$ is itself electronic health data within the environment on the broad reading of Article 68(12). In that case C1 and C3 collide over $p_n(a)$, by the argument of Proposition 3, for exactly the records it identifies under case (ii). The collision follows from keeping $p_n(a)$ intact under condition (i) without the logged-removal exception that the subject fields have. Relocation (Section 4.10, Rival 6) is the exit this thesis identifies; logging at dataset granularity, the narrow reading, or anonymising $p_n(a)$ are others.

Proof sketch. Replace p by p_r in steps 1–4 and add p_n to the fields that condition (i) of Semantics II keeps intact. C1 holds as before. C2 holds for p_r as before, and for p_n through Article 17(3)(b), which applies because p_n is by assumption necessary. C3 constrains whatever is electronic health data within the environment: if p_n is not, C3 is met as before; if it is, C3 requires it gone from $t_\pi(a)+6$ while C1 requires it until $t(a) + F(a)$, and the argument of Proposition 3 gives the records for which these overlap. ∎

Feasibility therefore survives any enlargement of what auditing needs, except an enlargement into data concerning health inside a Secure Processing Environment, where it fails as Corollary 1.2 does and has the same exits.

A note on what kind of result this is. The results of this chapter are stated as propositions rather than theorems, because their proofs are short once the semantics are fixed. Propositions 1 and 3 follow almost immediately from the definitions, each resolving to a month in which α must be both 1 and 0, and the thesis states this plainly rather than presenting them as hard-won. The weight of the argument lies elsewhere: in Section 4.2's necessity analysis, which justifies Semantics II, in the legal-interpretive work on the Article 9 patient link, the ITI-55 payload and the scope of Article 68(12), and in the mechanism design that Propositions 3 and 4 frame. One objection is that Proposition 2 proves little, because Semantics II was defined in full knowledge of the trajectory that satisfies it. The objection has force. The response concedes its premise and denies its conclusion. The mathematical content of Proposition 2 is indeed modest: once verifiability is decoupled from payload accessibility, the existence of a satisfying trajectory is close to immediate, and the proof is a verification rather than a discovery. But the substantive claim of this chapter was never that a satisfying trajectory exists under some semantics; any number of semantics would admit one, including trivial semantics under which every record counts as verifiable always. The claim is that *this* semantics is a defensible reading of what the retention obligations require, grounded in the necessity boundary of Article 17(3)(b), the minimisation principle of Article 5(1)(c), and the accountability purpose the obligations serve. It is a departure from plaintext verifiability that achieves feasibility while preserving every element of the audit record that the accountability purpose needs and discarding only what it does not. Proposition 1 carries the load that Proposition 2 does not: it establishes that *some* departure is unavoidable, because plaintext verifiability admits no solution at all. Proposition 2 then shows

that a principled and minimal departure suffices. The legal defensibility of Semantics II is argued in Section 4.2 and its want of authority is confronted in Chapter 6, Section 6.2; it is not established by the proposition, and no reader should take the proposition as establishing it.

What the proposition does and does not establish. It establishes that the constraint system as formalised admits a solution, and exhibits one. It does not establish that the exhibited solution is lawful (that depends on whether the residue it leaves clears the legal threshold, which Section 4.9 addresses) nor that key destruction can be verified by an external party, which Section 4.9 and Chapter 6, Section 6.3 concede it cannot. The invalidation entry specified in Section 4.8 is an *attested* record of destruction, not a *proof* of it; the proof-of-secure-erasure and certified-deletion literatures reviewed in Chapter 2, Section 2.4 mark that boundary, and Chapter 6 treats it as the outer limit of the contribution. Proposition 2 is a mathematical result about a model, and its value is that it converts a question that has been debated qualitatively into one with a definite answer under stated assumptions.

4.8 The Mechanism: Crypto-Erasure by Invalidation

The proof of Proposition 2 is also a build sheet: the trajectory it constructs is the specification of the mechanism. This section states it as an implementable design: what is encrypted, what is committed, what is destroyed, and what is logged when it is. Figure 4.1 shows the whole of it on one page.

Key hierarchy. Each record's payload is encrypted under a per-record data key $k(a)$. Per-record granularity is the simplest construction that meets the invalidation events of Proposition 2, which occur at record granularity: a permit expiry invalidates the records of one permit, while an erasure request invalidates the records relating to one data subject, and these sets intersect without nesting, so no single per-subject or per-dataset key serves both. It is not the only one. A record encrypted so that a key share for its subject and a key share for its permit are each needed to read it becomes unreadable when either share is destroyed, with a key store that grows with subjects and permits rather than with records; policy-based secure deletion generalises the idea (Cachin et al., 2013). That construction is not implemented here. Data keys are themselves held under a key-encrypting key in a hardware security module or equivalent custody boundary. Destruction of $k(a)$ is effected by destruction of the wrapped data key and any cached copies, within the documented custody boundary. This is the hierarchy that key-management guidance prescribes, in which data keys are protected by key-encrypting keys and destruction means removing "all traces of a cryptographic key so that it cannot be recovered by either physical or electronic means" (Barker, 2020, Section 2.1). The optional module of the artefact executes it: per-record 256-bit data keys under AES in Galois/Counter Mode (Dworkin, 2007), each wrapped under a key-encrypting key and destroyed at the record's invalidation month (Appendix A, A.15). The custody object stands in for a hardware security module, so destruction there is destruction in program memory.

Proactive invalidation. The necessity analysis of Section 4.2 means that the payload need not wait for a request. The specification therefore allows a payload retention period $P(a)$, set by the controller from the payload's own purpose, after which the payload is invalidated on the ground of Article

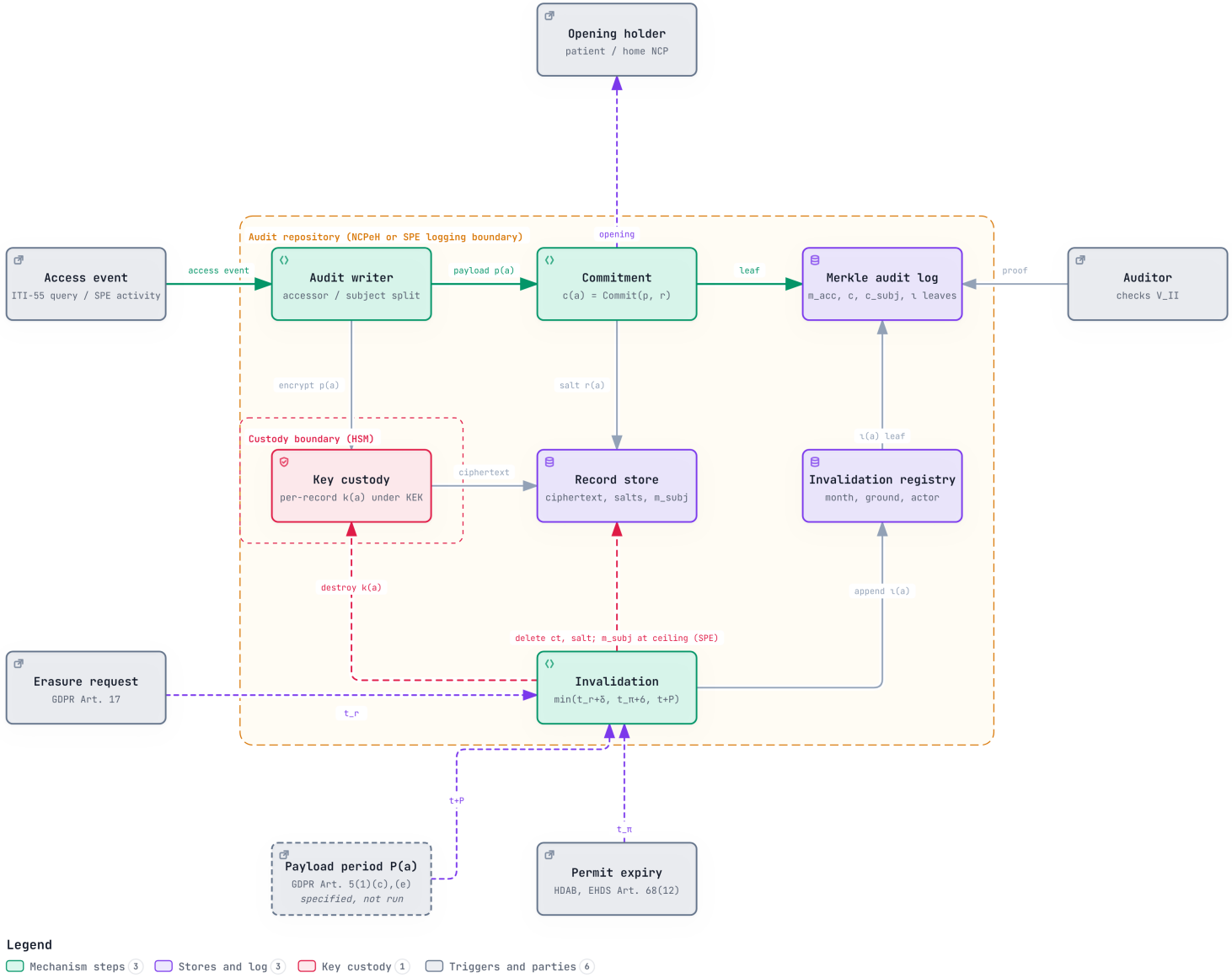


Figure 4.1. Crypto-Erasure by Invalidation at the audit boundary. Green arrows are writes at access time. Purple dashed arrows are the three triggers (an erasure request, a permit expiry and, where the controller sets one, the payload retention period, which is specified here but not run by the artefact) and the optional hand-over of the opening to the patient or the home contact point. Red dashed arrows are the destruction at the earliest of the resulting deadlines, which the invalidation entry then records in the registry and the log. The subject fields and their salt are removed only for patient-level Secure Processing Environment logs, at the ceiling. The Merkle log's leaves hold the accessor fields, the payload commitment, a salted commitment to the subject fields and the invalidation entries, never the payload or the subject fields themselves.

5(1)(c) and (e) GDPR. The invalidation month is then $t^I(a) = \min(t_r(a) + \delta,\ t_\pi(a) + 6,\ t(a) + P(a))$, with $P(a) = \infty$ where no period is set, as Section 4.7 defines it. Proposition 2's construction and proof are unchanged: C2 and C3 still hold because $t^I(a)$ can only move earlier, and C1 holds because nothing in its argument depends on which trigger fixed $t^I(a)$. The artefact runs with $P(a) = \infty$, so every figure in Chapter 5 is the case without proactive invalidation.

Ciphertext. At $t^I(a)$ the ciphertext of $p(a)$ is deleted from the audit store together with $k(a)$. Nothing in Semantics II uses it once the key is gone, and deleting it removes the exposure that a retained ciphertext would carry to future cryptanalytic capability, quantum capability included, over the rest of a ten-year floor (Section 4.9). Key destruction remains the operative means for copies the store cannot delete at once, such as replicas and backups: they become unreadable at $t^I(a)$ and leave by ordinary rotation. Until they leave, the Board holds that encrypted data of this kind are still personal data (European Data Protection Board, 2026b), so for those copies key destruction secures unintelligibility, not erasure. Nothing in the TRF Model distinguishes key destruction from deletion of the payload: both set α to zero, and the propositions hold for either. The case for keys rests on these copies, which the model does not represent and which the specification for Secure Processing Environments expressly reaches: electronic health data "MUST be deleted or rendered unrecoverable within six months of permit expiry, including any backups or redundant copies" (TEHDAS2, 2026b, Table 5.2, OPR-6, p. 43). The same requirement continues: deletion must proceed "while ensuring compliance with applicable legal obligations and traceability or reproducibility requirements where relevant", and its rationale leaves it to "the deletion and retention policy" to "balance these obligations". The specification asks for the balance and does not say how it is struck; for the logs, this mechanism is one way to strike it.

Commitment. $c(a) = \mathrm{Commit}(p(a), r(a))$ with a per-record salt $r(a)$. The salt is stored with the metadata until invalidation and is destroyed together with $k(a)$ at $t^I(a)$. Before invalidation it lets an auditor open the commitment against the payload. After invalidation no opening can be checked, because the payload is no longer readable, while a retained salt would let anyone holding a candidate payload confirm a guess against $c(a)$ (Section 4.9). Destroying the salt does not weaken binding, which is a property of the commitment value: no second payload can be opened against $c(a)$, and after $t^I(a)$ no payload can be opened against it at all. A party that holds its own copy of the payload and must later prove that it corresponds to $c(a)$ has to obtain and keep the opening before invalidation; the audit store does not keep one for it. Where a deployment wants the commitment to stay checkable after invalidation, the opening can be handed at write time to a party entitled to the payload, such as the data subject or the patient's home National Contact Point; the audit store itself never holds one after $t^I(a)$. Without such a party, the commitment fixes after invalidation only that some payload was bound at write time and has not since been substituted. The scheme must be hiding: an adversary holding $c(a)$ and lacking $r(a)$ must learn nothing about $p(a)$. A bare unsalted hash of the payload does not satisfy this and must not be used, for the reason given in Section 4.9.

The invalidation registry. Invalidation entries are appended to the audit trail as first-class records. Each entry $\iota(a)$ contains the identifier of the invalidated record, the invalidation month, the legal ground, the authorising actor, and a hash of the destroyed key's identifier: not of the key itself. The registry is append-only. Invalidation is an event that is logged, not an event that erases the

log. Key-management guidance anticipates exactly this record: once a key is destroyed, "its previous existence may be recorded (e.g., in metadata or audit logs)" (Barker, 2020, Section 7.6). The invalidation entry is that record, given a legal ground and an authorising actor.

Tamper evidence. An append-only registry is only as good as the means of detecting an append-only violation. Secure audit logging has addressed this since Schneier and Kelsey (1999), whose hash-chained logs make earlier entries unalterable without detection; Merkle trees (Merkle, 1988) let the same assurance be checked for a single entry with a logarithmic proof (Crosby & Wallach, 2009), and Certificate Transparency standardised that construction for public logs (Laurie et al., 2013). The mechanism appends every access event, invalidation and subject-link removal to such a log, with the leaf and node hashing of RFC 6962, and Semantics II condition (i) is checked as an inclusion proof against the log's root rather than as the presence of fields (Chapter 5, Section 5.7). What enters a leaf is chosen so that the log never needs rewriting: the accessor fields, the creation month, the commitment to the payload and a salted commitment to the subject fields, never the payload and never the subject fields themselves. The salt of the subject-field commitment is held with the subject fields and destroyed when they are removed, so the link to the patient, which a cross-border record keeps for the whole floor, is as tamper-evident as the accessor fields while it exists and confirms nothing once it is gone. The tension that Chapter 2, Section 2.4 found unresolved in blockchain audit logging, an immutable trail facing an erasure right, therefore does not arise: what the right and the ceiling reach is held outside the log and destroyed there, and what the log holds is what accountability requires. Redactable and chameleon-hash designs, reviewed in Chapter 2, Section 2.4, resolve the same tension the other way, by letting a key holder rewrite the log.

Accumulator-based validity witnesses. The set of currently valid (non-invalidated) records is maintained in a dynamic cryptographic accumulator supporting efficient revocation (Camenisch & Lysyanskaya, 2002). This provides an auditor with a succinct proof that a given record either is or is not currently valid, without the auditor enumerating the registry. The accumulator is an efficiency and verifiability layer, not a load-bearing component of the propositions: Proposition 2 holds if validity is established by linear scan of the registry, and the accumulator makes that check succinct. The accumulator is specified but not implemented in the artefact (Chapter 6, Section 6.1). Dynamic accumulators of the Camenisch and Lysyanskaya type also require a trusted accumulator manager holding a trapdoor, which adds a trust assumption stated in Section 4.9.

The auditor's view. After invalidation, an external auditor examining record a can establish four things. The access event occurred, with all its accountability attributes, which follows from $m(a)$. Some payload was bound to that event at write time and has not since been substituted, which follows from $c(a)$ and its inclusion in the log; which payload it was can be checked only by a party that kept an opening (*Commitment*, above). The payload was invalidated, and the auditor can see when, on what legal ground, and by whom, from $\iota(a)$. And the record's current validity status is as claimed, which follows from the accumulator witness where that layer is used, and otherwise from a scan of the registry. Each of these entries is, moreover, in the log as first written, which follows from its inclusion proof against the published root. What the auditor cannot do is read the payload. This is the intended state, and it is the difference between this mechanism and the practitioner crypto-shredding pattern reviewed in Chapter 2, Section 2.4: that pattern retains ciphertext and asserts that

erasure occurred, whereas this mechanism produces a verifiable record of what was invalidated and under what authority.

End of life at floor expiry. The constraints of Section 4.4 govern the record's behaviour through its retention window, but the window ends, and the model would be incomplete if it said nothing about what follows. After $t = t(a) + F(a)$, the last month of the closed window on which C1 is defined, the retention obligation lapses, and with it the necessity that justified retaining $m(a)$ under Article 17(3)(b). Because the metadata contains the patient pseudonym and the actor identifier, it is personal data, and the storage-limitation principle of Article 5(1)(e) GDPR requires that it not be kept in identifiable form longer than the purpose demands. The mechanism therefore specifies a terminal transition. In the first month after the window, $t(a) + F(a) + 1$, the record undergoes a second invalidation, in which the identifying fields of $m(a)$ are destroyed, together with $k(a)$, the salt $r(a)$ and the ciphertext where no earlier invalidation removed them. What remains is a residue intended to be non-identifiable, subject to the isolation, linkage and inference test below, being the event type, the document category, the outcome, and the commitment, which is sufficient for statistical and assurance purposes and insufficient to relate the record to any data subject. The terminal transition is itself logged, and the record's final state is the only state in the mechanism that is intended to be anonymous rather than pseudonymous in the sense of Section 4.9. Whether it is depends on the invalidation entries as well: the record identifier and authorising actor they carry must be generalised or destroyed with the identifying fields, and whether what remains resists isolation, linkage and inference, in the terms of the Board's draft Guidelines 02/2026 (European Data Protection Board, 2026c), is for the documented threat model to establish, not for this specification to assume. Where a longer-running obligation applies to the same record (a national archival duty, or litigation hold) the terminal transition is deferred and the floor parameter $F(a)$ is set to the longer period, which is the parameterisation the model already supports.

Applying the mechanism to the two cases. For the cross-border primary-use case, the mechanism operates at the audit repository of the National Contact Point, at the point where the ATNA audit record is written. The patient link is retained there through the floor, for the reason Section 4.2 gives, and removed at the terminal transition. For the Secure Processing Environment case, it operates at the environment's access-logging boundary. The identifiable log required by Article 73(1)(e) is written with its activity content committed rather than retained in plaintext beyond the ceiling, and with its subject fields held apart from its accessor fields. At $t_\pi(a) + 6$ the payload key is destroyed and, for logs kept at patient-record granularity, the subject fields are removed. The environment then holds a log that identifies every person who accessed it, when and under which permit, as Article 73(1)(e) requires, and holds no electronic health data from that log, as Article 68(12) requires on the broad reading. Whether auditing "all processing operations" after the ceiling also needs the subject link is an interpretive question this thesis cannot settle; Chapter 7, Section 7.4 puts it to the supervisory authority.

4.9 Residue Analysis

A mechanism that erases by destroying keys is only as good as what it leaves behind. Proposition 2 leaves a residue: $m(a), c(a), \iota(a)$, the leaf hashes of the audit log and, where the optional layer is used, the accumulator state. The salt $r(a)$, the key $k(a)$ and the ciphertext of $p(a)$ are destroyed at invalidation (Section 4.8). Whether the mechanism is lawful depends on whether this residue sits on the correct side of the threshold at which data cease to be personal. This section performs that analysis, and it is included because Chapter 2 identified its absence as the fourth gap in the literature.

The threat. Finck's analysis for the European Parliament establishes that hashed or encrypted data likely remain personal data under GDPR so long as re-identification remains possible (Finck, 2018, 2019). Applied to this mechanism, the threat is direct: if $c(a)$ is an unsalted hash of the payload, then an adversary who can guess candidate payloads can confirm a guess by recomputing the hash. For clinical documents drawn from a constrained space (a diagnosis code, a medication from a formulary) the guessing space may be small enough to make this practical. An unsalted commitment would therefore be a surviving item of personal data, and the mechanism would have relocated the erasure problem rather than solved it.

The response. This is why the hiding property is a requirement of the design and not an implementation preference. With a per-record salt $r(a)$ of adequate length, confirming a guessed payload requires the salt; the commitment alone leaks nothing. Because the salt is destroyed with the key, no party can confirm a guessed payload against $c(a)$ after invalidation unless it kept its own opening beforehand. What has been destroyed is both the ability to *recover* the payload, which depended on $k(a)$, and the ability to confirm a guess about it from the audit store, which depended on $r(a)$.

The audit log raises the same threat one level up, and the same response answers it. A leaf hash must outlive the record's fields, since the root depends on it, and it is computed over the accessor fields and the commitment. After the terminal transition the commitment survives and the accessor fields do not; an adversary who can enumerate candidate accessors, a small set in any one environment, could then recompute the leaf and confirm which accessor it was. The specification therefore places a per-entry random nonce in every leaf, held with the record and destroyed at the terminal transition with the identifying fields, so that a surviving leaf hash confirms nothing. The artefact does not implement the terminal transition, and its leaves omit the nonce accordingly (Chapter 6, Section 6.1).

The limit. The residue therefore does not meet the strict Norwegian anonymisation threshold. Datatilsynet's guidance holds that encryption protects rather than anonymises, and that data remain personal while any key or linkage capable of re-identification is retained (Datatilsynet, 2015). The European Data Protection Board's draft Guidelines 02/2026 on anonymisation, version 1.0 adopted on 7 July 2026 and published for public consultation, set the same bar at Union level: data may be regarded as anonymous where they resist record isolation, linkage and inference by means reasonably likely to be used, and the Guidelines hold that encryption is by its nature reversible and is not anonymisation, so that technical protection alone does not place data beyond the reach of the definition (European Data Protection Board, 2026c). The Court of Justice has since held that pseudonymised data are not personal data in all cases and for every person: for a recipient who

cannot lift the pseudonymisation they may not be, while for the controller who holds the additional information they remain personal data (Court of Justice of the European Union, 2025, paras 73 and 76–77). The repository controller holds both the subject link and the accessor's identity, so for it the residue remains personal data. By that standard the residue, which keeps metadata identifying the access event and identifies the accessor, is best characterised as pseudonymised rather than anonymous until the terminal transition. This thesis does not claim otherwise, and any claim that the mechanism achieves anonymisation would be false.

Why the mechanism is nonetheless defensible. The applicable legal test is not anonymisation but erasure. The mechanism meets it for the store itself by deletion: at $t^I(a)$ the payload's ciphertext, key and salt are deleted (Section 4.8). Key destruction is relied on only for copies that cannot be deleted at once, and for those the European Data Protection Board's Guidelines 02/2025 do not settle the question. They state that upon deletion of the decryption key the encrypted data will be unintelligible, at least until the algorithm is broken, but hold in the same paragraph that encrypted personal data is still personal data, and require that on an erasure request the data be erased or rendered anonymous (European Data Protection Board, 2026b). Such copies are therefore a bounded residue, unreadable from $t^I(a)$ and personal data until they leave by rotation, and are stated as such. The requirement that the controller document the threat model under which the data are considered unrecoverable is not the Board's formulation. It is Aikebaier's (2026) interpretation, which takes a Destruction-IND-CCA security notion to suffice for the Board's description of unintelligibility, and it is adopted here as a design discipline rather than asserted as a regulatory requirement. The final version 2.0 of Guidelines 02/2025, adopted on 7 July 2026 after public consultation, sharpens rather than softens the constraint this places on the present mechanism: it confirms that both metadata and content may in principle constitute personal data, and that this may extend to encrypted and hashed data. The residue characterisation of this section is therefore the one the Board's final position requires, and a thesis claiming anonymisation for that residue would now be contradicted by the guidance it relies upon. The design consequence is that the mechanism's defensibility for those copies rests on a documented threat model, which must state: the custody boundary within which key destruction occurs; the assumed adversary's access to that boundary; the leakage assumptions for the hardware holding key material; and the algorithmic-break horizon over which the ciphertext's confidentiality is assumed to hold. A mechanism deployed without that documentation would not meet the condition adopted here, however sound its cryptography.

The trust assumptions. Because key destruction is attested rather than proven, the mechanism's guarantees rest on a set of assumptions that a deploying institution must be willing to accept, and naming them is part of the documentation the Board's condition requires.

The controller is trusted to execute destruction when the invalidation entry says it did, and to have had no copy of the key outside the custody boundary at that moment. The custody boundary itself, whether a hardware security module or an equivalent key-management service, is trusted not to retain recoverable key material after a destruction instruction, and not to leak it through side channels during its lifetime. The audit-trail operator is trusted not to remove or alter entries, which the append-only construction makes detectable but not impossible: an altered entry fails its inclusion proof, and a rewritten history is exposed by a consistency proof between an earlier root and the

current one, provided earlier roots are published or countersigned (Laurie et al., 2013). The artefact implements inclusion proofs only. Where the optional accumulator layer is used, its manager is also trusted, since a party holding the accumulator trapdoor can forge validity witnesses. And the cryptographic assumption is that the commitment scheme remains binding and hiding, and the payload cipher remains unbroken, across the retention horizon.

What an external auditor can verify without any of this trust is bounded. The auditor can verify that the metadata is internally consistent, that an invalidation entry exists with its month, ground and authorising actor, and that the entry is bound into the append-only trail. The auditor can also verify that a commitment survives, to which a payload could be opened if one were produced. What the auditor cannot verify is that the key is gone. That gap is the difference between attestation and proof, and it closes only with hardware-backed or cryptographically certified deletion, which Chapter 6, Section 6.3 treats as the boundary of this contribution.

The residual cryptographic risk. Over a ten-year floor, the algorithmic-break horizon is a live concern rather than a formality: anything retained for a decade must be assumed to face cryptanalytic capability that does not exist when it is written. Deleting the ciphertext at invalidation (Section 4.8) removes this exposure for the store's own copy, so what is retained long-term is metadata, the commitment and the invalidation entry. The risk is reduced, not eliminated. Copies the store cannot delete at once, such as backups, hold ciphertext until rotation removes them; a record with no invalidation event keeps its ciphertext until the terminal transition; and the commitment must stay hiding across the horizon, which is a requirement on the hash function rather than on a cipher. This is recorded as a limitation in Chapter 6 rather than resolved here.

4.10 Rival Designs and Proposition 4

If a simpler design solved the problem, this mechanism would be unnecessary. Six alternative designs are therefore tested against it. Five are rejected for stated reasons; the sixth is accepted for the ceiling alone and bounded by Proposition 4.

Rival 1: Rely on the Article 17(3)(b) exemption and retain in full. This is the dissolution argument answered in Chapter 2, Section 2.3 and Section 4.2 above. It fails on the necessity boundary: the exemption protects retention that the legal obligation requires, and Section 4.2 established that the accountability purpose does not require payload accessibility. It fails additionally in the Secure Processing Environment case, where Article 68(12) admits no exemption parallel to Article 17(3)(b), so that on the broad and unharmonised reading Corollary 1.2's infeasibility survives the argument entirely (Section 4.6).

Rival 2: Anonymise the audit record instead. If the record were genuinely anonymised, Datatilsynet's equation of anonymisation with deletion would discharge the erasure obligation (Datatilsynet, n.d.-b). But genuine anonymisation of a cross-border audit record destroys its accountability function: an audit trail that cannot identify which clinician accessed which patient's record is not an audit trail, and Article 73(1)(e) requires the logs to be *identifiable* in terms. Anonymisation satisfies C2 and C3 by violating C1.

Rival 3: Minimise the payload at capture, so that nothing needs erasing. Recording less at the outset is good practice and is compatible with this mechanism; where a deployment can minimise, the mechanism has less to invalidate. For cross-border records it does not dissolve the problem, because the payload is put there by the standard rather than by the deployment: the IHE patient-discovery transaction requires the audit message to carry the query segment, which holds the name and birth time where demographic matching is used (Section 4.3). A deployment cannot minimise it away without departing from the profile. Where an identifier is supplied instead, the segment carries little beyond the identifier, which the mechanism keeps as the subject link in any case, and cross-border invalidation then removes little; the Secure Processing Environment case is unaffected. In the Secure Processing Environment case minimisation is a genuine alternative for the ceiling: a log kept at dataset granularity carries no subject fields and falls outside Article 68(12) on the narrow reading, and on the broad reading unless the activity content it retains is itself data concerning health, at the cost of patient-level traceability. The specification requires logs to identify the actor and to cover "access to electronic health data", and requires logging to be "proportionate, risk-based, and technically feasible" and to "avoid unnecessary collection of detailed user behaviour not required for auditability or misuse detection" (TEHDAS2, 2026b, Table 5.4, OPR-17, p. 51). It sets no requirement on the granularity of logs, which leaves the choice, and with it Corollary 1.2, to the operator. Minimisation does not remove from the scope of Article 17 the payload the standard requires, which is the case Proposition 4 below shows no relocation or reduction of the log can escape.

Rival 4: Delete the record and log the deletion. This is the closest rival and deserves the most care. Deleting the audit record while logging that a deletion occurred satisfies C2 and C3, and preserves a trace. It fails C1 under both semantics: under Semantics I trivially, and under Semantics II because condition (ii) fails: no commitment survives, so the auditor can establish that *something* was deleted but not that the deleted item was the payload bound to that specific access event. That failure is by definition, since condition (ii) requires a commitment, so the real question is what the commitment adds. Before invalidation an auditor can open it against the payload and detect the substitution of one record's content for another's. After invalidation it can be opened only by a party that kept an opening (Section 4.8), and otherwise fixes only that some payload was bound at write time. The advantage over this rival is therefore real but bounded: it lies chiefly in the logged, attributed invalidation entry and in the tamper-evident binding of the access record, and only partly in the commitment. The mechanism's advantage over Rival 4 is precisely the verifiability that Chapter 2 identified as absent from the practitioner crypto-shredding pattern. For the cross-border case, where the subject link is kept through the floor and no party is handed an opening by default, that advantage narrows to the logged, attributed, tamper-evidently bound invalidation entry: there, "delete the record and log the deletion" is close to an equivalent design, and the commitment earns its keep chiefly before invalidation, as substitution detection, and wherever an opening is handed to the data subject or home National Contact Point. It is in the Secure Processing Environment case, and wherever that opening is kept, that the commitment does work the deletion rival cannot.

Rival 5: Retain recoverable encrypted copies until the later date. This is the resolution developed in the closest prior art, the DePaul retention-and-purging programme reviewed in Chapter 2, Section 2.4. It holds encrypted copies in shadow tables and backups, with each copy's key selected to expire on

the governing purge date, and effects purging by destroying that key (Scope & Rasin, 2025; Scope, Rasin, Lenard, Heart, & Wagner, 2022). Where both obligations are floors and the purge date is fixed in advance, this is the right design.

It cannot work against a ceiling, and the reason is the residue analysis of Section 4.9 applied in reverse. A copy whose key still exists is recoverable, and recoverable ciphertext held together with the means of decryption remains personal data under the threshold set out in Chapter 2, Section 2.3. Retaining such copies to satisfy the Article 73(1)(e) floor is therefore exactly what the Article 68(12) ceiling forbids of the environment holding them. The prior art satisfies a retention obligation by preserving recoverability; the mechanism specified here satisfies one by destroying recoverability and preserving accountability instead. That inversion, rather than any difference in cryptographic technique, is what the tri-lateral case requires.

Rival 6: Move the logs out of the environment at permit closure. If Article 68(12) is read by location, exporting the access logs at permit closure to an audit store outside the environment, held for instance by the health data access body, satisfies it literally without cryptography, on the premise that Article 73(1)(e) fixes how long the logs are kept and not where. The rival is correct about the ceiling, and this thesis accepts it as a sufficient answer to Corollary 1.2. It does not answer the erasure right, for a reason that is general enough to state as a result.

> *Proposition 4 (location and right). This result depends on a legal premise stated here as an explicit assumption, not derived from the model: that a controller receiving a relocated record receives the erasure obligation of Article 17(1) GDPR with it.* Let a ceiling be anchored to a location, requiring data to be absent from that location after a deadline, and let a right be anchored to the data subject, requiring data to be inaccessible to any controller holding them after a deadline. Under Semantics I, and granting that assumption, relocating a record before the ceiling's deadline satisfies the ceiling and the floor together, while the floor and the right remain infeasible for every record satisfying the first disjunct of Proposition 1.

Proof. The ceiling quantifies over the location: after relocation the record is not in it, so the ceiling holds, and on the rival's premise the floor is met at the new location. The right quantifies over the controller: Article 17(1) obliges the controller holding the data to erase them, and, as a legal premise rather than a mathematical consequence, a controller receiving the record receives the obligation with it. Relocation therefore leaves C1 and C2 as they were, and the argument of Proposition 1 applies unchanged. ∎

Proposition 4 is stated over the model extended informally with the location and the controller of each record, which Section 4.3 does not represent. It is a legal argument given the form of a proposition so that its premise is explicit, and the artefact does not execute it.

Two consequences follow. Ending payload accessibility within the floor is necessary for the request-driven conflict, which no relocation escapes, and optional for the location-anchored one, where relocation is a lawful alternative. And relocation is not free. The exported log still carries its subject fields, now held by a second controller for the rest of the floor, so the personal data have been moved rather than reduced; where those fields are electronic health data, they are held outside the measures Article 73(1) prescribes for such data. The partition of Section 4.3 meets the ceiling without moving anything, and does so with the same mechanism that meets the right.

The critique that is not a rival. SecuPi (2025) argues that cryptographic erasure introduces operational complexity in row-level encryption scenarios and that auditable key management adds rather than removes overhead. This is not an alternative design for the problem; it is a cost objection, and it is partly correct. Per-record key granularity in a high-volume audit repository is an operational burden. The response is that the burden is the price of a solution to a problem that has none otherwise, and that the burden falls on audit records rather than on clinical data stores, which is the smaller of the two surfaces. Chapter 6 engages this critique at length rather than dismissing it.

4.11 Integration with the Norwegian Infrastructure

A mechanism is only as useful as the point at which it can be installed. This one is specified against the Norwegian infrastructure as verified in Chapter 2, Section 2.6, not against an idealisation of it.

Primary use: the National Contact Point. Norway's NCPeH is in live pilot operation (Helsedirektoratet, 2026), as Chapter 2, Section 2.2 describes. The mechanism attaches at the sixth step of the OpenNCP transmission flow, where the ATNA audit record is written to the audit repository. It requires no change to service discovery, patient discovery, document retrieval, pivot translation, or the security and consent module. This placement is deliberate: it is the narrowest point of the flow at which the intervention achieves its purpose, and interventions at the other five steps would touch the interoperability surface that Member States have agreed and Norway has implemented.

Secondary use: Helsedataservice and the Secure Processing Environments. Helsedataservice holds decision authority for eleven central health registries (Folkehelseinstituttet, 2024). The mechanism attaches at the access-logging boundary of the Secure Processing Environment rather than inside the environment's analytical machinery. This placement is forced by the empirical finding that the Norwegian environment landscape is fragmented well beyond the three NORTRE nodes, extending to controller-provided servers, folders, and in some cases consumer cloud services and disconnected personal computers (SPUHiN, 2024). A mechanism requiring capabilities of the environment would fail against that reality; a mechanism operating on the log the environment must in any case produce does not. The reference architecture of the Joint Action's specification locates the same boundary (TEHDAS2, 2026b, Figure 5.13, p. 60). It divides a Secure Processing Environment into a control-and-management layer, comprising user authentication and identification, activity monitoring and access control, and the project workspaces in which data users work. The mechanism belongs to the activity-monitoring component, which writes the logs, and takes each permit's expiry from the coordination portal of the health data access body, which issues the permit. It touches neither the project workspace nor the interfaces to data users and data holders.

Compatibility with the national criteria. The Norwegian criteria for Secure Processing Environments, in the version put to hearing, require an information-security management system as mandatory, recommend ISO 27001 certification, and require eID-based authentication at defined assurance levels (SPUHiN, 2025). The November 2024 draft is specific on logging (SPUHiN, 2024; requirement numbers as in the draft). Tamper-proof, identifiable logs of access to the environment are mandatory "for at least one year" (P13). Logs of when files are extracted and by whom are mandatory, kept for one

year (P24). Logs of activities inside the environment are recommended (P14). A defined termination procedure is mandatory (P31), and its implementation examples include the handling of back-ups and log files. That is the one-year floor of Article 73(1)(e) in national form. None of the requirements inspected says how those logs are to be reconciled with deletion. The mechanism requires nothing beyond these: key custody within a documented boundary is an information-security-management concern of exactly the kind the mandatory requirement already covers. It adds no requirement that the criteria do not already impose, which was the design constraint derived from Chapter 2's third gap.

Relation to the pending implementing acts. The binding technical requirements for Secure Processing Environments are to be laid down by Commission implementing acts under Article 73(5) EHDS, due by 26 March 2027 (European Parliament and Council of the European Union, 2025), after the submission of this thesis. The secondary-use provisions they will operationalise become applicable on 26 March 2029 under Article 105. The specification published by TEHDAS2 during 2026 as deliverable D7.4 is the best available anticipation of their content (TEHDAS2, 2026b). The mechanism is therefore specified against a moving target, and the appropriate claim is compatibility with the infrastructure as currently specified rather than compliance with requirements not yet adopted. Chapter 6 treats the implications of this timing for the thesis's policy relevance.

Traceability. Table 4.1 sets the mechanism against each requirement it touches, so that the integration analysis above can be checked line by line rather than read as prose. It lists only requirements this thesis has read in the source, with the page of the specification (TEHDAS2, 2026b) where it applies.

Table 4.1. Requirements traced to the mechanism

Requirement	Source	What the mechanism does	Where	Status
Electronic health data within the SPE deleted within six months of permit expiry	EHDS Art. 68(12)	Payload key, salt and ciphertext destroyed at $t_\pi + 6$; subject fields of patient-level logs removed at the same month	§4.7 steps 2–4; `apply_invalidation()`	Met in the artefact (C3 over α and β: 0 violations)
Same, "deleted or rendered unrecoverable … including any backups or redundant copies"	TEHDAS2 D7.4, Table 5.2, OPR-6, p. 43	Key destruction renders copies the store cannot delete at once unrecoverable	§4.8 *Ciphertext*; `crypto_envelope.py`	Met in the optional module with real AES-256-GCM (138 of 138 refused); destruction in program memory, not hardware (§4.9, §6.3)
Identifiable logs of access and activities, kept for the period needed to audit, at least one year	EHDS Art. 73(1)(e)	Accessor fields kept identifiable for the full floor; activity committed	§4.3, §4.7; `V_II()`	Met in the artefact (C1 under Semantics II: 0 violations)

Requirement	Source	What the mechanism does	Where	Status
"All SPE logs MUST identify the actor"	D7.4, Table 5.1, EHDSR-7, p. 31	Actor is an accessor field, never removed within the floor	§4.3	Met in the artefact
"All SPE logs MUST be kept at least for one year"	D7.4, Table 5.1, EHDSR-8, p. 31; OPR-18, p. 51 (five years recommended)	Floor parameter $F = 12$; any longer value is a parameter change (Corollary 2.2)	§4.3	Met in the artefact
Logs available for verification and auditing	D7.4, Table 5.1, EHDSR-6, p. 31; OPR-8, p. 46	Every access, invalidation and subject-link removal in an append-only Merkle log; inclusion proofs	`MerkleLog`, `integrity()`	Met in the artefact (200/200 verify; tamper tests fail)
Logs protected against tampering	D7.4, Table 5.4, OPR-17, and OPR-18, p. 51	Append-only Merkle log; an altered entry fails its inclusion proof	`MerkleLog`, `integrity()`	Met in the artefact against alteration of an entry or of the patient link (all three tamper tests fail V^{II}); a rewritten log is detected only with published roots and consistency proofs, specified and not implemented (§4.9)
Logging proportionate; no unnecessary detail on user behaviour; must cover access to electronic health data	D7.4, Table 5.4, OPR-17, p. 51	Accessor fields kept; subject fields only where the log is kept per patient record, and removed at the ceiling	§4.3, §4.10 Rival 3	Met by specification; granularity is the operator's choice, which the specification leaves open
Deletion "while ensuring compliance with applicable legal obligations and traceability or reproducibility requirements"; the deletion and retention policy to "balance these obligations"	D7.4, Table 5.2, OPR-6, p. 43	Supplies the balance for the logs: what accountability needs is kept, what the ceiling reaches is invalidated	§4.7, §4.8	Met by specification: the specification asks for the balance and leaves its form open
Whether the audit purpose needs the subject link after the ceiling	EHDS Art. 73(1)(e) read with Art. 68(12)	Removes it; keeps accessor fields	§4.6, §7.4	Open: interpretation for the supervisory authority

Requirement	Source	What the mechanism does	Where	Status
Erasure without undue delay, within one month (extendable by two)	GDPR Arts. 17(1), 12(3)	Invalidation at $t_r + \delta$, $\delta \in \{1, 3\}$	§4.4 C2; `--delta-witness`	Met in the artefact (both δ)
Retention only as far as the legal obligation requires	GDPR Arts. 17(3)(b), 5(1)(c)	Keeps accountability content and commitment; removes payload	§4.2	Met by specification (necessity argument)
Not kept in identifiable form longer than necessary	GDPR Art. 5(1)(e)	Terminal transition after the floor	§4.8 *End of life*	Met by specification; not implemented in the checker (§6.1)
After key deletion encrypted data are unintelligible but remain personal data; erasure means deletion or anonymisation; threat model documented	EDPB Guidelines 02/2025 v2.0, paras. 50, 51, 125; Aikebaier (2026) on the threat model	Payload, key and salt deleted at t^I; key destruction only for copies not deletable at once, stated as residue	§4.8, §4.9; `crypto_envelope.py`	Deletion met in the artefact; key hierarchy met in the optional module; copies and the threat model by specification, and the copies remain personal data until rotation
Audit message records the query segment	IHE ITI-55, §3.55.5.1	Treated as payload: committed, then invalidated on request	§4.3	Met in the artefact (cross-border payload models the query)
Information-security management system (mandatory); ISO 27001 (recommended); eID login at defined assurance levels; personnel security	SPUHiN (2025), hearing version	Requires none of these to change; operates at the logging boundary	§4.11	No conflict
Tamper-proof, identifiable logs of access to the SPE, at least one year (mandatory); of file extraction, one year (mandatory); of activities (recommended)	SPUHiN (2024), draft, P13, P24, P14	Accessor fields kept identifiable for the floor; every access event in the append-only Merkle log	§4.3, §4.8; `MerkleLog`	Access logs met in the artefact ($F = 12$; all three tamper tests fail V^{II}); extraction and activity logs covered by the same mechanism, not modelled separately
Defined termination procedure (mandatory); implementation examples include back-ups and log files	SPUHiN (2024), draft, P31	Supplies the rule for the log files: invalidation at the ceiling, terminal transition after the floor	§4.8	Met by specification; the terminal transition is not implemented (§6.1)

Requirement	Source	What the mechanism does	Where	Status
Reconciliation of log retention with deletion	SPUHiN (2025), hearing version	Not addressed by the criteria at any grade; the mechanism supplies one	§2.6, §4.11	Gap the thesis addresses

Three things follow from the table. Every requirement the artefact can execute is met in the run; the requirements met only by specification are hardware key custody, the terminal transition and the legal necessity argument, none of which a sandbox can demonstrate; and one row is open, which no artefact can close. The rows met by specification are those the expert evaluation of Chapter 3, Section 3.8 is designed to test with practitioners.

4.12 Summary

This chapter formalised the tri-lateral retention conflict as a constraint-satisfaction problem over a single binary accessibility variable per record, with the retention floor parameterised so that an illustrative ten-year cross-border audit floor and the one-year Secure Processing Environment log floor are instances of one constraint. It proved that under plaintext-verifiability semantics the system is infeasible for any cross-border record whose erasure request arrives inside its window and, for Secure Processing Environment logs kept at patient-record granularity on the broad reading, without any erasure request at all, where two retention provisions of a single regulation collide over a single environment. It proved that under an accountability-preserving semantics the system is jointly satisfiable for every arrival pattern and every floor, and the proof exhibited the trajectory that achieves satisfaction. It showed that a ceiling collides with a floor only when it is no longer than the floor, and that the ceiling's anchor decides whether the collision can be read from the text (Proposition 3), and that relocating a record meets the ceiling but not the right (Proposition 4). That trajectory, specified as Crypto-Erasure by Invalidation (Section 4.8), retains metadata and a hiding commitment and destroys the payload key, with the salt and the payload ciphertext, at the earliest of the erasure deadline, the deletion ceiling and any payload retention period the controller sets, appending the invalidation to a tamper-evident audit log built never to hold what erasure reaches; at floor expiry a terminal transition destroys the identifying metadata, leaving a statistical residue intended to be non-identifiable, so that the record's whole life cycle is accounted for under the storage-limitation principle. The terminal transition, the per-entry nonce, proactive invalidation, consistency proofs and the accumulator layer are specified but not implemented in the artefact (Chapter 6, Section 6.1). For Secure Processing Environment records the result assumes that auditing does not need the payload; Corollary 2.3 states what follows if it needs part of it.

The mechanism's residue is pseudonymised rather than anonymous by the strict Norwegian standard, it is defensible under the erasure test the European Data Protection Board has articulated and, on Aikebaier's (2026) reading, provided the threat model is documented, and its long-horizon cryptographic risk is real and recorded. The limitations bearing on this chapter, the informal proof

standard and the conditionality on honest key destruction among them, are those stated canonically in Chapter 3, Section 3.7 and are not restated here. Six rival designs were considered: five were rejected on stated grounds and one, relocation, was accepted for the ceiling alone. The principal cost objection was acknowledged rather than dismissed. The integration analysis placed the mechanism at the two narrowest points of the Norwegian infrastructure at which it achieves its purpose, requiring nothing of the substrate that the national criteria do not already require.

Chapter 5 demonstrates Propositions 1 and 2 executably, over synthetic records generated as described in Chapter 3.

Chapter 5. Demonstration

Every figure reported in this chapter was produced by the code listed in Appendix A, executed under seed 20260915, with one code version throughout.

5.1 Purpose and Claim

This chapter discharges Activity 4 of the design science cycle set out in Chapter 3, Section 3.2: demonstration. Its function is narrow.

The chapter checks that the artefact (Abbasia, 2026) implements Propositions 1 and 2 of Chapter 4 on the instances examined; Proposition 4 is analytic and is not executed here; Section 5.4 computes the condition of Proposition 3 and Section 5.5 checks it. It does not verify them in the proof-assistant sense, it does not measure performance, and it does not deploy anything. Proposition 1 predicts that under plaintext-verifiability semantics the constraint system fails whenever an erasure deadline or a deletion-ceiling deadline falls inside a record's retention window. Proposition 2 predicts that under accountability-preserving semantics the invalidation trajectory satisfies all three constraints for every arrival pattern. The demonstration's job is to make both predictions checkable by execution rather than only by argument.

A subsidiary claim is made for Corollary 1.2: that, on the broad reading of Article 68(12) and for logs kept at patient-record granularity, Secure Processing Environment access-log records become infeasible under plaintext semantics *without any erasure request at all*, through the collision of the Article 73(1)(e) one-year retention floor with the Article 68(12) six-month deletion ceiling. The demonstration produces thirty-nine such witnesses, a number the generator determines (Section 5.4).

5.2 Implementation

The checker is a single Python module of 601 lines including documentation, the exhaustive cross-check and the audit-log integrity check, of which 466 are non-blank, non-comment lines and the constraint-evaluation logic proper occupies approximately one hundred. It depends only on the Python standard library: `hashlib` for commitments and the audit log, `json` for log entries, `random` for seeded generation, `os` for the optional random salts, `itertools` for the exhaustive cross-check, and `sys` for its exit status. The checker uses no cryptographic library, no solver, and no zero-knowledge proof

system, consistent with the scope commitments of Chapter 1, Section 1.5; the optional envelope-encryption module below is the only component that imports a cryptographic library.

Seven further modules accompany it, bringing the artefact to eight Python files in all; the eleven-page viewer is split across `app.py` and `ui.py`, which Table 5.1 lists on a single row. None of the seven alters anything the checker reports. Their line counts, and the full source of each, are given in Appendix A. Figure 5.1 maps the modules and the path a record takes through them.

Table 5.1. The artefact as published

Module	Lines	What it does	Reports a thesis figure?
`trf_checker.py`	601	Constraint evaluation under both semantics, plus the exhaustive cross-check and the audit-log integrity check	Yes: Tables 5.3 to 5.6
`synthea_layer.py`	156	Substitutes Synthea-generated (synthetic) FHIR R4 payloads and compares every figure against the constructed-payload run	Yes: Table 5.7
`norwegian_layer.py`	136	Three Norwegian record classes, varying only the floor, the pathway and the arrival of requests	No
`cross_sector_check.py`	113	The politiregisterloven § 17 instance discussed in Chapter 6, Section 6.10	No
`app.py`, `ui.py`	1124 + 217	Eleven-page viewer over the artefact, with the live architecture diagrams of Figures 4.1 and 5.1; never a source of results	No
`crypto_envelope.py`	122	Optional: the same lifecycle with AES-256-GCM envelope encryption (needs `cryptography`)	No
`z3_check.py`	160	Optional: bounded SMT check of Propositions 1–3 (needs `z3-solver`)	No

Every command has a recorded console run committed beside it in the repository, so that a reader who executes a command and diffs the output against its recorded file can tell a changed file from a changed result. The eight Synthea bundles the realism layer reads are committed with the code, so no regeneration is required to reproduce Table 5.7.

Records are represented exactly as the model specifies. Each carries metadata `m` split into accessor fields (the actor, the national contact point or the data permit, the document category, the legal basis, and the outcome) and subject fields (the patient pseudonym); a payload, which stands for the demographic query of the patient-discovery transaction in a cross-border record and for the logged activity in a Secure Processing Environment record; a hiding commitment `c = SHA-256(salt ‖ payload)` with a per-record sixteen-byte salt (derived from the record identifier in the reported run so that it reproduces exactly, and therefore not hiding in that run; drawn from `os.urandom` under `--random-salts`, Appendix A, A.6); a payload key `k`; a creation month `t_a`; a floor parameter `F`; and a pathway marker. Key destruction is modelled as irreversible removal of the key reference from the record's state, and deletion of the ciphertext as removal of the payload, which is the sandbox's analogue of destruction within a custody boundary and is not a claim that the simulation destroys anything cryptographically.

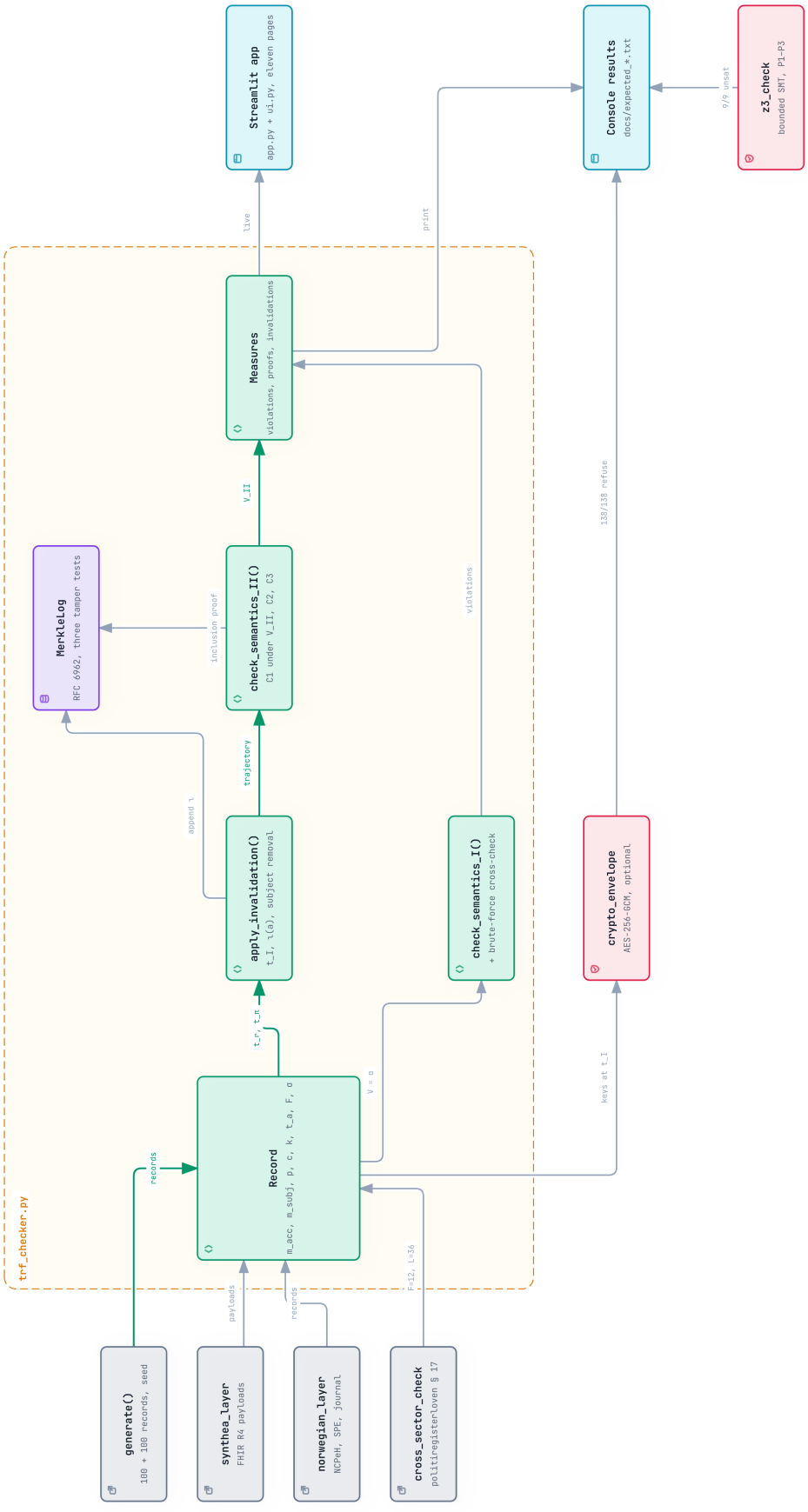


Figure 5.1. The artefact's modules and data path. Records enter from the generator or one of the optional layers, are invalidated on schedule, and are checked under both semantics; the optional cryptographic module and the bounded SMT check sit beside the checker and report separately, and every run is recorded in `docs/expected_*.txt`.

Two record classes are generated, implementing the two floor instances that Chapter 4 absorbed into one parameterised constraint:

- *Cross-border audit records*, `F = 120` months, primary pathway. Erasure requests arrive for a given record with probability 0.40, at a uniformly distributed offset of one to one hundred and thirty months after creation. The offset range deliberately exceeds the window so that some requests fall outside it and the checker is not rigged to find violations.
- *Secure Processing Environment access-log records*, `F = 12` months, secondary pathway. Each carries a permit expiry at a uniformly distributed one to twelve months after creation. Erasure requests arrive with probability 0.25. Every such record is treated as reached by the ceiling ($\rho(a) = 1$), which models the broad reading of Article 68(12) (Chapter 4, Section 4.4).

One hundred records of each class are generated, a scale in keeping with the cohort of about one hundred synthetic patients fixed in Chapter 3, Section 3.5. Requests are drawn per record, not per data subject, and pseudonyms repeat across the two classes; every proposition is stated per record, so no reported figure depends on this, but the generator does not model a request that reaches all of one person's records. Seed 20260915 is fixed and reported; the run is deterministic and reproduces identically.

Table 5.2. Generation parameters (complete)

Parameter	Cross-border audit	SPE access log
Records generated	100	100
Retention floor F	120 months (illustrative long floor; Norwegian pilot: 72)	12 months (Art 73(1)(e))
Pathway σ	primary	secondary
Creation month t_a	uniform [0, 11]	uniform [0, 11]
Erasure-request probability	0.40	0.25
Erasure offset from t_a	uniform [1, 130] months	uniform [1, 18] months
Permit expiry t_π	not applicable	t_a + uniform [1, 12] months
Response period δ	1 month (GDPR Art 12(3))	1 month
Deletion ceiling	not applicable	6 months (Art 68(12))

Erasure-request assignment is drawn independently of permit length, so no record is steered toward violation by the generator.

The reported run (Tables 5.3 to 5.6) uses the constructed payloads just described, 43 bytes on average. For the comparison of Section 5.8, payloads are drawn instead from FHIR R4 resources in patient bundles generated by Synthea (Walonoski et al., 2018), produced with Synthea at commit `d9d07a6` (`java -jar synthea.jar -s 20260915 -cs 20260915 -r 20260916 -p 100`) and yielding 98 usable bundles. The generator was run with `--generate.only_alive_patients=true`, and two of the hundred requested patients did not survive to the end of their simulated lifetime and were therefore not exported. One clinical resource (a Condition, Observation, MedicationRequest, AllergyIntolerance, Immunization, or Procedure) is taken per bundle and serialised as the payload, giving a mean payload of 1,002 bytes.

These resources stand in for payload bytes of realistic size and structure; they are not what $p(a)$ is in either record class (Chapter 4, Section 4.3), and Section 5.8 uses them only to test that no figure depends on payload content.

5.3 Results under Semantics I

Under plaintext-verifiability semantics, $V(a,t) = \alpha(a,t)$, so constraint C1 requires the payload to remain accessible throughout the retention window while C2 and C3 require it to become inaccessible from their respective deadlines. For each record the checker reports, per conflicting constraint, the first month at which both are required at once; a violation is therefore a (record, constraint) pair, not a month.

Table 5.3. Violations under Semantics I (seed 20260915, n = 200)

Record class	Records	With ≥1 violation	Share
Cross-border audit (F = 120)	100	37	37%
SPE access log (F = 12)	100	53	53%
Total	**200**	**90**	**45%**

Total constraint violations: 95 across 90 records. The two counts differ because five SPE records collide with both C2 and C3; each is counted once in the per-record column and twice in the violation total. The full decomposition is 41 records violating C2 only, 44 violating C3 only, and 5 violating both: all five necessarily in the secondary pathway, since only that pathway carries both constraints.

First, the violation rate is not one hundred per cent, and this is the correct behaviour. The rates in this chapter are functions of the generator parameters in Table 5.2 and are not estimates of real frequency; in particular, the generator treats every erasure request as valid, whereas many would be lawfully refused under Article 17(3) (Chapter 3, Section 3.7). Proposition 1 is conditional: it states infeasibility for records whose erasure or ceiling deadline falls inside the retention window. A cross-border record for which no data subject ever exercises Article 17 has no second constraint to collide with C1, and is trivially feasible. Of the one hundred cross-border records, thirty-eight received an erasure request; of those, thirty-seven had a deadline landing inside the one-hundred-and-twenty-month window, and all thirty-seven are among the violations. The single exception is the record whose request arrived beyond the window, which is precisely the case the proposition excludes. The checker therefore reproduces the proposition's conditional structure exactly, including its boundary.

Second, the witnesses are specific and inspectable, which is the property Chapter 3 required of this component. Three examples, verbatim from the run:

```
C1 requires V=1 (=> alpha=1) at t=116 within [11,131]; C2 requires alpha=0 from t=116
C1 requires V=1 (=> alpha=1) at t=120 within [4,124]; C2 requires alpha=0 from t=120
C1 requires V=1 (=> alpha=1) at t=41 within [0,120]; C2 requires alpha=0 from t=41
```

Each names the collision month, the two constraints in conflict, and the window within which the conflict arises. A reader who doubts Proposition 1 can take any of these lines and check the arithmetic by hand.

Third, the Secure Processing Environment class violates at a higher rate than the cross-border class, fifty-three per cent against thirty-seven, although it receives erasure requests at a *lower* probability. The reason is the constraint structure, not frequency: every SPE record faces the Article 68(12) ceiling by construction, while only forty per cent of cross-border records face any second constraint; 49 of the 53 violating SPE records are ceiling-driven and 4 request-only, against 37 request-driven cross-border violations. Section 5.4 isolates the structural ones.

5.4 Corollary 1.2: Infeasibility Without an Erasure Request

Seventy-eight of the one hundred Secure Processing Environment records received no erasure request. Under the received account of the retention–erasure problem, these records should be unproblematic: no data subject has asked for anything, so there is nothing for the retention obligation to conflict with.

Thirty-nine of them are infeasible under Semantics I. That is exactly half of the records with no erasure request.

The witnesses, verbatim:

```
rid=100: t_a=7 permit expires t_pi=10 -> C3 from t=16, C1 to t=19  | collision at t=16
rid=103: t_a=7 permit expires t_pi=10 -> C3 from t=16, C1 to t=19  | collision at t=16
rid=104: t_a=3 permit expires t_pi=4 -> C3 from t=10, C1 to t=15  | collision at t=10
```

Take the first. The access-log record is created in month seven. Article 73(1)(e) requires the identifiable log to remain verifiable until month nineteen. The data permit expires in month ten, so Article 68(12) requires the electronic health data to be gone from the environment by month sixteen. Months sixteen through nineteen are therefore months in which the same regulation requires the same environment both to retain an identifiable access log and, if that log's entries are themselves electronic health data, to hold none of them. No data subject has exercised any right. No deployment baseline is involved. No synthesis across instruments of differing legal weight has occurred. On the broad reading of Article 68(12), and for logs kept at patient-record granularity (Chapter 4, Section 4.6), the conflict is internal to Regulation (EU) 2025/327. Under the narrower reading, the forty-four ceiling-only collisions lapse, these thirty-nine witnesses and five records whose requests fall outside the window, and the secondary-use collisions reduce to the nine records in this population whose erasure requests fall inside the retention window (four that collide with C2 only and five that also collide with C3; twenty-two records received requests in all); Proposition 1, Corollary 1.1, and every Semantics II result are unaffected. Moving the logs out of the environment at permit closure would also remove these thirty-nine collisions, at the cost set out in Chapter 4, Section 4.10; it would not remove the erasure-driven ones.

The fifty per cent figure follows from the generator. The collision occurs when $t_\pi + 6 \le t_a + 12$, the condition of Proposition 3(ii) with $F = 12$, $L = 6$ and the ceiling anchored to permit expiry,

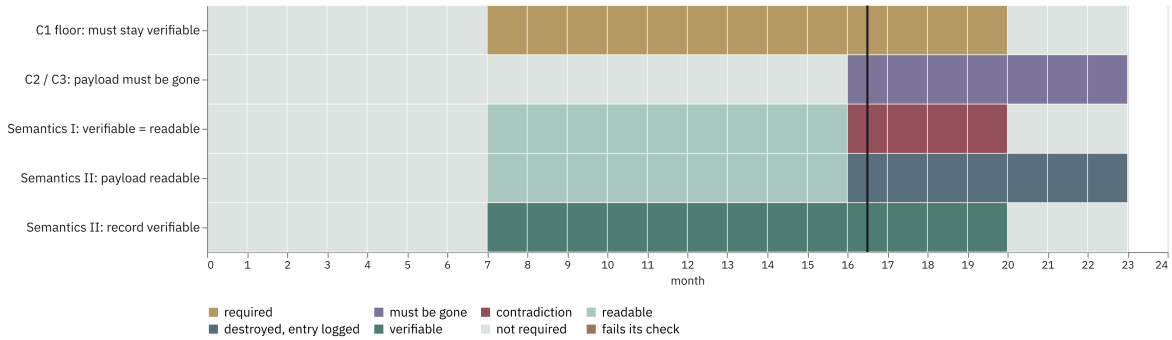


Figure 5.2. Record 100, month by month. The access log is created in month seven under a one-year floor, which runs to month nineteen; the permit expires in month ten, so the ceiling of Article 68(12) applies from month sixteen. No erasure request is made. Under Semantics I the floor requires the payload readable and the ceiling requires it gone in months sixteen to nineteen, the contradiction of Proposition 1. Under Semantics II the payload key is destroyed in month sixteen, the invalidation entry is logged, and the record stays verifiable to the end of the floor, the trajectory of Proposition 2. Drawn by the artefact's viewer from the checker's own quantities; the vertical line marks month sixteen.

and permit lengths were drawn uniformly from one to twelve months, so half fall at or below six. Article 68(12) allows permits of up to ten years; with the remaining duration drawn uniformly over a five-year permit, about one log in ten would fall in the window. The frequency is in any case secondary to a structural fact: an entry written in the last six months of a permit always has a floor that outlasts the ceiling, so every permit used in its final six months produces colliding entries, whatever the distribution of permit lengths. A longer horizon lowers the rate as $6/\pi_{\max}$ without removing the collision, which Proposition 1 establishes independently of any distribution.

5.5 Independent Cross-Check

A checker that implements the constraints incorrectly would produce violations that reflect the implementation rather than the model. To guard against this, the sandbox includes a second, separately written procedure that takes the constraint definitions directly. It searches exhaustively over every possible assignment of the accessibility variable across a fourteen-month horizon, 2^{14} = 16,384 assignments per case, and reports whether *any* assignment satisfies C1 under Semantics I together with C2 and C3. Because every constraint is pointwise in time, enumerating all assignments is equivalent to checking each month in turn, so this search is best read as a sanity check rather than as independent evidential weight; the bounded SMT check described below carries the robustness argument. Its value is that it is a separate function sharing only the constants δ and the ceiling with the main checker, and an automated test compares the two on every boundary month of a twelve-month window, so a boundary error in either shows up as a disagreement (Appendix A, A.2).

Table 5.4. Exhaustive search over α assignments (horizon = 14 months)

Case	Feasible assignment exists?
SPE, no erasure request, permit 3 months	**False**
SPE, erasure request at t = 2	**False**
Cross-border (floor scaled to 12 for tractability), erasure at t = 4	**False**
Control: no erasure request, no permit expiry	**True**

The three conflict cases admit no satisfying assignment whatsoever, which is a stronger statement than the main checker makes: it establishes not merely that the trajectory the checker examined fails, but that no trajectory succeeds. The control case, in which neither C2 nor C3 is active, is feasible: confirming that the search is capable of returning True and that the infeasibility results are not an artefact of a procedure that never succeeds.

This cross-check is separate code, not independent evidence in a stronger sense. It was written in the same AI-assisted process as the main checker and encodes the same constraint definitions from Section 4.4, so it guards against implementation error in the checker and not against error in the model.

The cross-border floor is scaled from one hundred and twenty months to twelve for this check, because exhaustive search over 2^{120} assignments is not computable. The scaling does not affect the logic: Proposition 1's argument depends on the deadline falling inside the window, not on the window's length, and the scaled case preserves that relation. It is the one place in the checker's demonstration where a parameter was altered for tractability.

A bounded check in a different formalism guards against error in the proofs. An optional module poses the propositions to the Z3 SMT solver as requests for a counterexample: a record with any parameter values inside stated bounds (creation month 0–12, floor 1–120 months, so the cross-border floor is covered, response period 1–3 months, request month and ceiling anchor anywhere up to a 140-month horizon, ceiling 1–120 months). It checks Proposition 1 and the converse Chapter 5 relies on (a record with no deadline inside its window is feasible), the constructive trajectory of Proposition 2 with the accountability state of Semantics II encoded (accessor fields, commitment, invalidation entry, subject link and its removal entry), a check that holds by construction and whose evidential weight lies in the refuted mutations below, and both directions of Proposition 3 with its two cases. The solver finds no counterexample in any of the nine checks. It does find counterexamples to deliberately broken versions: the Proposition 2 construction without its invalidation entry, without its commitment, or without the subject-link entry, and Proposition 3 shifted by one month, which shows the checks can fail (Appendix A, A.23 and A.24). The check covers every parameter combination within the bounds rather than a sample and shares no code with the checker. It was written in the same AI-assisted process and takes the constraint definitions from Section 4.4, so it checks that the propositions follow from the constraints as encoded, not that the constraints translate the law, and it is bounded rather than general.

5.6 Witness at the Extended Response Period

Chapter 4, Section 4.4 sets the erasure response period δ from Article 12(3) GDPR, which allows the controller one month from receipt and permits extension by a further two months for complex or numerous requests. The propositions are stated for arbitrary finite δ, and the model admits $\delta = 3$. That claim is witnessed here at $\delta = 3$.

Table 5.5. Results at $\delta = 1$ and $\delta = 3$ (seed 20260915, n = 200)

Measure	$\delta = 1$	$\delta = 3$
Semantics I: records with violation	90	89
Semantics I: total violations	95	94
Corollary 1.2 witnesses	39	39
Records invalidated	138	138
Semantics II: records with violation	0	0
Semantics II: total violations	0	0

Extending the response period moves one record out of violation under Semantics I, which is the expected behaviour: a longer deadline pushes one erasure collision past the end of its retention window, and Proposition 1 excludes exactly that case. Everything else is unchanged. The Corollary 1.2 count is identical because those collisions arise from the deletion ceiling rather than from any erasure request, and so do not involve δ at all. Semantics II yields zero violations at both settings, as Proposition 2 requires for any finite δ.

The run is reproduced with `python3 trf_checker.py --delta-witness`.

5.7 Results under Semantics II

The invalidation trajectory from the constructive proof of Proposition 2 was then applied to every record: destroy the payload key at $t^I = \min(t_r + \delta,\ t_\pi + 6)$ (the artefact runs with $P = \infty$; Chapter 4, Section 4.8), destroy the salt with it, append an invalidation entry recording the month, the legal ground, and the authorising actor, and retain metadata and commitment unchanged.

Table 5.6. Results under Semantics II (same 200 records, same seed)

Measure	Value
Records invalidated	138 / 200
of which on ground GDPR Article 17(1)	52
of which on ground EHDS Article 68(12)	86
Records with ≥1 constraint violation	**0 / 200**
Total constraint violations	**0**

Every record that was infeasible under Semantics I is feasible under Semantics II, and no record is made worse. The ninety violating records become zero.

The distribution of invalidation grounds is itself informative. Eighty-six invalidations are triggered by permit expiry under Article 68(12) and only fifty-two by erasure requests under Article 17(1); four records whose two deadlines fall in the same month are recorded under Article 17(1). The split follows from the generator's parameters, every Secure Processing Environment record carrying a permit expiry while erasure requests are drawn by probability, and is not evidence about practice. What it does show is that the ceiling alone, without any data-subject action, triggers invalidation in the model, consistent with Section 5.4.

The auditor's view of a record that was infeasible before invalidation, verbatim from the run for record 100:

```
accessor fields      : True  actor=R-008 permit=DP-015 outcome=success
subject link         : removed month 16
commitment c(a)      : 678ade47c1e6dc03296175e056fd8116...
payload key k(a)     : None   <- destroyed
salt, ciphertext     : None, None   <- destroyed, deleted
invalidation iota(a) : month=16 ground=EHDS Art 68(12)
payload readable?    : False
```

This is the state the mechanism is designed to produce, and it is worth reading against what Semantics I would have demanded. The access event is fully established: which researcher, under which permit, with what outcome. The link to the patient was removed at the ceiling, and its removal is itself a logged entry; a cross-border record keeps the link through the floor (Chapter 4, Section 4.2). The commitment survives, fixing that some payload was bound at write time, though after invalidation no one without a retained opening can check which. The invalidation is itself a logged, grounded, attributed event rather than a silent absence. And the payload is unreadable, at month nineteen as at month sixteen. An auditor examining this record learns what the accountability purpose is argued to require (Chapter 4, Section 4.2), while the payload is unreadable.

The record is also checked against the audit log. Every access event, invalidation and subject-link removal is an entry in an append-only Merkle log, and condition (i) of Semantics II is tested as an inclusion proof against the log's root rather than as the presence of fields. All two hundred records verify. Altering one accessor field of record 100, or the legal ground of its invalidation entry, makes V^{II} fail, and so does altering the patient link of a cross-border record that still holds it, record 3, because the link no longer opens the salted commitment its log leaf carries (Chapter 4, Section 4.8); restoring them makes it hold again (Appendix A, A.16). Before that commitment was added, a changed link went undetected, which is why the third test exists. The Semantics II result of Table 5.6 therefore rests on a check that can fail, which a test of the fields' presence alone could not. That check is the falsifiable part of the result: C2 and C3 hold by construction once invalidation is applied, since readability is derived from the invalidation month. Its reach is also bounded. The root is recomputed from the leaves the log holds, so the check detects divergence between a record and its logged events, not a rewrite of the log itself, which needs a root published outside the log or consistency proofs between roots (Chapter 6, Section 6.1).

5.8 What the Demonstration Establishes, and What It Does Not

Established. Both propositions hold on all two hundred generated instances. Proposition 1's conditional structure is reproduced exactly, including the boundary case of the request falling outside the window. Corollary 1.2 has thirty-nine witnesses in the model: records in which two provisions of one regulation collide over one environment with no data-subject action involved, on the broad reading of Article 68(12) for logs kept at patient-record granularity. The infeasibility results survive a separately written exhaustive search that considers every possible accessibility assignment rather than only the trajectory the main checker examines, and Propositions 1–3 survive a bounded SMT check over every parameter combination within its bounds. The invalidation trajectory eliminates every violation without introducing any.

Not established, and not claimed. The demonstration does not prove the propositions for all instances; it checks them on the instances generated under one seed, and the exhaustive cross-check covers four small cases rather than the general result. The proofs in Chapter 4, not this chapter, carry the general claim. No performance measurement was taken, and no statement about execution time, throughput, or storage overhead appears anywhere in this thesis. The sandbox does not connect to any National Contact Point, implement the OpenNCP transmission flow, or evaluate consent policies. Key destruction is simulated by removing a reference in program state, which demonstrates the mechanism's logic and demonstrates nothing whatever about whether key destruction can be assured in deployment. An optional module repeats the lifecycle with real AES-256-GCM envelope encryption (Appendix A, A.15 and A.22): after the 138 scheduled destructions exactly those records refuse to decrypt and the other 62 still read, so unreadability is exercised in code rather than only asserted (a refusal is the custody object's missing wrapped key; the cryptographic check is that none of the 62 surviving keys opens record 3); the keys are still destroyed in program memory, not in hardware: the limitation that Chapter 2 drew from the secure-deletion literature and that Chapter 6 engages.

How the tables should be read. The Semantics II result of Table 5.6 holds by construction: the checker derives payload accessibility from the same invalidation month that the trajectory of Proposition 2 prescribes, so zero violations is the expected outcome, and a failure would expose an implementation error and not a modelling error. The rates of Table 5.3 are read as Section 5.3 states.

Payload provenance. The realism layer specified in Chapter 3, Section 3.6 was built and executed; its result bears on how much the figures depend on the fixtures chosen.

The layer substitutes Synthea-generated FHIR R4 resources, synthetic like every record here, for the constructed payload strings and leaves every timing quantity (creation month, erasure arrival, permit expiry, floor, response period) exactly as generated. Mean payload size rises from 43 bytes to 891 with the committed subset and to 1,002 with the full cohort (Appendix A, A.17). All two hundred commitments change, confirming that the payloads genuinely differ.

Table 5.7. Constructed against Synthea-generated payloads (same seed, same timings)

Measure	Constructed	Synthea
Semantics I: records with violation	90	90
Semantics I: total violations	95	95
Corollary 1.2 witnesses (no erasure request)	39	39
Records invalidated	138	138
Semantics II: records with violation	0	0
Semantics II: total violations	0	0
Commitments differing between runs	n/a	200 / 200

Every reported figure is identical while every commitment differs. This is the expected result: no constraint in the TRF Model reads the content of a payload, so the results are functions of timing and accessibility alone, and the comparison tests that claim against inputs that demonstrably changed.

Repeating the comparison with an eight-bundle subset of the same generated cohort raises the mean payload to 891 bytes rather than 1,002, since a different set of clinical resources is drawn, and every payload is then reused roughly twenty-five times across the two hundred records rather than twice. All six measures are again identical to the constructed-payload run, and all two hundred commitments again differ, so neither the size of the cohort nor the frequency with which payloads repeat affects any reported figure.

The generated records carry US Core profiles, not the Norwegian basisprofiler; Chapter 3, Section 3.5 states why that cannot affect any figure here, and the invariance above confirms it.

The exhaustive cross-check of Section 5.5 searches a space of 65,536 assignments in all; it evaluates 65,535, because the control case stops at its first satisfying assignment.

The source repository and a hosted demonstration are listed in Appendix A. The hosted application executes the same unmodified source, checks at execution that its run reproduces the figures in this chapter, and shows a failure notice, with the expected and the computed values, beside the results if it does not. No claim depends on the hosting remaining available; the repository is the artefact. The demonstration thus supports the claim Chapter 1 made for it: the artefact behaves as specified, and Propositions 1 and 2 are checkable by a reader who declines to take the proofs on trust. Chapter 6 takes up what follows from them.

Chapter 6. Discussion

6.1 What the Thesis Establishes

Read one way, three obligations cannot be met together. Read another, they can. The thesis establishes, within its model, that the conflict between audit-retention floors and the obligations to erase is not a property of the obligations but of an assumption about what satisfies them. Under plaintext-verifiability semantics, a record is verifiable while its payload is readable, and the constraint system has no solution for any record whose erasure deadline falls inside its retention window. Under a semantics in which a record is verifiable while its accountability content is intact and any loss of payload accessibility is itself logged, grounded, and attributed, the system is satisfiable for every arrival pattern of erasure requests and permit expiries, and for every retention floor. Chapter 4 establishes both results by arguments it concedes are elementary (Section 4.7); Chapter 5 witnesses them executably, and a separately written exhaustive search, a scaled-down sanity check on the implementation rather than independent evidence, since it shares the Chapter 4 encoding (Section 5.5), finds no satisfying assignment of payload accessibility in the conflict cases under the first semantics.

The request-driven form of the conflict cannot be escaped by moving the record. A deletion ceiling anchored to a location yields to relocation, but the right to erasure attaches to whichever controller holds the data (Chapter 4, Section 4.10, Proposition 4). Ending payload accessibility within the floor is therefore necessary where a data subject's request meets a retention floor, and in the cross-border pathway that is every request arriving inside the floor, because the IHE patient-discovery profile requires the patient's identifying query to be recorded in the audit message; where that query carries an identifier rather than demographics, the payload adds little to the subject link the mechanism keeps (Chapter 4, Section 4.10).

A conditional extension rests on one contestable interpretive step. Article 73(1)(e) requires identifiable logs of access to and activity in a Secure Processing Environment to be kept for the period necessary to verify and audit, and logs of access for at least one year. Article 68(12) requires "the electronic health data within the secure processing environment" to be deleted within six months of the expiry of the data permit. Where an environment logs access at patient-record granularity, those log entries are electronic health data within the environment on the broad reading, and where the remaining permit duration at the time a log is written is six months or less, the two requirements overlap with no data subject acting. Chapter 4, Section 4.6 sets out the grounds on both sides. Chapter 5 produced witnesses of this collision in the model; how many depends on the permit lengths the generator draws, and the count is not an estimate of real frequency (Chapter 5, Section 5.4). Proposition 3 states the general condition: a ceiling no longer than the floor, anchored to an event

other than the one the floor runs from. On the narrow reading, or where logs are kept at dataset granularity, the collision does not arise. On either reading the mechanism is designed to meet both provisions, subject to the questions of Chapter 7, Section 7.4, because the accessor fields that Article 73(1)(e) requires to be identifiable are not the subject fields that Article 68(12) may reach.

Finally, the thesis specifies the mechanism that the feasibility proof exhibits: per-record keys under a key-encrypting key, hiding commitments, deletion of the ciphertext with the key, removal of the subject link at the ceiling, invalidation entries carrying month, legal ground, and authorising actor, a tamper-evident log built never to hold what erasure reaches, and a terminal transition at floor expiry that discharges the storage-limitation obligation on the metadata itself. The artefact executes all of these but the terminal transition, the per-entry nonce, proactive invalidation, the consistency proofs between successive log roots, and the accumulator-based validity witnesses, all specified but not implemented (Chapter 4, Sections 4.8–4.9); the accumulator is an efficiency and verifiability layer rather than a component of either proposition, since Proposition 2 holds if validity is established by linear scan. The demonstration of Chapter 5 exercises keys, commitments, and invalidation entries, and no accumulator was built or run.

What follows engages the objections to all of this in the order of their seriousness.

6.2 The Authority Problem

The most serious objection to this thesis is not technical. It is that Semantics II is an argument, not an authority.

No regulator, court, or supervisory authority has held that an audit record whose payload has been cryptographically invalidated continues to satisfy a retention obligation. I argue that it does. Article 17(3)(b) protects only processing that is *necessary* for the legal obligation, and Article 5(1)(c) requires that no more personal data be retained than the purpose demands. The accountability purpose of an audit record is served by knowing who accessed what, when, and under what authority, not by continued readability of the clinical payload. The Norwegian Data Protection Authority's internal-control guidance places exactly this balancing on the controller (Datatilsynet, n.d.-a), and its privacy-by-design guidance equates anonymisation with deletion (Datatilsynet, n.d.-b). But none of this amounts to a holding that invalidation discharges retention.

If a supervisory authority takes the view that Article 73(1)(e)'s requirement of "identifiable logs" entails logs whose subject matter remains readable, then Proposition 2 remains mathematically true and becomes practically inert: the mechanism would satisfy a constraint system that does not describe the law. The thesis would still have established the collision, which is textual and, on the narrow reading of Article 68(12), survives in its erasure-driven form, and would still have established that the collision is *dissolvable in principle* by a semantic move. It would not have established that the move is available.

Three considerations bear on how likely that outcome is, and they are offered as reasons rather than reassurance.

First, the alternative readings are worse. If verifiability requires readability, then on the broad reading the only way to honour both Article 73(1)(e) and Article 68(12) is to move the logs out of the environment at permit closure (Chapter 4, Section 4.10, Rival 6): the subject fields then sit with a second controller for the rest of the floor, and the erasure right is untouched (Proposition 4). For cross-border records there is no such route at all. A supervisory authority is unlikely to prefer that outcome to a reading under which every obligation is honoured where the data are.

Second, the regulatory direction is compatible with the argument, though it does not decide it. The European Data Protection Board's Guidelines 02/2025, finalised as version 2.0 on 7 July 2026, state that upon deletion of the decryption key the encrypted data will be unintelligible, at least until the algorithm is broken, while holding that encrypted personal data is still personal data and that an erasure request requires the data to be erased or rendered anonymous (European Data Protection Board, 2026b). They describe what key deletion achieves without treating it as erasure, which is why the mechanism deletes the payload and relies on key destruction only for copies it cannot delete at once (Chapter 4, Section 4.8). The further qualification that reliance on key destruction depends on a *documented threat model* is not the Board's formulation but Aikebaier's (2026), whose one-directional theorem holds that a Destruction-IND-CCA security notion suffices for a semantic-security formalisation of the Board's description; the distinction is preserved here because the two carry different authority. The Joint Action's specification points the same way from the infrastructure side. It requires deletion at permit expiry "while ensuring compliance with applicable legal obligations and traceability or reproducibility requirements" and leaves the deletion and retention policy to "balance these obligations" (TEHDAS2, 2026b, Table 5.2, OPR-6, p. 43), and its expert commentary, writing of the project logbooks researchers keep, notes open questions about how accountability and anonymisation obligations intersect (Annex 7, p. 96). A specification that asks for a balance it does not define has not adopted plaintext verifiability; Table 4.1 sets out one balance requirement by requirement.

Third, the question is decidable by asking, and an enquiry to Datatilsynet was sent on 23 September 2026 (Chapter 7, Section 7.4). Chapter 7 proposes, as the highest-value next step, seeking an opinion on whether accountability-preserving verifiability discharges the retention obligation in Article 73(1)(e). Datatilsynet is the natural addressee for the GDPR-side questions; because Articles 68 and 73 are provisions of the EHDS Regulation, the Norwegian authorities responsible for its incorporation (Helsedirektoratet and the Ministry of Health and Care Services) and the Commission are the more appropriate addressees for those. That is a tractable request with a determinate answer, and it would convert the thesis's central interpretive move from argument to authority or else refute it cleanly. Either outcome is worth more than the present uncertainty.

A second authority question sits beside the first and is narrower. Whether Article 68(12) reaches the access logs is a question of statutory construction that a supervisory authority or, ultimately, a court will settle, and that I cannot. I state Corollary 1.2 conditionally rather than adopting the broad reading or the narrow one, on the grounds set out in Chapter 4, Section 4.6. What makes this tolerable rather than fatal is that the dependency is confined: Corollary 1.2 stands or falls with it, as does the conditional branch of Corollary 2.3, and nothing else in the thesis does. The same request, addressed to the authorities responsible for EHDS incorporation, could reasonably carry this one alongside it.

6.3 Key Destruction and the Limits of Assurance

Nobody can watch a key being destroyed. That is the second objection, the one the thesis has carried since Chapter 2, and it is the ceiling of the contribution.

The mechanism's guarantees are conditional on the irreversible destruction of key material. The canonical systematisation of secure deletion establishes that the further a deletion approach operates from the physical storage medium, the harder it becomes to assert that destruction actually occurred (Reardon et al., 2013). Cryptographic erasure is the limiting case: it operates entirely above the medium, reducing the deletion of arbitrary data to the deletion of a key, and inheriting in concentrated form the problem that key destruction cannot be confirmed by inspection.

My response is to be precise about what the invalidation entry is. It is an *attested* record of destruction, not a *proof* of it. The entry records that a named actor destroyed a named key at a named month on a named legal ground, and binds that claim into an append-only Merkle log alongside a hash of the destroyed key's identifier, so that the claim, once made, cannot be altered without detection, nor withdrawn once a root containing it has been published (Chapter 4, Section 4.8). Key-management guidance treats such a record as the normal trace of a destroyed key (Barker, 2020). An auditor can establish that the claim was made, by whom, and when; an auditor cannot establish that the claim is true. The difference between attestation and proof is the boundary of this contribution. Two things narrow it without closing it. Hardware security modules validated against FIPS 140-3 (National Institute of Standards and Technology, 2019) place destruction inside a tested boundary, though validation attests the design of the module, not any particular destruction. And the optional module of the artefact replaces the simulated key with real AES-256-GCM envelope encryption: after the 138 scheduled destructions, exactly those records refuse to decrypt (Chapter 5, Section 5.8), which shows that unreadability follows from the destruction, not that the destruction took place.

That boundary is where an active research programme sits. Proof-of-secure-erasure protocols seek evidence that a prover has erased its memory, with recent work relaxing the isolation assumptions such protocols traditionally require (Bursuc et al., 2024). In the quantum setting, encryption with certified deletion produces a deletion certificate, and its authors identify *public verifiability*, enabling parties other than the originator to verify such a certificate, as an open problem (Broadbent & Islam, 2020). Were public verifiability of deletion certificates achieved, the invalidation entry specified in Chapter 4 could carry a proof rather than an attestation, and the mechanism's guarantee would strengthen from conditional to demonstrable without any change to the model.

One further consideration limits the practical weight of this objection. The alternative to attested key destruction is not proven deletion; it is unattested deletion. A controller who deletes an audit record and logs that a deletion occurred is making exactly the same kind of unverifiable claim, with strictly less structure: there is no surviving commitment and no tamper-evident binding of the deleted record, so an auditor cannot establish *what* was destroyed. Under this mechanism too an auditor cannot read what was destroyed; what the commitment and the log add is that the record of the access and of its invalidation cannot be rewritten without detection. The mechanism does not solve the assurance problem. It improves on unlogged deletion with respect to it; against deletion

logged in the same tamper-evident log, its advantage is confined to the commitment (Chapter 4, Section 4.10, Rival 4).

6.4 The Cost Objection

Per-record keys cost something, and the question is whether the cost is worth paying. SecuPi (2025) argues that cryptographic erasure introduces operational complexity in row-level encryption scenarios, that auditable key management adds rather than removes overhead, and that policy-based access control is a better answer to the right to erasure in heavily distributed systems. This critique is substantially correct on its own terms and must be engaged rather than dismissed.

The mechanism specified in Chapter 4 uses per-record key granularity, the simplest construction that serves, and Section 4.8 explains why: invalidation events occur at record granularity, because a permit expiry invalidates the records of one permit while an erasure request invalidates the records relating to one data subject, and those sets intersect without nesting. A single coarser key would make some invalidations impossible to perform without over-invalidating; a key-share construction would avoid per-record keys at the cost of a more complex hierarchy (Chapter 4, Section 4.8). Per-record keys in a high-volume audit repository are an operational burden, and I do not pretend otherwise.

Three observations bound that burden without denying it.

The burden falls on audit records rather than on clinical data stores. The mechanism operates at the audit-trail boundary (the sixth step of the MyHealth@EU transmission flow, or the access-logging boundary of a Secure Processing Environment) not on the electronic health records themselves. This is the smaller of the two surfaces by a wide margin, and the placement was chosen for that reason as much as for substrate independence.

The burden is bounded and auditable in a way the alternative's is not. Key-management overhead is a known quantity that scales with record volume and can be budgeted, monitored, and inspected. The residual-copy problem that plaintext deletion faces (establishing that no backup, cache, replica, or derived index retains the deleted data) is unbounded and largely uninspectable. Trading an unbounded and invisible cost for a bounded and visible one is a defensible engineering choice, and it is the choice the mechanism makes.

The critique's proposed alternative does not address the problem this thesis identifies. Policy-based and attribute-based access control govern *who may read* data; they do not cause data to cease to be readable. Against Article 68(12), which requires that electronic health data not remain in the environment, an access-control answer does not satisfy the obligation: the data remain, protected by policy. Against the collision of Corollary 1.2, access control offers nothing at all. The critique is well-aimed at crypto-shredding as a general answer to the right to erasure, which is the claim SecuPi is addressing; it is not aimed at the tri-lateral retention problem, and does not reach it.

6.5 Scalability

The demonstration ran two hundred records. A national audit repository handles volumes several orders of magnitude larger, and the mechanism's costs do not all scale in the same way.

Three components grow linearly with the number of records and present no difficulty at realistic volumes, and the audit log adds a fourth whose verification grows only logarithmically: an inclusion proof for one entry in a log of n entries needs about $\log_2 n$ hashes, some thirty for a billion entries, which is why the same construction carries the web's certificate logs (Laurie et al., 2013). Metadata and commitments are small fixed-size additions per record; the invalidation registry grows only with the number of invalidation events, which is bounded by the number of records but in practice far smaller; and the feasibility check itself is a per-record operation independent of the rest of the population.

The key registry is where the cost concentrates, and it is the component the cost objection of Section 6.4 correctly identifies. Per-record keys mean one key-management entry per audit record, and at national cross-border volumes over a ten-year retention horizon that is a large registry to maintain, back up, and audit. Two properties mitigate the growth without eliminating it. Keys for invalidated records are destroyed rather than retained, so the live registry shrinks as invalidations accumulate, and over a long horizon the steady-state registry is smaller than the cumulative record count. And key material is small and uniform, so the registry is an indexing and custody problem rather than a storage one.

The accumulator layer has the least favourable scaling profile and is also the most dispensable. Dynamic accumulators with efficient revocation require witness maintenance as the accumulated set changes, and witness update costs grow with the frequency of revocation. This is why Chapter 4, Section 4.8 specifies the accumulator as a verifiability and efficiency layer rather than a component of either proposition: an implementation that finds witness maintenance too costly at its volume can establish validity by scanning the invalidation registry, losing succinctness and retaining correctness. The Merkle log already makes the presence of an invalidation entry succinct to check; what the accumulator would add is a succinct proof that a record has *not* been invalidated.

No measurement supports any of this. The demonstration made no performance claim and none is made here; these are structural observations about how the specified components grow, and establishing their practical limits is work for an implementation rather than for this thesis.

6.6 Evaluation Design and the Role of Stakeholder Assessment

A model can be right and still be refused by the people who would have to run it. The evaluation reported in this thesis is analytical, and Section 3.7 states its criteria. That evaluation assesses whether the artefact is internally coherent, whether it fits the infrastructure it was designed against, and whether its results reproduce. It does not assess whether the people who would have to deploy it find it defensible, implementable, or trustworthy, and those are different questions that analytical evaluation cannot answer. In the terms of Venable et al.'s (2016) framework for evaluation in design

science research, the evaluation reported here is artificial rather than naturalistic: it tests the design against a formal model, an infrastructure analysis and generated data, not in use. Utility, efficacy in operation and acceptance by those who would run the mechanism are therefore not evaluated, and naturalistic evaluation is the purpose of the instrument described next.

An instrument for answering them has been designed and is specified in full in Appendix C: an eight-person expert panel spanning data protection, health IT architecture, Secure Processing Environment operation, and information logistics, a demonstration-led session structure, a semi-structured interview guide, and a sixteen-item closed-response instrument across perceived utility, regulatory alignment, operational viability, and audit integrity.

Three questions in that instrument bear directly on matters this chapter has had to leave open, and the connection is worth making explicit. Interview question seven asks practitioners whether Article 68(12) reaches the access logs an environment generates, which is the interpretive condition Section 6.2 identifies as carrying Corollary 1.2. Questionnaire item A2 asks whether attested key destruction is sufficient without hardware-backed proof, which is the boundary Section 6.3 describes. And items O1 to O4 address the operational burden that Section 6.4 concedes and cannot quantify. Each of these is a question about practitioner judgement rather than about the model, and none can be settled by further analysis.

The instrument has not been executed, for the reasons given in Chapter 3, Section 3.8: doing so would process personal data about identifiable professionals, require notification to Sikt, and require revision of the scope and ethics statements that are accurate for the thesis as submitted. Its execution is the immediate next step identified in Chapter 7, Section 7.5, and the findings would feed back into the design cycle rather than being appended to it, revising the trust model of Chapter 4, Section 4.9, the residue analysis, and the direction of the next iteration.

6.7 Synthetic Data and the Limits of the Demonstration

The patients in this thesis do not exist, and no result depends on who they are. Substituting Synthea-generated FHIR R4 resources for constructed payload strings changed all two hundred commitments and no reported figure (Chapter 5, Section 5.8, Table 5.7), as it must, since no constraint in the TRF Model reads payload content.

The two limitations of the generated cohort, US Core rather than Norwegian profiles and the validity bounds found by Chen et al. (2019), are stated in Chapter 3, Section 3.5; both lie in dimensions the thesis does not use, because its claims concern the behaviour of audit records under constraint, not clinical content.

The deeper limitation is that a demonstration over generated instances is not a proof over all instances. The general claims rest on the arguments in Chapter 4, and those arguments are informal rather than machine-checked. The executable check, the exhaustive cross-check and the bounded SMT check reduce the probability that an error in the proofs has gone unnoticed; they do not eliminate it, and none of them can show that the constraints translate the law.

6.8 Implications for Practice and Policy

The EHDS provisions that create the collision in Secure Processing Environments do not apply until 26 March 2029, and that is the opportunity. The timing argument is the strongest claim to practical relevance this thesis makes.

Regulation (EU) 2025/327 entered into force on 26 March 2025. Under Article 105 it applies generally from 26 March 2027, and the secondary-use provisions of Chapter IV, which contain both Article 68(12) and Article 73(1)(e), apply from 26 March 2029. Article 73(5) requires the Commission, by means of implementing acts and by 26 March 2027, to lay down the technical, organisational, information-security, confidentiality, data-protection, and interoperability requirements for Secure Processing Environments.

The collision in Secure Processing Environments is therefore not yet operative, and the specifications that will determine how it is handled are not yet written. That is an unusually favourable position for a piece of academic work to occupy. A framework that arrives after infrastructure has hardened around a problem is archaeology; one that arrives while the specifications are being drafted can affect defaults. The Norwegian position sharpens this further: the national criteria for Secure Processing Environments went through a public hearing in the SPUHiN process from July to October 2025, and are positioned explicitly as a national reference basis pending the Union implementing act (SPUHiN, 2025). The compliance checklists, in the hearing version inspected, address information-security management, identity assurance, and access governance, and the 2024 draft makes identifiable access logs mandatory for at least one year (Chapter 4, Section 4.11); their grades are set out in Chapter 2, Section 2.6. No requirement addressing the reconciliation of retention with erasure and deletion appears among them. The absence is observed in the hearing version of the checklists, not established against the deliverable as submitted.

The state of Norwegian cross-border operations reinforces this. Norway's National Contact Point is in live pilot operation, but no relevant patients had yet presented when the Directorate last reported (Helsedirektoratet, 2026), as Chapter 2, Section 2.2 sets out. The cross-border audit stream has not yet carried a relevant patient. A design element proposed now would shape how those records are structured from the outset rather than requiring their retrospective reconstruction.

Three concrete implications follow for the bodies that will write the specifications.

For the Commission drafting the Article 73(5) implementing acts, the reconciliation of Article 73(1)(e) with Article 68(12) is a question the acts must answer, and this thesis offers a candidate answer that does not require amending either provision. Proposition 3 also gives the acts a drafting test: any further ceiling no longer than a floor and anchored to a different event will collide for some records, and only the records' histories will show which. Silence in the implementing acts would leave every Health Data Access Body to resolve the collision independently, which is the outcome that produces the fragmentation the EHDS exists to prevent.

For Health Data Access Bodies including Helsedataservice, the invalidation entry is the practical takeaway even if the full mechanism is not adopted: recording *what was invalidated, when, on what*

legal ground, and by whom as a first-class audit event costs little and converts an unexplained absence into an accountable one.

For TEHDAS2 and its successors, whose Secure Processing Environment specification of 2026 defines minimum capabilities and the interoperability baseline for federating environments, the collision is named but not resolved: the specification asks for a balance between deletion and traceability and flags the intersection of accountability and anonymisation as needing guidance (Section 6.2). Table 4.1 is written in the specification's own requirement identifiers so that it can be read as a proposal against them.

This thesis is a Master's dissertation proposing a design, not a regulatory impact assessment. The policy implications above are offered as an argument to the bodies concerned, not as advice they are obliged to weigh, and their force depends entirely on the authority question of Section 6.2 being resolved favourably.

6.9 Theoretical Implications

Three theoretical implications follow from the work, each modest and each stated at its actual size. They are implications of the four contributions set out in Chapter 7, Section 7.2, not a competing list.

The first is the formalisation itself. Treating a retention conflict as a constraint-satisfaction problem over a single binary accessibility variable per record, and making the semantics of verifiability an explicit parameter of the model rather than an unexamined assumption, is a way of stating retention problems that appears not to have been used before in this domain. The general method of formalising legal compliance as satisfiability is established (Feng et al., 2023); its application here is what is new, and the applicability of the formulation beyond health data is an open question the thesis does not settle. The structure (one or more floors, a subject-triggered right, a ceiling) is not obviously specific to health. Section 6.10 tests that expectation against a statute outside health and returns a negative result which revises it: what matters is not that a floor and a ceiling coexist but where the ceiling is anchored.

The second is the identification of the semantic assumption as the locus of the problem. The literature treats the retention-erasure tension as a conflict between obligations. The model locates it instead in an interpretive assumption that neither obligation states, and shows that the assumption is doing the work: with it, infeasibility; without it, satisfiability. This reframing suggests a general question for regulatory-compliance modelling, namely how many apparent conflicts between legal obligations are artefacts of implicit operational semantics inherited from systems built under earlier law.

The third is the positioning of the contribution relative to the cryptographic literature. Aikebaier's (2026) systematisation of cryptographic erasure closes by naming five open problems, of which the fifth is erasure under multi-regime retention conflict. That source is an unreviewed preprint and is cited as corroboration rather than authority. This thesis addresses the problem in one regulatory setting, with the reservations of Sections 6.2 and 6.3 attached. The fourth open problem on the

same list, composition with zero-knowledge selective disclosure, is a problem this thesis creates rather than solves, and Chapter 7 treats it accordingly.

For the logistics discipline in which this thesis sits, the result carries over in a specific form. Any regulated consignment record held against a retention floor while a destruction or deletion duty runs from an external event, such as a release, a recall or the end of a contract, is a two-clock object of the kind Proposition 3 describes, and the diagnostic question of Section 6.10 applies to it unchanged. The customs case of Chapter 2, Section 2.7 keeps the two clocks apart by letting them act on different objects; the audit trail is the case in which they must be separated inside a single record.

6.10 Where the Ceiling Is Anchored: a Cross-Sector Test

The first of those three implications raised a question it did not answer. If the structure of one or more floors, a subject-triggered right and a ceiling is not specific to health, then some other domain ought to exhibit it, and running that domain through the same model ought to produce the same infeasibility. A cross-sector instance was therefore constructed and executed rather than argued.

The instance is Norwegian police register law. Section 17 of politiregisterloven imposes a traceability duty on the use of police information systems and converts it into a retention rule: *Opplysninger om bruk av systemet skal registreres og lagres i minst 1 år og slettes senest etter 3 år* (Politiregisterloven, 2010, § 17). The provision therefore places a floor of twelve months and a ceiling of thirty-six months on the same access log, outside health, and the data subject's rights operate on that log as they do on any other personal data. On the reading that motivated the thesis, this ought to be a second instance of the tri-lateral collision.

It is not, and the result is the more informative one. Sixty records were generated under a floor of twelve months and a ceiling of thirty-six, with erasure requests arriving as they do elsewhere in the demonstration. Seven records carried at least one Semantics I violation. Of those seven, **none** arose without an erasure request. Under Semantics II there were no violations at all, and every record was invalidated at its scheduled month. That zero is narrower than the health case's: the § 17 limit reaches the whole log entry, while the module tests only the payload and the patient link against it, so the accessor fields outlive the three years unchecked; the terminal transition that would remove them is specified but not implemented (Chapter 4, Section 4.8). The module that produces this is listed in full at Appendix A, Section A.13, and its console output at Section A.20.

The zero is the finding, and Proposition 3(i) predicts it, since the three-year limit is longer than the one-year floor. Section 17 fixes both of its limbs against the same event, the making of the log entry: the log is stored for at least a year from that point and deleted at the latest three years from the same point. Two periods measured from one origin, the later longer than the earlier, do not collide; they bound a retention window, and the later limit is simply the end of it. Every collision the model finds in this instance is therefore erasure-driven, which is the ordinary bi-lateral conflict the literature already describes, not the structure this thesis is about.

Article 68(12) behaves differently for a structural reason as well as a numerical one: its ceiling is no longer than the floor, which any collision requires, and it is anchored where the shortfall cannot be

seen. Its ceiling is anchored not to the creation of the record but to the expiry of the data permit, an event external to the record and capable of falling at any point relative to the floor, including before the floor has run. A floor measured from creation and a ceiling measured from an unrelated later event are not two ends of one window; they are two clocks that can cross. That crossing is what Proposition 1 characterises, Corollary 1.2 is the case where it happens with no erasure request present at all, and Chapter 4, Section 4.6 states the general condition as Proposition 3: floor and ceiling collide for a record exactly when the ceiling's end falls inside the floor, which needs a ceiling no longer than the floor and, under an external anchor, depends on each record's history.

This sharpens the contribution and narrows it at the same time. It suggests that the diagnostic question for any candidate instance is not whether a floor and a ceiling both exist, which is common, but whether a ceiling no longer than the floor is anchored to a different event, which is not (Chapter 4, Proposition 3). It also withdraws the loose expectation, expressed in the preceding section, that any domain combining the three constraint types will exhibit the collision. Financial record-keeping under MiFID II remains a candidate on that revised test only if some ceiling there is anchored externally, which I have not investigated.

Three limits belong with the result. The instance is illustrative and not empirical: no Norwegian police data was obtained, no operational retention practice was observed, and the record population was generated exactly as elsewhere in the demonstration. The provision does not state in words when either period begins; that both run from the log entry is a reading of the sentence's own syntax, and a reader who requires the anchor to be expressly fixed will find that Section 17 does not fix it. And whether the mechanism of Chapter 4 transfers to a record-level ceiling in a policing context is a design question I do not open here. What the instance establishes is narrower and sufficient: that the collision at the centre of this thesis depends on where a ceiling is anchored, and that a statute pairing a floor with a longer ceiling from a single origin does not produce it.

6.11 Summary

The thesis establishes four things. Audit-retention floors, the right to erasure and the deletion ceiling conflict only under an assumption about verifiability, and not because of the obligations themselves. On the broad reading of Article 68(12) and for logs kept at patient-record granularity, the conflict arises inside the European Health Data Space Regulation with no data subject acting. A ceiling collides with a floor exactly when Proposition 3 says. And relocation escapes the ceiling but not the right (Proposition 4). It exhibits the mechanism that dissolves the conflict and checks Propositions 1 and 2 executably, with a separately written cross-check and a bounded SMT check.

Its principal vulnerability is that the interpretive move at its centre has no regulatory authority behind it, and resolving that is the most valuable next step available. Its ceiling is that attested key destruction is not proven key destruction, a boundary marked by an active research programme in proof-of-secure-erasure and certified deletion. Its principal cost is per-record key management, bounded and auditable where the alternative's residual-copy problem is neither. Its demonstration is a witness rather than a proof, and its synthetic records are structurally genuine but not Norwegian.

These limitations are stated once, in Chapter 3, Sections 3.5 and 3.7, and engaged where they bite; none of them was claimed, so none of them reduces what was, and a contribution that states its boundaries can be checked at them.

Against those, the collision is textual and, on the narrow reading of Article 68(12), survives in its erasure-driven form; the field's own systematisation names the problem class as open; the specifications that will determine the outcome are not yet written; and the Norwegian cross-border audit stream has not yet carried a relevant patient. Chapter 7 draws the conclusions and states the work that follows.

Chapter 7. Conclusion

7.1 The Problem and the Answer

This thesis began from a conflict that the European Health Data Space Regulation does not resolve. Cross-border health data exchange generates audit records subject to retention floors: for MyHealth@EU audit repositories a period left to national law, six years in the Norwegian pilot as set by Helsedirektoratet and ten as reported in the literature, and one year under Article 73(1)(e) for the access logs of Secure Processing Environments. The same records are subject to the erasure right of Article 17 GDPR, exercisable at any moment within those windows, and to the deletion ceiling of Article 68(12) EHDS, which requires data to be gone from a Secure Processing Environment within six months of permit expiry. No instrument reconciles them, the Joint Action's specification asks operators to balance deletion against applicable legal obligations without saying how (TEHDAS2, 2026b, Table 5.2, OPR-6, p. 43), and the implementing acts that will have to handle them are not due until 26 March 2027.

The thesis answered the question in three movements.

It formalised the conflict as the Tri-Lateral Retention Feasibility Model, a constraint-satisfaction problem over a single binary variable per record: the accessibility of its payload. The model has three constraint types, being a parameterised retention floor, an erasure deadline, and a deletion ceiling, and it makes the semantics of *verifiability* an explicit parameter rather than an unexamined assumption.

It proved four results within that model. Under plaintext-verifiability semantics, in which a record is verifiable while its payload remains readable, the constraint system is infeasible whenever an erasure deadline or a ceiling deadline falls inside a retention window. Under accountability-preserving semantics, in which a record is verifiable while its metadata is intact, its commitment survives, and any loss of payload accessibility is itself logged and attributed, the system is jointly satisfiable for every arrival pattern of erasure requests and permit expiries and for every floor parameter. A deletion ceiling can collide with a retention floor only if it is no longer than the floor, and its anchor decides whether the collision can be read from the text or only from each record's history; Article 68(12), anchored to permit expiry, is of the second kind. And moving a record out of the regulated environment meets the ceiling but not the right to erasure, on the legal premise that a controller receiving the record receives the obligation with it.

It specified the mechanism that the second proof exhibits. Crypto-Erasure by Invalidation retains the accessor fields of each record and a hiding commitment, and destroys the per-record payload

key, with the salt and the ciphertext, at the earliest of the erasure deadline, the deletion ceiling and any payload retention period the controller sets; for logs kept at patient-record granularity it removes the subject link at the ceiling, while cross-border records keep it, for at least the period the person's right to learn who accessed their data requires and, where national law fixes a longer period, for the rest of the floor. It appends each invalidation to a tamper-evident audit log as a first-class event carrying its month, legal ground, and authorising actor, in a log whose entries never hold what erasure reaches. At floor expiry it performs a terminal transition that destroys the identifying metadata and leaves a statistical residue intended to be non-identifiable; that transition, the per-entry nonce, proactive invalidation, consistency proofs and the accumulator layer are specified, not implemented.

The three sub-questions of Chapter 1, Section 1.3 are answered as follows. *SQ1*, on the points of conflict and the conditions of joint satisfiability: the regimes conflict wherever an erasure deadline, or a deletion ceiling that reaches the record, falls inside its retention window, and under plaintext verifiability they are then jointly unsatisfiable (Proposition 1, Corollaries 1.1 and 1.2); a ceiling can collide with a floor only if it is no longer than the floor, and its anchor decides whether the collision can be read from the text (Proposition 3). The collision that needs no erasure request holds on the broad reading of Article 68(12) only. *SQ2*, on whether an invalidation mechanism can satisfy all three constraints across floors of differing duration: yes, within the model. Under accountability-preserving verifiability, a mechanism that ends payload accessibility at the earliest deadline while keeping the accessor fields, a commitment and a logged invalidation entry satisfies all three for every arrival pattern and every floor (Proposition 2, Corollary 2.2), as Chapter 5 witnesses on generated instances; cryptography serves the copies the store cannot delete at once (Chapter 4, Section 4.8). *SQ3*, on integration with Norwegian infrastructure: the mechanism attaches at the audit-repository step of the MyHealth@EU flow and at the access-logging boundary of a Secure Processing Environment, and adds no requirement of a new kind to the national criteria (Chapter 4, Section 4.11, Table 4.1), a compatibility established by specification rather than by deployment.

The answer to the research question is therefore that the three regimes can be reconciled within the model without amending any instrument, that what the reconciliation requires instead is abandoning an assumption about audit records that no instrument states, and that whether it holds in law turns on the two principal questions of authority set out in Section 7.4.

7.2 Contributions

Four contributions are claimed, each bounded. They are contributions of framing and feasibility, not of cryptographic invention: the conflict is dissolved by precision about what a verifiable retained record must be, not, on the necessity analysis of Chapter 4, Section 4.2, by weakening any obligation.

A formal characterisation of the tri-lateral retention conflict. The general method of treating legal compliance as a satisfiability problem is established (Feng et al., 2023) and is not claimed here. What is new is its application to a retention system combining floors, a subject-triggered right, and a ceiling, and the isolation of verifiability semantics as the parameter that determines feasibility. The

most recent systematisation of the cryptographic-erasure literature, an unreviewed preprint cited here as corroboration rather than authority, names erasure under multi-regime retention conflict among five open problems for the field (Aikebaier, 2026); this thesis addresses that problem in one regulatory setting.

Feasibility results with an executable witness. Proposition 1 establishes infeasibility under plaintext-verifiability semantics; Proposition 2 establishes satisfiability under the alternative and exhibits the trajectory that achieves it. Proposition 3 gives the condition under which a ceiling and a floor collide, which the cross-sector test of Chapter 6, Section 6.10 illustrated on a statute outside health (an instance generated by the thesis's own code, which checks the code rather than independently confirming the proposition); Proposition 4 shows why relocation answers the ceiling and not the right. Both were checked over two hundred generated records, with violations under the first semantics and none under the second (their number is set by the generator), a separately written exhaustive search confirmed that under the first semantics no assignment of payload accessibility succeeds in the cases it covers, and a bounded SMT check found no counterexample to Propositions 1–3 within its bounds. The proofs are informal and the demonstration covers generated instances; neither is presented as more. Proposition 1 is itself a negative result: it marks as unworkable any design that keeps the payload readable for the length of the floor wherever an erasure or deletion deadline falls inside it.

A mechanism specification with its residue analysed. The mechanism applies established primitives (cryptographic erasure as recognised in NIST SP 800-88 Revision 2, hiding commitments, and, without implementing them, dynamic accumulators) and claims no cryptographic novelty. What it adds to the practitioner crypto-shredding pattern is a combination whose parts are standard: a legally grounded, attributed invalidation entry in a tamper-evident Merkle log, against whose root an auditor can check what was invalidated, when, on what ground, and by whom (Chapter 5, Section 5.7), and a partition of each record into the accessor fields that accountability requires and the subject link and payload that erasure and the ceiling reach. The key hierarchy is executed with real AES-256-GCM in an optional module of the artefact. The residue it leaves is characterised as pseudonymised rather than anonymous, by the Norwegian threshold and by the European Data Protection Board's Guidelines 02/2025, under which encrypted data remain personal data after key deletion makes them unintelligible.

An integration analysis against verified Norwegian infrastructure. The mechanism is placed at the two narrowest points at which it achieves its purpose: the audit-repository step of the MyHealth@EU transmission flow, and the access-logging boundary of a Secure Processing Environment. It adds no requirement of a new kind to the national criteria: key custody falls under their mandatory information-security management system, and the log under their requirement of tamper-proof access logs. That constraint was derived from the documented fragmentation of Norwegian practice rather than assumed. Table 4.1 traces the mechanism to each requirement of the regulation and of the Joint Action's specification it touches, and places it in the activity-monitoring component of the specification's reference architecture.

7.3 What the Thesis Does Not Establish

Against the objectives set in Chapter 3, Section 3.2, verifiability by an external auditor is met for the invalidation record, whose attributed entry and inclusion proof the artefact checks against the log root (Chapter 5, Section 5.7), and not met for destruction itself, which no auditor can verify (Chapter 4, Section 4.9). The limitations bounding this contribution are stated canonically in Chapter 3, Sections 3.5 and 3.7, and engaged where they bite. They are the informal proof standard, the single-seed demonstration, the simulation of key destruction, the US Core profiles of the synthetic cohort, the unquantified operational cost of per-record key management, and the absence of regulatory authority behind two principal interpretive steps and four subsidiary premises. They are not restated here.

Two deserve a final word because they bound the contribution rather than merely qualifying it. The invalidation entry is an attested record of destruction and not a proof of one, and no approach operating above the storage medium can supply the latter (Reardon et al., 2013). And the two principal interpretive steps are the subject of the next section, which states where this thesis is weakest.

7.4 The Two Principal Open Questions of Authority

Both questions are legal rather than technical, and neither can be settled by better modelling.

The first concerns verifiability. No regulator or court has held that an audit record whose payload has been cryptographically invalidated continues to satisfy a retention obligation. I argue that it does, from the necessity boundary of Article 17(3)(b) read with the data-minimisation principle of Article 5(1)(c), and from the Norwegian Data Protection Authority's own framing of retention as a balancing duty on the controller. If a supervisory authority instead reads "identifiable logs" in Article 73(1)(e) as requiring logs whose subject matter remains readable, Proposition 2 remains true of the model and inert in practice.

The second concerns scope: whether Article 68(12), which requires "the electronic health data within the secure processing environment" to be deleted within six months of permit expiry, reaches, on the broad reading, access logs kept at patient-record granularity (Chapter 4, Section 4.6). Corollary 1.2 stands or falls with this question, as does the conditional branch of Corollary 2.3; nothing else in the thesis does. A related question, best treated as part of the question of scope, remains open on either reading: whether auditing "all processing operations" after the ceiling needs the subject link, or only the accessor fields that the Joint Action's specification requires every log to carry.

Both questions are decidable by asking, and asking is the single highest-value action available to this research programme. A request to the competent authorities (Datatilsynet on the GDPR side; Helsedirektoratet, the Ministry of Health and Care Services or the Commission on the EHDS side) on whether accountability-preserving verifiability discharges a retention obligation, whether Article 68(12) reaches access logs kept at patient-record granularity, and whether the audit purpose of Article 73(1)(e) needs the subject link after the ceiling, has a determinate answer. A favourable answer converts the thesis's central interpretive moves from argument into authority. An unfavourable

answer refutes them cleanly and identifies precisely what would have to change. Either outcome is worth more than the present uncertainty, and neither requires further modelling to obtain. The enquiry to Datatilsynet on the GDPR-side questions was sent on 23 September 2026; no response had been received at the time of submission. The parallel enquiry to Helsedirektoratet on the audit-retention floor was answered on 19 October 2026, and its substance is incorporated in Chapter 2, Section 2.3.

7.5 Future Work

Four lines follow, the first immediate and the remainder in ascending order of difficulty.

Execution of the expert evaluation. The instrument specified in Appendix C is designed and ready to execute. It comprises an eight-person panel across data protection, health IT architecture, Secure Processing Environment operation, and information logistics; a live demonstration of the artefact; a semi-structured guide; and a sixteen-item closed-response questionnaire across utility, regulatory alignment, operational viability, and audit integrity. It requires notification to Sikt and a lead time of four to six weeks, and it would supply exactly the evidence this thesis cannot generate analytically: practitioner readings of the Article 68(12) scope question, operator judgements on whether attested key destruction is sufficient in their context, and architectural assessment of the boundary placement. Together with the two authority questions of Section 7.4, this is the shortest route from the present contribution to a validated one.

Selective disclosure of invalidation completeness. The mechanism creates a problem it does not solve. When a data subject exercises Article 17, every record relating to them is invalidated, and an auditor should be able to confirm that *all* of them were. But identifying which records those are would show the auditor the subject's cross-border care history. The controller keeps the link to those records (Chapter 4, Section 4.2); the problem is disclosing it to a third party in order to prove completeness. Proving completeness of invalidation without revealing the invalidated set is a zero-knowledge problem, and it corresponds to the fourth of the five open problems identified by Aikebaier (2026), composition with zero-knowledge selective disclosure. This is where succinct arguments may become necessary rather than decorative, and the audit log of Chapter 4, Section 4.8 gives the problem a concrete form. If each leaf also carried a hiding commitment to its record's subject link, a circuit taking the published root as its public input could prove that every leaf committed to a given subject is matched by an invalidation leaf, while revealing neither the leaves nor their number. Pairing-based arguments give proofs of constant size (Groth, 2016), and universal-setup systems avoid a trusted setup per circuit (Gabizon et al., 2019); which suits a regulator who must verify without trusting the controller is a design question for that work. The project name carried by this work originates in an earlier design that assumed zero-knowledge machinery would enforce the retention conflict; the analysis showed it unnecessary there, and suggests it may be necessary here, though alternatives are not excluded.

Public verifiability of deletion certificates. The boundary identified in Chapter 6, Section 6.3 would move if a deletion could be proven rather than attested. Proof-of-secure-erasure protocols pursue

this in the classical setting under relaxed isolation assumptions (Bursuc et al., 2024), and quantum encryption with certified deletion produces a certificate whose public verifiability its authors identify as open (Broadbent & Islam, 2020). Were public verifiability achieved, the invalidation entry specified here could carry a proof in place of an attestation, and the mechanism's guarantee would strengthen from conditional to demonstrable with no change to the model.

Generalisation beyond health data. The structure the model captures (one or more retention floors, a subject-triggered erasure right, and a deletion ceiling) is not obviously specific to health, and Chapter 6, Section 6.10 ran one test outside it: Norwegian police register law pairs a floor with a longer ceiling from the same event and, as Proposition 3 predicts, produces no collision without an erasure request. Proposition 3 turns the search for other instances into a test that can be applied to a statute's text: look for a ceiling no longer than a floor and anchored to a different event. Applying it across regulated sectors, the Norwegian energy data hub first and financial record-keeping next, would determine whether the contribution is a result about one regulation or a method for a class of them.

7.6 Closing

The European Health Data Space is being built now. Norway's National Contact Point is in live pilot at two emergency clinics, with no relevant patient yet presented when the Directorate last reported. The implementing acts that will specify how Secure Processing Environments handle their records are due in March 2027, and the secondary-use provisions they will operationalise apply from March 2029. The Norwegian national criteria, put to public hearing in 2025, govern how such environments are secured and who may enter them, while saying nothing about what happens when the retention regimes on their records collide.

I do not claim to have found something no one could have seen. The provisions this thesis sets against each other are public, short, and adjacent in the same chapter of the same regulation. What I claim is to have set them against each other formally, and to have shown that the resulting impossibility follows from an assumption rather than from the obligations. I claim to have exhibited and demonstrated the mechanism that dissolves it, and to have done all of that while the specifications are still being written, rather than after infrastructure has hardened around the problem.

The contribution is small, bounded, and checkable. Every reported result of the demonstration was produced by code that any reader can execute. The places where the argument outruns its authority are named, two principal and four subsidiary, and the means of settling the two principal ones is a letter rather than a research programme. What remains is to ask the questions I cannot answer myself, and I have begun to ask them.

References

Abbasia, A. A. (2026). *TRF: Tri-Lateral Retention Feasibility Model* (Version 1.3.0) [Computer software]. Zenodo. https://doi.org/10.5281/zenodo.23989242

Aikebaier, Y. (2026). *SoK: Cryptographic erasure on public ledgers: Application-layer architectures, key-lifecycle adversaries, and GDPR Art. 17 sufficiency* (Cryptology ePrint Archive, Paper 2026/1109). Nexum Ledger Ltd. https://eprint.iacr.org/2026/1109 [Preprint; not peer-reviewed]

Albalwy, F. (2026). Zero-knowledge-based policy enforcement for privacy-preserving cross-institutional health data sharing on blockchain. *Systems*, *14*(4), 385. https://doi.org/10.3390/systems14040385

Arfelt, E., Basin, D., & Debois, S. (2019). Monitoring the GDPR. In *Computer Security – ESORICS 2019* (Lecture Notes in Computer Science, pp. 681–699). Springer. https://doi.org/10.1007/978-3-030-29959-0_33

Ateniese, G., Chou, D. H., de Medeiros, B., & Tsudik, G. (2005). Sanitizable signatures. In S. de Capitani di Vimercati, P. Syverson, & D. Gollmann (Eds.), *Computer Security – ESORICS 2005* (LNCS 3679, pp. 159–177). Springer. https://doi.org/10.1007/11555827_10

Ateniese, G., Magri, B., Venturi, D., & Andrade, E. R. (2017). Redactable blockchain – or – rewriting history in Bitcoin and friends. In *2017 IEEE European Symposium on Security and Privacy (EuroS&P)* (pp. 111–126). IEEE. https://doi.org/10.1109/EuroSP.2017.37

Bai, T., Hu, Y., He, J., Fan, H., & An, Z. (2022). Health-zkIDM: A healthcare identity system based on Fabric blockchain and zero-knowledge proof. *Sensors*, *22*(20), 7716. https://doi.org/10.3390/s22207716

Barker, E. (2020). *Recommendation for key management: Part 1 – General* (NIST Special Publication 800-57 Part 1, Rev. 5). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-57pt1r5

Belen-Saglam, R., Altuncu, E., Lu, Y., & Li, S. (2023). A systematic literature review of the tension between the GDPR and public blockchain systems. *Blockchain: Research and Applications*, *4*(2), 100129. https://doi.org/10.1016/j.bcra.2023.100129

Benaloh, J., & de Mare, M. (1994). One-way accumulators: A decentralized alternative to digital signatures. In T. Helleseth (Ed.), *Advances in Cryptology – EUROCRYPT '93* (LNCS 765, pp. 274–285). Springer. https://doi.org/10.1007/3-540-48285-7_24

Berngaard. (2024). *Ivaretar din teknologiske tjeneste kravet til innebygd personvern?* [Legal commentary]. Advokatfirmaet Berngaard. https://www.berngaard.no/aktuelt/ivaretar-deres-teknologiske-tjeneste-kravene-til-innebygd-personvern-etter-gdpr-gwd56

Boneh, D., & Lipton, R. J. (1996). A revocable backup system. In *Proceedings of the 6th USENIX Security Symposium* (pp. 91–96). USENIX Association. https://www.usenix.org/legacy/publications/library/proceedings/sec96/boneh.html

Bourtoule, L., Chandrasekaran, V., Choquette-Choo, C. A., Jia, H., Travers, A., Zhang, B., Lie, D., & Papernot, N. (2021). Machine unlearning. In *2021 IEEE Symposium on Security and Privacy (SP)* (pp. 141–159). IEEE. https://doi.org/10.1109/SP40001.2021.00019

Broadbent, A., & Islam, R. (2020). Quantum encryption with certified deletion. In *Theory of Cryptography (TCC 2020)* (LNCS 12552, pp. 92–122). Springer. https://doi.org/10.1007/978-3-030-64381-2_4

Brunner, S., Johannessen, A., García-Torres, J., Çatak, F. Ö., Meinich-Bache, Ø., Rettedal, S., & Engan, K. (2025). Consent-driven, semi-automated data collection during birth and newborn resuscitation: Insights from the NewbornTime study. *PLOS Digital Health*. https://doi.org/10.1371/journal.pdig.0000730

Bursuc, S., Gil-Pons, R., Mauw, S., & Trujillo-Rasua, R. (2024). *Software-based memory erasure with relaxed isolation requirements* (Extended version). arXiv. https://arxiv.org/abs/2401.06626 [Published version: 37th IEEE Computer Security Foundations Symposium (CSF 2024), Enschede, 8–12 July 2024]

Cachin, C., Haralambiev, K., Hsiao, H.-C., & Sorniotti, A. (2013). Policy-based secure deletion. In *Proceedings of the 2013 ACM SIGSAC Conference on Computer and Communications Security (CCS '13)* (pp. 259–270). ACM. https://eprint.iacr.org/2013/152

Camenisch, J., & Lysyanskaya, A. (2002). Dynamic accumulators and application to efficient revocation of anonymous credentials. In *Advances in Cryptology – CRYPTO 2002* (LNCS 2442, pp. 61–76). Springer. https://doi.org/10.1007/3-540-45708-9_5

Cao, Y., & Yang, J. (2015). Towards making systems forget with machine unlearning. In *2015 IEEE Symposium on Security and Privacy* (pp. 463–480). IEEE. https://doi.org/10.1109/SP.2015.35

Chakraborty, V., Kaminsky, Y., Mehrotra, S., Naumann, F., Nawab, F., Pappachan, P., Sadoghi, M., & Venkatasubramanian, N. (2025). Meaningful data erasure in the presence of dependencies. *Proceedings of the VLDB Endowment*, *18*(10), 3435–3448. https://doi.org/10.14778/3748191.3748206

Chandramouli, R., & Hibbard, E. (2025). *Guidelines for media sanitization* (NIST Special Publication 800-88 Rev. 2). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-88r2

Chen, J., Chun, D., Patel, M., Chiang, E., & James, J. (2019). The validity of synthetic clinical data: A validation study of a leading synthetic data generator (Synthea) using clinical quality measures. *BMC Medical Informatics and Decision Making*, *19*, 44. https://doi.org/10.1186/s12911-019-0793-0

Council of Supply Chain Management Professionals. (n.d.). *Frequently asked questions* [Includes the CSCMP definition of logistics management]. Retrieved 5 October 2026, from https://cscmp.org/CSCMP/CSCMP/Develop/Starting_Your_Career/Frequently_Asked_Questions.aspx

Court of Justice of the European Union. (2025). *European Data Protection Supervisor v Single Resolution Board* (Case C-413/23 P, judgment of 4 September 2025). https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:62023CJ0413

Crosby, S. A., & Wallach, D. S. (2009). Efficient data structures for tamper-evident logging. In *Proceedings of the 18th USENIX Security Symposium* (pp. 317–334). USENIX Association. https://www.usenix.org/legacy/events/sec09/tech/full_papers/crosby.pdf

Datatilsynet. (n.d.-a). *Etablere internkontroll* [Guidance]. Norwegian Data Protection Authority. https://www.datatilsynet.no/rettigheter-og-plikter/virksomhetenes-plikter/informasjonssikkerhet-internkontroll/etablere-internkontroll/

Datatilsynet. (n.d.-b). *Innebygd personvern og personvern som standard* [Guidance]. Norwegian Data Protection Authority. https://www.datatilsynet.no/rettigheter-og-plikter/virksomhetenes-plikter/innebygd-personvern-og-personvern-som-standard/

Datatilsynet. (2015). *Anonymisering av personopplysninger: veileder*. Norwegian Data Protection Authority. https://www.datatilsynet.no/globalassets/global/dokumenter-pdfer-skjema-ol/regelverk/veiledere/anonymisering-veileder-041115.pdf

Datatilsynet. (2021, 11 May). *Vedtak om overtredelsesgebyr til Norges idrettsforbund for mangelfull testing* [Administrative decision]. Norwegian Data Protection Authority. https://www.datatilsynet.no/regelverk-og-verktoy/lover-og-regler/avgjorelser-fra-datatilsynet/2021/vedtak-om-overtredelsesgebyr-til-norges-idrettsforbund-for-mangelfull-testing/

Deloitte Advokatfirma. (2020). *Syntetiske testdata eller personopplysninger ved testing?* [Legal commentary]. Deloitte. https://www.deloitte.com/no/no/services/legal/perspectives/syntetiske-testdata-eller-personopplysninger-i-test.html

Derler, D., Samelin, K., Slamanig, D., & Striecks, C. (2019). Fine-grained and controlled rewriting in blockchains: Chameleon-hashing gone attribute-based. In *Network and Distributed System Security Symposium (NDSS 2019)*. Internet Society. https://doi.org/10.14722/ndss.2019.23066

Deuber, D., Magri, B., & Thyagarajan, S. A. K. (2019). Redactable blockchain in the permissionless setting. In *2019 IEEE Symposium on Security and Privacy (SP)* (pp. 124–138). IEEE. https://doi.org/10.1109/SP.2019.00039

Dhandala, N. (2026, 17 February). *How to set up crypto-shredding for GDPR right-to-erasure compliance in Google Cloud* [Implementation commentary]. OneUptime. https://oneuptime.com/blog/post/2026-02-17-how-to-set-up-crypto-shredding-for-gdpr-right-to-erasure-compliance-in-google-cloud/view

Diamantopoulos, S., Karamitros, D., Romano, L., Coppolino, L., Koutkias, V., Votis, K., Stan, O., Campegiani, P., Martinez, D., Nalin, M., Baroni, I., Clemente, F., Faiella, G., Mesaritakis, C., Grivas, E., Rasmussen, J., Petersen, J., Cano, I., Puigdomènech, E., . . . Voss-Knude, M. (2019). Secure cross-border exchange of health related data: The KONFIDO approach. In R. Montella, A. Ciaramella, G. Fortino, A. Guerrieri, & A. Liotta (Eds.), *Internet and Distributed Computing Systems: 12th International Conference, IDCS 2019* (LNCS 11874, pp. 318–327). Springer. https://doi.org/10.1007/978-3-030-34914-1_30

Dworkin, M. J. (2007). *Recommendation for block cipher modes of operation: Galois/Counter Mode (GCM) and GMAC* (NIST Special Publication 800-38D). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-38D

eHealth Network. (2017). *Agreement between National Authorities or National Organisations responsible for National Contact Points for eHealth on the Criteria required for the participation in Cross-Border eHealth Information Services* (adopted 9 May 2017). European Commission. https://health.ec.europa.eu/system/files/2017-07/ev_20170509_co06_en_0.pdf

Elhub. (2026). *Elhubs personvernerklæring* [Elhub's privacy statement; last updated 31 March 2026]. Elhub AS. Retrieved 5 October 2026, from https://elhub.no/personvern-og-sikkerhet/elhubs-personvernerklaering

European Commission. (2019). Commission Implementing Decision (EU) 2019/1765 of 22 October 2019 laying down the rules for the establishment, management and functioning of the network of national authorities responsible for eHealth, and repealing Implementing Decision (EU) 2015/1302. *Official Journal of the European Union*, L 270, 83. https://eur-lex.europa.eu/eli/dec_impl/2019/1765/oj

European Commission. (2025a). *Electronic cross-border health services*. Directorate-General for Health and Food Safety. https://health.ec.europa.eu/ehealth-digital-health-and-care/digital-health-and-care/electronic-cross-border-health-services_en

European Commission. (2025b). *European Health Data Space Regulation (EHDS)*. Directorate-General for Health and Food Safety. https://health.ec.europa.eu/ehealth-digital-health-and-care/european-health-data-space-regulation-ehds_en

European Commission. (2026). Commission Implementing Regulation (EU) 2026/2083 of 18 September 2026 on MyHealth@EU. *Official Journal of the European Union*, L, 2026/2083. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=OJ:L_202602083

European Data Protection Board. (2026a). *Coordinated Enforcement Action, implementation of the right to erasure by controllers* (18 February 2026). EDPB. https://www.edpb.europa.eu/our-work-tools/our-documents/other/coordinated-enforcement-action-implementation-right-erasure_en

European Data Protection Board. (2026b). *Guidelines 02/2025 on processing of personal data through blockchain technologies* (Version 2.0, adopted 7 July 2026 following public consultation). EDPB. https://www.edpb.europa.eu/system/files/2026-07/edpb_guidelines_202502_blockchain_v2_en.pdf

European Data Protection Board. (2026c). *Guidelines 02/2026 on anonymisation* (Version 1.0, adopted 7 July 2026, for public consultation) [Draft]. EDPB. https://www.edpb.europa.eu/system/files/2026-07/edpb_guidelines_202602_anonymisation_v1_en_0.pdf

European Parliament and Council of the European Union. (2013). Regulation (EU) No 952/2013 of 9 October 2013 laying down the Union Customs Code. *Official Journal of the European Union*, L 269, 1–101. https://eur-lex.europa.eu/eli/reg/2013/952/oj

European Parliament and Council of the European Union. (2016). Regulation (EU) 2016/679 of 27 April 2016 (General Data Protection Regulation). *Official Journal of the European Union*, L 119, 1–88. https://eur-lex.europa.eu/eli/reg/2016/679/oj

European Parliament and Council of the European Union. (2025). Regulation (EU) 2025/327 of the European Parliament and of the Council of 11 February 2025 on the European Health Data Space and amending Directive 2011/24/EU and Regulation (EU) 2024/2847. *Official Journal of the European Union*, L, 2025/327. https://eur-lex.europa.eu/eli/reg/2025/327/oj

Feng, N., Marsso, L., Sabetzadeh, M., & Chechik, M. (2023). Early verification of legal compliance via bounded satisfiability checking. In *Computer Aided Verification (CAV 2023)* (LNCS 13966, pp. 374–396). Springer. https://doi.org/10.1007/978-3-031-37709-9_18

Finck, M. (2018). Blockchains and data protection in the European Union. *European Data Protection Law Review*, *4*(1), 17–35. https://doi.org/10.21552/edpl/2018/1/6

Finck, M. (2019). *Blockchain and the General Data Protection Regulation: Can distributed ledgers be squared with European data protection law?* (PE 634.445). European Parliament, Panel for the Future of Science and Technology (STOA), EPRS. https://doi.org/10.2861/535

Folkehelseinstituttet. (2024). *Helsedata* [Department page describing Helsedataservice, the national health data access body]. Norwegian Institute of Public Health. https://www.fhi.no/om/organisasjon/helsedata/

Folkehelseinstituttet. (2026, October 19). *FHIs rolle og oppdrag i EHDS*. Norwegian Institute of Public Health. https://www.fhi.no/hd/det-europeiske-helsedataomradet/fhis-rolle-og-oppdrag-i-ehds/

Forskningsetikk. (2023). *Helsedataservice takes over authority to process applications and grant access to health data*. Norwegian National Research Ethics Committees. https://www.forskningsetikk.no/en/news-archive/helsedataservice-takes-over-authority-to-process-applications-and-grant-access-to-health-data/

Gabizon, A., Williamson, Z. J., & Ciobotaru, O. (2019). *PLONK: Permutations over Lagrange-bases for oecumenical noninteractive arguments of knowledge* (Cryptology ePrint Archive, Paper 2019/953) [Preprint]. https://eprint.iacr.org/2019/953

Geambasu, R., Kohno, T., Levy, A. A., & Levy, H. M. (2009). Vanish: Increasing data privacy with self-destructing data. In *Proceedings of the 18th USENIX Security Symposium*. USENIX Association. https://www.usenix.org/conference/usenixsecurity09/technical-sessions/presentation/vanish-increasing-data-privacy-self

Groth, J. (2016). On the size of pairing-based non-interactive arguments. In *Advances in Cryptology – EUROCRYPT 2016* (LNCS 9666, pp. 305–326). Springer. https://doi.org/10.1007/978-3-662-49896-5_11

Healthy Europe. (2026, 12 February). *EHDS progress report: Where does Europe's Health Data Space stand?* https://healthyeurope.eu/european-health-data-space/

Helse- og omsorgsdepartementet. (2020). *Prop. 63 L (2019–2020): Endringer i helseregisterloven m.m. (tilgjengeliggjøring av helsedata)*. Norwegian Ministry of Health and Care Services. https://www.regjeringen.no/no/dokumenter/prop.-63-l-20192020/id2696220/

Helsedataservice. (n.d.-a). *Priser* [Prices]. helsedata.no. Retrieved 6 October 2026, from https://helsedata.no/no/priser/

Helsedataservice. (n.d.-b). *Vedtak hos Helsedataservice* [Decisions at Helsedataservice]. helsedata.no. Retrieved 6 October 2026, from https://helsedata.no/no/vedtak-hos-hds/

Helsedirektoratet. (n.d.). *Det europeiske helsedataområdet (EHDS)*. Norwegian Directorate of Health. Retrieved 28 September 2026, from https://www.helsedirektoratet.no/digitalisering-og-e-helse/det-europeiske-helsedataomradet-ehds

Helsedirektoratet. (2024). *Helsedirektoratets årsrapport 2023* [Annual report; records the Direktoratet for e-helse merger in the chapter *Styring og kontroll i virksomheten*]. Norwegian Directorate of Health. https://www.helsedirektoratet.no/rapporter/helsedirektoratets-arsrapport-2023/styring-og-kontroll-i-virksomheten

Helsedirektoratet. (2025). *FAIR Secure provision and use of health data in Norway (SPUHiN)* [Project page]. Norwegian Directorate of Health. https://www.helsedirektoratet.no/om-oss/forsoksordninger-og-prosjekter/fair-secure-provision-and-use-of-health-data-in-norway-spuhin

Helsedirektoratet. (2026). *MyHealth@EU, Helsedirektoratet* [National e-health portfolio measure]. Norwegian Directorate of Health. https://www.helsedirektoratet.no/digitalisering-og-e-helse/nasjonal-e-helseportefolje/tiltak-i-nasjonal-e-helseportefolje/myhealth-eu-helsedirektoratet

Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004). Design science in information systems research. *MIS Quarterly*, *28*(1), 75–105. https://doi.org/10.2307/25148625

HL7 Norway. (2025). *hl7.fhir.no.basis* (Version 2.2.2, released 27 March 2025) [FHIR R4 national base profile package]. Simplifier.net. https://simplifier.net/packages/hl7.fhir.no.basis/2.2.2

IHE International. (2023). *Audit Trail and Node Authentication (ATNA) Profile*, IT Infrastructure Technical Framework, Vol. 1, Ch. 9 (Revision 20.0, 4 August 2023, Final Text). https://profiles.ihe.net/ITI/TF/Volume1/ch-9.html

IHE International. (2024). *IT Infrastructure (ITI) Technical Framework, Volume 2: Transactions* (Revision 20.1, 12 December 2024, Final Text), Section 3.55 Cross Gateway Patient Discovery [ITI-55]. https://profiles.ihe.net/ITI/TF/Volume2/ITI-55.html

International Chamber of Commerce. (2025). *Data flows in supply chains: Practical realities and policy implications*. ICC. https://iccwbo.org/news-publications/policies-reports/data-flows-in-supply-chains-practical-realities-and-policy-implications/

Johnson, R., Molnar, D., Song, D., & Wagner, D. (2002). Homomorphic signature schemes. In B. Preneel (Ed.), *Topics in Cryptology – CT-RSA 2002* (LNCS 2271, pp. 244–262). Springer. https://doi.org/10.1007/3-540-45760-7_17

Krawczyk, H., & Rabin, T. (1998). *Chameleon hashing and signatures* (Cryptology ePrint Archive, Paper 1998/010; full version of the NDSS 2000 paper). https://eprint.iacr.org/1998/010

Laurie, B. (2014). Certificate transparency. *Communications of the ACM*, *57*(10), 40–46. https://doi.org/10.1145/2659897

Laurie, B., Langley, A., & Kasper, E. (2013). *Certificate transparency* (RFC 6962). RFC Editor. https://doi.org/10.17487/RFC6962

March, S. T., & Smith, G. F. (1995). Design and natural science research on information technology. *Decision Support Systems*, *15*(4), 251–266. https://doi.org/10.1016/0167-9236(94)00041-2

Matheson. (2026). *EDPB publishes CEF report on the right to erasure* [Legal commentary]. Matheson LLP. https://www.matheson.com/insights/edpb-publishes-cef-report-on-the-right-to-erasure/

Merkle, R. C. (1988). A digital signature based on a conventional encryption function. In C. Pomerance (Ed.), *Advances in Cryptology – CRYPTO '87* (LNCS 293, pp. 369–378). Springer. https://doi.org/10.1007/3-540-48184-2_32

Nahmias, S. (1982). Perishable inventory theory: A review. *Operations Research*, *30*(4), 680–708. https://doi.org/10.1287/opre.30.4.680

National Institute of Standards and Technology. (2019). *Security requirements for cryptographic modules* (Federal Information Processing Standards Publication 140-3). U.S. Department of Commerce. https://doi.org/10.6028/NIST.FIPS.140-3

Natsiavas, P., Mazzeo, G., Faiella, G., Campegiani, P., Dumortier, J., Stan, O., … Romano, L. (2021). Developing an infrastructure for secure patient summary exchange in the EU context: Lessons learned from the KONFIDO project. *Health Informatics Journal*, *27*(2). https://doi.org/10.1177/14604582211021459

Norsk forening for allmennmedisin. (2025, 3 October). *Høring — Oversikt over kriterier til sikre analyserom for sekundærbruk av helsedata i Norge — i forberedelse til kommende krav i EHDS* [Consultation response]. Den norske legeforening. https://www.legeforeningen.no/contentassets/6d966320995146c791837a915f6fc11b/hoering-oversikt-over-kriterier-til-sikre-analyserom-for-sekundarbruk-av-helsedata-i-norge-i-forberedelse-til-kommende-krav-i-ehds-3.10.2025.pdf

Norwegian Trusted Research Environments. (n.d.). *Norwegian Trusted Research Environments (NORTRE)* [A collaboration between TSD/UiO, SAFE/UiB and HUNT Cloud/NTNU]. Retrieved 28 September 2026, from https://nortre.no/

OpenNCP Project. (2017). *OpenNCP* [Computer software; GitHub mirror of the epSOS/eHDSI source, commit c8a82d8, 21 April 2017]. GitHub. https://github.com/khypponen/openncp

Peffers, K., Tuunanen, T., Rothenberger, M. A., & Chatterjee, S. (2007). A design science research methodology for information systems research. *Journal of Management Information Systems*, *24*(3), 45–77. https://doi.org/10.2753/MIS0742-1222240302

Perlman, R. (2005). The Ephemerizer: Making data disappear. *Journal of Information Systems Security*, *1*(1), 51–68. https://jissec.org/Contents/V1/N1/V1N1-Perlman.html

Politiregisterloven. (2010). *Lov om behandling av opplysninger i politiet og påtalemyndigheten* (LOV-2010-05-28-16), § 17 Kravet til sporbarhet [Consolidated text as last amended by LOV-2026-06-19-49, in force 1 October 2026; § 17 unamended; read 5 October 2026]. Norwegian Ministry of Justice and Public Security. https://lovdata.no/lov/2010-05-28-16

Politou, E., Casino, F., Alepis, E., & Patsakis, C. (2021). Blockchain mutability: Challenges and proposed solutions. *IEEE Transactions on Emerging Topics in Computing*, *9*(4), 1972–1986. https://doi.org/10.1109/TETC.2019.2949510

Rak, R. (2024). Anonymisation, pseudonymisation and secure processing environments relating to the secondary use of electronic health data in the European Health Data Space (EHDS). *European Journal of Risk Regulation*, *15*(4), 928–938. https://doi.org/10.1017/err.2024.67

Reardon, J., Basin, D., & Capkun, S. (2013). SoK: Secure data deletion. In *2013 IEEE Symposium on Security and Privacy* (pp. 301–315). IEEE. https://doi.org/10.1109/SP.2013.28

Ren, J. (2022). Cryptographic accumulator and its application: A survey. *Security and Communication Networks*, Article 5429195. https://doi.org/10.1155/2022/5429195

Schneier, B., & Kelsey, J. (1999). Secure audit logs to support computer forensics. *ACM Transactions on Information and System Security*, *2*(2), 159–176. https://doi.org/10.1145/317087.317089

Scope, N. C., & Rasin, A. (2025). *Systems and methods for data retention and purging* (U.S. Patent No. 12,425,209 B2, granted 23 September 2025). U.S. Patent and Trademark Office. https://patents.google.com/patent/US12425209B2/en

Scope, N., Rasin, A., Lenard, B., Heart, K., & Wagner, J. (2022). Harmonizing privacy regarding data retention and purging. In *Proceedings of the 34th International Conference on Scientific and Statistical Database Management (SSDBM 2022)* (pp. 1–12). ACM. https://doi.org/10.1145/3538712.3538718

Scope, N., Rasin, A., Lenard, B., Wagner, J., & Heart, K. (2022). Purging compliance from database backups by encryption. *Journal of Data Intelligence*, *3*(1), 149–168. https://www.rintonpress.com/xjdi3/xjdi3-1/149-168.pdf

SecuPi. (2025). *Crypto-shredding is not nirvana for right of erasure or RTBF compliance* [Industry commentary]. https://secupi.com/crypto-shredding-is-not-nirvana-for-right-of-erasure-or-rtbf-compliance/

Sharma, S., Petrovic, G., & Kaushik, S. (2025). *zkFL-Health: Blockchain-enabled zero-knowledge federated learning for medical AI privacy* [Preprint; not peer-reviewed]. arXiv. https://doi.org/10.48550/arXiv.2512.21048

Simjanoska Misheva, M., Shahpaski, D., Dobreva, J., Bukovec, D., Gjorgjioski, B., Nikolov, M., … Gams, M. (2025). AI Act compliance within the MyHealth@EU framework: Tutorial. *Journal of Medical Internet Research*, *27*, e81184. https://doi.org/10.2196/81184

SPUHiN. (2024). *Recommendations for minimum requirements for Secure Processing Environments in Norway* (Draft, 29 November 2024; project 101128232, Milestone M10). Helsedirektoratet & Folkehelseinstituttet. https://helsedata.no/contentassets/bdc68d971f1343ed92fb3d3673fb9905/helsedataradet/utkast---recommendations-for-minimum-requirements-for-secure-processing-environments-in-norway_29.11.2024-1.pdf

SPUHiN. (2025). *Recommendations for minimum requirements for Secure Processing Environments in Norway* (Deliverable D5.2, project 101128232; version issued for public hearing, July–October 2025) [Project deliverable]. Helsedirektoratet & Folkehelseinstituttet. The hearing page has since been withdrawn and no stable public locator for this version could be established; the deliverable number and the hearing window are confirmed on the project page at https://www.helsedirektoratet.no/om-oss/forsoksordninger-og-prosjekter/fair-secure-provision-and-use-of-health-data-in-norway-spuhin

Staffa, M., Coppolino, L., Sgaglione, L., Gelenbe, E., Komnios, I., Grivas, E., Stan, O., & Castaldo, L. (2018). KONFIDO: An OpenNCP-based secure eHealth data exchange system. In *Security in Computer and Information Sciences – Euro-CYBERSEC 2018* (CCIS 821, pp. 11–27). Springer. https://doi.org/10.1007/978-3-319-95189-8_2

Stortinget. (2025). *Innst. 71 L (2025–2026): Innstilling fra helse- og omsorgskomiteen om Endringer i helsepersonelloven og pasientjournalloven mv. (taushetsplikt og tilgjengeliggjøring av pasientopplysninger).* Norwegian Parliament. https://www.stortinget.no/no/Saker-og-publikasjoner/Publikasjoner/Innstillinger/Stortinget/2025-2026/inns-202526-071l/

Sundhedsdatastyrelsen. (2026). *ehdsi* [Computer software; Danish NCPeH deployment of OpenNCP 9.1.0, commit 61094e6, 28 September 2026]. GitHub. https://github.com/Sundhedsdatastyrelsen/ehdsi

TEHDAS2. (2026a). *Guideline for Health Data Access Bodies on the procedures and formats for data access* (D6.3, Version 2.0, final deliverable, 24 February 2026). TEHDAS2 Joint Action. https://doi.org/10.5281/zenodo.20199187

TEHDAS2. (2026b). *Technical specification for Health Data Access Bodies on the implementation of secure processing environments* (D7.4, Version 1.2, 24 February 2026). TEHDAS2 Joint Action. https://doi.org/10.5281/zenodo.20266473

Venable, J., Pries-Heje, J., & Baskerville, R. (2016). FEDS: A framework for evaluation in design science research. *European Journal of Information Systems*, *25*(1), 77–89. https://doi.org/10.1057/ejis.2014.36

VeritasChain. (2026, 18 January). *Crypto-shredding: The technical foundation for reconciling GDPR and financial record-keeping obligations* [Industry analysis, published under the name VeritasChain Standards Organization, a self-declared standards initiative founded 24 November 2025, operationally supported by VeritasChain Inc. and not accredited by any recognised standards body]. https://veritaschain.org/blog/posts/2026-01-18-crypto-shredding-gdpr-mifid-ii-reconciliation/

Walonoski, J., Kramer, M., Nichols, J., Quina, A., Moesel, C., Hall, D., Duffett, C., Dube, K., Gallagher, T., & McLachlan, S. (2018). Synthea: An approach, method, and software mechanism for generating synthetic patients and the synthetic electronic health care record. *Journal of the American Medical Informatics Association*, *25*(3), 230–238. https://doi.org/10.1093/jamia/ocx079

Zhuang, Z., Lee, X., Wei, J., Fu, Y., & Zhang, A. (2024). *CBCMS: A compliance management system for cross-border data transfer* [Preprint; not peer-reviewed]. arXiv. https://doi.org/10.48550/arXiv.2412.08993

Appendix A. Code Artefacts and Reproduction Record

Thesis: Verifiable Crypto-Erasure for Cross-Border Health Data Audit Trails under the European Health Data Space *Author:* Arshad Akhtar Abbasia, MSc Sustainable Energy Logistics, Høgskolen i Molde *Supervisor:* Prof. João Ferreira *Artefact date:* 18 September 2026; revised 3 to 6 October and 5 to 6 November 2026 (release 1.3.0)

This appendix contains every piece of code written for the thesis, the exact commands used to produce every reported result, and the provenance of all data. Nothing reported in Chapters 4 or 5 was produced by code not listed here.

A.1 Availability

The artefact is publicly available in two forms.

Form	Location
Archived release (cite this)	Version 1.3.0, Zenodo, https://doi.org/10.5281/zenodo.23989242 (this version) and https://doi.org/10.5281/zenodo.23819274 (all versions, resolving to the latest); versions 1.0.1 to 1.2.0 produce the same figures
Source repository	https://github.com/Astheno-sphere/TRF-thesis, branch `joao-base` (code in `demo_app/`, reproduction package in `repro_package/`)
Live demonstration	https://trfhimolde.streamlit.app/

The archived release is the citable artefact: version 1.3.0 of the repository, deposited on Zenodo, is the exact code whose outputs this thesis reports and the viewer described below; its result modules produce the same figures as versions 1.0.1 to 1.2.0 and differ from them in the corrections of the code review (an audit log per population, fuller exit codes, two reworded output lines), recorded in `CODE_REVIEW.md` of the thesis repository, whereas the repository's default branch may change after submission. It contains eight Python files, the checker and seven further modules as Chapter 5, Section 5.2 counts them, the viewer among them split across `app.py` and `ui.py`, together with a test suite run on every change, the eight-bundle Synthea subset the realism layer reads, a recorded console run for every module (`docs/expected_*.txt`), and an earlier copy of this appendix; the current copy is the one in this thesis and on the repository's default branch. The live application is a convenience for readers who prefer not to clone and run: it executes the same unmodified source, and its Thesis run page asserts that the run reproduces the figures reported in Chapter 5, displaying a failure notice, with the expected and the computed values, beside the results if it does not.

The demonstration has eleven pages. *Start here* states the problem and sets out a walk through the remaining pages in the order of the thesis. *The four propositions* quotes each proposition from Chapter 4 with the limits the thesis states for it, shows the corresponding figures from the checker, and runs the bounded SMT check of Section 5.5, including the deliberately broken variants it must refute; Proposition 4, which rests on a legal premise, is marked as argued and not executed. *Claim ledger* sets each figure reported in Chapter 5 beside the same figure recomputed when the page opens. *Witness a record* draws one record of the thesis population through its months, showing where Semantics I contradicts itself and where Semantics II holds, and lights the components of Figure 4.1 that act in each month. *How it is built* embeds Figures 4.1 and 5.1 as interactive diagrams. *Thesis run* reproduces, on opening, Tables 5.3 and 5.6 and shows the audit-log integrity check and all three tamper tests of Section 5.7. *Where the ceiling is anchored* evaluates the condition of Proposition 3 for any floor and ceiling, with Article 68(12) and politiregisterloven § 17 as presets. *Robustness and cross-checks* runs the independent exhaustive cross-check of Section 5.5, the erasure-response-period witness of Section 5.6 and the optional envelope-encryption module of Section 5.8. *Synthea realism* reproduces Table 5.7. *Norwegian context* runs the illustrative Norwegian modules, and *Explore* varies population parameters as a teaching aid; neither reports a thesis figure.

A note on durability. Hosted applications are not archival objects: the live demonstration may be withdrawn or may sleep after inactivity, and no claim in this thesis depends on its availability. Every

result reported here is reproducible from the code listed below by executing a single command on any machine with Python installed, which is the form in which the artefact should be assessed.

A.2 Contents

File	Purpose	Lines
`trf_checker.py`	Feasibility checker: executable witness for Propositions 1 and 2, including the exhaustive cross-check and the audit-log integrity check; exits non-zero if Semantics II reports any violation, the cross-check disagrees with the checker, a record fails its inclusion proof or a tamper test goes undetected	601
`synthea_layer.py`	Realism layer: substitutes Synthea-generated FHIR R4 payloads and compares every reported figure against the constructed-payload run; exits non-zero on a divergence	156
`norwegian_layer.py`	Three Norwegian record classes, parallel to the thesis and reporting no thesis figure	136
`cross_sector_check.py`	Cross-sector instance drawn from politiregisterloven § 17	113
`app.py`, `ui.py`	Eleven-page demonstration viewer with live architecture diagrams (Figures 4.1 and 5.1), never a source of results	1124 + 217
`crypto_envelope.py`	Optional: the same lifecycle with real AES-256-GCM envelope encryption; needs the `cryptography` package and reports no thesis figure; counts a ciphertext that fails authentication as refused; exits non-zero on a mismatch	122
`z3_check.py`	Optional: bounded SMT check of Propositions 1–3 with the Z3 solver; needs the `z3-solver` package; exits non-zero if any check, the sanity check or a mutation check fails; solver timeout two minutes per check	160
`data/synthea_subset/`	Eight untrimmed Synthea bundles from the reported cohort, so a reader can run the realism layer without regenerating it	8 files, 40 MB
`docs/expected_trf_output.txt`	Recorded console run of the checker	n/a
`docs/expected_delta_witness_output.txt`	Recorded run at $\delta = 1$ and $\delta = 3$	n/a
`docs/expected_synthea_subset_output.txt`	Recorded realism-layer run against the committed subset	n/a
`docs/expected_norwegian_output.txt`	Recorded Norwegian-layer run	n/a
`docs/expected_cross_sector_output.txt`	Recorded politiregisterloven § 17 run	n/a
`docs/Data_Provenance_Statement.md`	Where the synthetic data came from, the six Synthea markers a reader can check for, and the cohort-size comparison	n/a
`docs/expected_crypto_envelope_output.txt`, `docs/expected_z3_check_output.txt`	Recorded runs of the two optional modules (A.22, A.24)	n/a

File	Purpose	Lines
`docs/expected_synthea_full_cohort_rerun_2026-10-06.txt`	Recorded full-cohort comparison (A.17)	n/a
`tests/test_app.py`, `tests/test_props.py`, `.github/workflows/tests.yml`	Automated checks run on every change: every recorded run reproduces byte for byte, every viewer page renders, the viewer's claim ledger matches Chapter 5, the exhaustive cross-check agrees with the checker on 31 cases including every boundary month of a twelve-month window and refuses a horizon too short to examine the window, and each population keeps its own audit log; 56 tests, run on Python 3.11 to 3.13, also from `demo_app/` in the thesis repository; they report no thesis figure	n/a
`docs/architecture/`, `assets/`	Archify sources and renderings of Figures 4.1 and 5.1	n/a
`LICENSE`, `CITATION.cff`, `.zenodo.json`, `CHECKSUMS.md`	MIT licence, citation and archive metadata, file checksums	n/a
`requirements.txt`	Pinned to the tested versions: `streamlit==1.66.1`, `cryptography==50.0.1`, `z3-solver==5.3.3.0`; the checker itself needs nothing	3

Every module has a recorded run committed beside it. A reader who executes a command and diffs the result against its recorded file can distinguish a changed file from a changed result, which is the distinction that matters when a figure disagrees with the text.

Two files are *not* included and the reason is stated rather than omitted: the full 98-bundle Synthea cohort (314 MB) and the Synthea jar (197 MB). Both are regenerable from the commands in A.5, deterministically, under the seeds given. The eight-bundle subset that is included is drawn from that cohort and is sufficient to run the realism layer; Chapter 5, Section 5.8 reports the comparison at both cohort sizes and finds every figure identical.

A.3 Environment and generation provenance

The synthetic cohort was generated by the official Synthea release jar, downloaded from the project's own GitHub releases and executed with the command in Section A.5. Generation was carried out in a Linux environment with OpenJDK 21 rather than under Windows PowerShell, which does not affect the output: Synthea is deterministic under fixed population and clinician seeds, and reproduces the same patients and clinical events in any environment with a compatible JVM, although file timestamps differ between runs (Section A.5). The bundles carry Synthea's own resource-identifier namespace, its `disability-adjusted-life-years` Patient extension, US Core profile conformance and its default Massachusetts demographics, all of which are verifiable by inspecting any bundle.

A.4 Software environment

```
OS            Ubuntu 24.04
Python        3.11 to 3.13 tested, standard library only (hashlib, random, itertools, glob, json, os,
     sys)
Java          OpenJDK 21.0.10 (required for Synthea only)
Dependencies  none for the checker; cryptography for crypto_envelope.py and z3-solver for z3_check.py,
     both optional
```

The checker has no third-party dependencies. This is deliberate: a reader should be able to run it on any machine with Python installed, without a package manager, and confirm the thesis's central results for themselves.

A.5 Exact commands

The commands run from the root of the archived release, or of a clone of the code repository; in the thesis repository they run unchanged from `repro_package/` (`./run_all.sh` runs them all) and, with the viewer and the tests, from `demo_app/`.

1. Run the feasibility checker (produces every figure in Chapter 5, Sections 5.3–5.5 and 5.7; Section 5.6 needs `--delta-witness`):

```
python3 trf_checker.py
```

Deterministic. Seed 20260915 is set in the module header. Output is byte-identical across runs and across machines.

2. Obtain Synthea (required only for the realism layer):

```
curl -sL -o synthea.jar \
  https://github.com/synthetichealth/synthea/releases/download/master-branch-latest/synthea-with-depe⌋
     ndencies.jar
unzip -p synthea.jar version.txt   # must print d9d07a6
sha256sum synthea.jar              # 018ad7f04f7aacb995804d7d4781c76d5fc714f7f23257ba50daa9eefae224ac
     on 6 Oct 2026
```

`master-branch-latest` is a moving release. The cohort was generated with Synthea commit `d9d07a6eef91ee5144293b42ab64224d84d124f8`, the version every bundle records; if the jar's `version.txt` prints anything else, build that commit from source.

3. Generate the synthetic cohort:

```
mkdir -p synthea_run && cd synthea_run
java -jar ../synthea.jar \
  -s 20260915 -cs 20260915 -r 20260916 -p 100 \
  --exporter.fhir.export=true \
  --exporter.hospital.fhir.export=false \
  --exporter.practitioner.fhir.export=false \
  --generate.only_alive_patients=true
```

`-s` sets the population seed and `-cs` the clinician seed; both are fixed to the thesis seed. `-r` fixes the reference date. Synthea anchors the simulated timeline to the clock time of the run, so a regeneration reproduces the patients and their clinical events but not byte-identical files: regenerated on 6 October 2026, seven of the eight committed patients reappeared with the same events and timestamps shifted by a constant time of day, and every measure of Table 5.7 was unchanged. The run yields 98 usable patient bundles from 100 requested. Output lands in `synthea_run/output/fhir/`.

4. Run the realism layer and the payload-provenance comparison (produces Table 5.7):

```
python3 synthea_layer.py
```

Looks for bundles in `./synthea_run/output/fhir/` first and falls back to `./data/synthea_subset/`, so it runs against either the regenerated cohort or the subset shipped with the artefact. Reports both runs side by side and flags any divergence.

5. Run the erasure-response-period witness (produces Table 5.5):

```
python3 trf_checker.py --delta-witness
```

Re-runs the population at $\delta = 1$ and $\delta = 3$, the extension Article 12(3) GDPR permits for complex requests, and prints both rows for comparison.

6. Run the Norwegian context modules (illustrative; no thesis figure depends on them):

```
python3 norwegian_layer.py
python3 cross_sector_check.py
```

The first builds the NO-XB, NO-SPE and NO-JOURNAL classes and walks through one case per class. The second builds the politiregisterloven § 17 instance discussed in Chapter 6, Section 6.10.

7. Run the demonstration viewer locally:

```
pip install -r requirements.txt
streamlit run app.py
```

8. Verify any run against its recorded output:

```
python3 trf_checker.py | diff - docs/expected_trf_output.txt && echo identical
```

The same form applies to every recorded run in docs/. A difference means a file changed, not that the result changed.

A.6 What the code does

`trf_checker.py`

Implements the TRF Model of Chapter 4 directly. Records are the seven-element tuples of Section 4.3, with the metadata split into accessor fields and subject fields. A Secure Processing Environment record carries a researcher and a permit rather than a clinician and a contact point, and its payload stands for the logged activity; a cross-border record's payload stands for the demographic query that

the IHE patient-discovery transaction puts into the audit message. Two record classes are generated: cross-border audit records with a 120-month floor, and Secure Processing Environment access-log records with a 12-month floor and the Article 68(12) ceiling. Generation parameters are listed in full in Chapter 5, Table 5.2.

Four components matter for the thesis's claims:

- `check_semantics_I()` evaluates the constraint system under plaintext verifiability, reporting for each record the first month at which C1 and C2, or C1 and C3, are simultaneously required. These are the witnesses for Proposition 1.
- `apply_invalidation()` applies the constructive trajectory from the proof of Proposition 2 (destroy the payload key and the commitment salt and delete the payload at `min(t_r + δ, t_π + 6)`, the artefact running with no payload retention period; remove the subject fields of a Secure Processing Environment record at `t_π + 6`; append a grounded entry for each to the record's own population log; retain the accessor fields and the commitment), and `check_semantics_II()` then verifies all three constraints, including C3 over the subject link.
- `integrity()` and the `MerkleLog` class give condition (i) of Semantics II real content. Every access event, invalidation and subject-link removal is appended to an append-only Merkle log using RFC 6962 hashing, and `V_II` checks each of a record's entries against the current root with an inclusion proof. The run includes three tamper tests, an altered accessor field and an altered invalidation ground of record 100 and an altered patient link of record 3, under each of which `V_II` fails, and a restore after which it holds.
- `brute_force_semantics_I()` is written independently of the first function, taking the constraint definitions directly and enumerating all 2^{14} assignments of the accessibility variable over a fourteen-month horizon. It exists so that the infeasibility results do not rest on the correctness of a single implementation. The control case, in which neither C2 nor C3 is active, returns feasible: confirming the search can succeed when it should.

Cryptographic operations use `hashlib` only. Commitments are salted (`SHA-256(salt ‖ payload)`) because Chapter 4, Section 4.9 establishes that an unsalted hash of a low-entropy clinical payload would itself remain personal data. By default `make_salt()` derives each salt from the record identifier so that runs reproduce exactly; `--random-salts` draws them from `os.urandom` instead and gives the same results. The derivation is for reproducibility only: a production deployment must draw each salt from a cryptographically secure random source, since a salt derivable from the record identifier offers no hiding against an adversary who knows the derivation.

Key destruction is modelled as setting the key reference to `None`, and deletion of the ciphertext as setting the payload to `None`. This demonstrates the mechanism's logic and demonstrates nothing about deployment assurance: a limitation stated in Chapter 5, Section 5.8 and treated in Chapter 6.

`synthea_layer.py`

Replaces the constructed payload strings with Synthea-generated (synthetic) FHIR R4 resources drawn from the bundles (one clinical resource per bundle, from `Condition`, `Observation`, `MedicationRe-`

`quest`, `AllergyIntolerance`, `Immunization`, or `Procedure`), recomputes each commitment over the substituted payload, and leaves every timing quantity untouched. It then runs both populations through the same checks and prints them side by side.

The expected result, and the observed one, is that every reported figure is identical while all 200 commitments differ. Mean payload size rises from 43 bytes to 891 with the committed subset (to 1,002 with the full cohort; see A.17). The model reads timing and accessibility, never payload content; running the comparison rather than asserting the invariance lets a reader see the claim tested against inputs that demonstrably changed.

A.7 Data provenance

All data used anywhere in this thesis is synthetic. No real patient data was requested, obtained, or processed at any point.

The cohort is generated by Synthea (Walonoski et al., 2018), an open-source synthetic patient generator. Synthea's default export conforms to the *US Core* implementation guide with United States demographic, geographic, and care-pattern parameters. The FHIR version is *R4*, which matches the version the Norwegian basisprofiler constrain; the *profiles* are not Norwegian, and no claim of Norwegian clinical representativeness is made for these records. The invariance result of Table 5.7 establishes that this mismatch cannot affect any reported figure. The thesis's Norwegian grounding rests on the infrastructure analysis of Chapter 4, Section 4.11.

The eight bundles in `data/synthea_subset/` are untrimmed output from that cohort. With the subset the mean payload is 891 bytes rather than the 1,002 bytes of the full cohort, because a different set of clinical resources is drawn; Chapter 5, Section 5.8 reports both and every other figure is identical.

A.8 Integrity record

Result	Value	Where reported

Results reported in Chapters 4 and 5 and confirmed by execution:

Result	Value	Where reported
Semantics I, records with ≥1 violation	90 / 200	Table 5.3
Semantics I, total violations	95	§5.3
Violation decomposition	41 C2-only, 44 C3-only, 5 both	§5.3
Corollary 1.2 witnesses (no erasure request)	39	§5.4
Exhaustive cross-check, three conflict cases	no satisfying assignment	Table 5.4
Exhaustive cross-check, control case	satisfying assignment exists	Table 5.4
Semantics II, records invalidated	138 (52 Art 17, 86 Art 68(12))	Table 5.6
Semantics II, total violations	0	Table 5.6
Synthea comparison, figures changed	none	Table 5.7
Synthea comparison, commitments changed	200 / 200	Table 5.7
Audit-log integrity	200 / 200 records verify; all three tamper tests fail V_II	§5.7
Reference commitment, record 100	`678ade47c1e6dc03…`	§5.7

The reference commitment is included so that a reader re-running the checker can confirm in one glance that their run matches the one reported. It changed once, on 3 October 2026, when the Secure Processing Environment payload was redefined as the logged activity (Chapter 4, Section 4.3). Under `--random-salts` it differs on every run, by design.

A.9 Known limitations of the artefact

Stated here so that they are not inferred from silence:

1. The demonstration checks the propositions on the instances generated under one seed. The general claims rest on the proofs in Chapter 4, not on this code.
2. The exhaustive cross-check covers four small cases at a fourteen-month horizon. The cross-border floor is scaled from 120 months to 12 for that check because 2^{120} assignments are not enumerable; Proposition 1's argument depends on the deadline falling inside the window, not on the window's length.
3. No performance measurement is offered as a result, and no execution time is reported.
4. Key destruction is simulated in program state. The artefact demonstrates the mechanism's logic and says nothing about whether destruction can be assured in deployment.
5. The checker does not connect to any National Contact Point, implement the OpenNCP transmission flow, evaluate consent policies, or implement any zero-knowledge proof system. None of these is claimed anywhere in the thesis.

A.10 Source listing: `trf_checker.py`

The complete source of the feasibility checker, reproduced as executed. It depends on the Python standard library only. Line count: 601.

```
"""
TRF feasibility checker
=======================
Executable witness for Proposition 1 (infeasibility under plaintext-verifiability
semantics) and Proposition 2 (feasibility under accountability-preserving semantics)
of the Tri-Lateral Retention Feasibility Model.

Thesis: Verifiable Crypto-Erasure for Cross-Border Health Data Audit Trails
        under the European Health Data Space.
Author: Arshad Akhtar Abbasia, HiMolde.

Model reference: Chapter 4, Sections 4.3-4.7.
  Record a = (m, p, c, k, t_a, F, sigma)
  C1 retention floor : V(a,t) = 1 for t in [t_a, t_a + F]
  C2 erasure right   : alpha(a,t) = 0 for t >= t_r + delta
  C3 deletion ceiling: alpha(a,t) = 0 for t >= t_pi + 6   (secondary pathway)

Run:  python trf_checker.py           (reproducible: salts derived from the record id)
      python trf_checker.py --random-salts   (salts from os.urandom, as a deployment must)
Deterministic by default: fixed seed, identical output on every run.

Beyond the constraint check itself:
  - metadata split into accessor fields and subject fields (Ch4 s4.3); the subject link is
    removed at the deletion ceiling and the removal is logged (Ch4 s4.7, step 4)
  - payload ciphertext deleted with key and salt at invalidation (Ch4 s4.8)
  - payloads modelled per record class: the ITI-55 patient-discovery query for cross-border
    records, the logged activity for SPE records (Ch4 s4.3)
  - each log leaf also holds a salted commitment to the patient link, so a changed link no longer
    opens it, while the leaf still never holds the subject fields themselves
  - V_II tests integrity against an append-only Merkle log (RFC 6962 hashing), with a tamper
    test, instead of checking only that fields are present
  - make_salt() derives salts from the record id for reproducibility; --random-salts draws them
    from os.urandom, as a deployment must
"""

import hashlib
import json
import os
import random
import sys
from itertools import product

SEED = 20260915
DELTA = 1          # GDPR Art 12(3) baseline response period, months
CEILING = 6        # EHDS Art 68(12), months after permit expiry
FLOOR_XBORDER = 120  # eHDSI baseline as reported; illustrative (Ch4 s4.3)
FLOOR_SPE = 12       # EHDS Art 73(1)(e), months
INF = float("inf")
RANDOM_SALTS = "--random-salts" in sys.argv
SUBJECT_FIELDS = ("patient_pseudonym",)   # m_subj(a); every other metadata field is m_acc(a)


# ---------------------------------------------------------------------
# Cryptographic primitives (hiding commitment + simulated key destruction)
```

```
# ---------------------------------------------------------------------

def make_salt(rid: int) -> bytes:
    """Per-record 16-byte salt. By default derived from the record id so that every run
    reproduces exactly; that derivation is for reproducibility only and gives no hiding
    against an adversary who knows it. --random-salts draws each salt from os.urandom,
    which is what a deployment must do (Appendix A, A.6). The derived salts repeat with
    period 256 in rid (make_salt(0) == make_salt(256)); the 200-record run stays inside one
    period."""
    if RANDOM_SALTS:
        return os.urandom(16)
    return bytes([(rid * 7 + i) % 256 for i in range(16)])


# ---------------------------------------------------------------------
# Append-only audit log: Merkle tree with RFC 6962 hashing
# leaf = H(0x00 || data), node = H(0x01 || left || right)
# ---------------------------------------------------------------------

def _h(b: bytes) -> bytes:
    return hashlib.sha256(b).digest()


class MerkleLog:
    """Append-only log of audit events. An auditor holding the current root can check that
    a given event is in the log, unaltered, with an inclusion proof of log2(n) hashes.

    Scope: the root is recomputed from the leaves held here, so this detects divergence
    between a record and its logged events. Detecting a rewrite of the log itself needs a
    root published or anchored outside the log, or consistency proofs between roots; those
    are specified in Chapter 6, Section 6.1, not implemented."""

    def __init__(self):
        self.leaves = []                        # leaf hashes

    def append(self, data: bytes) -> int:
        self.leaves.append(_h(b"\x00" + data))
        return len(self.leaves) - 1

    @staticmethod
    def _mth(leaves):
        if len(leaves) == 1:
            return leaves[0]
        k = 1 << ((len(leaves) - 1).bit_length() - 1)     # largest power of 2 < n
        return _h(b"\x01" + MerkleLog._mth(leaves[:k]) + MerkleLog._mth(leaves[k:]))

    def root(self) -> bytes:
        return self._mth(self.leaves) if self.leaves else _h(b"")

    def proof(self, m: int, leaves=None):
        leaves = self.leaves if leaves is None else leaves
        if len(leaves) == 1:
            return []
        k = 1 << ((len(leaves) - 1).bit_length() - 1)
        if m < k:
            return self.proof(m, leaves[:k]) + [("R", self._mth(leaves[k:]))]
        return self.proof(m - k, leaves[k:]) + [("L", self._mth(leaves[:k]))]

    @staticmethod
    def verify(data: bytes, proof, root: bytes) -> bool:
```

```
        node = _h(b"\x00" + data)
        for side, sib in proof:
            node = _h(b"\x01" + (sib + node if side == "L" else node + sib))
        return node == root


AUDIT_LOG = MerkleLog()


def _creation_entry(rec) -> bytes:
    """What the floor protects: accessor fields, commitment, creation month (not m_subj)."""
    m_acc = {k: v for k, v in rec.m.items() if k not in SUBJECT_FIELDS}
    return json.dumps({"event": "access", "rid": rec.rid, "t_a": rec.t_a,
                       "m_acc": m_acc, "c": rec.c, "c_subj": rec.c_subj},
                      sort_keys=True).encode()


def _entry(obj) -> bytes:
    return json.dumps(obj, sort_keys=True).encode()


def new_log():
    """Start a fresh audit log for a new population and make it the module's current log."""
    global AUDIT_LOG
    AUDIT_LOG = MerkleLog()
    return AUDIT_LOG


def log_creation(rec):
    if getattr(rec, "log_idx", None) is None:
        rec.log_idx = {"access": rec.log.append(_creation_entry(rec))}


def log_of(rec):
    """The log the record was bound to when it was created."""
    return rec.log


def integrity(rec):
    """(ok, reason): every logged event of the record verifies against the current root."""
    idx = getattr(rec, "log_idx", None)
    if not idx:
        return False, "record not in the audit log"
    if any(f in rec.m for f in SUBJECT_FIELDS):                # the link, while it is held
        link = _entry({f: rec.m.get(f) for f in SUBJECT_FIELDS})
        if rec.subj_salt is None or commit(link, rec.subj_salt) != rec.c_subj:
            return False, "patient link does not open its logged commitment (altered)"
    log = log_of(rec)
    root = log.root()
    checks = [("access", _creation_entry(rec))]
    if rec.iota is not None:
        checks.append(("invalidation", _entry(rec.iota)))
    if rec.iota_subj is not None:
        checks.append(("subject_link", _entry(rec.iota_subj)))
    for name, data in checks:
        if name not in idx:
            return False, f"{name} event not logged"
        if not MerkleLog.verify(data, log.proof(idx[name]), root):
            return False, f"{name} entry fails its inclusion proof (altered)"
    return True, ""
```

```
def commit(payload: bytes, salt: bytes) -> str:
    """Hiding, binding commitment. Salt is REQUIRED (Chapter 4, Section 4.9):
    an unsalted hash of a low-entropy clinical payload is guessable and would
    itself remain personal data."""
    return hashlib.sha256(salt + payload).hexdigest()


class Record:
    """One audit record and its lifecycle state."""

    def __init__(self, rid, t_a, floor, sigma, payload, t_r=INF, t_pi=INF, log=None):
        self.rid = rid
        self.log = log if log is not None else AUDIT_LOG   # bound at creation: the population's log
        self.t_a = t_a
        self.floor = floor
        self.sigma = sigma
        self.t_r = t_r
        self.t_pi = t_pi
        # metadata m(a) = m_acc(a) + m_subj(a); no clinical content (Ch4 s4.3).
        # Synthetic pseudonyms PSN-{rid % 100}: 100 distinct patients, so two records may share
        # one patient, as real audit logs do; no figure depends on pseudonym uniqueness.
        if sigma == "primary":                # cross-border: clinician, contact point
            self.m = {"rid": rid, "actor": f"HP-{rid % 37:03d}",
                      "ncp": ["NO", "PT", "CZ", "FI"][rid % 4],
                      "patient_pseudonym": f"PSN-{rid % 100:04d}",
                      "doc_category": "PatientSummary", "legal_basis": "Art9(2)(h)",
                      "outcome": "success"}
        else:                                 # SPE: researcher named in the permit
            self.m = {"rid": rid, "actor": f"R-{rid % 23:03d}",
                      "permit": f"DP-{rid % 17:03d}",
                      "patient_pseudonym": f"PSN-{rid % 100:04d}",
                      "doc_category": "SPE-AccessLog", "legal_basis": "DataPermit",
                      "outcome": "success"}
        self.salt = make_salt(rid)
        self.payload = payload                # stands for the ciphertext of p(a)
        self.c = commit(payload, self.salt)   # survives invalidation
        # salted commitment to the patient link, logged with the accessor fields (Ch4 s4.8)
        self.subj_salt = make_salt(rid + 100000)
        self.c_subj = commit(_entry({f: self.m[f] for f in SUBJECT_FIELDS}), self.subj_salt)
        self.k = f"KEY-{rid:06d}"             # destroyed at invalidation
        self.iota = None                      # invalidation entry
        self.iota_subj = None                 # subject-link removal entry (SPE, ceiling)
        self.log_idx = None

    # -- model quantities ------------------------------------------------
    def window(self):
        return range(self.t_a, self.t_a + self.floor + 1)

    def erasure_deadline(self):
        return self.t_r + DELTA if self.t_r < INF else INF

    def ceiling_deadline(self):
        if self.sigma != "secondary" or self.t_pi == INF:
            return INF
        return self.t_pi + CEILING

    def t_invalidation(self):
        return min(self.erasure_deadline(), self.ceiling_deadline())
```

```
    def subject_removal(self):
        """Month from which m_subj is gone: the ceiling, where C3 reaches the subject fields."""
        return self.ceiling_deadline()


# ---------------------------------------------------------------------
# Semantics I - plaintext verifiability:  V_I(a,t) = alpha(a,t)
# ---------------------------------------------------------------------

def check_semantics_I(rec):
    """C1 demands alpha=1 across the window; C2/C3 demand alpha=0 from their
    deadlines. Report, per conflicting constraint (C2, C3), the first month at which
    both are demanded at once; a violation is a (record, constraint) pair."""
    violations = []
    for deadline, constraint in ((rec.erasure_deadline(), "C2"),
                                 (rec.ceiling_deadline(), "C3")):
        if deadline == INF:
            continue
        for t in rec.window():
            if t >= deadline:
                violations.append({
                    "rid": rec.rid, "month": t, "constraint": constraint,
                    "detail": (f"C1 requires V=1 (=> alpha=1) at t={t} within "
                               f"[{rec.t_a},{rec.t_a + rec.floor}]; {constraint} "
                               f"requires alpha=0 from t={deadline}")})
                break   # first collision month is the witness
    return violations


# ---------------------------------------------------------------------
# Semantics II - accountability-preserving verifiability
# Trajectory from the constructive proof of Proposition 2.
# ---------------------------------------------------------------------

def apply_invalidation(rec):
    log_creation(rec)                     # the access event enters the log first
    t_I = rec.t_invalidation()
    if t_I < INF:
        # The earlier deadline names the ground; on a tie (4 records in the thesis run) the
        # data subject's request is recorded, since it is the act that triggered erasure.
        ground = ("GDPR Art 17(1)" if rec.erasure_deadline() <= rec.ceiling_deadline()
                  else "EHDS Art 68(12)")
        rec.k = None                      # simulated key destruction: reference removed (attested, not
     proven)
        rec.salt = None                   # salt destroyed with the key (Ch4 s4.8)
        rec.payload = None                # ciphertext deleted with the key (Ch4 s4.8, D-17)
        rec.iota = {"rid": rec.rid, "month": t_I, "ground": ground,
                    "authorised_by": "DPO", "key_id_commitment":   # key identifier digest, not a hiding
                         hashlib.sha256(f"KEY-{rec.rid:06d}".encode()).hexdigest()[:16]}  # commitment:
     toy keys are predictable
        rec.log_idx["invalidation"] = log_of(rec).append(_entry(rec.iota))
    t_S = rec.subject_removal()
    if t_S < INF and any(f in rec.m for f in SUBJECT_FIELDS):
        for f in SUBJECT_FIELDS:          # beta = 0 from the ceiling (Ch4 s4.7, steps 2 and 4)
            rec.m.pop(f, None)
        rec.subj_salt = None              # the link's salt goes with the link
        rec.iota_subj = {"rid": rec.rid, "month": t_S, "removed": list(SUBJECT_FIELDS),
                         "ground": "EHDS Art 68(12)", "authorised_by": "DPO"}
        rec.log_idx["subject_link"] = log_of(rec).append(_entry(rec.iota_subj))
```

```
    return rec


def alpha(rec, t):
    return 1 if t < rec.t_invalidation() else 0


def beta(rec, t):
    """Subject-link variable: 0 from the month the subject fields were removed."""
    return 0 if rec.iota_subj is not None and t >= rec.iota_subj["month"] else 1


def V_II(rec, t, integrity_result=None):
    """(i) m_acc intact and unmodified, checked against the audit log;
       (ii) commitment present and logged; (iii) every loss of accessibility,
       of the payload or of the subject link, is itself a logged entry."""
    ok, why = integrity_result if integrity_result is not None else integrity(rec)
    if not ok:
        return False, why
    if not rec.c:
        return False, "commitment missing"
    if alpha(rec, t) == 0 and t >= rec.t_a and rec.iota is None:
        return False, "payload inaccessible but no invalidation entry"
    if not any(f in rec.m for f in SUBJECT_FIELDS) and rec.iota_subj is None:
        return False, "subject fields removed without a logged entry"
    return True, ""


def check_semantics_II(rec):
    """C1, C2, C3 under accountability semantics. alpha is derived from the invalidation
    month, so C2 and C3 hold by construction once invalidation is applied; the part that
    can fail is C1, through the integrity check of every logged event (Chapter 5, Section 5.7)."""
    violations = []
    integ = integrity(rec)                                  # one proof check per record
    for t in rec.window():                                  # C1
        ok, why = V_II(rec, t, integ)
        if not ok:
            violations.append({"rid": rec.rid, "month": t,
                               "constraint": "C1", "detail": why})
            break
    d = rec.erasure_deadline()                              # C2
    if d < INF:
        horizon = int(min(rec.t_a + rec.floor, d + 24))
        for t in range(int(d), horizon + 1):
            if alpha(rec, t) != 0:
                violations.append({"rid": rec.rid, "month": t, "constraint": "C2",
                                   "detail": "payload still accessible after erasure deadline"})
                break
    d = rec.ceiling_deadline()                              # C3
    if d < INF:
        horizon = int(min(rec.t_a + rec.floor, d + 24))
        for t in range(int(d), horizon + 1):
            if alpha(rec, t) != 0:
                violations.append({"rid": rec.rid, "month": t, "constraint": "C3",
                                   "detail": "payload still accessible after deletion ceiling"})
                break
        for t in range(int(d), horizon + 1):                # C3 over the subject link
            if beta(rec, t) != 0:
                violations.append({"rid": rec.rid, "month": t, "constraint": "C3",
                                   "detail": "subject link still present after deletion ceiling"})
```

```
                break
    return violations


# ---------------------------------------------------------------------
# Independent cross-check: exhaustive search over alpha assignments.
# Confirms Semantics I infeasibility is a property of the constraints and
# not an artefact of how check_semantics_I is written.
# ---------------------------------------------------------------------

def brute_force_semantics_I(t_a, floor, t_r, t_pi, sigma, horizon):
    """Enumerate every alpha in {0,1}^horizon; return True if any satisfies
    C1 (under V_I = alpha), C2 and C3 simultaneously over months 0..horizon-1.

    Precondition: horizon > t_a + floor, so every month of the retention window
    is examined. A deadline at or beyond the horizon then falls after the window
    and cannot collide with C1, so the answer is exact for the whole timeline."""
    if horizon <= t_a + floor:
        raise ValueError(f"horizon {horizon} must exceed t_a + floor = {t_a + floor}")
    e_dl = t_r + DELTA if t_r < INF else INF
    c_dl = t_pi + CEILING if (sigma == "secondary" and t_pi < INF) else INF
    for assign in product([0, 1], repeat=horizon):
        ok = True
        for t in range(horizon):
            if t_a <= t <= t_a + floor and assign[t] != 1:
                ok = False; break                    # C1 under Semantics I
            if t >= e_dl and assign[t] != 0:
                ok = False; break                    # C2
            if t >= c_dl and assign[t] != 0:
                ok = False; break                    # C3
        if ok:
            return True
    return False


# ---------------------------------------------------------------------
# Record generation
# ---------------------------------------------------------------------

def generate(n_primary=100, n_secondary=100, seed=SEED):
    """A fresh population with a fresh audit log: one append-only log per run."""
    log = new_log()
    rng = random.Random(seed)
    records = []
    rid = 0
    # Class 1: cross-border audit records, floor 120 months
    for _ in range(n_primary):
        t_a = rng.randint(0, 11)
        t_r = t_a + rng.randint(1, 130) if rng.random() < 0.40 else INF
        payload = (f"<ITI-55 QBP name=N{rid:03d} birthTime=19{40 + rid % 60:02d} "
                   f"rid={rid}>").encode()       # demographic query (Ch4 s4.3)
        records.append(Record(rid, t_a, FLOOR_XBORDER, "primary", payload, t_r=t_r, log=log))
        rid += 1
    # Class 2: SPE access-log records, floor 12 months, ceiling applies
    for _ in range(n_secondary):
        t_a = rng.randint(0, 11)
        permit_len = rng.randint(1, 12)
        t_pi = t_a + permit_len
        t_r = t_a + rng.randint(1, 18) if rng.random() < 0.25 else INF
        payload = f"<SPE-activity query=cohort-extract rid={rid}>".encode()
```

```
        records.append(Record(rid, t_a, FLOOR_SPE, "secondary", payload,
                              t_r=t_r, t_pi=t_pi, log=log))
        rid += 1
    return records


# ---------------------------------------------------------------------
# Main
# ---------------------------------------------------------------------

def main():
    print("=" * 74)
    print("TRF FEASIBILITY CHECKER".center(74))
    print(f"seed={SEED}  delta={DELTA}  ceiling={CEILING}  "
          f"floors: cross-border={FLOOR_XBORDER}, SPE={FLOOR_SPE}".center(74))
    print("=" * 74)

    records = generate()
    prim = [r for r in records if r.sigma == "primary"]
    sec = [r for r in records if r.sigma == "secondary"]
    print(f"\nGenerated {len(records)} records "
          f"({len(prim)} cross-border, {len(sec)} SPE access-log)")

    # ---------------- Semantics I ----------------
    print("\n" + "-" * 74)
    print("SEMANTICS I  (plaintext verifiability:  V = alpha)   -> Proposition 1")
    print("-" * 74)
    v1 = {r.rid: check_semantics_I(r) for r in records}
    n_bad = sum(1 for k in v1 if v1[k])
    n_bad_p = sum(1 for r in prim if v1[r.rid])
    n_bad_s = sum(1 for r in sec if v1[r.rid])
    total_v = sum(len(x) for x in v1.values())
    print(f"records with >=1 violation : {n_bad}/{len(records)}")
    print(f"  cross-border (F=120)     : {n_bad_p}/{len(prim)}")
    print(f"  SPE access-log (F=12)    : {n_bad_s}/{len(sec)}")
    print(f"total constraint violations: {total_v}")

    # SPE records violating WITHOUT any erasure request -> Corollary 1.2
    no_req = [r for r in sec if r.t_r == INF and v1[r.rid]]
    print(f"\nCorollary 1.2 witnesses (SPE, NO erasure request, still infeasible):"
          f" {len(no_req)}")
    for r in no_req[:3]:
        d = v1[r.rid][0]
        print(f"  rid={r.rid}: t_a={r.t_a} permit expires t_pi={r.t_pi} "
              f"-> C3 from t={int(r.ceiling_deadline())}, "
              f"C1 to t={r.t_a + r.floor}  | collision at t={d['month']}")

    print("\nSample violation witnesses (cross-border):")
    shown = 0
    for r in prim:
        if v1[r.rid] and shown < 3:
            print(f"  {v1[r.rid][0]['detail']}")
            shown += 1

    # ---------------- Independent cross-check ----------------
    print("\n" + "-" * 74)
    print("INDEPENDENT CROSS-CHECK: exhaustive search over alpha assignments")
    print("-" * 74)
    cases = [
        ("SPE, no erasure request, permit 3mo", 0, 12, INF, 3, "secondary"),
```

```
    ("SPE, erasure at t=2",                0, 12, 2,   9, "secondary"),
    ("cross-border scaled (F=12), erasure at t=4", 0, 12, 4, INF, "primary"),
    ("control: no request, no expiry",     0, 12, INF, INF, "primary"),
]
cross_ok = True
for label, t_a, floor, t_r, t_pi, sigma in cases:
    feasible = brute_force_semantics_I(t_a, floor, t_r, t_pi, sigma, horizon=14)
    agrees = feasible == (check_semantics_I(Record(-1, t_a, floor, sigma, b"", t_r=t_r, t_pi=t_pi,
                                                   log=MerkleLog())) == [])
    cross_ok &= agrees
    print(f"  {label:<46} feasible={feasible}")

# ---------------- Semantics II ----------------
print("\n" + "-" * 74)
print("SEMANTICS II (accountability preservation)          -> Proposition 2")
print("-" * 74)
for r in records:
    apply_invalidation(r)
v2 = {r.rid: check_semantics_II(r) for r in records}
n_bad2 = sum(1 for k in v2 if v2[k])
total_v2 = sum(len(x) for x in v2.values())
n_inv = sum(1 for r in records if r.iota is not None)
print(f"records invalidated        : {n_inv}/{len(records)}")
print(f"  ground = GDPR Art 17(1)  : "
      f"{sum(1 for r in records if r.iota and 'Art 17' in r.iota['ground'])}")
print(f"  ground = EHDS Art 68(12) : "
      f"{sum(1 for r in records if r.iota and '68(12)' in r.iota['ground'])}")
print(f"records with >=1 violation : {n_bad2}/{len(records)}")
print(f"total constraint violations: {total_v2}")

# auditor view on a previously-violating record
demo = no_req[0] if no_req else sec[0]
print(f"\nAuditor view of rid={demo.rid} after invalidation:")
print(f"  accessor fields      : {integrity(demo)[0]}  actor={demo.m['actor']} "
      f"permit={demo.m.get('permit', '-')} outcome={demo.m['outcome']}")
print(f"  subject link         : "
      f"{'removed month ' + str(demo.iota_subj['month']) if demo.iota_subj else 'present'}")
print(f"  commitment c(a)      : {demo.c[:32]}...")
print(f"  payload key k(a)     : {demo.k}   <- destroyed")
print(f"  salt, ciphertext     : {demo.salt}, {demo.payload}   <- destroyed, deleted")
print(f"  invalidation iota(a) : month={demo.iota['month']} "
      f"ground={demo.iota['ground']}")
print(f"  payload readable?    : {bool(alpha(demo, demo.t_a + demo.floor))}")

# ---------------- Integrity of the audit log ----------------
print("\n" + "-" * 74)
print("AUDIT-LOG INTEGRITY (Merkle log, RFC 6962 hashing)     -> V_II condition (i)")
print("-" * 74)
n_ok = sum(1 for r in records if integrity(r)[0])
print(f"log entries                : {len(AUDIT_LOG.leaves)}")
print(f"log root                   : {AUDIT_LOG.root().hex()[:32]}...")
print(f"records verifying          : {n_ok}/{len(records)}")
saved = demo.m["actor"]
demo.m["actor"] = "R-999"                                  # tamper with one accessor field
ok_t, why_t = V_II(demo, demo.t_a)
demo.m["actor"] = saved
print(f"tamper test, rid={demo.rid} actor altered : V_II={ok_t}  ({why_t})")
saved_g = demo.iota["ground"]
demo.iota["ground"] = "none"                               # tamper with the invalidation entry
ok_g, why_g = V_II(demo, demo.t_a)
```

```
    demo.iota["ground"] = saved_g
    print(f"tamper test, rid={demo.rid} ground altered: V_II={ok_g}  ({why_g})")
    xb = next(r for r in prim if r.iota is not None)          # a cross-border record keeps its link
    saved_p = xb.m["patient_pseudonym"]
    xb.m["patient_pseudonym"] = "PSN-9999"                    # tamper with the patient link
    ok_p, why_p = V_II(xb, xb.t_a)
    xb.m["patient_pseudonym"] = saved_p
    print(f"tamper test, rid={xb.rid} link altered  : V_II={ok_p}  ({why_p})")
    print(f"after restoring all three  : V_II={V_II(demo, demo.t_a)[0] and V_II(xb, xb.t_a)[0]}")

    print("\n" + "=" * 74)
    print(f"RESULT  Semantics I : {total_v} violations across {n_bad} records  "
          f"-> {'INFEASIBLE' if total_v else 'FEASIBLE'}")
    print(f"RESULT  Semantics II: {total_v2} violations across {n_bad2} records  "
          f"-> {'INFEASIBLE' if total_v2 else 'FEASIBLE'}")
    print("=" * 74)
    # Failure if Proposition 2 fails, the cross-check disagrees with the checker, a record fails its
    # inclusion proof, or a tamper test goes undetected.
    detected = not (ok_t or ok_g or ok_p)
    return 0 if (total_v2 == 0 and cross_ok and n_ok == len(records) and detected) else 1


if __name__ == "__main__":
    _status = main()          # exit status is set at the end of the file, after the optional delta
     witness


# ---------------------------------------------------------------------------
# Extended response period witness (Chapter 5, Section 5.6)
# GDPR Art 12(3) permits extension of the one-month response period by a
# further two months. The propositions are stated for arbitrary finite delta;
# this runs the model at delta = 3 to witness that claim rather than assert it.
# ---------------------------------------------------------------------------

def delta_witness(delta_values=(1, 3)):
    """Re-run the population at each delta and report the figures."""
    global DELTA
    original, rows = DELTA, []
    for d in delta_values:
        DELTA = d
        recs = generate()
        v1 = {r.rid: check_semantics_I(r) for r in recs}
        sec = [r for r in recs if r.sigma == "secondary"]
        row = {"delta": d,
               "sem1_records": sum(1 for k in v1 if v1[k]),
               "sem1_total": sum(len(x) for x in v1.values()),
               "cor12": sum(1 for r in sec if r.t_r == INF and v1[r.rid])}
        for r in recs:
            apply_invalidation(r)
        v2 = {r.rid: check_semantics_II(r) for r in recs}
        row["sem2_records"] = sum(1 for k in v2 if v2[k])
        row["sem2_total"] = sum(len(x) for x in v2.values())
        row["invalidated"] = sum(1 for r in recs if r.iota is not None)
        rows.append(row)
    DELTA = original
    return rows


if __name__ == "__main__" and "--delta-witness" in __import__("sys").argv:
    print(f"{'delta':>6}{'SemI recs':>11}{'SemI viol':>11}{'Cor1.2':>9}"
```

```
          f"{'SemII recs':>12}{'SemII viol':>12}{'invalidated':>13}")
    for r in delta_witness():
        _status |= 1 if r["sem2_total"] else 0      # a Semantics II violation at any delta fails the run
        print(f"{r['delta']:>6}{r['sem1_records']:>11}{r['sem1_total']:>11}"
              f"{r['cor12']:>9}{r['sem2_records']:>12}{r['sem2_total']:>12}"
              f"{r['invalidated']:>13}")


if __name__ == "__main__":
    __import__("sys").exit(_status)
```

A.11 Source listing: `synthea_layer.py`

The realism layer, reproduced as executed.

```
"""
Synthea realism layer for the TRF feasibility checker
=====================================================
Chapter 3, Section 3.6 specifies two layers: the feasibility checker (the
load-bearing component) and a realism layer feeding it FHIR-structured
records generated by Synthea.

This module is the realism layer. It replaces the synthetic byte-string
payloads of trf_checker.generate() with FHIR R4 resources (synthetic) drawn from
Synthea-generated patient bundles, leaving every timing quantity
(t_a, t_r, t_pi, F, sigma, delta) untouched.

The purpose is to establish, by execution rather than assertion, that the
model's results are functions of timing and accessibility alone and do not
depend on payload provenance. If any reported figure changes, the model
reads something it should not.

Cohort: synthea -s 20260915 -cs 20260915 -p 100, FHIR R4 export.
Run:    python synthea_layer.py
"""

import glob
import json
import os

import trf_checker as trf

_HERE = os.path.dirname(os.path.abspath(__file__))
# Search order: the full regenerated cohort first, then the 8-bundle subset
# shipped in the repository. The first directory that contains bundles wins.
SYNTHEA_DIRS = [os.path.join(_HERE, "synthea_run", "output", "fhir"),
                os.path.join(_HERE, "data", "synthea_subset"),
                os.path.join(_HERE, "synthea_subset"),
               # the thesis repository keeps one copy of the subset, beside demo_app/ and code_artefacts/
                os.path.join(_HERE, os.pardir, "repro_package", "data", "synthea_subset")]


def _resolve_dir():
    for d in SYNTHEA_DIRS:
        if glob.glob(os.path.join(d, "*.json")):
            return d
    return SYNTHEA_DIRS[0]
```

```
SYNTHEA_DIR = _resolve_dir()
CLINICAL_TYPES = ("Condition", "Observation", "MedicationRequest",
                  "AllergyIntolerance", "Immunization", "Procedure")


def load_payloads(limit=400, seed=trf.SEED):
    """Extract clinically meaningful resources from Synthea bundles and
    serialise each as a payload. These stand in for the content of an
    exchanged patient summary or the subject of an SPE access."""
    files = sorted(glob.glob(os.path.join(_resolve_dir(), "*.json")))
    if not files:
        raise FileNotFoundError(
            "No Synthea bundles found. Looked in:\n  "
            + "\n  ".join(SYNTHEA_DIRS)
            + "\nRegenerate the full cohort with:\n"
              "  java -jar synthea.jar -s 20260915 -cs 20260915 -p 100")
    payloads, meta = [], []
    for path in files:
        with open(path) as fh:
            bundle = json.load(fh)
        for entry in bundle.get("entry", []):
            res = entry.get("resource", {})
            if res.get("resourceType") in CLINICAL_TYPES:
                payloads.append(json.dumps(res, sort_keys=True).encode())
                meta.append((os.path.basename(path).split("_")[0],
                             res["resourceType"]))
                break          # one resource per bundle keeps the mapping 1:1
        if len(payloads) >= limit:
            break
    return payloads, meta, len(files)


def generate_with_synthea(n_primary=100, n_secondary=100, seed=trf.SEED):
    """Identical to trf_checker.generate() in every timing respect; only the
    payload bytes differ."""
    records = trf.generate(n_primary, n_secondary, seed)
    payloads, meta, n_files = load_payloads()
    for rec in records:
        p = payloads[rec.rid % len(payloads)]
        rec.payload = p
        rec.c = trf.commit(p, rec.salt)     # recompute commitment over real payload
        rec.m["doc_category"] = (
            f"PatientSummary/{meta[rec.rid % len(meta)][1]}"
            if rec.sigma == "primary"
            else f"SPE-AccessLog/{meta[rec.rid % len(meta)][1]}")
    return records, n_files, len(payloads)


def main():
    print("=" * 74)
    print("SYNTHEA REALISM LAYER — comparison against constructed payloads".center(74))
    print("=" * 74)

    base = trf.generate()
    real, n_files, n_payloads = generate_with_synthea()
    print(f"\nSynthea bundles read : {n_files}")
    print(f"clinical payloads    : {n_payloads}")
    print(f"records              : {len(real)}")
```

```
    print(f"payload bytes (mean) : constructed={sum(len(r.payload) for r in base)//len(base)}"
          f"  synthea={sum(len(r.payload) for r in real)//len(real)}")

    results = {}
    for label, recs in (("constructed", base), ("synthea", real)):
        v1 = {r.rid: trf.check_semantics_I(r) for r in recs}
        n_bad = sum(1 for k in v1 if v1[k])
        tot = sum(len(x) for x in v1.values())
        sec = [r for r in recs if r.sigma == "secondary"]
        cor12 = sum(1 for r in sec if r.t_r == trf.INF and v1[r.rid])
        for r in recs:
            trf.apply_invalidation(r)
        v2 = {r.rid: trf.check_semantics_II(r) for r in recs}
        n_bad2 = sum(1 for k in v2 if v2[k])
        tot2 = sum(len(x) for x in v2.values())
        n_inv = sum(1 for r in recs if r.iota is not None)
        results[label] = (n_bad, tot, cor12, n_inv, n_bad2, tot2)

    print("\n" + "-" * 74)
    hdr = f"{'measure':<42}{'constructed':>15}{'synthea':>15}"
    print(hdr); print("-" * 74)
    names = ["Semantics I: records with violation",
             "Semantics I: total violations",
             "Corollary 1.2 witnesses (no request)",
             "Records invalidated",
             "Semantics II: records with violation",
             "Semantics II: total violations"]
    identical = True
    for i, nm in enumerate(names):
        a, b = results["constructed"][i], results["synthea"][i]
        flag = "" if a == b else "   <-- DIFFERS"
        if a != b:
            identical = False
        print(f"{nm:<42}{a:>15}{b:>15}{flag}")
    print("-" * 74)

    # commitments must differ - different payloads, same salts
    diff_c = sum(1 for x, y in zip(base, real) if x.c != y.c)
    print(f"\ncommitments differing between the two runs: {diff_c}/{len(base)}"
          f"   (expected {len(base)} — same salt, different payload)")

    print("\n" + "=" * 74)
    if identical and diff_c == len(base):
        print("RESULT: every reported figure is IDENTICAL under Synthea FHIR payloads,".center(74))
        print("while every commitment differs. The model reads timing, not content.".center(74))
    else:
        print("RESULT: DIVERGENCE DETECTED — investigate before reporting.".center(74))
    print("=" * 74)
    return 0 if (identical and diff_c == len(base)) else 1


if __name__ == "__main__":
    import sys
    sys.exit(main())
```

A.12 Source listing: `norwegian_layer.py`

The Norwegian context module, reproduced as executed. It imports `trf_checker.py` without modifying it and changes nothing the thesis reports: it varies only the retention floor, the pathway, and the arrival of erasure requests and permit expiries. Line count: 136.

```
"""
Norwegian context layer for the TRF feasibility checker
=======================================================
PLUG-AND-PLAY. This module imports trf_checker unmodified and adds record
classes shaped by the Norwegian implementation context. It changes nothing the
thesis depends on: `python3 trf_checker.py` still reproduces 95/90/39/0/138.

What it varies is what the model actually reads: the retention floor F(a), the
pathway, and the arrival of erasure requests and permit expiries. It does NOT
claim that Norwegian payloads change any result — Chapter 5 shows the results
are invariant to payload content, and that invariance is why the illustrative
payloads below are safe to use.

Classes
  NO-XB      Cross-border audit record at the Norwegian NCPeH. Inbound patient
             summary from PT/CZ/FI to a legevakt (Bodo, Stjordal).
             F = 120 months (eHDSI deployment baseline).
  NO-SPE     Secure Processing Environment access log, Helsedataservice permit,
             processing in a NORTRE node. F = 12 (Art 73(1)(e)),
             ceiling 6 months after permit expiry (Art 68(12)).
  NO-JOURNAL Audit record tied to a patient record held under Norwegian law.
             Floor is INDEFINITE: pasientjournalloven s 25 and journalforskriften
             s 14 require retention until, given the character of the health care,
             the record is no longer assumed to be needed; archive law may then
             preserve it. There is no number in the primary sources, so none is
             invented here. For computation the indefinite floor is truncated at
             HORIZON_INDEFINITE months and labelled as a truncation.

Run:  python3 norwegian_layer.py
"""

import random
import trf_checker as trf

HORIZON_INDEFINITE = 600          # 50 years; a computation bound, NOT a legal period
SEED = trf.SEED

NCPS = ["PT", "CZ", "FI"]
SITES = ["Bodo legevakt", "Stjordal legevakt"]
NODES = ["TSD (UiO)", "SAFE (UiB)", "HUNT Cloud (NTNU)", "controller-provided server"]


def _xb_payload(rid, rng):
    """Stands for the ITI-55 QueryByParameter segment an ATNA record carries:
    the demographics typed into patient discovery. Constructed, not real."""
    return (f"<ITI-55 QueryByParameter base64> name=SYN-{rid:04d} "
            f"birthTime=19{rng.randint(40,99)}{rng.randint(10,12)}{rng.randint(10,28)} "
            f"gender={rng.choice('MF')} addr=NO-{rng.randint(1000,9999)}").encode()


def _spe_payload(rid, rng):
    return (f"<SPE activity log> query=SELECT diagnosis,birthyear FROM permit-"
            f"{rng.randint(2026,2031)}-{rid:04d} rows={rng.randint(50,5000)}").encode()
```

```
def build(n_xb=60, n_spe=60, n_journal=40, seed=SEED):
    rng = random.Random(seed)
    log = trf.new_log()                  # this population's own audit log
    recs, rid = [], 0
    for _ in range(n_xb):                                  # NO-XB
        t_a = rng.randint(0, 11)
        t_r = t_a + rng.randint(1, 130) if rng.random() < 0.40 else trf.INF
        r = trf.Record(rid, t_a, trf.FLOOR_XBORDER, "primary", _xb_payload(rid, rng), t_r=t_r, log=log)
        r.m.update({"klasse": "NO-XB", "site": rng.choice(SITES),
                    "ncp": rng.choice(NCPS), "doc_category": "PatientSummary (inbound)",
                    "legal_basis": "Art9(2)(h)"})
        recs.append(r); rid += 1
    for _ in range(n_spe):                                 # NO-SPE
        t_a = rng.randint(0, 11)
        t_pi = t_a + rng.randint(1, 12)
        t_r = t_a + rng.randint(1, 18) if rng.random() < 0.25 else trf.INF
        r = trf.Record(rid, t_a, trf.FLOOR_SPE, "secondary", _spe_payload(rid, rng),
                       t_r=t_r, t_pi=t_pi, log=log)
        r.m.update({"klasse": "NO-SPE", "node": rng.choice(NODES),
                    "doc_category": "SPE-ActivityLog", "legal_basis": "DataPermit (Helsedataservice)"})
        recs.append(r); rid += 1
    for _ in range(n_journal):                             # NO-JOURNAL
        t_a = rng.randint(0, 11)
        t_r = t_a + rng.randint(1, 240) if rng.random() < 0.40 else trf.INF
       r = trf.Record(rid, t_a, HORIZON_INDEFINITE, "primary", _xb_payload(rid, rng), t_r=t_r, log=log)
        r.m.update({"klasse": "NO-JOURNAL", "doc_category": "JournalAccess",
                    "legal_basis": "pasientjournalloven s 25 (purpose-based, indefinite)"})
        recs.append(r); rid += 1
    return recs


def run(recs, label="NORWEGIAN LAYER"):
    klasser = sorted({r.m["klasse"] for r in recs})
    v1 = {r.rid: trf.check_semantics_I(r) for r in recs}
    for r in recs:
        trf.apply_invalidation(r)
    v2 = {r.rid: trf.check_semantics_II(r) for r in recs}
    print("=" * 74); print(label.center(74)); print("=" * 74)
    print(f"\n{'class':<12}{'n':>5}{'SemI recs':>11}{'SemI viol':>11}"
          f"{'invalidated':>13}{'SemII viol':>12}")
    for k in klasser:
        sub = [r for r in recs if r.m["klasse"] == k]
        print(f"{k:<12}{len(sub):>5}"
              f"{sum(1 for r in sub if v1[r.rid]):>11}"
              f"{sum(len(v1[r.rid]) for r in sub):>11}"
              f"{sum(1 for r in sub if r.iota):>13}"
              f"{sum(len(v2[r.rid]) for r in sub):>12}")
    print(f"\n{'TOTAL':<12}{len(recs):>5}"
          f"{sum(1 for r in recs if v1[r.rid]):>11}"
          f"{sum(len(x) for x in v1.values()):>11}"
          f"{sum(1 for r in recs if r.iota):>13}"
          f"{sum(len(x) for x in v2.values()):>12}")
    return v1, v2


def walkthrough(recs, v1):
    """One record per class, shown end to end: which obligation binds, where it
    collides, and what an auditor is left with after invalidation."""
```

```
    print("\n" + "-" * 74); print("CASE WALKTHROUGHS"); print("-" * 74)
    for k in sorted({r.m["klasse"] for r in recs}):
        cand = [r for r in recs if r.m["klasse"] == k and v1[r.rid]]
        if not cand:
            print(f"\n{k}: no infeasible record under Semantics I in this draw."); continue
        r = cand[0]
        print(f"\n{k}  rid={r.rid}  ({r.m.get('site') or r.m.get('node') or r.m['legal_basis']})")
        print(f"  floor    : t={r.t_a} .. {r.t_a + r.floor}"
              + ("   [indefinite, truncated]" if k == "NO-JOURNAL" else ""))
        print(f"  erasure  : {'none' if r.t_r == trf.INF else 't_r=' + str(r.t_r) + ' -> deadline ' +
             str(int(r.erasure_deadline()))}")
        print(f"  ceiling  : {'n/a' if r.ceiling_deadline() == trf.INF else 't_pi=' + str(r.t_pi) + ' ->
             ' + str(int(r.ceiling_deadline()))}")
        print(f"  collision: {v1[r.rid][0]['constraint']} at t={v1[r.rid][0]['month']}")
        print(f"  after invalidation -> log integrity={trf.integrity(r)[0]}, commitment={r.c[:16]}..., "
              f"key={r.k}, salt={r.salt}, ground={r.iota['ground'] if r.iota else None}")


if __name__ == "__main__":
    recs = build()
    v1, _ = run(recs)
    walkthrough(recs, v1)
    print("\nNote: figures above are illustrative of the Norwegian setting, not")
    print("empirical. The canonical result of the thesis is unchanged and is")
    print("reproduced by running trf_checker.py on its own.")
```

A.13 Source listing: `cross_sector_check.py`

The cross-sector instance discussed in Chapter 6, Section 6.10. It takes the floor and ceiling of politiregisterloven § 17 and runs them through the same unmodified model. Line count: 113.

```
"""
Cross-sector instance: Norwegian police register logs
=====================================================
PLUG-AND-PLAY. Imports trf_checker unmodified.

Why this exists. Chapter 6 s 6.9 and Chapter 7 s 7.5 say the structure the TRF
Model captures — a retention floor, a subject-triggered erasure right, and a
deletion ceiling — is probably not specific to health. Norwegian law supplies a
genuine instance outside health (Chapter 6, Section 6.10). Illustrative: the
records reuse the health model's invalidation grounds and field names, and C3 here
tests payload and patient link only, not the whole log entry the s 17 limit reaches.

  Politiregisterloven (LOV-2010-05-28-16) s 17, kravet til sporbarhet:
    information about use of the system shall be registered and stored for at
    least 1 year and deleted at the latest after 3 years.
  Politiregisterforskriften (FOR-2013-09-20-1097) ch. 40 mirrors this:
    deleted at the earliest after 1 year and at the latest after 3 years.
  Politiregisterloven s 50-51 give the registered person rights to correction,
    blocking and deletion of information no longer necessary for the purpose.

That is a floor of 12 months and a ceiling of 36 months on the SAME log, plus a
subject-triggered right: the tri-lateral structure, in another sector, in
national law.

THE RESULT IS NOT THE ONE EXPECTED, AND IT IS THE MORE USEFUL ONE. Running the
model on this instance produces NO structural collision at all: the floor ends
```

```
at t_a + 12 and the ceiling bites at t_a + 36, so the provision defines a
bounded retention window rather than a contradiction. The Norwegian legislator
ordered the two limbs. Collisions appear only where an erasure request lands
inside the window.

That isolates what is defective about the EHDS pair. There the ceiling is
anchored to an EXTERNAL event, the expiry of the data permit, which can fall
before the floor on a log written late in the permit. A floor and a ceiling on
the same record are compatible when the instrument orders them from the same
origin, and collide when one is anchored elsewhere. The contribution of the
thesis is therefore not that floors and ceilings conflict in general; it is that
they conflict when their origins differ, which is the EHDS case.

Two further differences from the EHDS case are stated rather than hidden:
  1. The ceiling here runs from the log's own creation, not from the expiry of a
     permit. It is modelled by setting t_pi so that the ceiling lands at
     t_a + 36 (the checker computes ceiling = t_pi + 6).
  2. The ceiling attaches to the whole record, not only to a payload inside it.
     Under Semantics II the metadata cannot survive it, so the terminal
     transition of Chapter 4 s 4.8 is what discharges the ceiling here, at
     t_a + 36 rather than at floor expiry. This module reports the collision;
     it does not claim the mechanism transfers unchanged.

Run:  python3 cross_sector_check.py
"""

import random
import trf_checker as trf

FLOOR_POLITI = 12      # politiregisterloven s 17: at least 1 year
CEILING_POLITI = 36    # politiregisterloven s 17: deleted at the latest after 3 years


def build(n=60, seed=trf.SEED):
    rng = random.Random(seed)
    log = trf.new_log()                  # this population's own audit log
    recs = []
    for rid in range(900, 900 + n):
        t_a = rng.randint(0, 11)
        # ceiling lands at t_a + 36; checker computes t_pi + 6
        t_pi = t_a + CEILING_POLITI - trf.CEILING
        t_r = t_a + rng.randint(1, 40) if rng.random() < 0.30 else trf.INF
        payload = f"<politiloggpost> bruker=POL-{rid % 97:03d} oppslag=register".encode()
        r = trf.Record(rid, t_a, FLOOR_POLITI, "secondary", payload, t_r=t_r, t_pi=t_pi, log=log)
        r.m.update({"klasse": "POLITI-LOG", "doc_category": "SystemUseLog",
                    "legal_basis": "politiregisterloven s 17"})
        recs.append(r)
    return recs


def main():
    recs = build()
    v1 = {r.rid: trf.check_semantics_I(r) for r in recs}
    n_bad = sum(1 for k in v1 if v1[k])
    structural = sum(1 for r in recs if r.t_r == trf.INF and v1[r.rid])
    for r in recs:
        trf.apply_invalidation(r)
    v2 = {r.rid: trf.check_semantics_II(r) for r in recs}
    print("=" * 74)
    print("CROSS-SECTOR INSTANCE: politiregisterloven s 17 (floor 12, ceiling 36)".center(74))
```

```
    print("=" * 74)
    print(f"\nrecords                              : {len(recs)}")
    print(f"Semantics I, records with violation  : {n_bad}")
    print(f"  of which with NO erasure request   : {structural}  <- floor vs ceiling alone")
    print(f"Semantics II, total violations       : {sum(len(x) for x in v2.values())}")
    print(f"records invalidated                  : {sum(1 for r in recs if r.iota)}")
    if structural == 0:
        print("\nNo structural collision: s 17 orders its two limbs from one origin")
        print("(floor at t_a + 12, ceiling at t_a + 36), so the provision defines a")
        print("bounded retention window rather than a contradiction. Every collision")
        print("found is erasure-driven.")
    cand = [r for r in recs if v1[r.rid]]
    if cand:
        r = cand[0]; d = v1[r.rid][0]
        print(f"\nwitness rid={r.rid}: log written t={r.t_a}; floor to t={r.t_a + r.floor}; "
              f"ceiling at t={int(r.ceiling_deadline())}; erasure deadline "
              f"{int(r.erasure_deadline())}; collision {d['constraint']} at t={d['month']}")
    print("\nThe floor parameter F(a) took a third value with no change to the model.")
    print("The finding: floors and ceilings coexist when one instrument fixes both from")
    print("the same origin, and collide when the ceiling is anchored to an external")
    print("event, as Art 68(12) anchors it to permit expiry. Scope: a structural")
    print("parallel. Whether the mechanism transfers to a record-level ceiling is a")
    print("design question this module does not answer.")


if __name__ == "__main__":
    main()
```

A.14 The demonstration viewer: `app.py` and `ui.py`

Not reproduced here, because the viewer is never a source of results: every figure it displays comes from executing one of the modules listed in this appendix, unmodified. `app.py` (1124 lines) holds the pages and the self-checks; `ui.py` (217 lines) holds presentation: the theme and navigation, the record life strip, whose Semantics II row it computes from V^{II}, and the embedding of the two Archify diagrams. The Thesis run page asserts the reported figures and shows a failure notice, with the expected and the computed values, beside the results if the run disagrees with Chapter 5. Both files are in the repository (https://github.com/Astheno-sphere/TRF-thesis, `demo_app/`).

A.15 Source listing: `crypto_envelope.py`

The optional envelope-encryption module. Each record's payload is encrypted under its own AES-256-GCM data key; the data keys are wrapped under a key-encrypting key held in a custody object standing in for a hardware security module; at each record's invalidation month the wrapped key is destroyed; every record is then decrypted again. It is the only module with a dependency outside the standard library. Line count: 122.

```
"""
Envelope encryption with real AES-256-GCM (optional module)
============================================================
The feasibility checker (trf_checker.py) models key destruction as removing a reference and
```

```
uses the standard library only. This module shows the same lifecycle with real cryptography,
so that "rendered unrecoverable" (TEHDAS2 D7.4, OPR-6) is exercised in code rather than only
asserted. Destruction itself is attested, not proven: deleting a key object in Python does not
show that no copy exists elsewhere.

  - each record's payload is encrypted under its own random 256-bit data key (AES-256-GCM,
    record id as associated data);
  - each data key is wrapped under a key-encrypting key held in a custody object standing in
    for a hardware security module (Chapter 4, Section 4.8, key hierarchy);
  - at the record's invalidation month the wrapped data key is destroyed in custody;
  - every record is then decrypted again: invalidated records must fail, the rest must succeed.

It reads its population and invalidation months from trf_checker unchanged and reports no
thesis figure. Destruction here is still destruction in program memory: the module shows that
the ciphertext is unreadable without the key, not that a key was erased from hardware
(Chapter 6, Section 6.3).

Run:  pip install cryptography   then   python3 crypto_envelope.py
Keys are random on every run; the printed counts are deterministic.
"""

import os

from cryptography.exceptions import InvalidTag
from cryptography.hazmat.primitives.ciphers.aead import AESGCM

import trf_checker as trf


class Custody:
    """Stands in for an HSM: holds the key-encrypting key and the wrapped data keys."""

    def __init__(self):
        self._kek = AESGCM(AESGCM.generate_key(bit_length=256))
        self._wrapped = {}                                  # rid -> (nonce, wrapped data key)

    def new_data_key(self, rid):
        dek = AESGCM.generate_key(bit_length=256)
        nonce = os.urandom(12)
        self._wrapped[rid] = (nonce, self._kek.encrypt(nonce, dek, f"dek:{rid}".encode()))
        return dek

    def data_key(self, rid):
        if rid not in self._wrapped:
            raise KeyError(f"data key for record {rid} destroyed")
        nonce, wrapped = self._wrapped[rid]
        return self._kek.decrypt(nonce, wrapped, f"dek:{rid}".encode())

    def destroy(self, rid):
        self._wrapped.pop(rid, None)


def encrypt(custody, rid, payload):
    dek = custody.new_data_key(rid)
    nonce = os.urandom(12)
    ct = AESGCM(dek).encrypt(nonce, payload, f"rec:{rid}".encode())
    del dek                                                 # unbinds the plaintext key; Python gives no
        guarantee it is erased from memory
    return nonce, ct
```

```
def decrypt(custody, rid, nonce, ct):
    return AESGCM(custody.data_key(rid)).decrypt(nonce, ct, f"rec:{rid}".encode())


def main():
    print("=" * 74)
    print("ENVELOPE ENCRYPTION (AES-256-GCM, wrapped data keys)".center(74))
    print("=" * 74)
    records = trf.generate()
    custody = Custody()
    store = {r.rid: encrypt(custody, r.rid, r.payload) for r in records}
    ok_before = sum(1 for r in records if decrypt(custody, r.rid, *store[r.rid]) == r.payload)
    print(f"records encrypted                    : {len(records)}")
    print(f"decrypt and match before invalidation : {ok_before}/{len(records)}")

    invalidated = [r for r in records if r.t_invalidation() < trf.INF]
    for r in invalidated:
        custody.destroy(r.rid)                          # key destroyed at t_I (Ch4 s4.7 step 2)
    print(f"data keys destroyed (t_I finite)     : {len(invalidated)}")

    readable, refused = 0, 0
    for r in records:
        try:
            decrypt(custody, r.rid, *store[r.rid])
            readable += 1
        except (KeyError, InvalidTag):    # no wrapped key in custody, or a ciphertext that fails
             authentication
            refused += 1
    print(f"decryptable after invalidation       : {readable}  (expected {len(records) -
         len(invalidated)})")
    print(f"refused, key destroyed               : {refused}  (expected {len(invalidated)})")

    # The ciphertext of an invalidated record does not open under any surviving key.
    victim = invalidated[0]
    survivors = [r for r in records if r.t_invalidation() == trf.INF]
    opened = 0
    for s in survivors:
        try:
            AESGCM(custody.data_key(s.rid)).decrypt(store[victim.rid][0], store[victim.rid][1],
                                                    f"rec:{victim.rid}".encode())
            opened += 1
        except InvalidTag:
            pass
    print(f"rid={victim.rid} ciphertext tried under {len(survivors)} surviving keys : opened {opened}")

    for r in invalidated:                               # then the ciphertext is deleted (D-17)
        del store[r.rid]
    print(f"ciphertexts kept after deletion      : {len(store)}")

    ok = (ok_before == len(records) and refused == len(invalidated)
          and readable == len(records) - len(invalidated) and opened == 0)
    print("=" * 74)
    print(f"RESULT: {'no invalidated record decrypts through custody; every other record reads' if ok
         else 'MISMATCH'}")
    print("=" * 74)
    return 0 if ok else 1


if __name__ == "__main__":
```

```
    import sys
    sys.exit(main())
```

A.16 Console output of the reported run

Verbatim output of `python3 trf_checker.py` under seed 20260915. Every figure in Chapter 5, Tables 5.3, 5.4 and 5.6 appears here, with the δ = 1 row of Table 5.5; its δ = 3 row is in A.18.

```
================================================================================
                        TRF FEASIBILITY CHECKER
   seed=20260915  delta=1  ceiling=6  floors: cross-border=120, SPE=12
================================================================================

Generated 200 records (100 cross-border, 100 SPE access-log)

--------------------------------------------------------------------------------
SEMANTICS I  (plaintext verifiability:  V = alpha)   -> Proposition 1
--------------------------------------------------------------------------------
records with >=1 violation : 90/200
  cross-border (F=120)     : 37/100
  SPE access-log (F=12)    : 53/100
total constraint violations: 95

Corollary 1.2 witnesses (SPE, NO erasure request, still infeasible): 39
  rid=100: t_a=7 permit expires t_pi=10 -> C3 from t=16, C1 to t=19  | collision at t=16
  rid=103: t_a=7 permit expires t_pi=10 -> C3 from t=16, C1 to t=19  | collision at t=16
  rid=104: t_a=3 permit expires t_pi=4 -> C3 from t=10, C1 to t=15  | collision at t=10

Sample violation witnesses (cross-border):
  C1 requires V=1 (=> alpha=1) at t=116 within [11,131]; C2 requires alpha=0 from t=116
  C1 requires V=1 (=> alpha=1) at t=120 within [4,124]; C2 requires alpha=0 from t=120
  C1 requires V=1 (=> alpha=1) at t=41 within [0,120]; C2 requires alpha=0 from t=41

--------------------------------------------------------------------------------
INDEPENDENT CROSS-CHECK: exhaustive search over alpha assignments
--------------------------------------------------------------------------------
  SPE, no erasure request, permit 3mo            feasible=False
  SPE, erasure at t=2                            feasible=False
  cross-border scaled (F=12), erasure at t=4     feasible=False
  control: no request, no expiry                 feasible=True

--------------------------------------------------------------------------------
SEMANTICS II (accountability preservation)          -> Proposition 2
--------------------------------------------------------------------------------
records invalidated        : 138/200
  ground = GDPR Art 17(1)  : 52
  ground = EHDS Art 68(12) : 86
records with >=1 violation : 0/200
total constraint violations: 0

Auditor view of rid=100 after invalidation:
  accessor fields      : True  actor=R-008 permit=DP-015 outcome=success
  subject link         : removed month 16
  commitment c(a)      : 678ade47c1e6dc03296175e056fd8116...
  payload key k(a)     : None   <- destroyed
  salt, ciphertext     : None, None   <- destroyed, deleted
  invalidation iota(a) : month=16 ground=EHDS Art 68(12)
```

```
  payload readable?    : False

------------------------------------------------------------------------
AUDIT-LOG INTEGRITY (Merkle log, RFC 6962 hashing)     -> V_II condition (i)
------------------------------------------------------------------------
log entries                : 438
log root                   : a91c07936a4eb9752b58c6483ca93d7d...
records verifying          : 200/200
tamper test, rid=100 actor altered : V_II=False  (access entry fails its inclusion proof (altered))
tamper test, rid=100 ground altered: V_II=False  (invalidation entry fails its inclusion proof
     (altered))
tamper test, rid=3 link altered  : V_II=False  (patient link does not open its logged commitment
     (altered))
after restoring all three  : V_II=True

========================================================================
RESULT  Semantics I : 95 violations across 90 records  -> INFEASIBLE
RESULT  Semantics II: 0 violations across 0 records  -> FEASIBLE
========================================================================
```

A.17 Console output of the payload-provenance comparison, full cohort

Produced by command 4 against the 98-bundle cohort regenerated on 6 October 2026 with the pinned jar (commands 2 and 3), with the code of that date. The code review later reworded its result line from “real FHIR payloads” to “Synthea FHIR payloads” (`CODE_REVIEW.md`, Section 4); the full cohort is not committed, so this record was not re-run, and no figure in it depends on that line. It is the source of Chapter 5, Table 5.7, at a mean payload of 1,002 bytes; the September cohort it replaces gave the same six measures at 1,006 bytes. Reproducing it requires regenerating the cohort with command 3, because the full cohort is about 315 MB and is not committed.

```
========================================================================
     SYNTHEA REALISM LAYER — comparison against constructed payloads
========================================================================

Synthea bundles read : 98
clinical payloads    : 98
records              : 200
payload bytes (mean) : constructed=43  synthea=1002

------------------------------------------------------------------------
measure                                      constructed        synthea
------------------------------------------------------------------------
Semantics I: records with violation                   90             90
Semantics I: total violations                         95             95
Corollary 1.2 witnesses (no request)                  39             39
Records invalidated                                  138            138
Semantics II: records with violation                   0              0
Semantics II: total violations                         0              0
------------------------------------------------------------------------

commitments differing between the two runs: 200/200   (expected 200 — same salt, different payload)
```

```
======================================================================
   RESULT: every reported figure is IDENTICAL under real FHIR payloads,
   while every commitment differs. The model reads timing, not content.
======================================================================
```

A.18 Console output of the erasure-response-period witness

Produced by command 5. Reproduces Table 5.5: the infeasibility survives the extension Article 12(3) GDPR permits.

```
======================================================================
                        TRF FEASIBILITY CHECKER
   seed=20260915  delta=1  ceiling=6  floors: cross-border=120, SPE=12
======================================================================

Generated 200 records (100 cross-border, 100 SPE access-log)

----------------------------------------------------------------------
SEMANTICS I  (plaintext verifiability:  V = alpha)   -> Proposition 1
----------------------------------------------------------------------
records with >=1 violation : 90/200
  cross-border (F=120)     : 37/100
  SPE access-log (F=12)    : 53/100
total constraint violations: 95

Corollary 1.2 witnesses (SPE, NO erasure request, still infeasible): 39
  rid=100: t_a=7 permit expires t_pi=10 -> C3 from t=16, C1 to t=19  | collision at t=16
  rid=103: t_a=7 permit expires t_pi=10 -> C3 from t=16, C1 to t=19  | collision at t=16
  rid=104: t_a=3 permit expires t_pi=4 -> C3 from t=10, C1 to t=15  | collision at t=10

Sample violation witnesses (cross-border):
  C1 requires V=1 (=> alpha=1) at t=116 within [11,131]; C2 requires alpha=0 from t=116
  C1 requires V=1 (=> alpha=1) at t=120 within [4,124]; C2 requires alpha=0 from t=120
  C1 requires V=1 (=> alpha=1) at t=41 within [0,120]; C2 requires alpha=0 from t=41

----------------------------------------------------------------------
INDEPENDENT CROSS-CHECK: exhaustive search over alpha assignments
----------------------------------------------------------------------
  SPE, no erasure request, permit 3mo            feasible=False
  SPE, erasure at t=2                            feasible=False
  cross-border scaled (F=12), erasure at t=4     feasible=False
  control: no request, no expiry                 feasible=True

----------------------------------------------------------------------
SEMANTICS II (accountability preservation)          -> Proposition 2
----------------------------------------------------------------------
records invalidated        : 138/200
  ground = GDPR Art 17(1)  : 52
  ground = EHDS Art 68(12) : 86
records with >=1 violation : 0/200
total constraint violations: 0

Auditor view of rid=100 after invalidation:
  accessor fields      : True  actor=R-008 permit=DP-015 outcome=success
  subject link         : removed month 16
  commitment c(a)      : 678ade47c1e6dc03296175e056fd8116...
  payload key k(a)     : None   <- destroyed
```

```
  salt, ciphertext     : None, None   <- destroyed, deleted
  invalidation iota(a) : month=16 ground=EHDS Art 68(12)
  payload readable?    : False

--------------------------------------------------------------------------
AUDIT-LOG INTEGRITY (Merkle log, RFC 6962 hashing)     -> V_II condition (i)
--------------------------------------------------------------------------
log entries                : 438
log root                   : a91c07936a4eb9752b58c6483ca93d7d...
records verifying          : 200/200
tamper test, rid=100 actor altered : V_II=False  (access entry fails its inclusion proof (altered))
tamper test, rid=100 ground altered: V_II=False  (invalidation entry fails its inclusion proof
    (altered))
tamper test, rid=3 link altered  : V_II=False  (patient link does not open its logged commitment
    (altered))
after restoring all three  : V_II=True

==========================================================================
RESULT  Semantics I : 95 violations across 90 records  -> INFEASIBLE
RESULT  Semantics II: 0 violations across 0 records  -> FEASIBLE
==========================================================================
 delta  SemI recs  SemI viol   Cor1.2  SemII recs  SemII viol  invalidated
     1         90         95       39           0           0          138
     3         89         94       39           0           0          138
```

A.19 Console output of the Norwegian context module

Produced by the first command in 6. Illustrative of the Norwegian setting; no figure here is a thesis claim, and the module states so in its own output. NO-XB uses the illustrative 120-month floor; the Norwegian pilot's six-year floor (F = 72) is a parameter change with no effect on the propositions (Chapter 4, Corollary 2.2).

```
==========================================================================
                           NORWEGIAN LAYER
==========================================================================

class           n  SemI recs  SemI viol  invalidated  SemII viol
NO-JOURNAL     40         12         12           12           0
NO-SPE         60         36         40           60           0
NO-XB          60         20         20           23           0

TOTAL         160         68         72           95           0

--------------------------------------------------------------------------
CASE WALKTHROUGHS
--------------------------------------------------------------------------

NO-JOURNAL  rid=121  (pasientjournalloven s 25 (purpose-based, indefinite))
  floor    : t=0 .. 600   [indefinite, truncated]
  erasure  : t_r=10 -> deadline 11
  ceiling  : n/a
  collision: C2 at t=11
  after invalidation -> log integrity=True, commitment=c8eb840b7abcb3e4..., key=None, salt=None,
     ground=GDPR Art 17(1)

NO-SPE  rid=61  (controller-provided server)
```

```
  floor    : t=10 .. 22
  erasure  : none
  ceiling  : t_pi=15 -> 21
  collision: C3 at t=21
  after invalidation -> log integrity=True, commitment=900dc608470b8289..., key=None, salt=None,
     ground=EHDS Art 68(12)

NO-XB  rid=1  (Bodo legevakt)
  floor    : t=4 .. 124
  erasure  : t_r=119 -> deadline 120
  ceiling  : n/a
  collision: C2 at t=120
  after invalidation -> log integrity=True, commitment=af06e57b08ba4cf8..., key=None, salt=None,
     ground=GDPR Art 17(1)

Note: figures above are illustrative of the Norwegian setting, not
empirical. The canonical result of the thesis is unchanged and is
reproduced by running trf_checker.py on its own.
```

A.20 Console output of the cross-sector instance

Produced by the second command in 6, and discussed in Chapter 6, Section 6.10. The zero in the second row is the finding: § 17 fixes both its limbs from the same origin, so it bounds a retention window rather than contradicting itself, and every collision the model finds is erasure-driven.

```
============================================================================
  CROSS-SECTOR INSTANCE: politiregisterloven s 17 (floor 12, ceiling 36)
============================================================================

records                              : 60
Semantics I, records with violation  : 7
  of which with NO erasure request   : 0  <- floor vs ceiling alone
Semantics II, total violations       : 0
records invalidated                  : 60

No structural collision: s 17 orders its two limbs from one origin
(floor at t_a + 12, ceiling at t_a + 36), so the provision defines a
bounded retention window rather than a contradiction. Every collision
found is erasure-driven.

witness rid=906: log written t=0; floor to t=12; ceiling at t=36; erasure deadline 11; collision C2 at
     t=11

The floor parameter F(a) took a third value with no change to the model.
The finding: floors and ceilings coexist when one instrument fixes both from
the same origin, and collide when the ceiling is anchored to an external
event, as Art 68(12) anchors it to permit expiry. Scope: a structural
parallel. Whether the mechanism transfers to a record-level ceiling is a
design question this module does not answer.
```

A.21 Console output of the payload-provenance comparison, committed subset

Produced by command 4 against the eight bundles committed at `data/synthea_subset/`, which is what a reader who clones the repository obtains without regenerating anything. Chapter 5, Section 5.8 reports both cohort sizes because one figure changes and the rest do not: the mean payload is 891 bytes here against 1,002 for the full cohort, while all six measures and all 200 differing commitments are identical. That the measures hold across cohort size and across payload repetition frequency is a stronger result than a single substitution would give.

```
============================================================================
     SYNTHEA REALISM LAYER — comparison against constructed payloads
============================================================================

Synthea bundles read : 8
clinical payloads    : 8
records              : 200
payload bytes (mean) : constructed=43  synthea=891

----------------------------------------------------------------------------
measure                                      constructed        synthea
----------------------------------------------------------------------------
Semantics I: records with violation                   90             90
Semantics I: total violations                         95             95
Corollary 1.2 witnesses (no request)                  39             39
Records invalidated                                  138            138
Semantics II: records with violation                   0              0
Semantics II: total violations                         0              0
----------------------------------------------------------------------------

commitments differing between the two runs: 200/200   (expected 200 — same salt, different payload)

============================================================================
 RESULT: every reported figure is IDENTICAL under Synthea FHIR payloads,
   while every commitment differs. The model reads timing, not content.
============================================================================
```

A.22 Console output of the envelope-encryption module

Verbatim output of `python3 crypto_envelope.py`. Keys are random on every run; the counts are the same on every run. All 200 records decrypt before invalidation; after the 138 data keys due for destruction are destroyed, those 138 records are refused and the other 62 still read, and the ciphertext of an invalidated record opens under none of the surviving keys.

```
============================================================================
           ENVELOPE ENCRYPTION (AES-256-GCM, wrapped data keys)
============================================================================
records encrypted                    : 200
decrypt and match before invalidation : 200/200
data keys destroyed (t_I finite)      : 138
decryptable after invalidation        : 62  (expected 62)
refused, key destroyed                : 138  (expected 138)
```

```
rid=3 ciphertext tried under 62 surviving keys : opened 0
ciphertexts kept after deletion       : 62
================================================================================
RESULT: no invalidated record decrypts through custody; every other record reads
================================================================================
```

A.23 Source listing: `z3_check.py`

Optional module. It poses each of Propositions 1–3 to the Z3 SMT solver as a request for a counterexample within stated bounds, and checks that deliberately wrong versions of Proposition 3 are refuted (Chapter 5, Section 5.5). It reports no thesis figure from the generated population.

```
"""
Bounded SMT check of Propositions 1-3 (optional module)
=======================================================
An independent check of the TRF Model's propositions in a different formalism from the
checker. trf_checker.py evaluates 200 generated records; this module asks the Z3 SMT solver
whether ANY record, with ANY parameter values inside the stated bounds, contradicts a
proposition. Every check is posed as "find a counterexample"; the expected answer is
"unsat" (no counterexample exists within the bounds).

Model (Chapter 4, Sections 4.3-4.6), one record, months t = 0..H:
  alpha_t        payload accessible at month t (free Boolean per month)
  C1 floor       alpha_t for t in [t_a, t_a + F]                    (Semantics I: V = alpha)
  C2 right       not alpha_t for t >= t_r + delta, if a request arrives
  C3 ceiling     not alpha_t for t >= e + L, if a ceiling applies (e: its anchor event)
Semantics II (Proposition 2) adds the accountability state per month: m_acc kept, c kept,
an invalidation entry iota present, the subject link beta readable, and a subject-link
entry iota_subj present. V_II = m_acc and c and (alpha or iota) and (beta or iota_subj),
and C3 also requires beta = 0 from the ceiling where it reaches the subject fields.

Bounds: t_a in [0, 12], F in [1, 120] (so the 120-month cross-border floor is covered),
delta in [1, 3], request month and anchor event in [t_a, H], L in [1, 120], H = 140.
This is a bounded check: it covers every combination within the bounds, not all integers.
It checks that the propositions follow from the constraints as encoded here; like the
checker, it does not check that the constraints translate the law (Section 4.2 does that).

Run:  pip install z3-solver   then   python3 z3_check.py
"""

from z3 import And, Bool, If, Implies, Int, Not, Or, Solver, sat, unsat

H = 140
T = range(H + 1)


def record():
    """Symbolic parameters and constraints common to every check."""
    ta, F, d = Int("t_a"), Int("F"), Int("delta")
    tr, e, L = Int("t_r"), Int("e"), Int("L")
    req, ceil = Bool("request"), Bool("ceiling")
    alpha = [Bool(f"alpha_{t}") for t in T]
    bounds = And(ta >= 0, ta <= 12, F >= 1, F <= 120, d >= 1, d <= 3,
                 tr >= ta, tr <= H, e >= ta, e <= H, L >= 1, L <= 120)
    return ta, F, d, tr, e, L, req, ceil, alpha, bounds
```

```
def C1(alpha, ta, F):
    return And([Implies(And(ta <= t, t <= ta + F), alpha[t]) for t in T])


def C2(alpha, req, tr, d):
    return And([Implies(And(req, t >= tr + d), Not(alpha[t])) for t in T])


def C3(alpha, ceil, e, L):
    return And([Implies(And(ceil, t >= e + L), Not(alpha[t])) for t in T])


def check(name, formula):
    s = Solver()
    s.set(timeout=120_000)               # milliseconds; an unknown result counts as a failure
    s.add(formula)
    r = s.check()
    verdict = "unsat (no counterexample)" if r == unsat else ("SAT: counterexample found" if r == sat
     else f"{r}: no verdict")
    print(f"{name:<74} {verdict}")
    return r == unsat


def main():
    print("=" * 100)
    print("BOUNDED SMT CHECK OF PROPOSITIONS 1-3 (Z3)".center(100))
    print("=" * 100)
    print(f"bounds: t_a 0..12, F 1..120, delta 1..3, t_r and e in [t_a, {H}], L 1..120, horizon {H}")
    ok = []
    ta, F, d, tr, e, L, req, ceil, alpha, B = record()

    # Proposition 1, infeasibility direction: if a deadline falls inside the window,
    # no accessibility trajectory satisfies C1, C2 and C3 under Semantics I.
    inside = Or(And(req, tr + d <= ta + F), And(ceil, e + L <= ta + F))
    ok.append(check("P1  deadline inside window => no trajectory satisfies C1-C3 (Sem I)",
                    And(B, inside, C1(alpha, ta, F), C2(alpha, req, tr, d), C3(alpha, ceil, e, L))))

    # Proposition 1, boundary: if no deadline falls inside the window, the trajectory
    # "accessible until the earliest deadline" satisfies all three. Counterexample = it fails.
    dl = If(req, If(ceil, If(tr + d < e + L, tr + d, e + L), tr + d), If(ceil, e + L, H + 1))
    witness = [t < dl for t in T]
    ok.append(check("P1  no deadline inside window => witness trajectory satisfies C1-C3",
                    And(B, Not(inside),
                      Not(And(C1(witness, ta, F), C2(witness, req, tr, d), C3(witness, ceil, e, L))))))

    # Proposition 2: under Semantics II the constructive trajectory satisfies C1, C2 and C3
    # for every arrival pattern and floor. The construction keeps m_acc and c, sets alpha = 0
    # and logs iota from t_I = earliest deadline, and, where a ceiling applies (SPE records
    # whose subject fields it reaches), sets beta = 0 and logs iota_subj from the ceiling.
    tI = dl
    traj = [t < tI for t in T]

    # The accountability conjuncts are instantiated true by construction below (m_acc and c kept,
    # iota logged from t_I), so this check verifies the timing of the trajectory, not that
    # accountability is preserved; that is argued in Chapter 4, Section 4.7 (see Section 5.5).
    def sem2(macc, c, iota, beta, iota_s):
        V2 = [And(macc[t], c[t], Or(traj[t], iota[t]), Or(beta[t], iota_s[t])) for t in T]
        c1 = And([Implies(And(ta <= t, t <= ta + F), V2[t]) for t in T])
        c3b = And([Implies(And(ceil, t >= e + L), Not(beta[t])) for t in T])
```

```
        return And(c1, C2(traj, req, tr, d), C3(traj, ceil, e, L), c3b)

    keep = [True for t in T]
    iota = [t >= tI for t in T]
    beta = [Or(Not(ceil), t < e + L) for t in T]
    iota_s = [And(ceil, t >= e + L) for t in T]
    ok.append(check("P2  constructive trajectory satisfies C1 (Sem II), C2, C3 for all inputs",
                    And(B, Not(sem2(keep, keep, iota, beta, iota_s)))))
    # Mutations of the construction must be refuted (sat): no invalidation entry; the
    # commitment removed at t_I; the subject link removed without its entry.
    mut2 = [Solver() for _ in range(3)]
    mut2[0].add(B, Not(sem2(keep, keep, [False for t in T], beta, iota_s)))
    mut2[1].add(B, Not(sem2(keep, [t < tI for t in T], iota, beta, iota_s)))
    mut2[2].add(B, Not(sem2(keep, keep, iota, beta, [False for t in T])))
    m2ok = all(m.check() == sat for m in mut2)
    print(f"{'mutation: construction without iota / without c / without iota_subj refuted':<74} {'sat,
        counterexamples found (as expected)' if m2ok else 'UNSAT: check insensitive'}")

    # Proposition 3: floor F from t_a, ceiling L from e >= t_a, Semantics I.
    # (a) collision whenever e + L <= t_a + F: no trajectory satisfies floor and ceiling.
    both = And(C1(alpha, ta, F), C3(alpha, True, e, L))
    ok.append(check("P3  e + L <= t_a + F => floor and ceiling not jointly satisfiable",
                    And(B, e + L <= ta + F, both)))
    # (b) no collision whenever e + L > t_a + F: accessible-until-(e+L) satisfies both.
    w3 = [t < e + L for t in T]
    ok.append(check("P3  e + L > t_a + F => witness satisfies floor and ceiling",
                    And(B, e + L > ta + F, Not(And(C1(w3, ta, F), C3(w3, True, e, L))))))
    # (i) same anchor (e = t_a): satisfiable for the record iff L > F.
    ok.append(check("P3(i)  e = t_a: jointly satisfiable only if L > F",
                    And(B, e == ta, L <= F, both)))
    ok.append(check("P3(i)  e = t_a and L > F: witness satisfies floor and ceiling",
                    And(B, e == ta, L > F, Not(And(C1(w3, ta, F), C3(w3, True, e, L))))))
    # (ii) external anchor with L <= F: collision exactly when e - t_a <= F - L.
    ok.append(check("P3(ii) L <= F, e - t_a <= F - L => collision",
                    And(B, L <= F, e - ta <= F - L, both)))
    ok.append(check("P3(ii) L <= F, e - t_a >  F - L => witness satisfies both",
                    And(B, L <= F, e - ta > F - L, Not(And(C1(w3, ta, F), C3(w3, True, e, L))))))

    # Sanity: the encoding can return sat, so unsat above is not an artefact of a broken model.
    s = Solver(); s.add(B, Not(req), Not(ceil), C1(alpha, ta, F))
    sanity = s.check() == sat
    print(f"{'sanity: no request, no ceiling => some trajectory satisfies C1':<74} {'sat (as expected)'
        if sanity else 'UNSAT: encoding broken'}")
    # Mutation checks: deliberately wrong versions of Proposition 3 must be refuted (sat),
    # showing the checks are sensitive to an off-by-one in the condition.
    m1 = Solver(); m1.add(B, e + L <= ta + F + 1, both)       # claims collision one month too late
    m2 = Solver(); m2.add(B, e + L > ta + F - 1, Not(And(C1(w3, ta, F), C3(w3, True, e, L))))
    mut = m1.check() == sat and m2.check() == sat
    print(f"{'mutation: Proposition 3 with an off-by-one condition is refuted':<74} {'sat,
        counterexample found (as expected)' if mut else 'UNSAT: checks insensitive'}")
    sanity = sanity and mut and m2ok
    print("=" * 100)
    print(f"RESULT: {sum(ok)}/{len(ok)} checks found no counterexample; sanity and mutation checks
        {'passed' if sanity else 'FAILED'}")
    print("=" * 100)
    return 0 if all(ok) and sanity else 1


if __name__ == "__main__":
```

```
    import sys
    sys.exit(main())
```

A.24 Console output of the bounded SMT check

Verbatim output of `python3 z3_check.py` (Z3 5.1.0). Nine checks find no counterexample; the sanity check finds a satisfying trajectory and the mutation check finds counterexamples, as they must.

```
============================================================================================================
                            BOUNDED SMT CHECK OF PROPOSITIONS 1-3 (Z3)
============================================================================================================
bounds: t_a 0..12, F 1..120, delta 1..3, t_r and e in [t_a, 140], L 1..120, horizon 140
P1  deadline inside window => no trajectory satisfies C1-C3 (Sem I)        unsat (no counterexample)
P1  no deadline inside window => witness trajectory satisfies C1-C3        unsat (no counterexample)
P2  constructive trajectory satisfies C1 (Sem II), C2, C3 for all inputs   unsat (no counterexample)
mutation: construction without iota / without c / without iota_subj refuted sat, counterexamples found
     (as expected)
P3  e + L <= t_a + F => floor and ceiling not jointly satisfiable          unsat (no counterexample)
P3  e + L > t_a + F => witness satisfies floor and ceiling                 unsat (no counterexample)
P3(i)  e = t_a: jointly satisfiable only if L > F                         unsat (no counterexample)
P3(i)  e = t_a and L > F: witness satisfies floor and ceiling             unsat (no counterexample)
P3(ii) L <= F, e - t_a <= F - L => collision                              unsat (no counterexample)
P3(ii) L <= F, e - t_a >  F - L => witness satisfies both                 unsat (no counterexample)
sanity: no request, no ceiling => some trajectory satisfies C1            sat (as expected)
mutation: Proposition 3 with an off-by-one condition is refuted           sat, counterexample found (as
     expected)
============================================================================================================
RESULT: 9/9 checks found no counterexample; sanity and mutation checks passed
============================================================================================================
```

Appendix B. Search Query Log

This log records every search query executed in the course of the literature review, recovered from the working record of each session. Queries are reproduced as run, including those that produced nothing usable, since a curated log would be less credible than a complete one.

Some entries are document-retrieval or verification queries rather than discovery queries: targeting a known citation, a regulation's text, or a specific document's status. Entries 33, 34 and 36, which retrieved the author's own drafts, are marked as such and excluded from the counts; other retrieval queries are not individually marked, so the counts combine discovery queries, which sought literature not already known to the review, with retrieval queries. Both are reported because the distinction matters for interpreting what the log evidences: only discovery queries bear on the absence claim of Chapter 2, Section 2.9. They are natural-language queries rather than Boolean strings, which is what the review actually used; Chapter 2, Section 2.1 states this and gives a Boolean replication protocol separately.

Round 1: 25 May 2026 (landscape, infrastructure, regulatory baseline)

1. `Norway electronic health record EHR infrastructure 2026 new regulations`
2. `MyHealth@EU cross-border patient summary how it works national contact point`
3. `eHDSI OpenNCP audit trail consent data minimisation HCP authorization IHE XCA`
4. `Norway Helsenorge kjernejournal architecture FHIR HL7 helseplattformen DIPS`
5. `European Health Data Space EHDS regulation 2025 primary secondary use timeline`
6. `Norway health data research innovation Helseanalyseplattformen Norwegian Centre HUNT BigMed`
7. `Norway Helsedataservice secondary use health data 2025 application portal Direktoratet for e-helse`
8. `Norwegian patient gets treated Spain ePrescription patient summary how process works`
9. `Norway MyHealth@EU national contact point eHealth go-live status 2025 2026`
10. `Norway AI medical imaging research 2025 federated learning health data`
11. `ZK-EHR zk-SNARK blockchain electronic health records MDPI Systems 2026`
12. `MDPI Systems "14" "385" 2026 zero-knowledge health blockchain cross-institutional` [restored from the session record]
13. `KONFIDO project "Health Informatics Journal" lessons learned patient summary exchange` [restored from the session record]

14. Helsedirektoratet EHDS European Health Data Space gap analysis Norway 2025
15. OpenNCP github repository ehdsi.europa.eu source code documentation NCP gateway
16. Norway AI Act implementation Nkom DigDir consultation 2025 høring Regulation 2024/1689

Round 2: 29 May 2026 (verification and correction round)

17. SPUHiN ”minimum requirements” ”secure processing environments” Norway 2024 helsedata [restored from the session record]
18. EHDS implementation 2026 cross-border patient summary technical infrastructure Member State
19. IHE ATNA Audit Trail Node Authentication integration profile retention requirement
20. eHDSI MyHealth@EU audit log retention period years requirement
21. eHDSI security framework audit log retention specification cross-border European
22. GDPR Article 17 right erasure audit log retention healthcare EDPB guidance
23. cryptographic erasure audit log healthcare GDPR right to be forgotten academic
24. KONFIDO project OpenNCP architecture cross-border 2018 technical paper Natsiavas
25. zero-knowledge proof healthcare audit log verifiable revocation 2024 2025 2026
26. cryptographic accumulator commitment scheme revocation healthcare audit hash chain

Round 3: 15 September 2026 (resumption; novelty and currency)

27. Helsedataservice Norway secondary use access body workflow data permit registry
28. information logistics digital supply chain cross-border data flow regulatory compliance academic
29. Norwegian offshore workers health records cross-border medical exchange maritime logistics
30. formal model conflict audit log retention GDPR right to erasure constraint satisfaction
31. formal verification regulatory compliance conflicting retention requirements temporal logic healthcare audit
32. operations research optimization model data governance compliance reconciliation supply chain regulatory constraints
33. thesis chapter 3 TRF model formal specification VERA-SNARK [not a literature search: retrieval of the author’s own drafts]
34. TRF model gate feasibility theorem crypto-erasure invalidation chapter 4 [not a literature search: retrieval of the author’s own drafts]
35. Norge EHDS EØS gjennomføring helsedata juni 2026
36. Google Drive read file content [not a literature search: retrieval of the author’s own drafts]

Round 4: 16 September 2026 (adversarial novelty, prior art, currency)

37. `EHDS secondary use audit log retention erasure 2026 IEEE Scopus formal compliance health data`
38. `"retention conflict" OR "conflicting retention" cryptographic erasure formal model 2026 arXiv`
39. `EUR-Lex 2025/327 Article 73 secure processing environment "keeping of identifiable logs" access activities year`
40. `Regulation 2025/327 EHDS entry into force 26 March 2025 application date Article 105 staggered 2029`
41. `EDPB Guidelines 02/2025 blockchain personal data final version adopted after public consultation`
42. `TEHDAS2 deliverable secure processing environment technical specifications 2026 D7 tehdas.eu`
43. `eHOMB eHealth Operational Management Board Norway ePrescription without eDispensation change proposal requirement catalogue approved`
44. `EHDS Article 68 paragraph 12 "data permit" delete personal electronic health data secure processing environment six months expiry`
45. `Walonoski Synthea synthetic patient generator JAMIA 2018 25(3) 230-238`
46. `validity synthetic clinical data Synthea validation clinical quality measures limitations`
47. `HL7 Norway basisprofiler FHIR R4 no-basis 2026 status`
48. `Datatilsynet NIF Norges idrettsforbund vedtak syntetiske testdata personopplysninger test`
49. `Peffers Tuunanen Rothenberger Chatterjee design science research methodology Journal of Management Information Systems 2007 24 3 45-77`
50. `NIST SP 800-88 Revision 2 media sanitization published date 2025 draft final`
51. `Norge MyHealth@EU pasientsammendrag pilot Bodø Stjørdal legevakt Portugal Tsjekkia Finland`
52. `EHDS implementing acts 2026 secure processing environment specifications adopted status`
53. `eprint 2026/1109 SoK cryptographic erasure public ledgers Destruction-IND`
54. `GDPR Article 12(3) one month respond erasure request extension two months`
55. `SPUHiN D5.2 recommendations minimum requirements secure processing final helsedirektoratet`
56. `Reardon Basin Capkun SoK secure data deletion 2013 IEEE`
57. `Finck blockchain GDPR European Parliament study 2019 can distributed ledgers be squared right erasure`
58. `Datatilsynet sletting anonymisering kryptering personopplysninger krav`
59. `formal model audit retention versus erasure crypto-shredding paper 2026`

Round 5: 28 September 2026 (locator verification and source-standing audit) [R]

This round contains no discovery queries. Every lookup targeted a source already in the bibliography and asked one of two questions: does a stable locator exist for it, and does the document say what the citation claims it says. It is recorded because it changed the reference list, and a log that

omitted the round that removed two entries would misstate how the bibliography reached its final form.

Thirty-nine entries carrying no DOI or URL were taken as the working set and verified in four parallel sweeps: European Union institutional sources; Norwegian government and health-authority sources; academic papers and patents; and project deliverables, technical standards and industry commentary. Each lookup was required to retrieve the document and quote matching text before a locator was accepted, and to return a negative rather than a plausible-looking substitute where no locator could be retrieved.

Because these were executed as parallel verification sweeps rather than as single typed queries, they are recorded here by target rather than by verbatim string. Reporting invented query strings would be worse than reporting none.

#	Target verified	Outcome
60	European Commission EHDS Regulation page, and whether a separate *Implementation calendar* document exists	**No such document.** The milestones are a section of the Regulation page headed "Key milestones towards full implementation". Entry removed
61	Helsedirektoratet national e-health portfolio, MyHealth@EU measures	The *Norsk helsenett* measure returns HTTP 404 and no live equivalent exists; the portfolio lists Helsedirektoratet and KS measures only. Entry removed
62	IHE ITI Technical Framework Volume 1 Chapter 9, revision and date	Revision 20.0, 4 August 2023, Final Text. The cited year 2024 was wrong and was corrected
63	VeritasChain Standards Organization, legal standing and accreditation	Founded 24 November 2025; not a registered legal entity; operationally supported by VeritasChain Inc.; states it is "aspiring to be" comparable to ISO, IEEE and IETF. Retained with its standing stated, not as a standards body
64	helsedata.no, the page cited as *Application workflow and fees*	No page of that title. The page is *Fees and processing times* and carries no publication year
65	TEHDAS2 deliverable D6.3, version and date	The final is Version 2.0, 24 February 2026; the 2025 document is Version 1.5, a final draft. Dated accordingly
66	Journal of Data Intelligence 3(1), Scope et al.	Pages 149–168, added. No DOI is issued by the publisher
67	Finck (2019) European Parliament STOA study	DOI 10.2861/535, PE 634.445
68	United States Patent 12,425,209	Confirmed: kind code B2, granted 23 September 2025, inventors Scope and Rasin
69	Staffa et al. (2018) KONFIDO chapter	DOI 10.1007/978-3-319-95189-8_2, all eight authors confirmed against the publisher record
70	Broadbent and Islam (2020), Springer chapter and arXiv identifier	DOI 10.1007/978-3-030-64381-2_4; LNCS 12552, pp. 92–122; arXiv:1910.03551 confirmed
71	Bursuc et al. (2024), publication status	Since published at the 37th IEEE Computer Security Foundations Symposium, July 2024. The IEEE DOI could not be retrieved and is therefore not stated

#	Target verified	Outcome
72	SPUHiN deliverable D5.2, public-hearing version	The consultation page has been withdrawn and returns 404. No stable locator established; the entry says so and cites the project page
73	Deloitte Advokatfirma commentary, publication date	Published 24 August 2020. The citation's "n.d." was avoidable and was corrected
74	Norsk forening for allmennmedisin consultation response	Retrieved. The citation read "analyserum"; the document reads "analyserom"
75	Norwegian Maritime Authority 2023 amendment	The cited title was the regulations' name. The amending instrument is Circular RSR 2-2023. Later removed from the bibliography with the seafarer material it supported, cut from Chapter 1 on 3 October 2026
76	EDPB documents 2026a and 2026b, official titles	Both titles corrected to the Board's own wording
77	Remaining institutional and standards sources: Datatilsynet, Folkehelseinstituttet, Forskningsetikk, Helse- og omsorgsdepartementet, Stortinget, HL7 Norway, NORTRE, ICC, Berngaard, OneUptime, Healthy Europe, Ernst & Young, GDPR	Locators retrieved and matched against title, issuer and year. Ernst & Young was later removed from the bibliography when the EHDS dates in Chapter 2, Section 2.2 were re-anchored on Article 105 of the Regulation (3 October 2026)

Round 5 outcome: every entry left in the bibliography carried a verified locator. Two entries were removed as documents that do not exist as cited, and six citations were corrected on year, title or author. Nothing was linked that was not retrieved.

Total distinct queries logged: 56 discovery and verification queries across four rounds, three retrievals of the author's own drafts (entries 33, 34 and 36), and 18 locator verifications in round 5.

Note on coverage

The log records queries executed through the review's search tooling. Two categories of source entered the review by other routes and are noted here so that the log is not read as exhaustive of how sources were found.

Backward snowballing from reference lists supplied several sources, including the Camenisch and Lysyanskaya accumulator work and the Benaloh and de Mare original, which were reached from Ren's survey rather than by query.

The closest prior art, the DePaul retention-and-purging programme and United States Patent 12,425,209, was located during the adversarial round 4 through patent-database searching, which sits outside the query tooling this log records. That search is noted here rather than omitted, because a log claiming completeness while containing no query capable of finding the most important prior-art item in the review would misrepresent itself.

Prospective Boolean protocol for replication

The following strings are offered so that a researcher may test the review's conclusions (Chapter 2, Section 2.1.6) against a systematic sweep of indexed databases. They were not the instrument used in this thesis, and are stated prospectively.

Table B.1. Prospective Boolean search strings

#	Target	String
B1	Scopus, Web of Science	`TITLE-ABS-KEY(("crypto-shredding" OR "cryptographic erasure" OR "crypto erasure" OR "secure deletion" OR "data sanitization") AND ("GDPR" OR "right to erasure" OR "right to be forgotten"))`
B2	Scopus, IEEE Xplore	`TITLE-ABS-KEY(("audit log" OR "audit trail" OR "access log") AND ("retention" OR "retention period") AND ("erasure" OR "deletion") AND ("conflict" OR "tension" OR "reconcil*"))`
B3	Scopus, PubMed	`TITLE-ABS-KEY(("European Health Data Space" OR "EHDS" OR "MyHealth@EU" OR "eHDSI") AND ("secure processing environment" OR "audit" OR "retention" OR "erasure"))`
B4	Scopus, IEEE Xplore, ACM	`TITLE-ABS-KEY(("formal verification" OR "satisfiability" OR "temporal logic" OR "constraint satisfaction") AND ("regulatory compliance" OR "legal compliance" OR "GDPR"))`
B5	Scopus, Web of Science	`TITLE-ABS-KEY(("health data" OR "electronic health record") AND ("cross-border" OR "cross border") AND ("privacy" OR "data protection") AND ("Norway" OR "Nordic" OR "EEA"))`
B6	IACR ePrint, arXiv	`("certified deletion" OR "proof of secure erasure" OR "provable deletion") AND ("verifiab*" OR "attestation")`

Filters for replication: publication years 2018 to 2026 for B1, B2, B4 and B6; unrestricted for B3 and B5, since the relevant regulatory material predates the window. Document types: articles, conference papers, reviews, and preprints. Languages: English and Norwegian.

Appendix C. Expert Evaluation Instrument

(v1.1, 18 September 2026; item U1 corrected and item A1 reworded October 2026. The instrument specified here was designed following supervisory feedback of September 2026 and constitutes the evaluation design for the next iteration of the design science cycle. Its execution status is stated in Chapter 3, Section 3.8. ***This is a design, not a fielded instrument. Section C.1 states what is expected to change once it meets real respondents.****)*

C.1 Purpose and status

Chapter 3, Section 3.7 sets out the analytical evaluation strategy adopted for this thesis: internal validity through logical consistency and executable checking, external validity through compatibility analysis against verified infrastructure, and reliability through deterministic execution. That strategy evaluates the artefact against the objectives stated in Chapter 1, Section 1.3, and it is the evaluation the thesis reports.

It does not collect stakeholder input. Design Science Research as elaborated by Hevner et al. (2004) and Peffers et al. (2007) treats evaluation as an activity that may be conducted through several methods, of which expert assessment is one, and a specification-and-demonstration study of the kind reported here frequently designs the evaluation that a subsequent cycle executes. This appendix is that design.

The instrument is specified in sufficient detail to be executed without further design work: panel composition and recruitment approach, session structure, demonstration script, semi-structured interview guide, a closed-response questionnaire, the analysis approach, and the data-protection arrangements execution would require. The four closed-response dimensions follow the structure proposed in supervisory feedback and are reproduced with their anchor statements as proposed, except for the two changes stated under *Status of this instrument.*

Status of this instrument, and what is expected to change

An instrument that has never been administered is a hypothesis about what respondents will understand, not a measurement device. This one has been reviewed by a supervisor and reasoned through against the thesis's claims; it has not been piloted, and no respondent has yet tried to answer it. The distinction matters for how its results should be read if it is executed, and it is stated here rather than discovered afterwards.

The following are expected to change, and changing them would not constitute a departure from the design:

Wording of the closed-response items. The four dimensions and their anchor statements are reproduced as proposed in supervisory feedback, except the term "erasure ceilings" in item U1, corrected to "deletion ceilings", and item A1, reworded in October 2026 with the supervisor's agreement because the proposed wording ("full confidence that data was lawfully deleted") made a claim the thesis does not make (Chapter 6, Section 6.3).

The panel. Eight participants across four perspectives is a target, not a recruitment outcome. Norwegian health-data governance is a small professional community and some of the roles sought are held by very few people. If a perspective cannot be filled, the analysis reports which voice is missing rather than redistributing its weight silently.

Session length and the demonstration script. Forty-five minutes is an estimate. The demonstration walks through a live artefact, and the first session will establish whether the script fits the time or whether the closed-response section must move to a follow-up.

The coding frame. The three areas derived from supervisory feedback (legal defensibility, key custody and trust assumptions, operational viability) carry an open category precisely because the frame is expected to be incomplete. Themes that recur outside it are a finding about the frame, not noise to be forced into it.

What would not change. The instrument's purpose is to test whether practitioners find the artefact defensible, not to elicit endorsement. Items are not to be reworded toward agreement if early responses are unfavourable, and an unfavourable result is reportable as a result. Any revision made after piloting is to be recorded with its reason, and the version of the instrument actually administered is to be reproduced in the thesis that reports it, rather than this one.

Should the evaluation be executed, this appendix stands as the design specified in advance, against which any subsequent version can be compared.

C.2 Panel composition

Eight participants across four perspectives, two in each, chosen so that no single professional viewpoint dominates and so that legal, architectural, operational, and disciplinary assessments are each represented by more than one voice.

#	Perspective	Profile sought	Assesses
P1, P2	Data protection	Data Protection Officer or privacy counsel in a Norwegian health or research institution	Whether invalidation is defensible as satisfying retention; whether the surviving residue is personal data, and for whom; the Article 68(12) scope question
P3, P4	Health IT architecture	Architect or senior engineer at Norsk Helsenett or Helsedataservice with NCPeH or HDAB exposure	Whether the mechanism attaches at the right boundary; interoperability consequences; effect on the OpenNCP transmission flow

#	Perspective	Profile sought	Assesses
P5, P6	Secure Processing Environment operation	Operator or technical lead at a NORTRE node (TSD, SAFE, or HUNT Cloud)	Key custody in practice; operational burden of per-record granularity; single-point-of-failure risk absent hardware security modules
P7, P8	Information logistics	Academic or practitioner in logistics or supply-chain compliance	Whether the customs-ledger framing holds; transferability of the tri-lateral structure to other regulated flows

Recruitment would proceed by direct approach through institutional channels, with the supervisor's introduction where available. A minimum of six completed sessions, with at least one from each perspective, would be treated as the threshold for reporting; below that the results would be reported as indicative commentary rather than as evaluation.

C.3 Session structure

Forty-five minutes, conducted in Norwegian or English at the participant's preference, remotely or in person.

Minutes	Segment	Content
0–5	Framing	Purpose, voluntariness, recording and anonymity arrangements, participant's right to withdraw. No thesis conclusions stated at this point.
5–12	Problem presentation	The three retention regimes and their sources, presented from the primary instruments without the thesis's resolution. Participants are asked how their institution currently handles the conflict, before being shown any proposed answer.
12–22	Demonstration	Live execution of the feasibility checker (Section C.4).
22–35	Semi-structured discussion	Interview guide, Section C.5.
35–43	Closed-response instrument	Questionnaire, Section C.6, completed by the participant.
43–45	Close	Opportunity to add anything not asked; follow-up arrangements.

The ordering is deliberate. Participants describe current practice before seeing the proposed mechanism, so that their account of the status quo is not shaped by the solution. The closed-response instrument follows the open discussion so that numerical responses are informed rather than first impressions.

C.4 Demonstration script

The demonstration runs the artefact rather than describing it. Approximately ten minutes.

1. *Show the record structure.* One audit record: metadata, payload, commitment, key. Identify which parts the accountability purpose needs and which it does not.
2. *Run the checker under plaintext semantics.* `python3 trf_checker.py`. Show the output: ninety-five violations across ninety of two hundred records. Open one witness line and walk through the arithmetic: the collision month, the two constraints, the window.
3. *Isolate the Corollary 1.2 cases.* Thirty-nine Secure Processing Environment records with no erasure request at all. Show record 100: created month 7, permit expires month 10, ceiling from month 16, floor to month 19. State the interpretive condition (Chapter 4, Section 4.6) explicitly rather than glossing it.
4. *Show the exhaustive cross-check.* Sixteen thousand three hundred and eighty-four assignments per case; no satisfying assignment in the three conflict cases; the control case passes.
5. *Run under invalidation semantics.* Zero violations. Show the auditor's view of record 100 after invalidation: accessor fields verified against the log, patient link removed at month 16 with its removal logged, commitment present, key destroyed, invalidation entry with month and legal ground, payload unreadable.
6. *State the limits before being asked.* Key destruction is simulated in program state; the invalidation entry is an attestation, not a proof; no National Contact Point is connected; no performance claim is made.

Step 6 is not optional. A demonstration that presents only strengths invites participants to spend their time finding the weaknesses instead of assessing the design.

C.5 Semi-structured interview guide

Thirteen questions across four themes. Prompts are used only where a participant's answer is brief; the guide is not a script to be read verbatim.

Current practice and problem recognition

1. How does your institution currently handle a request to erase personal data that is also subject to an audit-retention obligation? Is there a documented position, or is it decided case by case?
2. Before today, had you encountered the interaction between Article 68(12) and Article 73(1)(e)? *(Prompt: if not, does it look like a real problem or an artefact of how it has been presented?)*
3. Where in your organisation would responsibility for resolving this sit?

Legal defensibility

4. The mechanism treats an audit record as verifiable when its metadata is intact, its commitment survives, and the invalidation is logged: without the payload remaining readable. Is that defensible as satisfying a retention obligation, in your judgement?
5. What would a supervisory authority need to see before accepting it?

6. The surviving residue is characterised as pseudonymised rather than anonymous. Does that characterisation match your reading of the Norwegian threshold?
7. Article 68(12) provides that "the electronic health data within the secure processing environment shall be deleted within six months of the expiry of the data permit." Does that reach access logs kept at patient-record granularity, or only the dataset supplied under the permit? And does auditing "all processing operations" under Article 73(1)(e) after that point need the link to the patient, or only the identity of the person who accessed?

Trust and key custody

8. The invalidation entry attests that a key was destroyed; it does not prove it. Is attestation sufficient in your operating context, and if not, what would make it sufficient?
9. Where would key custody sit in your architecture, and what failure modes concern you most?
10. Does per-record key granularity create a single point of failure you would be unwilling to accept without hardware-backed attestation?

Operational viability

11. What would implementing this at your institution actually require: systems, process, people?
12. At what record volume would the per-record key registry become a problem?
13. What would you change about the design before deploying it?

Question 7 is included because the thesis's sharpest result depends on the answer, and practitioner readings of it are evidence this author cannot generate.

C.6 Closed-response questionnaire

Five-point Likert scale throughout: 1 = strongly disagree, 2 = disagree, 3 = neither agree nor disagree, 4 = agree, 5 = strongly agree. A sixth option, *not able to judge*, is offered on every item and is reported separately rather than treated as a midpoint.

Each dimension opens with the anchor statement proposed in supervisory feedback, reproduced as proposed, with the two changes stated in Section C.1, followed by items that decompose it.

Dimension 1: Perceived utility

Item	Statement
U1	*The key-invalidation mechanism effectively resolves the conflict between retention floors and deletion ceilings.*
U2	The problem this mechanism addresses is one my institution will face in practice.
U3	The mechanism addresses the problem more effectively than the approach my institution currently uses or would default to.

Item	Statement
U4	The distinction between plaintext verifiability and accountability-preserving verifiability is one I had not previously considered explicitly.

Dimension 2: Regulatory alignment

Item	Statement
R1	*The residual audit log provides sufficient verification without violating GDPR Article 17 or EDPB guidelines.*
R2	The surviving residue (metadata, commitment, invalidation entry) would be defensible to a supervisory authority.
R3	Article 68(12) should be read as reaching the access logs generated within a Secure Processing Environment.
R4	The mechanism's characterisation of its residue as pseudonymised rather than anonymous is the correct characterisation.

Dimension 3: Operational viability

Item	Statement
O1	*The proposed key registry structure is practical to implement within current Norwegian health data infrastructure (SPUHiN / NORTRE).*
O2	Per-record key granularity is operationally sustainable at the record volumes my institution handles.
O3	The mechanism requires nothing of the processing environment beyond what the national criteria (in the version put to hearing) already demand.
O4	Placing the mechanism at the audit-logging boundary, rather than inside the processing environment, is the right architectural choice.

Dimension 4: Audit integrity

Item	Statement
A1	The mechanism lets an auditor verify that a record's invalidation was logged at the required month and has not been altered since.
A2	An attested invalidation entry, without hardware-backed proof of key destruction, is sufficient for audit purposes in my context.
A3	The mechanism provides stronger audit assurance than deleting the record and logging that a deletion occurred.
A4	An external auditor could establish, from the surviving record alone, what was invalidated and on what legal ground.

Open items

Item	Prompt
X1	The single change you would most want made to the design.
X2	The assumption in the design you consider least safe.
X3	Anything the questions above did not ask about.

A note on items A1 and A2. A1 asks about what the mechanism lets an auditor verify: that the invalidation was logged and is unaltered, which the audit log's inclusion proofs establish. A2 asks whether that is enough without proof that the key was destroyed, which the mechanism does not provide: Chapter 6, Section 6.3 states that the invalidation entry is an attestation rather than a proof. Analysis reads the two together.

C.7 Analysis

Closed responses would be reported as medians with full distributions rather than means, given ordinal data and a panel of eight; no inferential statistics would be computed, and none would be meaningful at this size. *Not able to judge* responses would be reported by item, since a concentration of them is itself a finding about which audiences can assess which dimensions.

Open responses and interview transcripts would be analysed thematically following a coding frame derived from the three areas supervisory feedback identified (legal defensibility, key custody and trust assumptions, operational feasibility) with an open category for themes not anticipated. Coding by a single researcher would be stated as a limitation, as it is for the literature review in Chapter 2, Section 2.1.7.

Item R1 is kept verbatim as the supervisor's anchor statement, although it asks about two standards at once, GDPR Article 17 and the EDPB guidelines. A respondent who accepts one and not the other cannot say so on the scale, so R1 would be read together with the open responses, and the double barrel would be stated as a limitation of the item.

Integration into the thesis would follow the design science cycle rather than being appended to it:

Misalignments between the design and operational reality would be documented as findings, not smoothed over. If Secure Processing Environment operators identify key custody as a single point of failure absent hardware security modules, that becomes a stated limitation of the mechanism and a design requirement for the next iteration.

Assumption revision. Legal responses to items R2, R3 and R4, and to interview questions 4 through 7, would revise the trust model and the residue analysis of Chapter 4, Section 4.9: in particular whether attestation of key destruction is treated as adequate.

Future iterations. Responses to A2 would inform whether the next design iteration should move from software-attested key destruction to hardware-backed attestation through a hardware security

module or secure enclave, which Chapter 7, Section 7.5 already identifies as the direction in which the assurance boundary would move.

Disconfirming responses would be reported with the same prominence as confirming ones. An evaluation that can only strengthen the artefact is not an evaluation.

C.8 Data protection, if executed

Execution would process personal data about identifiable professionals and would therefore require notification to Sikt (Norwegian Agency for Shared Services in Education and Research) before any participant is approached. Typical processing time is four to six weeks.

The arrangements would be: written information and consent obtained before each session; audio recording only with consent, transcribed and the recording deleted on transcription; participants identified in reporting by perspective and number only (P1 through P8), with institutions named only where a participant expressly agrees; no special-category data collected; storage on institutional infrastructure for the duration of the project and deletion on completion; and withdrawal permitted at any point up to the completion of analysis.

Executing this instrument would change the thesis's ethics position materially. Chapter 1, Section 1.5, Chapter 3, Section 3.9, and the Declaration of Originality each state that this research involves no human participants and required no ethical approval. Those statements are accurate for the thesis as submitted and would require revision if the instrument were executed. This appendix does not revise them.

Appendix D. Correspondence with Public Authorities

Reproduced so that the one figure in this thesis that rests on correspondence, the six-year retention period of the Norwegian cross-border pilot, can be checked by the reader. The reply is reproduced with the sender's permission. Contact details other than name, role and organisation are omitted.

D.1 Helsedirektoratet, on the retention of the cross-border audit trail

Enquiry. Sent by the author on Monday 5 October 2026, 15:48, to Helsedirektoratet's central mailbox (postmottak). It asked for the source and duration of the audit-repository retention requirement for the Norwegian National Contact Point for eHealth (NCPeH) and its MyHealth@EU cross-border audit trail.

Reply. Received Monday 19 October 2026 from Hans Löwe Larsen, Avdelingsdirektør (Director of Department), Division of Information Management and Method, Helsedirektoratet. Verbatim:

> Hei. Takk for din henvendelse, og det er bare hyggelig å kunne være til assistanse.
>
> 1. Jeg finner ingen spesifikk henvisning til lengden på oppbevaring i requirements catalouge eller tilhørende dokumentasjon (Security Services Specification, System Architecture Specifications, NCPeH Architecure Specifications, Audit Trail Profil osv). Det henvises til nasjonal lovgivning, men konkretiserer ikke lagringsmåte eller lagringstid.
> 2. Under utprøvingen er det besluttet en lagringstid på 6 år, men en endelig beslutning når det går i full produksjon er ikke tatt. Hdir er dataansvarlig og vil ta den beslutningen.
>
> Håper dette besvarer dine spørsmål, bare ta kontakt dersom du har behov for ytterligere informasjon. Med vennlig hilsen Hans Löwe Larsen

Translation (the author's).

> Hello. Thank you for your enquiry; it is a pleasure to be of assistance.
>
> 1. I find no specific reference to the length of retention in the requirements catalogue or the associated documentation (Security Services Specification, System Architecture Specifications, NCPeH Architecture Specifications, Audit Trail Profile, etc.). Reference is made to national legislation, but neither the manner nor the period of storage is specified.

> 2. During the pilot, a retention period of 6 years has been decided, but a final decision for when it goes into full production has not been taken. Hdir is the data controller and will take that decision.
>
> I hope this answers your questions; do get in touch if you need further information. Kind regards, Hans Löwe Larsen

What the thesis takes from it. The directorate finds no retention period in the eHDSI requirements catalogue or the specifications it names; they refer the matter to national law; for the Norwegian pilot the directorate, as controller, has decided on six years, with the production figure undecided and reserved to Helsedirektoratet as data controller (Chapter 2, Section 2.3). The thesis therefore treats the cross-border floor as a parameter (Chapter 4, Section 4.3) and uses ten years only as an illustrative long value.

D.2 Datatilsynet, on the GDPR-side questions

An enquiry to Datatilsynet on the GDPR-side questions of Chapter 7, Section 7.4 was sent on 23 September 2026. No reply had been received at the time of submission.